

Manual de Conformidade GRC da Lei de Inteligência Artificial da UE

Guia prático de governança, riscos, conformidade, controles, evidências, auditoria e implementação

Al Leiva, com apoio de redação e revisão assistida por IA

30 de julho de 2026

Sumário

1 Manual de Conformidade GRC da Lei de Inteligência Artificial da UE

Status de publicação: Edição controlada em português brasileiro para revisão. A edição preserva a estrutura e as referências jurídicas da fonte inglesa controlada.

1.1 Aviso jurídico e educacional

Este manual é um recurso educacional e operacional de governança. Não substitui assessoria jurídica qualificada, avaliação de conformidade, análise de organismo notificado, orientação de autoridade competente, obrigações setoriais ou o texto consolidado vigente da legislação aplicável.

1.2 Como utilizar este manual

Use cada capítulo para identificar o requisito aplicável, compreendê-lo em linguagem clara, aplicar o exemplo da GlobalWay Travel Services, definir a atividade de controle, manter evidências e executar um teste de auditoria.

1.3 Base jurídica controlada

- Regulamento (UE) 2024/1689, conforme alterado.
- Regulamento (UE) 2026/1744.
- Texto consolidado vigente do EUR-Lex.
- Material oficial da Comissão Europeia e do Gabinete Europeu de IA, identificado como orientação não vinculante, salvo quando incorporado por instrumento vinculante.

1.4 Capítulo 1 Entendendo a Lei de IA da UE

Estado jurídico: Mestre inglês corrigido. Este capítulo é uma introdução educacional e operacional. Conclusões vinculativas devem ser verificadas em relação ao texto consolidado atual do Regulamento (UE) 2024/1689, conforme alterado, para o ator relevante, sistema, uso, jurisdição e data de aplicação.

1.5 Exigência

As organizações que desenvolvem, fornecem, fornecem, importam, distribuem, integram ou implantam sistemas de inteligência artificial ou modelos de IA de uso geral devem determinar se a Lei de IA da UE se aplica, identificar seu papel legal, classificar o sistema ou modelo corretamente e implementar as obrigações que se aplicam a esse papel e classificação.

A Lei usa uma estrutura baseada em risco e baseada em atores. Não impõe as mesmas obrigações a todos os sistemas de IA ou a todas as organizações. Os deveres aplicáveis dependem de fatos como finalidade pretendida, colocação no mercado, contexto de implantação, pessoas afetadas, integração de produtos, tipo de sistema ou modelo, entidade legal, jurisdição e tempo.

1.6 Explicação em linguagem simples

A Lei de IA da UE não é uma única lista de verificação para toda a IA. Cria diferentes caminhos legais:

- Certas práticas de IA são proibidas;
- Alguns sistemas de IA são classificados como de alto risco e estão sujeitos a extensos controles de ciclo de vida;
- Alguns sistemas e saídas desencadeiam deveres de transparência;
- Os fornecedores de modelos de IA de uso geral têm obrigações separadas, com deveres adicionais para modelos que apresentem risco sistêmico;
- Muitos outros usos da IA permanecem sujeitos a requisitos mais amplos de governança, privacidade, segurança cibernética, emprego, consumidor, segurança de produtos, acessibilidade e setor.

Uma empresa deve, portanto, responder a quatro perguntas antes de decidir quais controles são necessários:

1. A capacidade atende à definição legal atual de um sistema de IA ou modelo de IA de uso geral?
2. Que entidade jurídica desempenha qual função regulamentada?
3. Qual prática proibida, de alto risco, transparência, GPAI, produto ou outra categoria legal se aplica?

4. Quando se aplica a disposição relevante, incluindo regras transitórias?

As classificações de risco interno, rótulos de fornecedores, descrições de marketing, títulos de contrato ou pontuações de maturidade não substituem essa análise legal.

1.7 Exemplo de GlobalWay Travel Services

A GlobalWay Travel Services usa IA para chatbots de suporte ao cliente, recomendações de itinerário, alertas de risco de viagem, detecção de fraude, triagem de recrutamento, pontuação de fornecedores e assistência generativa para consultores de viagens.

Esses usos não compartilham uma classificação legal. O chatbot do cliente pode desencadear funções de transparência de interação. A triagem de recrutamento pode exigir análise de alto risco sob a categoria de emprego. A detecção de fraude pode levantar problemas de perfil, discriminação, privacidade e supervisão humana. Um modelo de propósito geral incorporado em uma ferramenta de consulta de viagens cria perguntas separadas do sistema de upstream e downstream.

Portanto, a GlobalWay mantém um registro de inventário por sistema e versão, mapeia cada pessoa jurídica envolvida e papel de ator, registra o propósito pretendido, identifica pessoas e jurisdições afetadas e completa as telas legais aplicáveis antes da aquisição, piloto, implantação ou mudança material.

1.8 Atividade de controle

Estabelecer uma porta de aplicação e classificação de IA que exija revisão documentada antes que um sistema ou modelo de IA seja comprado, desenvolvido, pilotado, modificado materialmente, colocado no mercado, colocado em serviço ou implantado.

O portão deve exigir:

- um registo de inventário e proprietários de empresas e técnicos responsáveis;
- análise legal-entidade e ator-papel;
- Documentação para fins pretendidos e para uso previsível;
- triagem de prática proibida;
- Análise de classificação de alto risco;
- Transparência e triagem GPAI;
- verificação da data de aplicação e das regras transitórias;
- Identificação da privacidade, segurança, emprego, consumidor, produto, acessibilidade e obrigações setoriais;
- aprovação, restrição, escalada ou rejeição baseada em evidências;

- reavaliação após mudança material.

1.9 Provas

Reter, conforme aplicável:

- Registros de inventário e ingestão de IA;
- Descrições de sistemas e modelos;
- declarações para fins pretendidos;
- Mapas de entidade jurídica e de cadeia de valor;
- avaliações do ator-papel e da aplicabilidade;
- Prática proibida e folhas de cálculo de alto risco;
- Análises de transparência e GPAI;
- Registros de fonte legal e data de aplicação;
- aprovações, condições, exceções e decisões de escalada;
- versão, mudança e reavaliação do histórico;
- documentação e contratos do fornecedor.

As evidências devem ser atribuíveis, atuais, ligadas à versão, internamente consistentes, protegidas contra alterações não autorizadas e recuperáveis para o propósito de revisão relevante.

1.10 Teste de auditoria

1. Selecione uma amostra baseada em risco de sistemas e modelos de IA de aquisição, tecnologia, nuvem, dados, RH, atendimento ao cliente e registros de fornecedores.
2. Verifique se cada item amostrado aparece no inventário de IA com a entidade jurídica correta, proprietário, finalidade pretendida, versão e jurisdição.
3. Inspecione o papel do ator, prática proibida, alto risco, transparência, GPAI e avaliações de data de aplicação.
4. Compare conclusões com a funcionalidade real do sistema, contratos, branding, implantação e contexto da pessoa afetada.
5. Confirme que os controles e aprovações necessários foram concluídos antes da implantação ou mudança de material.
6. Teste se a reavaliação ocorreu após modelo, finalidade, dados, fornecedor, jurisdição, população ou mudanças legais.
7. Relate classificações ausentes, não suportadas, inconsistentes ou desatualizadas como resultados e avalie se a operação deve ser restrita ou suspensa até a resolução.

1.11 Métricas

Indicadores de governança úteis incluem:

- Percentagem de sistemas de IA identificados registrados no inventário;

- Percentagem com revisões completas de ator-papel e classificação;
- Prática proibida não resolvida ou determinações de alto risco;
- revisões de data legal ou reavaliação atrasadas;
- Sistemas que operam sob restrições temporárias ou evidências incompletas;
- Classificação repetida ou achados de propriedade.

Estes são indicadores de gestão interna, não prova legal de conformidade.

1.12 Lista de verificação de implementação

- ☐ Entrada de inventário concluída
- ☐ Entidades jurídicas e papéis de ator identificados
- ☐ Propósito pretendido e uso previsível documentado
- ☐ Proibido-prática triagem concluída
- ☐ Classificação de alto risco concluída
- ☐ Transparência e triagem GPAI concluída
- ☐ Datas de aplicação e regras de transição verificadas
- privacidade, segurança, emprego, consumidor, produto, acessibilidade e deveres do setor identificados
- ☐ Aprovação e condições registadas
- ☐ Repositório de evidências vinculado
- ☐ Reavaliação de gatilhos estabelecidos

1.13 1.1 Via de decisão da EU AI Act

**** Descrição da figura:**** Um caminho de decisão linear que começa com inventário e aplicabilidade, seguido de identificação ator-papel, triagem de prática proibida, classificação de alto risco, transparência e triagem GPAI, verificação de data de aplicação, implementação de controle, retenção de evidências, monitoramento e reavaliação.

Alt text: Caminho de decisão mostrando que as organizações primeiro inventário do sistema ou modelo de IA, determinar a aplicabilidade e papéis do ator, tela para usos proibidos e de alto risco, identificar a transparência e deveres GPAI, verificar datas de aplicação, implementar controles, reter evidências, monitorar a operação e reavaliar após a mudança.

1.14 Capítulo 2 mbito de aplicação, finalidade e abordagem regulamentar

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 2 anterior em conflito.

1.15 Exigência

As organizações devem determinar se o Regulamento (UE) 2024/1689, conforme alterado, se aplica a um sistema de IA, modelo, ator, atividade ou saída antes de atribuir controles. A avaliação deve considerar o ator regulamentado, a atividade realizada, a conexão geográfica com a União, exclusões, interações entre produtos e o uso pretendido e razoavelmente previsível.

1.16 Explicação em linguagem simples

A Lei da IA da UE não se limita a empresas de software estabelecidas na União Europeia. Regula os atores definidos em toda a cadeia de valor da IA e pode ser aplicada onde um sistema ou modelo é colocado no mercado da União, colocado em serviço na União, usado por um implantador na União, ou onde uma saída produzida fora da União é usada na União. A aplicabilidade é, portanto, uma questão legal e operacional, não apenas uma questão de localização.

O Ato usa uma estrutura baseada em risco. Ele proíbe práticas especificadas, impõe requisitos extensivos em sistemas de IA de alto risco, aplica deveres de transparência a sistemas e usos especificados, estabelece obrigações para provedores de modelos de IA de uso geral e deixa outras IA sujeitas a governança mais ampla, contrato, privacidade, segurança, segurança, emprego, proteção ao consumidor e lei específica do setor.

1.17 Avaliação do âmbito de aplicação

Documento no mínimo:

1. O sistema ou modelo de IA e a finalidade a que se destina;
2. As entidades jurídicas envolvidas;
3. papel de cada ator nos termos da Lei;
4. Quando o sistema ou modelo é colocado no mercado, colocado em serviço ou utilizado;
5. onde as pessoas afetadas e os resultados relevantes estão localizados ou usados;
6. Se se aplica uma regra especial ou de exclusão;
7. se a IA é um componente de segurança de, ou ela própria, um produto regulamentado;
8. se o uso poderia ser proibido, de alto risco, regulado pela transparência ou relacionado à GPAI;
9. Se uma mudança na marca, propósito, modificação, distribuição ou integração altera o papel ou tratamento legal.

1.18 Exclusões e limites

Não presume que uma exclusão é automática. Reivindicações envolvendo militar, defesa, segurança nacional, pesquisa científica, atividade pessoal não profissional ou tratamento de código aberto devem ser documentadas contra as condições estatutárias atuais. Uma exclusão de uma obrigação do AI Act não remove obrigações sob outra lei.

1.19 Exemplo GlobalWay

Mesmo que o provedor não esteja estabelecido na União, a GlobalWay deve avaliar a atividade do mercado do provedor, o papel de implantação da GlobalWay, o uso de saídas na União, os deveres de transparência, os requisitos de proteção de dados e se a personalização posterior ou a colocação de marca própria altera o papel da GlobalWay.

1.20 Atividade de controlo

As funções de Governança Legal e AI devem aprovar uma avaliação de aplicabilidade documentada antes da aquisição, desenvolvimento, implantação de produção ou modificação material. A avaliação deve estar vinculada ao inventário de IA e revisada após alterações no propósito, geografia, ator, marca, integração, dados, funcionalidade ou lei aplicável.

1.21 Provas

- Avaliação da aplicabilidade;
- Mapa da entidade e da jurisdição;
- Avaliação do papel;
- declaração para fins pretendidos;
- Diagrama de arquitetura e cadeia de suprimentos;
- análise de exclusão, quando reivindicada;
- Data de aprovação e revisão legal;
- Histórico de reavaliação.

1.22 Teste de auditoria

Confirme que a aplicabilidade foi avaliada usando o texto legal alterado atual, que cada ator relevante e conexão geográfica foi considerada, que as exclusões são apoiadas por análise escrita e que as mudanças materiais desencadearam reavaliação.

1.23 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: artigos 1.º-2.º e definições pertinentes do artigo 3.º
- Regulamento (UE) n.º 2026/1744, sempre que o âmbito de aplicação alterado ou o tratamento do setor do produto sejam materiais.

- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.24 Capítulo 3 Aplicabilidade territorial e extraterritorial

** Status legal: ** Mestre inglês corrigido para consolidação.

1.25 Exigência

A aplicabilidade deve ser avaliada pelo ator, atividade, conexão com o mercado, local de implantação e uso de saídas – não apenas pela localização da sede.

1.26 Sequência de avaliação jurídica

Determine se o assunto envolve:

- Um fornecedor que coloque um sistema de IA ou modelo GPAI no mercado da União;
- Um fornecedor que coloque um sistema de IA em serviço na União;
- Um deployer estabelecido ou localizado na União;
- Um fornecedor ou despachante fora da União em que a produção produzida pelo sistema é utilizada na União;
- Um importador, distribuidor, representante autorizado ou fabricante de produtos com uma função de mercado da União;
- Um produto regulamentado ou componente de segurança que entre no mercado da União.

Para cada conexão, registre a entidade legal, papel, sistema ou modelo, atividade, jurisdição, fluxo de saída e população afetada.

1.27 Explicação em linguagem simples

Uma organização não-UE pode enquadrar-se na Lei quando vende, fornece, implanta ou suporta IA coberta na União, ou quando a produção produzida fora da União é usada lá. Por outro lado, uma empresa-mãe da UE não torna automaticamente todos os afiliados globais e todos os usos globais sujeitos à mesma disposição. A análise deve seguir a entidade jurídica e a atividade real.

1.28 Exemplo GlobalWay

Um provedor baseado nos EUA fornece uma ferramenta de itinerário de IA para a filial da UE da GlobalWay. O provedor pode ter obrigações de mercado da União; a filial da UE pode ser um implantador; outra entidade da GlobalWay pode se tornar um provedor se comercializar uma versão modificada materialmente sob seu próprio nome. A organização documenta cada papel separadamente.

1.29 Atividade de controlo

Manter um mapa de entidade e fluxo de dados para cada sistema de IA material. Legal deve aprovar conclusões extraterritoriais e reavaliá-los quando a implantação de geografia, entidade contratante, uso de saída, marca ou arquitetura do sistema muda.

1.30 Provas

- mapa da entidade;
- Contratos e formulários de encomenda;
- registros de distribuição e implantação;
- análise de saída-uso;
- diagramas de fluxo de dados e arquitetura;
- Memorando legal;
- log de reavaliação.

1.31 Teste de auditoria

Verifique se as avaliações amostradas identificam todos os fornecedores, implementadores, intermediários, atividades de mercado relevantes e usos de saídas da União. Confirme que as conclusões não são baseadas apenas na sede do fornecedor ou do cliente.

1.32 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Artigo 2.º e definições pertinentes do artigo 3.º.
- Texto atual consolidado EUR-Lex.

1.33 Capítulo 4 Definições-chave em inglês simples

** Status legal: ** Mestre inglês corrigido para consolidação.

1.34 Exigência

As decisões de classificação e conformidade devem usar as definições legais atuais. As explicações em inglês simples podem apoiar a compreensão, mas não devem substituir ou expandir o texto legal.

1.35 Definições fundamentais para documentar

1.35.1 sistema AI

Avaliar as características estatutárias do sistema como um todo, incluindo operação baseada em máquina, grau de autonomia, possível adaptabilidade após a implantação, objetivos, inferência de insumos e saídas, como previsões, conteúdo, recomendações ou decisões que podem influenciar ambientes físicos ou virtuais.

1.35.2 Modelo de IA de uso geral

Um modelo GPAI é legalmente distinto de um sistema de IA. Avalie se o modelo exibe generalidade significativa, pode executar com competência uma ampla gama de tarefas distintas e pode ser integrado em uma variedade de sistemas ou aplicativos a jusante, sujeitos às exclusões e condições estatutárias.

1.35.3 Fornecedor

O ator que desenvolve ou desenvolveu um sistema de IA ou modelo GPAI e o coloca no mercado ou coloca um sistema de IA em serviço sob seu próprio nome ou marca registrada, seja para pagamento ou gratuitamente.

1.35.4 Deployer

O ator que usa um sistema de IA sob sua autoridade, exceto quando o sistema é usado em uma atividade pessoal não profissional.

1.35.5 Importador e distribuidor

Um importador coloca no mercado da União um sistema com o nome ou marca comercial de uma pessoa estabelecida fora da União. Um distribuidor disponibiliza um sistema de IA no mercado da União sem ser o fornecedor ou importador.

1.35.6 Representante autorizado

Uma pessoa estabelecida pela União que recebeu e aceitou um mandato por escrito de um provedor para executar obrigações e procedimentos especificados em nome do provedor.

1.35.7 fabricante do produto

Um fabricante de produto pode adquirir obrigações de fornecedor quando um sistema de IA é colocado no mercado ou colocado em serviço com o produto do fabricante sob o nome ou marca registrada do fabricante, sujeito às condições estatutárias aplicáveis.

1.35.8 Propósito pretendido

O uso pretendido pelo provedor, incluindo o contexto e as condições especificadas nas instruções, materiais promocionais ou de vendas, declarações e documentação técnica.

1.35.9 Uso indevido razoavelmente previsível

Uso não pretendido pelo provedor, mas resultante de comportamento humano razoavelmente previsível ou interação com outros sistemas.

1.35.10 Modificação substancial

Uma alteração pós-mercado não prevista ou planeada na avaliação inicial de conformidade que afecte a conformidade ou altere a finalidade pretendida, sujeita à definição legal e à orientação aplicável.

1.36 Controles de interpretação

- Parafraseando definições conservadoras.
- Cite o ponto exato do Artigo 3 quando uma decisão depende de uma definição.
- Não trate rótulos comerciais como “plataforma”, “assistente”, “copiloto” ou “modelo de fundação” como classificações legais.
- Avaliar vários papéis separadamente; uma entidade pode ter mais de um papel.
- Reavaliar definições após alterações na marca, finalidade pretendida, modificação, integração, distribuição ou estrutura de contratação.

1.37 Exemplo GlobalWay

A GlobalWay compra um assistente de viagem movido a GPAI de um fornecedor e o usa internamente e para clientes. O provedor de modelos, o provedor de sistemas, o intermediário de nuvem e a GlobalWay podem ter funções diferentes. Se a GlobalWay modificar materialmente o sistema e comercializá-lo sob sua própria marca, ele deve reavaliar se se tornou um provedor.

1.38 Atividade de controlo

A Governança Legal e de IA mantém um glossário controlado que vincula cada termo operacional à atual definição estatutária, referência do artigo, proprietário e data de revisão.

1.39 Provas

- glossário controlado;
- Planilhas de papel e classificação;
- Registros de contrato e marca;
- declaração para fins pretendidos;
- Avaliação da modificação;
- Histórico de aprovação legal.

1.40 Teste de auditoria

Confirme que as decisões amostradas usam a definição legal atual, identifique a referência legal exata e distinga os termos legais da terminologia comercial.

1.41 Referência jurídica primária

- Regulamento (UE) n.o 2024/1689, alterado: artigo 3.o e disposições conexas.
- Texto atual consolidado EUR-Lex.

1.42 Capítulo 5 Funções regulamentares e responsabilizabilidade

** Status legal: ** Mestre inglês corrigido para consolidação.

1.43 Exigência

Todo sistema de IA material e modelo GPAI devem ter uma determinação documentada do papel do ator. Obrigações anexas ao papel realmente realizado, não apenas ao rótulo usado em um contrato.

1.44 Análise do papel

Avaliar separadamente se cada entidade jurídica age como:

- fornecedor de um sistema de IA;
- fornecedor de um modelo GPAI;
- deployer;
- importador;
- distribuidor;
- Representante autorizado;
- fabricante do produto;
- Fornecedor a jusante que integra um modelo GPAI;
- outro ator adquirindo obrigações de provedor por meio de colocação de marca própria, modificação substancial ou mudança de propósito pretendido.

Uma entidade pode ter vários papéis para um produto ou papéis diferentes em todas as jurisdições e fases do ciclo de vida.

1.45 Princípios da responsabilizabilidade

1. **O papel segue a conduta.** Os contratos apoiam a análise, mas não podem apagar a responsabilidade legal.
2. **Entidades jurídicas são importantes.** Registre qual afiliada realiza cada atividade.
3. **As mudanças no ciclo de vida são importantes.** Branding, modificação, reaproveitamento, integração e distribuição podem mudar as funções.
4. **As funções de modelo e sistema diferem.** Um provedor de modelo GPAI e um provedor de sistema de IA não são automaticamente o mesmo ator.

5. **As responsabilidades devem ser operacionalizadas.** Atribuir aos proprietários responsáveis pela documentação, monitoramento, resposta a incidentes, supervisão humana, gerenciamento de fornecedores e cooperação regulatória.

1.46 Exemplo GlobalWay

A GlobalWay implanta o assistente de viagem de um fornecedor para atendimento ao cliente. O fornecedor continua a ser o provedor do sistema, enquanto a GlobalWay normalmente é o implantador. Se a GlobalWay modificar o sistema além das mudanças planejadas do provedor, mudar sua finalidade pretendida ou comercializá-lo sob a marca GlobalWay, a Legal deve reavaliar se a GlobalWay adquiriu as obrigações do provedor.

1.47 Atividade de controle

Antes da aprovação, Legal completa uma matriz de função por entidade e jurisdição. Compras garante contratos refletem a alocação operacional de responsabilidades, troca de informações necessárias, direitos de auditoria, notificação de mudança, cooperação de incidentes e suporte de saída. O proprietário da empresa deve desencadear reavaliação após alterações materiais.

1.48 Provas

- matriz ator-papel;
- organização e mapa afiliado;
- Contratos e mandatos escritos;
- registros de branding e colocação no mercado;
- Avaliação da finalidade prevista e das alterações;
- aprovações do RACI e do proprietário responsável;
- log de reavaliação.

1.49 Teste de auditoria

Para sistemas amostrados, compare a determinação do papel documentada com atividades reais de desenvolvimento, branding, contratação, colocação no mercado, implantação, modificação e distribuição. Confirme que as mudanças de papel desencadeiam obrigações e controles atualizados.

1.50 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Definições do artigo 3.º e obrigações específicas do ator em todo o regulamento.
- Texto atual consolidado EUR-Lex.

1.51 Capítulo 6 Prazo de aplicação e regras transitórias

1.52 Status da publicação

Este capítulo substitui a linguagem de linha do tempo conflitantes em rascunhos anteriores, figuras, apêndices ou arquivos de trabalho de tradução até que esses materiais sejam atualizados e verificados.

1.53 Finalidade

Este capítulo explica quando a Lei de Inteligência Artificial da UE se aplica, como o Regulamento (UE) 2026/1744 mudou o cronograma e por que as organizações devem avaliar a data efetiva de cada obrigação em vez de confiar em uma única data geral de conformidade.

1.54 Exigência

As organizações devem manter um calendário de implementação atual, controlado pela fonte, que mapeie cada obrigação aplicável do AI Act para o ator legal relevante, categoria do sistema, regra de transição e data efetiva.

As fontes de controle são:

- Regulamento (UE) n.o 2024/1689, alterado;
- Regulamento (UE) 2026/1744;
- O actual texto consolidado EUR-Lex;
- Orientações oficiais de implementação da Comissão Europeia, tratadas como não vinculativas, a menos que reflitam a legislação vinculativa.

1.55 Explicação em linguagem simples

A Lei AI não começa a aplicar tudo de uma vez. Algumas disposições já se aplicam, algumas se aplicam a partir de 2 de agosto de 2026, e requisitos específicos de alto risco têm datas posteriores. Uma empresa pode chegar atrasada para um dever, embora outro dever ainda não tenha começado.

A análise da data deve responder a quatro perguntas:

1. Que disposição legal está envolvida?
2. Qual categoria de ator e sistema ele cobre?
3. Existe uma regra de transição específica?
4. A legislação posterior alterou o calendário original?

1.56 Base de base de implementação verificada

Data	requisito ou marco
1 de agosto de 2024	O Regulamento (UE) n.o 2024/1689 entrou em vigor.

Data	requisito ou marco
2 Fevereiro 2025	As práticas proibidas originais do Artigo 5 e os deveres de alfabetização AI do Artigo 4 começaram a ser aplicados.
2 Agosto 2025	As disposições e obrigações de governança para provedores de modelos de IA de uso geral começaram a ser aplicadas, sujeitas às regras de transição da Lei.
27 Julho 2026	O Regulamento (UE) n.º 2026/1744 entrou em vigor e as suas alterações devem ser refletidas na linha de base legal da organização.
2 de agosto 2026	Aplicam-se a maioria das disposições restantes da Lei AI, exceto quando a Lei alterada fornecer outra data ou regra de transição.
2 dezembro 2026	Aplicam-se as proibições recém-adicionadas do Artigo 5 relativas aos sistemas de IA que geram conteúdo sexualmente explícito ou íntimo não consensual ou material de abuso sexual infantil.
2 dezembro 2026	A transição alterada para provedores especificados de sistemas de IA, incluindo sistemas GPAI, que geram conteúdo sintético de áudio, imagem, vídeo ou texto e foram colocados no mercado antes de 2 de agosto de 2026 deve ser avaliada para conformidade com o artigo 50(2).
2 de agosto 2027	Os fornecedores de modelos GPAI colocados no mercado antes de 2 de agosto de 2025 devem cumprir, sujeito às regras de transição aplicáveis.
2 dezembro 2027	Os requisitos que regem os sistemas de alto risco nos termos do artigo 6.º, n.º 2, e do anexo III aplicam-se ao calendário alterado.

Data	requisito ou marco
2 de agosto 2028	Os requisitos que regem os sistemas de alto risco nos termos do artigo 6.o, n.o 1, e da legislação relativa aos produtos do anexo I aplicam-se nos termos do calendário alterado.

1.57 Regra de interpretação crítica

As datas posteriores para IA de alto risco devem ser indicadas de forma restrita. Eles não significam que todas as disposições relativas à IA de alto risco, todos os deveres de governança, todos os poderes de execução ou todas as obrigações legais relacionadas sejam adiadas para a mesma data.

Para cada sistema, documento separadamente:

- Disposições de classificação e escopo;
- Capítulo III, Seções 13 requisitos;
- Prestador, implantador, importador, distribuidor e deveres representativos;
- obrigações de transparência;
- Obrigações GPAI;
- Disposições de governação e de execução;
- Regras de transição específicas do sistema;
- obrigações decorrentes do GDPR, do emprego, do consumidor, da segurança, da segurança cibernética e do direito do setor.

1.58 Exemplo de GlobalWay Travel Services

A GlobalWay opera um sistema de triagem de recrutamento, um chatbot de viajante e um serviço de detecção de fraude. Seu calendário de conformidade não atribui uma data a todos os três sistemas.

A equipe de chatbot se prepara para os deveres de transparência do Artigo 50, a equipe de recrutamento mapeia o cronograma de alto risco do Anexo III para 2 de dezembro de 2027 e o advogado rastreia separadamente os deveres de GDPR, legislação trabalhista, alfabetização por IA, incidentes e governança que já podem se aplicar.

1.59 Atividades de controle

- Manter um calendário de implementação legal de propriedade da Legal ou Compliance.
- Vincule cada data à categoria exata do artigo, parágrafo, anexo, ator e sistema.
- As alterações de registo e a data em que entraram em vigor.

- Exigir revisão legal antes de confiar em uma data de implementação atrasada.
- Reconciliar datas em capítulos, políticas, controles, contratos, apêndices, gráficos, treinamento e traduções.
- Configurar planos de projeto e portões do sistema para evitar a implantação com base em uma data desatualizada.
- Reverifique o cronograma imediatamente antes da publicação e antes das decisões de implantação de materiais.

1.60 Provas

- Calendário de implementação legal;
- mapeamento de artigos-to-date;
- avaliações legais de memorandos e emendas;
- classificação do sistema e registros de funções;
- planos de projeto e marcos de prontidão;
- atualizações de políticas e treinamento;
- Gráficos e apêndices corrigidos;
- registro de verificação de publicação.

1.61 Testes de auditoria

1. Selecione as obrigações materiais de IA e rastreie cada data para o texto legal alterado atual.
2. Confirmar datas de alto risco atrasadas são limitadas às disposições abrangidas pela alteração.
3. Os planos de projetos legais, operacionais e técnicos usam as mesmas datas.
4. Inspecione se resumos ou gráficos anteriores permanecem em circulação.
5. Confirme se a organização reavalia as datas após alterações legislativas ou correções oficiais.
6. Verifique se os proprietários do sistema entendem quais deveres já se aplicam.

1.62 Lista de verificação de gestão

- Estamos usando o atual texto legal alterado?
- Distinguimos a entrada em vigor da aplicação?
- Os atrasos de alto risco são indicados de forma restrita?
- Todos os gráficos, apêndices e traduções foram reconciliados?
- Cada data de implementação pode ser rastreada até uma fonte vinculativa?

1.63 Especificação EU AI Act Application Timeline

Crie uma linha do tempo horizontal acessível mostrando os marcos de 1 de agosto de 2024 a 2 de agosto de 2028. Distinga visualmente datas gerais de aplicação, transições GPAI, novas proibições do Artigo 5, requisitos de alto risco do Anexo III e requisitos de alto risco incorporados ao produto do Anexo I. Inclua uma nota proeminente de que a análise específica do sistema é necessária.

Alt text: Linha do tempo de implementação do EU AI Act que mostra a entrada em vigor em agosto de 2024, práticas proibidas e deveres de alfabetização em fevereiro de 2025, governança da GPAI em agosto de 2025, a alteração do Omnibus da AI de 2026, aplicação geral em agosto de 2026, novas proibições em dezembro de 2026, transição da GPAI em agosto de 2027, requisitos de alto risco do anexo III em dezembro de 2027 e requisitos incorporados ao produto do anexo I em agosto de 2028.

1.64 Capítulo 7 Relação com outras leis e marcos da UE

Estado jurídico: Mestre inglês corrigido. A Lei de IA da UE opera ao lado de outras leis aplicáveis da União e nacionais. O cumprimento da Lei de IA não substitui as obrigações sob proteção de dados, segurança cibernética, segurança do produto, emprego, consumidor, concorrência, acessibilidade, propriedade intelectual ou lei específica do setor.

1.65 Exigência

Identificar cada regime legal que se aplica à organização, ator, sistema de IA, caso de uso, pessoas afetadas, dados, contexto do produto, jurisdição e estágio do ciclo de vida. Resolver sobreposições explicitamente, em vez de assumir que uma avaliação satisfaz todas as funções legais.

1.66 Explicação em linguagem simples

Um sistema de IA pode ser legal sob um regime e ainda falhar em outro. Por exemplo, um uso pode ficar fora da categoria de alto risco do AI Act, mas ainda requer uma avaliação de impacto de proteção de dados, consulta de trabalhadores, controles de acessibilidade, divulgações do consumidor, medidas de segurança cibernética ou aprovação do setor.

1.67 Exemplo GlobalWay

A equipe avalia a classificação do AI Act, a base legal do GDPR e as regras de decisão automatizada, os deveres de consulta da lei de emprego, acessibilidade, risco de discriminação, obrigações do fornecedor, segurança e requisitos trabalhistas locais separadamente e registra como os controles interagem.

1.68 Atividade de controle

Manter um registro jurídico-interface que abranja:

- Lei e disposição aplicáveis;
- ator e gatilho regulamentado;
- sistema, versão, uso, jurisdição e população;
- proprietário legal ou de conformidade responsável;
- avaliação, aviso, controle, aprovação ou ação de relatório necessários;
- localização de provas e base de retenção;
- conflitos, dependências e interpretação não resolvida.

1.69 Provas

Manter análises de aplicabilidade, memorandos legais, DPIAs, FRIAs, avaliações de segurança, registros de consulta de trabalhadores, revisões de acessibilidade, aprovações de produtos ou setores, avisos, contratos e registros de decisão.

1.70 Teste de auditoria

Selecione uma amostra de sistemas de IA e verifique se a análise de interface legal é atual, específica do ator e da jurisdição, vinculada à versão implantada e apoiada por evidências. Confirme que nenhuma equipe tratou a prontidão da AI Act como um substituto para outra obrigação legal aplicável.

1.71 Aviso de controle de chave

Onde os regimes legais se sobrepõem ou conflitam, obtenha revisão jurídica qualificada e documente a resolução. Não apresente a política organizacional ou as normas voluntárias como lei vinculativa.

1.72 Capítulo 8 Modelo Operacional de Governança da IA

Estado legal: Mestre inglês corrigido. Um modelo operacional de governança de AI empresarial é geralmente uma estrutura de controle imposta pela organização. Ele suporta a conformidade, mas não substitui os deveres estatutários específicos do ator.

1.73 Exigência

Estabelecer um modelo operacional documentado que atribua responsabilidade, direitos de decisão, portões de ciclo de vida, escalada e responsabilidades de evidência para sistemas e modelos de IA.

1.74 Explicação em linguagem simples

A governança deve mostrar quem decide, quem executa controles, quem desafia as decisões e quem pode parar a implantação. Um nome de comitê por si só não é um modelo operacional.

1.75 Exemplo GlobalWay

A GlobalWay cria um Conselho de Governança de IA apoiado por Legal, Compliance, Privacidade, Segurança, Dados, Compras, RH, Acessibilidade, Auditoria Interna e proprietários de empresas. Cada sistema de IA tem um proprietário nomeado, proprietário técnico, proprietário de risco e proprietário de supervisão humana.

1.76 Atividade de controle

Documento:

- fóruns e mandatos de governança;
- mapeamento ator-papel e legal-responsabilidade;
- admissão, classificação, aprovação, liberação, monitoramento, mudança, incidente e portões de aposentadoria;
- escalada e parar a autoridade;
- segregação de deveres e conflitos;
- Registros necessários e repositórios de evidências;
- Gestão de cadências e exceções.

1.77 Provas

Cartas, matrizes RACI, registros de reuniões, aprovações, procedimentos de ciclo de vida, registros de decisão, registros de exceção, registros de escalada e relatórios de diretoria ou executivos.

1.78 Teste de auditoria

Decisões de governança de amostra e verificar se as funções necessárias participaram, direitos de decisão foram seguidos, evidências foram mantidas, conflitos foram abordados e questões legais ou técnicas não resolvidas foram escaladas antes da implantação.

1.79 Capítulo 9 Supervisão do Conselho e do Executivo

Estado legal: Mestre em inglês corrigido. Os requisitos de supervisão executiva e do conselho dependem de obrigações corporativas, setoriais, fiduciárias, de gerenciamento de riscos e organizacionais. A Lei de IA da UE não impõe um modelo universal de relatório do conselho.

1.80 Exigência

Fornecer aos órgãos governamentais e executivos informações precisas, oportunas e úteis à decisão sobre riscos materiais de IA, obrigações legais, incidentes, falhas de controle, dependências e remediação.

1.81 Explicação em linguagem simples

Os líderes seniores precisam de informações suficientes para desafiar a gestão, controles de fundos, definir tolerância ao risco e parar usos inaceitáveis. Os painéis devem divulgar limitações de incerteza e evidências.

1.82 Exemplo GlobalWay

O comitê executivo da GlobalWay recebe relatórios trimestrais sobre triagem de uso proibido, classificações não resolvidas, exposição de alto risco e GPAI, incidentes graves, reclamações, concentração de fornecedores, remediação atrasada e conclusão de AI-alfabetização. Eventos críticos são escalados imediatamente.

1.83 Atividade de controle

Definir:

- limiares de reporte e cadência;
- Proprietários de relatórios responsáveis;
- métricas, sistemas de origem, validação e limitações;
- decisões reservadas aos executivos ou ao conselho de administração;
- gatilhos de escalada imediata;
- tratamento de privilégio, confidencialidade e informações sensíveis ao regulador;
- Evidência de desafio e decisão.

1.84 Provas

Pacotes de conselhos e comitês, minutos, decisões, atestados de gestão, definições métricas, reconciliações de fontes, registros de escalada e aprovações de financiamento de remediação.

1.85 Teste de auditoria

Inspecione uma amostra de relatórios e minutos. Verifique a integridade, precisão, divulgação de limitações, escalada oportuna, desafio documentado e acompanhamento das decisões e ações necessárias.

1.86 Capítulo 10 Enquadramento da Política de IA

Estado legal: Mestre em inglês corrigido. Uma estrutura de política de IA é um controle de governança imposto pela organização. Deve traduzir os requisitos legais, contratuais, de risco, segurança, privacidade, acessibilidade e ética aplicáveis em regras internas aplicáveis.

1.87 Exigência

Manter políticas e padrões aprovados, controlados por versão, que regem a aquisição, desenvolvimento, implantação, uso, monitoramento, mudança, resposta a incidentes e aposentadoria de IA.

1.88 Explicação em linguagem simples

As políticas estabelecem as regras; os procedimentos explicam como segui-las. Eles devem combinar as operações reais, identificar proprietários responsáveis e distinguir a lei vinculativa dos requisitos internos e das práticas recomendadas.

1.89 Exemplo GlobalWay

A GlobalWay emite uma política de IA empresarial apoiada por padrões para ferramentas aprovadas, dados confidenciais, usos proibidos, compras, supervisão humana, transparência, testes, monitoramento, incidentes, registros e uso de IA gerativa.

1.90 Atividade de controle

O quadro deve definir:

- escopo, entidades, sistemas, modelos, usuários e jurisdições;
- usos proibidos e restritos;
- requisitos de admissão, classificação, aprovação e liberação;
- dados, privacidade, segurança, acessibilidade e regras de supervisão humana;
- requisitos de fornecedor, contrato, mudança, monitoramento, incidente e evidência;
- autoridade de exceção, duração, controles intermediários e escalada;
- gatilhos de revisão e responsabilidades de comunicação.

1.91 Provas

Políticas aprovadas, padrões, procedimentos, histórico de versões, revisão legal, registros de treinamento, atestados, registros de exceções, comunicações e resultados de monitoramento de conformidade.

1.92 Teste de auditoria

Verifique se as políticas são atuais, aprovadas, acessíveis, internamente consistentes, mapeadas para as obrigações aplicáveis, comunicadas ao pessoal relevante e operando na prática. Exceções de amostra e confirme autorização, expiração, controles compensatórios e fechamento.

1.93 Capítulo 11 Papéis, Responsabilidades e o Modelo das Três Linhas

Estado legal: Mestre inglês corrigido. O modelo de três linhas é uma prática de governança e garantia, não uma estrutura estatutária universal. A responsabilidade legal permanece com o ator e a entidade identificados pela lei aplicável.

1.94 Exigência

Atribuir responsabilidades claras para possuir o uso de IA, controles operacionais, fornecer supervisão especializada e fornecer garantia independente sem obscurecer os deveres legais do ator.

1.95 Explicação em linguagem simples

As equipes de negócios e técnicas possuem o sistema e seus riscos. As funções especializadas definem requisitos, aconselham, desafiam e monitoram. A auditoria interna ou outra função de garantia independente avalia a governança e os controles. A independência e a responsabilidade devem ser reais, não apenas mostradas em um gráfico da organização.

1.96 Exemplo GlobalWay

A GlobalWay atribui os proprietários de empresas e técnicos como primeira linha; Legal, Compliance, Privacidade, Segurança, Governança de Dados, Acessibilidade, RH e Risco do Fornecedor como segunda linha; e Auditoria Interna como terceira linha. O Conselho de Governança da IA coordena decisões, mas não absorve as responsabilidades dos proprietários do sistema ou atores regulamentados.

1.97 Atividade de controle

Documento:

- responsabilidades legais específicas do ator;
- proprietários de negócios, técnicos, riscos, supervisão e evidências;
- autoridade para aprovar, desafiar, restringir, suspender ou escalar;
- requisitos de independência, conflito e segregação;
- competência e cobertura de backup;
- Entregas entre fases e funções do ciclo de vida;

- responsabilidade pelos resultados e remediação.

1.98 Provas

Descrições de papéis, matrizes RACI, comitês charters, delegações, registros de competência, divulgações de conflitos, aprovações, registros de desafios, planos de garantia e atribuições de correção.

1.99 Teste de auditoria

Trace uma amostra de decisões e incidentes de IA através das funções atribuídas. Confirme que a propriedade foi clara, ocorreu um desafio necessário, a garantia independente não foi realizada pelos operadores de controle e conflitos não resolvidos ou lacunas de capacidade foram escaladas.

1.100 Capítulo 12 Alfabetização da IA, Treinamento Baseado em Funções e Garantia de Competências

1.101 12.1 Finalidade

Este capítulo estabelece um quadro prático de governança para cumprir a obrigação de AI-alfabetização da Lei de IA da UE e para demonstrar que as pessoas que operam, supervisionam, adquirem, aprovam, monitoram, auditam ou confiam em sistemas de IA estão preparadas para suas responsabilidades.

O objetivo não é transformar cada funcionário em um cientista de dados. É garantir que cada pessoa entenda o suficiente sobre os sistemas de IA que encontram para usá-los com segurança, questioná-los adequadamente, reconhecer limites, aumentar as preocupações e preservar a responsabilidade humana.

Princípio central: A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.102 12.2 Requisito Legal

O Artigo 4 exige que os provedores e implementadores de sistemas de IA tomem medidas de apoio à alfabetização em IA para funcionários e outras pessoas que operam ou usam sistemas de IA em seu nome. As medidas devem refletir o conhecimento técnico, a experiência, a educação e o treinamento da pessoa, o contexto em que o sistema de IA é usado e as pessoas ou grupos afetados por esse uso.

A obrigação é contextual. Um agente de apoio ao viajante, desenvolvedor, gerente de compras, revisor humano, patrocinador executivo e auditor interno não precisa de treinamento idêntico. Cada um precisa de

competência adequada ao papel, sistema, autoridade de decisão, risco e população afetada.

1.103 12.3 Explicação de linguagem simples

Um programa defensável deve responder a cinco perguntas:

1. Quem interage com cada sistema de IA?
2. Que decisões ou ações essa pessoa pode tomar?
3. O que pode dar errado nesse caso de uso?
4. O que a pessoa deve saber e ser capaz de fazer?
5. Que provas mostram que a pessoa permanece competente?

A participação no treinamento por si só não é competência. A competência requer compreensão, aplicação, julgamento e a capacidade de reconhecer quando o uso normal deve parar.

1.104 Exemplo de Serviços de Viagem GlobalWay

A GlobalWay Travel Services usa um assistente virtual voltado para o viajante, ferramentas de assistência ao agente, previsão de interrupção, triagem de fraude, IA generativa interna, análise de risco de fornecedor e triagem de recrutamento apoiada por IA.

A GlobalWay, portanto, mantém uma matriz de alfabetização de IA baseada em papéis.

Papel	O que a AI pode fazer	Responsabilidade humana	Competência requerida
Agente de apoio ao viajante	Sugerir itinerários e rascunhos de mensagens	Verificar fatos, aprovar comunicações, proteger viajantes, escalar exceções	Reconhecimento de alucinação, verificação de fonte, acessibilidade, substituição, escalada
Gerente de operações	Priorizar casos de interrupção	Aprovar decisões operacionais e monitorar o impacto	Bias, deriva, limiares, resposta a incidentes, documentação
Gerente de Compras	Resumir as respostas do fornecedor	Validar evidências e avaliar o risco contratual	Due diligence, limites de modelo, direitos de dados, direitos de auditoria, risco

Papel	O que a AI pode fazer	Responsabilidade humana	Competência requerida
Desenvolvedor ou integrador	Configurar e conectar componentes de IA	Implementar salvaguardas e preservar controles	de subcontratante Teste, registro, segurança, marcação, controle de mudança
Revisor humano	Revisão de decisões apoiadas por AI	Aprovar, corrigir, rejeitar ou escalar	Viés de automação, revisão significativa, direitos de desafio, qualidade de evidência
Patrocinador Executivo	Aprovar objetivos, financiamento e aceitação de riscos	Responsabilidade e empresarial própria	Direitos de governação, risco residual, impacto humano, critérios de paragem
Legal e Compliance	Interpretar obrigações e controles de desafio	Confirmar o tratamento regulatório e a suficiência de evidências	Classificação de papéis, transparência, práticas proibidas, documentação
Auditoria interna	Controles de teste independentes	Reportar deficiências e verificar a correção	Critérios de auditoria, amostragem, rastreabilidade, eficácia operacional

1.105 12.5 Objetivo de Controle

A GlobalWay deve manter um programa de literacia e competência em IA baseado no risco, garantindo que o pessoal e terceiros entendam:

- a finalidade e os limites dos sistemas de IA que utilizam;
- sua autoridade e responsabilidade;
- O que a IA pode e não pode fazer;

- quando a revisão humana é obrigatória;
- como identificar resultados não confiáveis, tendenciosos, inseguros ou manipulados;
- como parar, substituir, corrigir, desafiar e escalar;
- como proteger informações pessoais, confidenciais e regulamentadas;
- Como documentar decisões e preservar evidências;
- Como as pessoas afetadas podem obter ajuda, correção ou revisão humana.

1.106 12.6 Arquitetura de aprendizagem baseada em papéis

1.106.1 Nível da Fundação

Os tópicos incluem usos aprovados e proibidos, confidencialidade, alucinações, mídia sintética, viés, responsabilidade humana, relatórios de incidentes e o direito de parar e procurar ajuda.

1.106.2 Nível de profissional

Os tópicos incluem finalidade e limites específicos do sistema, manipulação de entrada e saída, validação de origem, procedimentos de substituição, acessibilidade, documentação e modos de falha conhecidos.

1.106.3 Nível de proprietário e revisor

Os tópicos incluem supervisão humana significativa, viés de automação, limiares de desempenho, incidentes, reclamações, gerenciamento de mudanças, impacto da pessoa afetada e critérios de uso.

1.106.4 Nível de especialista

Os tópicos podem incluir governança de dados, uso indevido de adversários, avaliação de modelos, risco de fornecedor, documentação técnica, marcação de transparência, registro, conformidade e evidência.

1.106.5 nível executivo e diretoria

Os tópicos incluem responsabilidade organizacional, exposição legal, impacto dos direitos humanos, limites de garantia, aceitação de risco residual e condições de suspensão ou retirada.

1.107 12.7 Garantia de Competência

A GlobalWay não se baseará apenas em certificados de conclusão, mas utilizará avaliações baseadas em cenários, práticas supervisionadas, exercícios de mesa, desempenho de tarefas observadas, simulações de desafio e superação, verificações periódicas de conhecimento, confirmação do gerente e treinamento corretivo.

O pessoal deve ser capaz de demonstrar o que faria quando:

- A saída de IA entra em conflito com informações autorizadas;
- Uma recomendação parece injusta ou insegura;
- Faltam dados necessários;
- Um viajante é vulnerável ou precisa de suporte de acessibilidade;
- Informações confidenciais são expostas;
- um sistema se comporta de forma diferente após uma atualização;
- Uma pessoa afetada desafia um resultado apoiado por IA.

1.108 12.8 Limite de decisão humana

Para cada função habilitada para IA, a GlobalWay documenta:

Elemento necessário	Exemplo
O que a AI pode fazer	Elaboração de uma recomendação de remarcação
O que permanece humano	Aprovar o itinerário final e a comunicação
Requisito de revisão	Verificar regras tarifárias, restrições de visto, acessibilidade e preferência do viajante
Condição de paragem	Dados conflitantes, viajante vulnerável, política pouco clara ou recomendação insegura
rota de escalação	Agente sênior, gerente de serviço, jurídico, segurança ou resposta de emergência
Proprietário responsável	Diretor de Operações de Viajantes
Desafio direito	Viajante pode solicitar correção ou revisão humana

1.109 12.9 Terceiros e Contratados

Os contratantes relevantes, consultores, funcionários temporários, pessoal de serviço gerenciado e provedores terceirizados devem completar o treinamento adequado antes que o acesso seja concedido. Os contratos devem abordar competência, uso aprovado, confidencialidade, notificação de incidentes, subcontratados, retenção de evidências, reciclagem e suspensão de acesso.

1.110 12.10 Triggers de treinamento

O treinamento deve ser atribuído ou atualizado quando um novo sistema de IA é introduzido, um papel muda, o modelo ou fluxo de trabalho muda

materialmente, uma nova população afetada é introduzida, um incidente ou reclamação ocorre, o monitoramento revela erros recorrentes, mudanças na lei, um fornecedor muda um recurso material ou uma auditoria identifica competência insuficiente.

1.111 12.11 Condições de Parada e Escalada

O pessoal deve parar o uso normal e escalar quando a saída pode causar danos significativos, o sistema parece comprometido, a revisão humana obrigatória não pode ser realizada, a informação é insuficiente para validar a saída, o conteúdo é discriminatório ou inseguro, informações confidenciais são expostas, um aviso ou log obrigatório está faltando, ou uma pessoa afetada solicita intervenção humana que o fluxo de trabalho não pode fornecer.

1.112 12.12 Evidência

Manter a política de alfabetização AI, inventário de papel, análise de necessidades de treinamento, currículo, histórico de versões, registros de conclusão, resultados de avaliação, demonstrações de competência, ações corretivas, evidências de empreiteiros, registros de gatilho de treinamento, aprovações de exceções, minutos de revisão de gerenciamento e links entre incidentes e melhorias de treinamento.

1.113 12.13 Métricas

A administração deve revisar as taxas de atribuição e conclusão, taxas de aprovação de avaliação, treinamento atrasado, reciclagem após mudanças, incidentes envolvendo uso indevido ou mal-entendido, taxas de substituição e escalada, falhas repetidas de validação, conformidade do contratante, tempo de correção e confiança dos funcionários na produção desafiadora de IA.

As métricas não devem recompensar a aceitação cega. Aumentos adequados em substituições ou escaladas podem mostrar que o pessoal está exercendo julgamento.

1.114 12.14 Teste de Auditoria

Um auditor deve provar os sistemas de IA em todos os níveis de risco e funções; identificar todas as funções operacionais, de revisão, aprovação, aquisição, manutenção e auditoria; comparar o aprendizado com a autoridade e o risco reais; verificar o treinamento específico do sistema; inspecionar evidências de competência; testar o conhecimento dos limites e condições de parada; rastrear mudanças no sistema para reciclagem; revisar incidentes para causas raiz relacionadas à alfabetização; verificar a cobertura do contratado; e confirmar a correção da gestão.

1.115 12.15 Especificação gráfica formal do processo

Figura 12-1 Alfabetização e ciclo de vida de competências com base em funções

Sistema de IA identificado → funções e pessoas afetadas mapeadas → requisitos de competência definidos → aprendizagem baseada em funções ministrada → competência testada em situações realistas → acesso aprovado → desempenho monitorado → mudança ou incidente aciona novo treinamento

Use duas faixas alinhadas:

- ** Faixa de organização: ** inventário, requisitos, treinamento, monitoramento, evidência.
- ** Faixa humana: ** compreender, praticar, questionar, substituir, escalar, melhorar.

** Preocupação humana: **

“A pessoa que está revisando este sistema realmente sabe quando está errado?”

Alt text: Um ciclo de vida de duas faixas que mostra como uma organização mapeia papéis de IA, oferece treinamento baseado em funções, testa competência, concede acesso, monitora o desempenho e retreina as pessoas após mudanças ou incidentes. A trilha humana enfatiza o questionamento, a superação e a escalada, em vez de apenas concluir um curso.

1.116 12.16 Gráfico original do local de trabalho-satisfatório

Figura 12-2 “Todos passaram no treinamento”

Cena: Um gerente aponta orgulhosamente para um painel mostrando 100% de conclusão de treinamento. Além disso, um funcionário pergunta a um sistema de IA se um viajante precisa de visto, recebe três respostas contraditórias e clica em “Aprovar tudo”.

Legenda:

“A taxa de conclusão do curso foi excelente. A taxa de competência ainda estava carregando.”

As estatísticas de conclusão não provam que o pessoal pode identificar resultados não confiáveis, exercer julgamento ou proteger as pessoas afetadas.

****Um gerente de escritório celebra a conclusão completa do treinamento de IA, enquanto um funcionário aprova cegamente respostas contraditórias de IA sobre o visto de um viajante.**

1.117 12.17 Key Takeaway

A alfabetização em IA não é um exercício de conscientização único. É um controle de governança conectando o conhecimento e o julgamento de cada pessoa ao sistema real, à decisão, ao risco e às pessoas afetadas.

1.118 12.18 Fontes oficiais

- Regulamento (UE) n.º 2024/1689, artigo 4.º – Alfabetização em IA.
- Comissão Europeia, questões de alfabetização AI, respostas e materiais de prática.

Nota de atualização legal: Verifique a linha de base regulamentar e os materiais oficiais de implementação da Comissão imediatamente antes da publicação.

1.119 Capítulo 13 Política e Normas de IA

As políticas e padrões organizacionais de IA operacionalizam as decisões de governança, mas não substituem leis vinculativas, contratos, regras setoriais, obrigações de conformidade ou direções de autoridade.

1.120 Exigência

As organizações devem manter políticas de IA aprovadas e controladas por versão e padrões de suporte que definam escopo, funções, usos permitidos e proibidos, controles de ciclo de vida, escalada, evidências, exceções e gatilhos de revisão.

1.121 Explicação em linguagem simples

Uma política explica o que a organização exige e quem é responsável. Os padrões explicam as condições mínimas de controle que sistemas, modelos, fornecedores e usuários devem cumprir. Cada requisito deve identificar se vem de lei, contrato, política interna ou prática recomendada.

1.122 Exemplo GlobalWay

A GlobalWay adota uma política de IA corporativa que abrange o cliente, força de trabalho, aquisição, segurança, privacidade e uso de IA gerativa. Padrões de suporte definem inventário, classificação, supervisão humana, transparência, segurança, testes, due diligence do fornecedor, resposta a incidentes e retenção de evidências.

1.123 Atividade de controle

- aprovar políticas e padrões por meio de governança definida;
- requisitos de mapas para papéis de atores, sistemas, jurisdições e datas;
- publicar procedimentos específicos e exceções;
- monitorar a adoção e o descumprimento;
- após revisão legal, sistema, fornecedor, incidente, auditoria ou mudança organizacional.

1.124 Provas

Política aprovada, padrões, matriz de propriedade, histórico de versões, comunicações, atestados, registro de exceções, mapeamentos de controle e registros de revisão.

1.125 Teste de auditoria

Verifique a aprovação, o escopo, a moeda, a rastreabilidade da fonte, a comunicação, as evidências de implementação, o manuseio de exceções e a consistência com as operações reais.

1.126 Capítulo 14 Modelo Operacional de Governança da IA

** Status legal: ** Mestre inglês corrigido. O modelo operacional é um mecanismo de governança organizacional. Ele deve apoiar, mas não substitui, deveres específicos do ator sob a lei aplicável.

1.127 Exigência

A organização deve definir como as decisões de IA são tomadas, desafiadas, escaladas, documentadas e monitoradas entre entidades jurídicas, unidades de negócios, tecnologias e jurisdições.

1.128 Explicação em linguagem simples

Um modelo operacional transforma a política em trabalho repetível. Ele identifica fóruns, direitos de decisão, portões de ciclo de vida, proprietários responsáveis, desafio de segunda linha, garantia independente, rotas de escalada e evidências necessárias.

1.129 Exemplo GlobalWay

A GlobalWay estabelece um conselho de governança de IA, proprietários de sistemas de negócios, revisão legal e de conformidade, revisão de privacidade e segurança, controles de compras, proprietários de supervisão humana e cobertura de auditoria interna. Decisões de alto impacto exigem aprovação multifuncional documentada.

1.130 Atividade de controle

- definir órgãos de governança e direitos de decisão;
- atribuir funções responsáveis, responsabilidades, consultadas e informadas;
- estabelecer entrada, classificação, aprovação, monitoramento, mudança, incidente e portões de aposentadoria;
- definir os limiares de escalada e os registros de decisão;
- Teste se os fóruns de governança operam como projetados.

1.131 Provas

Cartas, matrizes RACI, registros de reuniões, registros de decisão, aprovações, registros de escalada, saídas de portão de ciclo de vida e relatórios de garantia.

1.132 Teste de auditoria

As decisões de IA do material da amostra e verificar se o fórum correto, papéis, evidências, desafio, aprovação e escalada foram aplicados.

1.133 Capítulo 15 Papéis e Responsabilidade da Governança da IA

Estado legal: Mestre inglês corrigido. As atribuições de funções internas apoiam a prestação de contas, mas não alteram os papéis legais do ator ou transferem deveres legais meramente por política ou contrato.

1.134 Exigência

A organização deve atribuir a responsabilidade nomeada para sistemas de IA, modelos, dados, risco, conformidade, privacidade, segurança, supervisão humana, fornecedores, incidentes, evidências e resposta de auditoria.

1.135 Explicação em linguagem simples

Toda atividade material de IA precisa de um proprietário responsável com autoridade, competência, recursos e uma rota de escalada clara. A responsabilidade compartilhada não deve se tornar uma responsabilidade destituída.

1.136 Exemplo GlobalWay

A GlobalWay atribui um proprietário de empresa e proprietário técnico a cada sistema de IA, com risco separado, legal, privacidade, segurança, dados, supervisão humana e responsabilidades de fornecedores. O conselho de governança resolve conflitos e aprova o risco residual dentro da autoridade legal.

1.137 Atividade de controle

- Descrições de papéis documentais e direitos de decisão;
- identificar separadamente as responsabilidades estatutárias e contratuais;
- verificar competência, independência, autoridade e recursos;
- evitar conflitos e deveres incompatíveis;
- Reavaliar funções após mudanças organizacionais, de sistema, de fornecedor, de marca ou de propósito pretendido.

1.138 Provas

Descrições de papéis, matrizes RACI, delegações, registros de treinamento, avaliações de conflitos, aprovações, planos de sucessão e registros de escalada.

1.139 Teste de auditoria

Sistemas e decisões selecionados, então confirmam que os proprietários nomeados existiam, entenderam seus deveres, exerceram autoridade, mantiveram evidências e aumentaram as questões adequadamente.

1.140 Capítulo 16 Inventário do Sistema AI

** Status legal: ** Mestre inglês corrigido. Um inventário de IA é um mecanismo de governança e evidência. Seus campos obrigatórios e retenção dependem da lei aplicável, do papel do ator, do sistema, do uso, do contrato e da política organizacional.

1.141 Exigência

A organização deve manter um inventário completo, atual e vinculado a versões de sistemas de IA, modelos, casos de uso, entidades jurídicas, papéis de ator, fins pretendidos, pessoas afetadas, jurisdições, fornecedores, dados, proprietários, classificações e status do ciclo de vida.

1.142 Explicação em linguagem simples

Uma organização não pode governar o que não pode identificar. O inventário é o registro controlado que conecta cada uso de IA à propriedade, análise legal, risco, controles, evidências, monitoramento e histórico de mudanças.

1.143 Exemplo GlobalWay

GlobalWay inventários clientes chatbots, recomendações de itinerário, análise de fraude, ferramentas de força de trabalho, pontuação de fornecedores e assistentes generative-AI. Cada registro identifica a versão

implantada, provedor, proprietário da empresa, papel legal, exposição da UE, classificação, categorias de dados, supervisão e data de revisão.

1.144 Atividade de controle

- exigir a entrada no inventário antes da aquisição, desenvolvimento, piloto ou implantação;
- conciliar aquisição, nuvem, segurança, dados, finanças e registros de negócios;
- vincular sistemas a modelos, versões, fornecedores e usos a jusante;
- status de faixa desde o conceito até a aposentadoria;
- revisão após mudança material, incidente, auditoria ou desenvolvimento legal.

1.145 Provas

Registros de inventário, relatórios de reconciliação, atestados de propriedade, resultados de descobertas, histórico de mudanças, registros de exceções e registros de aposentadoria.

1.146 Teste de auditoria

Reconciliar uma amostra de compras, aplicativos, APIs, repositórios e processos de negócios relacionados à IA conhecidos no inventário e investigar omissões ou registros obsoletos.

1.147 Capítulo 17 Ingestão de IA e Triagem Inicial

**** Status legal: **** Mestre inglês corrigido. A ingestão e a triagem são controles organizacionais usados para identificar as avaliações legais, de risco, segurança, privacidade, compras e operacionais aplicáveis antes de uma atividade de IA prosseguir.

1.148 Exigência

A organização deve exigir um processo documentado de admissão e triagem antes de desenvolver, comprar, configurar, pilotar, mudar materialmente ou implantar um sistema ou modelo de IA.

1.149 Explicação em linguagem simples

O processo de admissão captura informações suficientes para decidir quais revisões e aprovações são necessárias. Deve identificar fatos não resolvidos cedo, em vez de permitir que um projeto prossiga com suposições.

1.150 Exemplo GlobalWay

Antes de uma equipe de negócios pilotar um assistente de viagem de IA, a GlobalWay registra seu propósito pretendido, provedor, modelo, usuários,

pessoas afetadas, jurisdições, dados, nível de automação, supervisão humana, dependências de fornecedores e lançamento planejado. A triagem encaminha o uso para legal, privacidade, segurança, compras, acessibilidade, risco e revisão técnica, conforme aplicável.

1.151 Atividade de controle

- exigir a ingestão antes do compromisso ou da implantação;
- tela para práticas proibidas, uso de alto risco, deveres de transparência, exposição à GPAI, privacidade, segurança, emprego, consumidor, acessibilidade e requisitos do setor;
- informações ausentes do documento e restrições provisórias;
- Atribuir revisores, prazos e requisitos de evidência;
- impedir a progressão até que os portões obrigatórios sejam satisfeitos ou uma exceção legal seja aprovada.

1.152 Provas

Formulários de admissão completos, decisões de triagem, atribuições de revisores, resultados de triagem, restrições, aprovações, solicitações rejeitadas e registros de escalada.

1.153 Teste de auditoria

Experimente iniciativas de IA novas e alteradas e verifique a ingestão oportuna, triagem completa, roteamento apropriado, decisões documentadas e a aplicação dos portões necessários.

1.154 Capítulo 18 Fornecedor, Deployer, Importador, Distribuidor, Representante Autorizado e Análise do Fabricante de Produtos

** Status legal: ** Mestre inglês corrigido para consolidação.

1.155 Exigência

O processo de admissão de IA deve determinar cada papel de ator aplicável por entidade legal, jurisdição, estágio do ciclo de vida, sistema e modelo. A avaliação deve ser aprovada antes da aquisição, desenvolvimento, colocação no mercado, implantação, distribuição ou mudança de material.

1.156 Método de avaliação

1.156.1 Passo 1 Mapear a cadeia de valor

Identificar quem:

- desenvolver ou comissionar o desenvolvimento;
- possui ou controla o modelo e o sistema;

- coloca o sistema ou modelo no mercado;
- coloca o sistema em serviço;
- usá-lo sob sua autoridade;
- Importa ou distribui na União;
- integrá-lo num produto regulamentado;
- Comercializá-lo sob um nome ou marca;
- Modificá-lo ou alterar a finalidade pretendida;
- fornece documentação, monitoramento e suporte a incidentes.

1.156.2 Passo 2 Avaliar cada função

Registro Sim, Não, ou Incerto para provedor, implantador, importador, distribuidor, representante autorizado, fabricante do produto, provedor do modelo GPAI, provedor a jusante, e qualquer gatilho de transferência de provedor-função.

1.156.3 Etapa 3 Teste os gatilhos de transferência de função do provedor

Escalar quando um ator:

- colocar um sistema no mercado ou colocá-lo em serviço sob o seu próprio nome ou marca;
- faz uma modificação substancial;
- Muda o objetivo pretendido para que o sistema se torne de alto risco ou mude materialmente o seu tratamento legal;
- integra um sistema de IA em um produto sob condições que atribuem responsabilidades ao provedor.

1.156.4 Passo 4 Alocar obrigações

Para cada função confirmada, mapeie os deveres aplicáveis, os proprietários responsáveis, as informações necessárias, as dependências contratuais, as evidências e os gatilhos de revisão.

1.157 Controles importantes

- Não confie apenas nos rótulos do contrato.
- Separe o modelo GPAI do sistema de IA a jusante.
- Avalie cada afiliado de forma independente.
- Grave incertezas e obtenha revisão legal.
- Reavaliar após mudanças de marca, integração, modificação, reaproveitamento, entidade, provedor ou distribuição.

1.158 Exemplo GlobalWay

A GlobalWay implanta um assistente de viagem construído por um fornecedor na União. A GlobalWay é normalmente o implantador. Um

fornecedor não-UE pode ser o provedor, uma afiliada da UE pode ser o importador e um revendedor pode ser o distribuidor. Se a GlobalWay modifica e comercializa substancialmente o assistente sob seu próprio nome, ele realiza uma nova avaliação do papel do provedor antes do lançamento.

1.159 Atividade de controle

O AI Governance Office mantém uma matriz de funções integrada com o inventário, a ingestão, a revisão do fornecedor, a revisão do contrato, o processo de gerenciamento de mudanças e o registro de obrigações regulatórias.

1.160 Provas

- mapa da cadeia de valor;
- folha de cálculo do papel;
- Contratos e mandatos;
- evidência de branding e marketing;
- Registos técnicos e de modificação;
- declaração para fins pretendidos;
- Aprovação legal;
- Mapeamento da obrigação de propriedade;
- log de reavaliação.

1.161 Teste de auditoria

Selecione uma amostra de IA internamente desenvolvida, adquirida, modificada, integrada e distribuída. Confirme que cada entidade e função relevante foi avaliada, que a conduta real apoia a conclusão e que os gatilhos de transferência de função são monitorados.

1.162 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Artigo 3.º e obrigações aplicáveis do ator.
- Texto atual consolidado EUR-Lex.

1.163 Capítulo 19 Decisão de Classificação e Evidência

As conclusões da classificação devem ser baseadas na lei consolidada atual, o propósito pretendido do sistema, o papel do ator, o uso afetado e a data aplicável.

1.164 Exigência

Documento se cada sistema de IA é proibido, de alto risco, sujeito a deveres de transparência, um modelo de IA de uso geral ou integração a jusante, ou fora dessas categorias.

1.165 Explicação em linguagem simples

Um rótulo não é suficiente. O registro de decisão deve mostrar os fatos, disposições legais, suposições, exclusões, revisor e data usada.

1.166 Exemplo GlobalWay

A GlobalWay registra por que um sistema de triagem de recrutamento é tratado de forma diferente de uma ferramenta de recomendação de itinerário e encaminha a incerteza para a revisão legal.

1.167 Atividade de controle

Exigir um memorando de classificação controlado por versão antes da aprovação, mudança de material ou implantação em uma nova jurisdição.

1.168 Provas

Registro de inventário, declaração de propósito pretendido, avaliação de papéis, mapeamento legal, memorando de decisão, aprovações e histórico de revisão.

1.169 Teste de auditoria

Decisões de classificação de amostra e verificar se os fatos declarados, provisões, papéis de ator, versões e datas de aplicação apoiam a conclusão.

1.170 Capítulo 20 Classificação de Alto Risco

1.171 Status da publicação

Este capítulo substitui a linguagem de classificação de alto risco conflitantes em rascunhos anteriores até que todos os arquivos de origem sejam reconciliados.

1.172 Finalidade

Este capítulo explica como determinar se um sistema de IA é de alto risco nos termos do artigo 6.o do Regulamento (UE) 2024/1689, alterado pelo Regulamento (UE) 2026/1744.

1.173 Exigência

As organizações devem realizar e documentar uma classificação de alto risco atual para cada sistema de IA material antes da implantação e após mudanças relevantes.

A classificação deve distinguir:

- 1 do artigo 6.o Sistemas ligados a produtos abrangidos pela legislação de harmonização da União do anexo I;
- 2 do artigo 6.o, os sistemas utilizados para efeitos do anexo III;
- Sistemas que figuram no anexo III, mas que podem beneficiar da exceção prevista no artigo 6.o, n.o 3, se aplicável;
- Sistemas fora do Artigo 6 que ainda podem ter transparência, GPAI, privacidade, emprego, consumidor, segurança, segurança cibernética ou obrigações do setor.

1.174 Explicação em linguagem simples

“Alto risco” é uma classificação legal, não uma descrição geral de um sistema que parece importante ou perigoso. A análise deve seguir o caminho do Artigo 6 e o anexo relevante.

Por outro lado, um sistema pode ser legalmente de alto risco, mesmo quando a organização acredita que sua pontuação de risco interna é moderada.

1.175 Via de classificação

1.175.1 Passo 1 Confirme o sistema e o propósito pretendido

Documento:

- o sistema de IA e os componentes do modelo;
- finalidade pretendida;
- usuários e pessoas afetadas;
- decisões ou resultados apoiados;
- Países e setores de implantação;
- funções de provedor e implantador;
- integração de produtos;
- dependências de fornecedores de material.

1.175.2 Passo 2 Teste o artigo 6.º, n.º 1, e o anexo I

Avalie se o sistema de IA:

- se destina a ser utilizado como componente de segurança de um produto abrangido pelo anexo I; ou
- É, em si, um produto abrangido pelo anexo I;
- e é obrigado a submeter-se a uma avaliação de conformidade de terceiros de acordo com a legislação aplicável do produto.

A data de aplicação alterada para os requisitos do Capítulo III, Seções 13 que regem os sistemas do Artigo 6(1)/Anexo I é **2 de agosto de 2028**. Esta data atrasada não deve ser usada para adiar obrigações aplicáveis independentemente.

1.175.3 Passo 3 Teste o n.o 2 do artigo 6.o e o anexo III

Avaliar se a finalidade pretendida está dentro de uma categoria do Anexo III, incluindo as categorias e condições alteradas atuais.

A data de aplicação alterada para os requisitos do capítulo III, secções 1-3, que regem os sistemas do n.o 2 do artigo 6.o/anexo III é **2 de Dezembro de 2027**.

1.175.4 Etapa 4 Avaliar qualquer exceção do artigo 6(3)

Quando legalmente disponível, determine se o sistema não representa um risco significativo de danos à saúde, segurança ou direitos fundamentais porque não influencia materialmente o resultado da tomada de decisões e atende às condições estatutárias.

Não aplique esta exceção quando o sistema executa a criação de perfis de pessoas naturais onde a Lei exclui a confiança na exceção.

A organização deve manter uma avaliação fundamentada e estar preparada para fornecê-la a uma autoridade competente.

1.175.5 Passo 5 Grave o resultado

Use um destes resultados controlados:

- Artigo 6.o, n.o 1/Anexo I de alto risco;
- Artigo 6.o, n.o 2/Anexo III, de alto risco;
- Utilização do anexo III com exceção documentada do artigo 6.o, n.o 3;
- Não de alto risco nos termos do artigo 6.o, mas sujeito a outras obrigações da AI Act;
- classificação pendente de prova legal ou técnica;
- Implantação proibida ou suspensa.

1.176 Regra da Data Efetiva

As datas de alto risco posteriores aplicam-se estritamente aos requisitos relevantes do Capítulo III, Seções 1-3. Eles não atrasam automaticamente:

- Deveres de literacia da IA;
- restrições de práticas proibidas;
- Obrigações GPAI;
- obrigações de transparência;
- disposições de governança e autoridade;
- GDPR, emprego, igualdade, consumidor, segurança, segurança cibernética ou deveres de direito do setor;
- Compromissos contratuais;
- Controles internos de risco necessários para evitar danos.

1.177 Exemplo de GlobalWay Travel Services

A GlobalWay avalia um sistema de triagem de recrutamento destinado a classificar os candidatos para decisões de emprego. O objetivo pretendido se enquadra em uma categoria de emprego do Anexo III. A GlobalWay classifica o sistema como artigo 6(2) de alto risco e mapeia a data alterada de 2 de dezembro de 2027 para os requisitos aplicáveis do Capítulo III.

A GlobalWay não trata a data como permissão para adiar a privacidade, a discriminação, a lei de emprego, a alfabetização em IA, o fornecedor, a segurança ou os controles de revisão humana. Esses controles permanecem regidos por suas próprias datas legais e operacionais.

1.178 Atividades de controle

- Exigir uma classificação documentada do Artigo 6 antes da aprovação.
- Vincule a avaliação ao texto atual do Anexo I e Anexo III.
- Exigir aprovação legal para as exceções do artigo 6(3).
- Registre o propósito pretendido e evite repurposing não aprovado.
- Reavaliar após modelo, dados, fluxo de trabalho, fornecedor, jurisdição, produto ou alterações do usuário.
- Resultados da classificação do mapa até a data de implementação correta.
- Manter evidências que sustentem determinações não de alto risco.

1.179 Provas

- declaração para fins pretendidos;
- Artigo 6.o Folha de cálculo;
- Mapeamento dos anexos I e III;
- Análise de produto-lei;
- Artigo 6.o, n.o 3, avaliação, se aplicável;
- Aprovação legal;
- Restrições à implantação;
- histórico de mudança e reavaliação;
- mapeamento artigo-para-controle.

1.180 Testes de auditoria

1. Trace sistemas selecionados através de cada etapa de classificação do Artigo 6.
2. Verifique se as referências dos Anexos I e III usam o texto alterado.
3. Artigo 6.o, n.o 3, exceção, prova e aprovação legal.
4. Os sistemas de criação de perfis não são excluídos incorretamente.
5. Verifique se as datas de 2027 e 2028 são aplicadas apenas aos requisitos relevantes.
6. Os sistemas de alto risco ainda são avaliados para outras obrigações.

7. Teste se as mudanças desencadeiam a reclassificação.

1.181 Lista de verificação de gestão

- O propósito pretendido é documentado com precisão?
- Os artigos 6.o, n.o 1, e 6.o, n.o 2, foram ambos testados?
- O artigo 6.o, n.o 3, é totalmente apoiado?
- As datas de 2027 e 2028 são usadas de forma restrita?
- Outros deveres legais são controlados de forma independente?

1.182 Especificação Caminho de classificação de alto risco

Criar uma árvore de decisão começando com o propósito pretendido, depois separar o artigo 6(1)/Anexo I e o artigo 6(2)/Anexo III, seguido da análise de exceção do artigo 6(3), resultados de classificação controlada e gatilhos de reavaliação.

Texto alternativo: Decisão de classificação de IA de alto risco que testa o artigo 6.o, n.o 1, e os sistemas de produtos do anexo I, o artigo 6.o, n.o 2, e os casos de utilização do anexo III, a exceção do artigo 6.o, n.o 3, os resultados finais da classificação, as datas de implementação e os gatilhos de reavaliação.

1.183 Capítulo 21 Análise dos Anexos I e III

1.184 Status da publicação

Este capítulo substitui a linguagem de análise de anexos conflitantes em rascunhos anteriores até que todos os capítulos, apêndices, gráficos e traduções afetados sejam reconciliados.

1.185 Finalidade

Este capítulo fornece um método estruturado para analisar os sistemas relacionados com os produtos do anexo I e os casos de utilização do anexo III nos termos do artigo 6.o do Regulamento (UE) 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) 2026/1744.

1.186 Exigência

As organizações devem analisar os Anexos I e III separadamente, documentar o caminho legal exato e evitar tratar os dois anexos como listas intercambiáveis de sistemas de alto risco.

1.187 Explicação em linguagem simples

Os Anexos I e Anexo III alcançam IA de alto risco através de diferentes rotas legais:

- **O Anexo I** diz respeito à IA ligada a produtos regidos pela legislação de harmonização da União listada e às condições previstas no artigo 6.o, n.o 1.
- **O Anexo III** diz respeito a casos de uso listados em áreas sensíveis e às condições do artigo 6.o, n.o 2, sujeito, quando aplicável, à exceção do artigo 6.o, n.o 3.

A análise deve ser baseada no propósito pretendido e na implantação real, não apenas no rótulo de marketing do fornecedor.

1.188 Análise do anexo I

Para cada sistema potencialmente relevante, documento:

- O produto ou componente de segurança envolvido;
- A legislação de harmonização aplicável do anexo I da União;
- se o próprio sistema de IA é o produto regulamentado ou um componente de segurança;
- se a avaliação da conformidade de terceiros é necessária nos termos dessa legislação sobre produtos;
- o fabricante, fornecedor, importador, distribuidor e outras funções da cadeia de produtos;
- A rota de avaliação da conformidade;
- dependências de documentação técnica;
- obrigações pós-comercialização e incidentes;
- mudanças que podem alterar a classificação.

A data de aplicação alterada para os requisitos relevantes do capítulo III, secções 1-3, para os sistemas do n.o 1 do artigo 6.o/anexo I é **2 de Agosto de 2028**.

1.189 Análise do anexo III

Para cada caso de uso potencialmente relevante, documento:

- O ponto e o subponto exatos do anexo III;
- a finalidade pretendida;
- a decisão, recomendação, classificação, classificação ou determinação de acesso apoiada;
- população afetada;
- se o sistema influencia materialmente o resultado;
- A existência de perfis de pessoas singulares;
- as funções de provedor e de deployer;
- Qualquer análise de exceção do artigo 6.o, n.o 3;
- direitos fundamentais, segurança, discriminação e implicações da visão humana;

- jurisdição e sobreposições setoriais.

A data de aplicação alterada para os requisitos relevantes do capítulo III, secções 1-3, para os sistemas do artigo 6.o, n.o 2/Anexo III é **2 de dezembro de 2027**.

1.190 Artigo 6.o, n.o 3, controlo da exceção

Quando a exceção estiver legalmente disponível, a avaliação deve:

- identificar a condição legal exata em que se baseia;
- explicar por que o sistema não representa um risco significativo de danos à saúde, segurança ou direitos fundamentais;
- explicar por que não influencia materialmente o resultado da decisão;
- confirmar se a definição de perfis ocorre;
- Documentos comprovativos de provas técnicas e operacionais;
- Receber aprovação legal;
- ser retidos e revisados após as mudanças.

Uma declaração superficial de que o sistema é “somente assistiva” é insuficiente.

1.191 Precaução eficaz

As datas alteradas de 2027 e 2028 aplicam-se aos requisitos especificados de alto risco. Eles não adiam as obrigações aplicáveis independentemente, incluindo:

- restrições de práticas proibidas;
- Requisitos de AI-literacia;
- Funções GPAI;
- Artigo 50.o Direitos de transparência;
- GDPR e requisitos de proteção de dados;
- emprego, igualdade, consumidor, segurança, segurança cibernética e direito do setor;
- obrigações contratuais e de controle interno.

1.192 Exemplo de GlobalWay Travel Services

A GlobalWay revisa dois sistemas:

1. uma ferramenta de classificação de recrutamento utilizada para listar candidatos; e
2. um componente de segurança habilitado para IA incorporado em um produto de mobilidade aeroportuária regulamentado.

O sistema de recrutamento segue o artigo 6(2)/Anexo III e o calendário de 2 de dezembro de 2027 para os requisitos relevantes de alto risco. O

componente de segurança incorporado no produto segue o artigo 6(1)/Anexo I e o calendário de 2 de agosto de 2028.

A GlobalWay mantém análises jurídicas separadas, proprietários, dependências de conformidade, pacotes de evidências e planos de projeto para os dois sistemas.

1.193 Actividades de controlo

- Manter seções separadas de avaliação dos Anexos I e III.
- Cite o artigo exato, o ponto de anexo e a legislação do produto.
- Exigir especialistas em segurança de produtos para avaliações do Anexo I.
- Exigir aprovação legal para as exceções do Anexo III.
- Vincule a classificação à data de implementação correta.
- Reavaliar após o propósito pretendido, produto, modelo, dados, fluxo de trabalho, fornecedor ou alterações na jurisdição.
- Reconciliar a análise com documentação técnica, contratos, avaliações de risco e controles de implantação.

1.194 Provas

- Mapeamento do produto-lei do anexo I;
- Mapeamento de casos de utilização do anexo III;
- declaração para fins pretendidos;
- Análise de avaliação da conformidade;
- Artigo 6.o, n.o 3, registo de exceção;
- Avaliação da definição de perfis;
- aprovações legais e de segurança de produtos;
- arquitetura do sistema e registros de fluxo de trabalho;
- calendário de implementação;
- Histórico de reavaliação.

1.195 Testes de auditoria

1. Verifique se as análises dos Anexos I e III estão separadas.
2. Trace as conclusões do anexo I à legislação aplicável sobre produtos e às condições de conformidade.
3. Trace as conclusões do Anexo III com o ponto exato e o propósito pretendido.
4. Reveja as exceções do artigo 6(3) para evidências completas e análise de perfil.
5. Confirme que as datas de 2 de dezembro de 2027 e 2 de agosto de 2028 são atribuídas corretamente.
6. Verifique se outras leis aplicáveis e deveres do AI Act não são diferidos incorretamente.

7. Teste se as alterações do sistema desencadeiam a reavaliação.

1.196 Lista de verificação de gestão

- Os Anexos I e III são tratados como diferentes vias legais?
- O ponto exato do anexo está documentado?
- A avaliação reflete o propósito real pretendido e a implantação?
- Alguma exceção é totalmente apoiada e aprovada?
- As datas de implementação são mapeadas corretamente?
- Outras tarefas são controladas de forma independente?

1.197 Especificação Anexo I e Anexo III Comparação

Criar uma comparação de duas colunas. O lado do Anexo I deve mostrar produtos regulamentados, componente de segurança, legislação do produto, avaliação de conformidade de terceiros e a data de 2 de agosto de 2028. O lado do Anexo III deve mostrar caso de uso sensível, finalidade pretendida, análise de exceção do Artigo 6(3), restrição de perfil e a data de 2 de dezembro de 2027. Junte-se a ambos os caminhos em governança, evidência, monitoramento e reavaliação.

**** Texto Alt:**** Comparação da IA de alto risco relacionada ao produto do Anexo I e da IA de alto risco de uso sensível do Anexo III, mostrando seus diferentes testes legais, conformidade e caminhos de exceção, datas de implementação, requisitos de evidência e controles de reavaliação.

1.198 Capítulo 22 Análise de Exceção e Escopo de Alto Risco

Estado legal: Mestre inglês corrigido. Escopo de alto risco e qualquer análise de exceção devem ser verificados contra o texto consolidado atual, incluindo o gatilho legal específico e data de aplicação.

1.199 Exigência

Avaliar se um sistema de IA se enquadra em uma categoria de alto risco e se qualquer exclusão, limitação ou exceção legalmente disponível se aplica.

1.200 Explicação em linguagem simples

A descrição do negócio por si só é insuficiente. A análise deve conectar o propósito pretendido e o uso real ao artigo relevante e à entrada em anexo.

1.201 Exemplo GlobalWay

A GlobalWay avalia separadamente uma ferramenta de classificação de recrutamento, um alerta de risco de viagem e um assistente de suporte ao cliente porque seus propósitos e efeitos diferem.

1.202 Atividade de controle

Exigir revisão legal e de conformidade de escopo de alto risco antes do uso da produção e após a mudança material.

1.203 Provas

Registro de propósito pretendido, descrição do caso de uso, mapeamento de anexo, justificativa de exceção, aprovações e data de revisão.

1.204 Teste de auditoria

Verifique se as decisões amostradas identificam a provisão legal correta, o ator, os fatos e as evidências que apoiam o resultado.

1.205 Capítulo 23 Revisão e aprovação da classificação

Estado legal: Mestre inglês corrigido. A aprovação de classificação é um controle organizacional que apoia a conformidade; não substitui o teste legal.

1.206 Exigência

Estabelecer revisão independente e aprovação documentada para decisões de classificação de IA.

1.207 Explicação em linguagem simples

A pessoa que propõe um uso não deve ser a única pessoa que decide sua categoria legal.

1.208 Exemplo GlobalWay

A GlobalWay requer análise de negócios, legal, privacidade, segurança e governança de IA para sistemas de materiais.

1.209 Atividade de controle

Use limites de aprovação definidos, regras de escalada e controles de conflito de interesses.

1.210 Provas

Comentários dos revisores, registro de aprovação, questões não resolvidas, condições e data de revisão.

1.211 Teste de auditoria

Confirme que os sistemas amostrados receberam a revisão necessária antes da implantação.

1.212 Capítulo 24 Reclassificação e mudança de gatilhos

Estado legal: Mestre inglês corrigido. A reclassificação deve ser baseada em fatos e leis atuais; limiares internos de gatilho são controles de governança.

1.213 Exigência

Reavaliar a classificação quando o propósito pretendido, funcionalidade, modelo, dados, população de usuários, jurisdição, fornecedor ou requisitos legais mudarem.

1.214 Explicação em linguagem simples

Uma decisão correta pode ficar desatualizada após uma mudança material.

1.215 Exemplo GlobalWay

A GlobalWay reabre a classificação quando um assistente de atendimento ao cliente é adaptado para classificar candidatos a emprego.

1.216 Atividade de controle

Conecte o gerenciamento de mudanças à revisão obrigatória de classificação e bloqueio de liberação.

1.217 Provas

Solicitação de mudança, análise de impacto, classificação revisada, aprovações e decisão de liberação.

1.218 Teste de auditoria

Traçado mudanças de material para reclassificação concluída antes da implantação.

1.219 Capítulo 25 Registo e Relatórios de Classificação

Estado legal: Mestre inglês corrigido. O registro é um controle organizacional e não deve exagerar as conclusões legais.

1.220 Exigência

Mantenha um registro atual de classificações de IA, proprietários, bases legais, condições e datas de revisão.

1.221 Explicação em linguagem simples

A gestão precisa de uma visão confiável do que foi decidido, por que e quando deve ser revisitado.

1.222 Exemplo GlobalWay

A GlobalWay relata classificações não resolvidas e revisões atrasadas ao seu comitê de governança de IA.

1.223 Atividade de controle

Reconciliar o registro para compras, arquitetura, privacidade, segurança e estoques de produção.

1.224 Provas

Registre extratos, registros de reconciliação, exceções, dashboards e aprovações.

1.225 Teste de auditoria

Verifique a integridade, precisão e revisão oportuna das entradas de registro amostradas.

1.226 Capítulo 26 Visão Geral das Práticas Proibidas

Estado legal: Mestre inglês corrigido. As conclusões da prática proibida devem ser verificadas em relação ao texto consolidado atual do Artigo 5 e às datas aplicáveis.

1.227 Exigência

A IA de tela usa para práticas proibidas pela Lei de IA da UE antes da aquisição, desenvolvimento, teste ou implantação.

1.228 Explicação em linguagem simples

Alguns usos não podem ser aprovados por meio de aceitação de risco comum ou controles de compensação.

1.229 Exemplo GlobalWay

A GlobalWay exige triagem de práticas proibidas para análise de funcionários, ferramentas biométricas, pontuação de clientes e casos de uso de influência comportamental.

1.230 Atividade de controle

Aplique uma lista de verificação de bloqueio de liberação com escalada legal obrigatória para a incerteza.

1.231 Provas

Descrição do caso de uso, resultado de triagem, análise legal, decisão, restrições e registro de monitoramento.

1.232 Teste de auditoria

Verifique se os sistemas amostrados foram rastreados antes do uso e se os usos proibidos foram bloqueados ou descontinuados.

1.233 Capítulo 27 Manipulação e Técnicas Subliminares

Estado legal: Mestre inglês corrigido. Avalie os critérios atuais consolidados do Artigo 5, incluindo a técnica, intenção ou efeito, pessoas afetadas e limiar de dano legalmente relevante.

1.234 Exigência

Impedir usos de IA que empregam técnicas manipulativas, enganosas ou subliminares proibidas.

1.235 Explicação em linguagem simples

Marketing, personalização ou design de interface não devem passar para uma influência legalmente proibida.

1.236 Exemplo GlobalWay

A GlobalWay revisa as interfaces de recomendação e preços para pressão enganosa ou exploração.

1.237 Atividade de controle

Exigir revisão de design comportamental, testes, escalada legal e bloqueio de liberação.

1.238 Provas

Registros de projeto, resultados de testes, revisão legal, aprovações e monitoramento.

1.239 Teste de auditoria

Inspecione as interfaces amostradas e verifique se os riscos de influência proibidos foram avaliados e controlados.

1.240 Capítulo 28 Exploração de Vulnerabilidades

Estado legal: Mestre inglês corrigido. Aplique o atual teste consolidado do Artigo 5 à vulnerabilidade, exploração, distorção material e danos.

1.241 Exigência

Impedir que a IA explore ilegalmente vulnerabilidades associadas à idade, deficiência ou circunstâncias sociais ou econômicas.

1.242 Explicação em linguagem simples

Um sistema não deve tirar proveito da vulnerabilidade de uma pessoa de uma forma que a lei proíbe.

1.243 Exemplo GlobalWay

A GlobalWay analisa ofertas e ferramentas de suporte usadas com viajantes encalhados, menores e pessoas que necessitam de assistência de acessibilidade.

1.244 Atividade de controle

Exigir revisão de impacto de pessoas vulneráveis, design acessível, monitoramento e escalada legal.

1.245 Provas

Avaliação de impacto, avaliação de projeto, testes, reclamações, aprovações e ações corretivas.

1.246 Teste de auditoria

Verifique se os casos de uso amostrados identificam grupos vulneráveis e abordam o risco de exploração proibida.

1.247 Capítulo 29 Pontuação social

Estado legal: Mestre inglês corrigido. Aplique os atuais critérios consolidados do Artigo 5 à finalidade de pontuação, contexto de dados, tratamento e prejuízo resultante.

1.248 Exigência

Evitar práticas de pontuação social proibidas.

1.249 Explicação em linguagem simples

As organizações não devem usar um comportamento amplo ou pontuações características para impor tratamento não relacionado ou desproporcional legalmente proibido.

1.250 Exemplo GlobalWay

A GlobalWay proíbe a combinação de comportamento não relacionado do cliente, conduta de funcionários e histórico de viagens em uma pontuação de confiança generalizada usada em todos os contextos.

1.251 Atividade de controle

Exigir limitação de propósito, revisão de contexto de dados, testes de consequência e aprovação legal.

1.252 Provas

Pontuação lógica, inventário de dados, restrições de uso, avaliação de impacto, aprovações e monitoramento.

1.253 Teste de auditoria

Escores amostrados para suas entradas, propósitos, consequências e controles.

1.254 Capítulo 30 Policiamento Preditivo e Inferência de Risco

Estado legal: Mestre inglês corrigido. Aplique as atuais regras consolidadas do Artigo 5 e quaisquer distinções de escopo legal ao ator, finalidade, dados e decisão específicos.

1.255 Exigência

Impedir o policiamento preditivo proibido ou usos individuais de inferência de risco.

1.256 Explicação em linguagem simples

A avaliação legal depende de quem usa o sistema, o que ele prevê, as evidências consideradas e como a saída afeta uma pessoa.

1.257 Exemplo GlobalWay

A GlobalWay não reaproveita a análise de risco de viajante para previsão de aplicação da lei sem autoridade legal e revisão separadas.

1.258 Atividade de controle

Bloquear o uso secundário fora do propósito aprovado e exigir revisão legal para solicitações governamentais ou de aplicação da lei.

1.259 Provas

Declaração de propósito, controles de acesso, registros de solicitação, revisão legal, aprovações e monitoramento.

1.260 Teste de auditoria

Verifique se as saídas não são reaproveitadas para previsão de risco individual proibida.

1.261 Capítulo 31 Scraping facial e bases de dados biométricas

Estado legal: Mestre inglês corrigido. Aplique a atual proibição consolidada do Artigo 5 e quaisquer limites de escopo relevantes para o método de coleta, fonte, propósito e ator.

1.262 Exigência

Impedir a raspagem não direcionada de imagens faciais para criar ou expandir bancos de dados de reconhecimento facial.

1.263 Explicação em linguagem simples

Uma fonte de dados conveniente não torna a coleta indiscriminada de imagens faciais lícita.

1.264 Exemplo GlobalWay

A GlobalWay proíbe os fornecedores de raspar sites públicos ou imagens de vigilância para construir bancos de dados de viajantes ou funcionários.

1.265 Atividade de controle

Exigir revisão de fornecimento de dados biométricos, restrições contratuais, bloqueio técnico e evidências de fornecedores.

1.266 Provas

Registros de fontes de dados, contratos, due diligence, controles de arquitetura, aprovações e monitoramento.

1.267 Teste de auditoria

Verifique a proveniência e a base de coleta legal para qualquer conjunto de dados de imagem facial.

1.268 Capítulo 32 Restrições ao reconhecimento de emoções

Estado legal: Mestre inglês corrigido. Aplique as atuais regras consolidadas do Artigo 5, o contexto do setor, as exceções, os deveres de transparência e as datas de aplicação.

1.269 Exigência

Impedir o uso proibido de reconhecimento de emoções e controlar qualquer uso que permaneça legalmente permitido.

1.270 Explicação em linguagem simples

Inferir emoção de sinais biométricos ou comportamentais é legalmente sensível e dependente do contexto.

1.271 Exemplo GlobalWay

A GlobalWay bloqueia a análise de emoções no monitoramento do desempenho dos funcionários e requer revisão legal para qualquer proposta relacionada à segurança.

1.272 Atividade de controle

Exigir revisão de propósito, setor, exceção, precisão, necessidade, privacidade e transparência antes do uso.

1.273 Provas

Registro de caso de uso, descrição técnica, análise legal, avaliação de impacto, aprovações e monitoramento.

1.274 Teste de auditoria

Verifique se os usos de reconhecimento de emoção amostrados não são proibidos e atendam a todas as condições aplicáveis.

1.275 Capítulo 33 Restrições à categorização biométrica

Estado legal: Mestre inglês corrigido. Aplique as atuais regras consolidadas do Artigo 5 à categoria inferida, base biométrica, finalidade, ator e qualquer exceção legalmente relevante.

1.276 Exigência

Prevenir a categorização biométrica proibida, particularmente onde características sensíveis ou protegidas são inferidas.

1.277 Explicação em linguagem simples

Um sistema não deve inferir características legalmente protegidas de dados biométricos onde a lei proíbe essa prática.

1.278 Exemplo GlobalWay

A GlobalWay proíbe a classificação de viajantes ou funcionários por etnia, religião, opinião política, orientação sexual ou características sensíveis semelhantes de dados faciais ou de voz.

1.279 Atividade de controlo

Exigir revisão de recursos biométricos, bloqueio de categoria proibida, restrições de fornecedores e aprovação legal.

1.280 Provas

Inventário de recursos, documentação de modelo, resultados de testes, contratos, aprovações e monitoramento.

1.281 Teste de auditoria

Verifique se os sistemas biométricos não geram ou expõem saídas de categorias sensíveis proibidas.

1.282 Capítulo 34 Novas Proibições para Conteúdo Íntimo Não-Consenso e Material de Abuso Sexual Infantil

1.283 Status da publicação

Texto mestre em inglês corrigido pela lei. Este capítulo substitui a linguagem de rascunho do capítulo 34 até que o rascunho original, os números, os apêndices e as traduções sejam reconciliados.

1.284 Finalidade

Este capítulo explica as práticas adicionais de IA proibidas introduzidas pelo Regulamento (UE) 2026/1744 relativo aos sistemas de IA que geram conteúdo sexualmente explícito ou íntimo não consensual e material de abuso sexual infantil.

1.285 Linha de base legal vinculativa

O Regulamento (UE) 2026/1744 alterou o Regulamento (UE) 2024/1689 adicionando novas proibições ao artigo 5.o Estas disposições entraram em vigor com o regulamento de alteração, mas aplicam-se a partir de **2 de dezembro de 2026**.

As organizações devem distinguir:

- adoção e entrada em vigor da emenda;
- a data em que as novas proibições começam a ser aplicadas;
- Os elementos jurídicos separados de cada categoria proibida;
- leis criminais, de proteção à criança, privacidade, plataforma, emprego e segurança de conteúdo que já podem ser aplicadas de forma independente.

1.286 Exigência

Uma organização não deve colocar no mercado, colocar em serviço ou usar um sistema de IA de maneira proibida pelo Artigo 5 alterado. Deve realizar uma avaliação legal elemento por elemento, em vez de confiar em um rótulo amplo, como “conteúdo prejudicial”.

1.287 Explicação em linguagem simples

A emenda tem como alvo os sistemas de IA usados para gerar duas categorias especialmente sérias de material:

1. conteúdo sexualmente explícito ou íntimo não consensual; e
2. material de abuso sexual infantil.

A organização deve manter essas categorias legalmente distintas, documentar os fatos que apoiam sua conclusão e evitar implicar que toda saída ofensiva, sexualizada ou invasiva à privacidade se enquadra automaticamente no mesmo elemento estatutário.

1.288 Controle de data efetiva

Antes de 2 de dezembro de 2026, as novas proibições da AI Act devem ser tratadas como adotadas, mas ainda não aplicáveis sob sua data específica de aplicação da AI Act. Isso não autoriza a conduta. Outros UE, Estado-Membro, criminal, privacidade, segurança infantil, plataforma, emprego ou regras contratuais já podem proibi-lo ou restringi-lo.

A partir de 2 de dezembro de 2026, as proibições alteradas do artigo 5o aplicam-se diretamente de acordo com sua redação estatutária.

1.289 Perguntas de triagem

Para cada sistema ou caso de uso relevante, determine:

- se o sistema pode gerar ou transformar materialmente conteúdo sexual, íntimo ou relacionado à criança;
- se o uso envolve uma pessoa identificável ou razoavelmente identificável;
- se o consentimento existe, é válido e abrange a geração e uso específicos;
- se o conteúdo é sexualmente explícito ou íntimo dentro do contexto legal aplicável;
- se o conteúdo constitui ou pode constituir material de abuso sexual infantil;
- se os prompts, ajuste fino, ferramentas, fontes de recuperação, edição de imagens ou ações do agente permitem a conduta proibida;
- funcionários, contratados, usuários, clientes ou fornecedores podem contornar as salvaguardas;
- se a organização é um provedor, implantador, distribuidor, importador ou outro ator relevante;
- se a suspensão imediata, preservação, relatório ou escalada da aplicação da lei é necessária.

1.290 gatilhos de escalada obrigatórios

escalar imediatamente quando:

- um sistema é projetado, comercializado ou configurado para “nudificação” ou geração de conteúdo íntimo não consensual equivalente;
- um sistema pode gerar representações sexualizadas de uma pessoa real sem o consentimento verificado;
- qualquer saída pode representar uma criança em material de abuso sexual;
- As salvaguardas são ignoradas repetidamente;
- um fornecedor se recusa a fornecer controles adequados, registros ou suporte a incidentes;
- a classificação legal é incerta, mas o dano potencial é grave;
- evidências sugerem conduta criminosa, perigo infantil, coerção, extorsão, assédio ou exploração.

1.291 Exemplo de GlobalWay Travel Services

A equipe de marketing da GlobalWay propõe uma ferramenta de edição de imagens para campanhas de viagens personalizadas. Testes mostram que os

usuários podem fazer upload de fotografias e solicitar que a ferramenta remova roupas ou gere versões sexualizadas de pessoas reais.

A GlobalWay bloqueia imediatamente o recurso, preserva evidências de teste, aumenta para Legal, Segurança, Privacidade e gerenciamento executivo e exige que o fornecedor demonstre restrições técnicas eficazes. O sistema não é aprovado para implantação. O registro de decisão analisa separadamente conteúdo íntimo não consensual, possível exposição à segurança infantil, privacidade, emprego e preocupações com a lei criminal.

1.292 Atividades de controle

- Adicione as duas categorias proibidas alteradas à ingestão e à triagem de práticas proibidas.
- Bloqueie prompts de alto risco, transformações, modelos, ferramentas e fluxos de trabalho em várias camadas de controle.
- Proibir o marketing ou descrições de produtos que incentivem usos proibidos.
- Exigir controles de consentimento verificados quando relevante, sem tratar o consentimento como suficiente para material de abuso sexual infantil.
- Implementar controles relacionados à idade e à segurança infantil proporcionais ao caso de uso.
- Preserve alertas, saídas, logs, versões de modelo, identificadores de usuário e eventos de controle após um incidente.
- Defina suspensão imediata, restrição de conta, escalada do fornecedor e procedimentos legais.
- O pessoal do trem na data de aplicação de 2 de dezembro de 2026 e em leis aplicáveis independentemente.
- Reavaliar as capacidades open-source, afinadas, de edição de imagens, de geração de vídeo e de agentes após as alterações.

1.293 Provas

- Avaliação de práticas proibidas;
- citação de artigo e emenda;
- Registros de consentimento e de projeto de controle de identidade;
- Políticas de segurança e configurações de modelo;
- resultados dos testes de prompt e de saída;
- Testes de equipe vermelha e caso de abuso;
- logs de eventos bloqueados;
- Registros de incidentes e escaladas;
- Evidência de correspondência e remediação do fornecedor;
- Suspensão, rejeição ou aprovação de descomissionamento;
- registros legais e de relatórios.

1.294 Testes de auditoria

1. Confirme se a organização distingue as duas categorias proibidas alteradas.
2. Verifique se a data de aplicação de 2 de dezembro de 2026 é indicada de forma consistente.
3. Teste se os usuários podem ignorar as salvaguardas por meio de alertas, uploads, edição, ferramentas ou APIs.
4. Revise se os eventos de segurança infantil recebem escalada imediata e preservação de evidências.
5. Confirme que os controles de consentimento não são tratados como uma defesa para material de abuso sexual infantil.
6. Trace rejeitado ou suspenso usa para documentar decisões legais e executivas.
7. Verifique se os apêndices relacionados, treinamento, gráficos e controles do fornecedor estão alinhados.

1.295 Lista de verificação de gestão

- Já examinamos todos os sistemas generativos de imagem, áudio, vídeo e edição?
- O sistema pode sexualizar ou expor uma pessoa real sem consentimento válido?
- Algum fluxo de trabalho poderia gerar material de abuso sexual infantil?
- As tentativas de bypass são detectadas e escaladas?
- A data de inscrição de 2 de dezembro de 2026 está corretamente registrada?
- Outras leis já aplicáveis são avaliadas separadamente?

1.296 Especificação Caminho de Decisão íntima-Conteúdo Proibido

Criar um fluxo de decisão começando com a capacidade do sistema e uso pretendido, em seguida, separar ramos para conteúdo sexualmente explícito ou íntimo não consensual e material de abuso sexual infantil. Mostrar análise de consentimento apenas no ramo de conteúdo íntimo adulto, parada imediata e escalada para possível material de abuso sexual infantil e preservação de evidências para ambos os ramos.

Alt text: Caminho de decisão para sistemas de IA capazes de gerar conteúdo sexual ou íntimo, separando a análise de conteúdo íntimo adulto não consensual da parada imediata e da escalada para possível material de abuso sexual infantil, com preservação de evidências e revisão legal.

1.297 Capítulo 35 Governança e Garantia de Prática Proibida

Estado legal: Mestre inglês corrigido. Os controles de governança apoiam a conformidade, mas não podem autorizar uma prática proibida ou substituir a análise legal atual.

1.298 Exigência

Manter os controles da empresa para identificar, bloquear, escalar, monitorar e remediar práticas de IA proibidas.

1.299 Explicação em linguagem simples

A conformidade com a prática proibida deve operar através da ingestão, aquisição, desenvolvimento, mudança, implantação, monitoramento e resposta a incidentes.

1.300 Exemplo GlobalWay

A GlobalWay combina portões de liberação, cláusulas de fornecedores, treinamento de funcionários, canais de reclamações e escalada executiva para evitar usos proibidos.

1.301 Atividade de controle

Atribuir proprietários responsáveis, manter uma lista de verificação de proibição, testar controles, preservar evidências e exigir suspensão imediata, quando necessário.

1.302 Provas

Políticas, exames, treinamento, contratos, blocos de sistema, monitoramento de resultados, incidentes, ações corretivas e relatórios de auditoria.

1.303 Teste de auditoria

Teste o design e a eficácia operacional em uma amostra de sistemas, mudanças, fornecedores e preocupações relatadas.

1.304 Capítulo 36 Sistema de Gestão da Qualidade de Alto Risco

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 36 linguagem de rascunho.

1.305 Exigência

Os fornecedores de sistemas de IA de alto risco devem estabelecer, documentar, implementar, manter e melhorar continuamente um sistema de gestão da qualidade proporcional à organização e ao sistema. O sistema deve abranger os elementos exigidos pelo artigo 17.o do Regulamento (UE) 2024/1689, conforme alterado.

1.306 Explicação em linguagem simples

Um sistema de gestão da qualidade é a estrutura operacional que torna a conformidade repetível. Ele conecta política, responsabilidade, design, testes, governança de dados, documentação, gerenciamento de riscos, monitoramento, incidentes, ações corretivas, controles de fornecedores e manutenção de registros. Não pode ser reduzido a uma declaração de política ou uma revisão única.

A certificação ISO / IEC 42001 ou outra norma pode apoiar o ambiente de controle da organização, mas a certificação por si só não estabelece conformidade com a Lei AI. A organização ainda deve demonstrar que os requisitos estatutários aplicáveis ao sistema de IA de alto risco específico estão satisfeitos.

1.307 Elementos do sistema necessários

O sistema documentado deve abordar, conforme aplicável:

1. Estratégia de conformidade regulamentar;
2. procedimentos de design, desenvolvimento e controle de projeto;
3. Exame, teste e validação antes, durante e após o desenvolvimento;
4. Especificações técnicas e normas utilizadas;
5. Sistemas e procedimentos de gestão de dados;
6. Gestão dos riscos nos termos do artigo 9.o;
7. Acompanhamento pós-comercialização nos termos do artigo 72.o;
8. relatórios de incidentes graves e mau funcionamento;
9. comunicação com autoridades, organismos notificados, operadores, clientes e outras partes interessadas;
10. manutenção de registos e controlo de documentos;
11. gestão de recursos, competência e responsabilidade;
12. Acções correctivas e verificação da eficácia;
13. mecanismos de revisão de gestão e melhoria contínua.

1.308 Exemplo GlobalWay

A GlobalWay desenvolve um sistema de triagem de recrutamento de alto risco para uso sob sua própria marca. Seu sistema de gerenciamento de qualidade vincula classificação legal, padrões de desenvolvimento

aprovados, revisões de dados, testes de viés e precisão, documentação técnica, design de supervisão humana, aprovação de liberação, controles de fornecedores, monitoramento pós-mercado, escalada de incidentes e registros de ações corretivas.

1.309 Atividade de controle

O provedor responsável deve manter um manual de gestão da qualidade aprovado e um plano de conformidade específico do sistema. Cada processo necessário deve ter um proprietário, procedimento, requisito de evidência, frequência de revisão, rota de escalada e mecanismo de revisão de gerenciamento.

1.310 Provas

- Manual de gestão da qualidade;
- mapa de processo e RACI;
- Plano de conformidade regulamentar;
- procedimentos de projeto e teste;
- Registos de gestão de risco;
- registros de governança de dados;
- índice de documentação técnica;
- Plano de monitorização pós-comercialização;
- Procedimentos de incidente e de ação corretiva;
- minutos de gestão-revisão;
- registros de competência e treinamento.

1.311 Teste de auditoria

Selecione um sistema de IA de alto risco. Trace cada elemento de gerenciamento de qualidade do Artigo 17 para um processo aprovado, proprietário responsável, evidência operacional e revisão de gerenciamento. Confirme se o sistema é mantido na prática e não meramente documentado.

1.312 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 17.o
- Regulamento (UE) n.o 2026/1744 relativo às datas de aplicação alteradas e às disposições de simplificação conexas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.313 Capítulo 37 Gestão Contínua do Risco

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 37 linguagem de rascunho.

1.314 Exigência

Um fornecedor de um sistema de IA de alto risco deve estabelecer, implementar, documentar e manter o sistema de gerenciamento de risco contínuo e iterativo exigido pelo Artigo 9 durante todo o ciclo de vida do sistema.

1.315 Explicação em linguagem simples

A gestão de riscos não é uma lista de verificação de lançamento. O provedor deve identificar, estimar, avaliar, controlar, testar, monitorar e reavaliar os riscos à saúde, segurança e direitos fundamentais. A análise deve abordar o uso pretendido, o mau uso razoavelmente previsível, as informações do monitoramento pós-comercialização e se o risco residual é aceitável quando ponderado em relação aos benefícios pretendidos do sistema.

1.316 Processo necessário

O processo deve incluir:

1. Identificação e análise dos riscos conhecidos e razoavelmente previsíveis durante a utilização prevista;
2. avaliação e avaliação dos riscos decorrentes do uso pretendido e do mau uso razoavelmente previsível;
3. Avaliação de riscos adicionais identificados através de monitorização pós-comercialização;
4. adoção de medidas específicas de controle de risco;
5. Testes para identificar os controlos mais adequados e verificar a eficácia;
6. Revisão do risco residual e do risco residual global;
7. Consideração dos efeitos sobre as crianças e outros grupos vulneráveis, quando relevante;
8. revisão e atualização sistemáticas ao longo do ciclo de vida.

Os controles de risco devem seguir uma hierarquia defensável: eliminar ou reduzir o risco através do design sempre que possível, implementar salvaguardas técnicas e organizacionais e fornecer informações e treinamento para o risco restante.

1.317 Exemplo GlobalWay

O sistema de triagem de recrutamento da GlobalWay pode criar discriminação, viés de automação, qualidade de dados, privacidade e riscos de segurança cibernética. O provedor documenta cenários de risco, testa controles alternativos, limita a classificação automatizada, requer revisão humana treinada, monitora disparidades de taxa de seleção e reabre a avaliação após modelo, dados, limite ou mudanças na família do trabalho.

1.318 Atividade de controlo

O proprietário do sistema e a função de risco devem manter um arquivo de risco controlado por versão vinculado a requisitos, testes, supervisão humana, monitoramento pós-comercialização, incidentes e gerenciamento de mudanças. A aprovação da liberação é proibida quando os controles de risco necessários estiverem ausentes ou o risco residual não tiver aceitação autorizada.

1.319 Provas

- Plano de gestão do risco do ciclo de vida;
- Registo de risco de perigo e direitos fundamentais;
- Análise de utilização prevista e de utilização previsível;
- Racionalidade controle-seleção;
- Planos de teste e resultados;
- decisão de risco residual;
- análise de grupo vulnerável;
- Atualizações pós-mercado;
- Reavaliações desencadeadas por mudanças;
- aprovações e exceções.

1.320 Teste de auditoria

Para um sistema de IA de alto risco de amostra, confirme que o gerenciamento de riscos começou antes da implantação, aborda todas as etapas do Artigo 9, está vinculado a testes e evidências pós-comercialização e foi atualizado após mudanças relevantes, incidentes ou riscos emergentes.

1.321 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 9.º
- Artigo 72.º para a gestão dos riscos de alimentação de informação pós-comercialização.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.322 Capítulo 38 Governança de dados

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 38 linguagem de rascunho.

1.323 Exigência

Caso um sistema de IA de alto risco utilize conjuntos de dados de treinamento, validação ou teste, o provedor deve aplicar os requisitos de governança de dados e dados do artigo 10.º do Regulamento (UE) 2024/1689, conforme alterado.

1.324 Explicação em linguagem simples

O objetivo legal não é dados perfeitos. É disciplinado, governança de dados documentada apropriada para o propósito e risco pretendido. O provedor deve entender de onde os dados vieram, por que é adequado, como foi preparado, quais limitações ou erros existem, se os grupos afetados são adequadamente representados e se o sistema poderia criar ou reforçar viés.

O Artigo 10 não cria de forma independente uma base legal para processar dados pessoais ou dados de categoria especial. O GDPR e outros requisitos de privacidade aplicáveis devem ser avaliados separadamente.

1.325 Áreas de governança necessárias

O provedor deve documentar, conforme aplicável:

1. escolhas de concepção de dados e processos de recolha;
2. origem dos dados, proveniência e finalidade original;
3. preparação, anotação, rotulagem, limpeza, enriquecimento e agregação de dados;
4. pressupostos sobre o que os dados medem ou representam;
5. disponibilidade, quantidade e adequação dos conjuntos de dados;
6. exame de possíveis vieses e seus efeitos na saúde, segurança ou direitos fundamentais;
7. Medidas para detectar, prevenir e mitigar o viés;
8. Relevância, representatividade, integridade e características de erro;
9. Propriedades estatísticas e adequação para as pessoas, grupos, geografia, contexto e condições de uso pretendido;
10. controles para lacunas de dados, deriva, vazamento, duplicação, contaminação e uso não autorizado;
11.
 - a) Separação e governança de conjuntos de dados de treinamento, validação e teste, quando apropriado;
12. exceções documentadas, limitações e riscos residuais.

1.326 Exemplo GlobalWay

A GlobalWay desenvolve um sistema de triagem de recrutamento usando dados históricos de aplicação e contratação. A revisão de governança de dados identifica sub-representação em certas famílias de trabalho, rótulos históricos inconsistentes, variáveis proxy para características protegidas e diferenças geográficas. A GlobalWay remove recursos inadequados, melhora a documentação, testa o desempenho de subgrupos, limita o uso pretendido e requer revisão humana.

1.327 Atividade de controle

O provedor deve aprovar um plano de governança de dados específico do sistema antes do desenvolvimento do modelo ou da reciclagem de material. Versões de conjunto de dados, transformações, verificações de qualidade, análises de viés, controles de acesso e aprovações devem ser rastreáveis para o modelo ou a versão do sistema liberada.

1.328 Provas

- Plano de governança de dados;
- Registro de conjunto de dados e registros de proveniência;
- Procedimentos de processamento de dados e de anotação;
- análise de qualidade e representatividade dos dados;
- vies e testes de subgrupos;
- privacidade e avaliação de base legal;
- Histórico de versões do conjunto de dados;
- Registros de acesso e alteração;
- Limitações e registro de risco residual;
- registros de aprovação.

1.329 Teste de auditoria

Confirme que a adequação, proveniência, qualidade, representatividade, viés, privacidade, transformações e limitações foram avaliadas e aprovadas antes do lançamento. Confirme que a adequação, proveniência, qualidade, representatividade, viés, privacidade, transformações e limitações foram avaliadas e aprovadas antes do lançamento.

1.330 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 10.o
- O GDPR e a legislação aplicável do Estado-Membro ou setor permanecem aplicáveis de forma independente.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.331 Capítulo 39 Documentação técnica

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 39 linguagem de rascunho.

1.332 Exigência

Antes que um sistema de IA de alto risco seja colocado no mercado ou colocado em serviço, o provedor deve preparar e manter a documentação técnica que demonstre o cumprimento dos requisitos aplicáveis. A documentação deve abordar o artigo 11.o e o anexo IV do Regulamento

(UE) 2024/1689, conforme alterado, e permanecer atualizada durante todo o ciclo de vida.

1.333 Explicação em linguagem simples

A documentação técnica é o pacote de evidências que explica o que é o sistema, como ele foi desenvolvido, quais dados e métodos foram usados, como ele funciona, quais riscos e limitações existem, como a supervisão humana funciona e por que o provedor acredita que os requisitos legais são atendidos. Deve ser específico o suficiente para as autoridades, organismos notificados, quando aplicável, e revisores internos para avaliar a conformidade.

Cartões modelo, cartões de sistema, documentos de arquitetura e relatórios de teste podem suportar o pacote, mas nenhum deles satisfaz necessariamente o Anexo IV.

1.334 Áreas de documentação necessárias

O pacote deve abranger, conforme aplicável:

1. uma descrição geral, finalidade pretendida, versão do sistema e informações do provedor;
2. arquitetura de sistema, componentes, dependências, interfaces e recursos computacionais;
3. métodos de design e desenvolvimento;
4. requisitos de dados, conjuntos de dados, proveniência, preparação e governança;
5. Escolhas de modelo ou algoritmo, parâmetros e pressupostos relevantes;
6. métodos de validação e teste, métricas, limiares, ambientes e resultados;
7. Processo de gestão de riscos e conclusões de risco residual;
8. medidas de supervisão humana;
9. precisão, robustez, segurança cibernética e limitações previsíveis;
10. Capacidades de registo e disposições de manutenção de registos;
11. Via de avaliação da conformidade, normas, especificações comuns e desvios;
12. monitoramento pós-mercado, incidentes e arranjos de ação corretiva;
13. alterações, atualizações e histórico de versões;
14. instruções de uso e outras informações fornecidas aos operadores.

1.335 Exemplo GlobalWay

Para seu sistema de triagem de recrutamento de alto risco, a GlobalWay mantém um índice do Anexo IV que liga o propósito pretendido, arquitetura,

conjuntos de dados, testes de subgrupos, limites de desempenho, fluxo de trabalho de revisão humana, testes de segurança cibernética, controles de risco, registros de conformidade e plano de monitoramento pós-comercialização ao lançamento exato da produção.

1.336 Atividade de controle

O provedor deve manter um repositório de documentação técnica controlado com um índice aprovado do Anexo IV. Nenhuma liberação pode prosseguir, a menos que os documentos necessários sejam completos, internamente consistentes, vinculados à versão, revisados e aprovados. As alterações de materiais devem desencadear a revisão e atualização da documentação.

1.337 Provas

- índice de documentação do anexo IV;
- descrição e arquitetura do sistema;
- desenvolvimento e documentação de dados;
- Planos de teste, métricas e resultados;
- Arquivo de gestão de risco;
- Plano de Supervisão Humana;
- evidências de segurança cibernética e robustez;
- instruções de uso;
- Registos de conformidade;
- Plano de monitorização pós-comercialização;
- versão e histórico de mudanças;
- registros de revisão e aprovação.

1.338 Teste de auditoria

Confirme se o pacote de documentação técnica existia antes do lançamento, aborde os elementos aplicáveis do Anexo IV, concorde com a configuração implantada e tenha sido atualizado após alterações relevantes ou novas informações pós-mercado.

1.339 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 11.º e anexo IV.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.340 Capítulo 40 Registos e manutenção de registos

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 40 linguagem de rascunho.

1.341 Exigência

Os sistemas de IA de alto risco devem ser projetados para permitir o registro automático de eventos ao longo da vida útil do sistema, na medida apropriada para o propósito pretendido. Os provedores e implantadores devem manter registros e registros relacionados pelos períodos exigidos pelo Regulamento (UE) 2024/1689, conforme alterado, e outras leis aplicáveis.

1.342 Explicação em linguagem simples

Os registros são a trilha de evidências operacionais de como um sistema de IA de alto risco se comportou. Eles suportam monitoramento, investigação de incidentes, supervisão humana, avaliação de conformidade, ação corretiva e revisão regulatória. O registro deve ser útil, proporcional, seguro e vinculado à versão correta do sistema.

A Lei AI não cria um período de retenção universal para cada registro. A retenção deve ser determinada pelo papel do ator, tipo de registro, artigo aplicável, lei do setor, requisitos de proteção de dados, obrigações contratuais, períodos de limitação e litígios ou retenções regulatórias.

1.343 Requisitos de registro

O projeto de registro deve abordar, conforme aplicável:

1. sistema e versão do modelo;
2. Data e hora da operação;
3. Fonte de entrada e contexto de processamento relevante;
4. produção, pontuação, recomendação ou decisão;
5. Informações de confiança ou de limiar, se relevante;
6. revisão humana, intervenção, superação ou escalada;
7. erros, anomalias, falhas nos controles e eventos de segurança;
8. configuração, pronta, recuperação e mudanças de dependência;
9. identidade ou papel dos operadores autorizados quando legal e necessário;
10. ligações a reclamações, incidentes, ações corretivas e registros de monitoramento.

1.344 Controles de proteção e segurança de dados

A organização deve definir propósito legal, minimização de dados, restrições de acesso, proteção de integridade, retenção, exclusão e procedimentos de exportação seguros.

1.345 Exemplo GlobalWay

O sistema de recrutamento de alto risco da GlobalWay registra a versão do modelo de produção, o carimbo de data e hora do processo do candidato, o resultado de pontuação relevante, o limiar aplicado, a identidade do revisor, a decisão do revisor, a razão de substituição e qualquer erro do sistema. O acesso é restrito ao RH autorizado, conformidade, auditoria e pessoal de segurança.

1.346 Atividade de controle

O provedor deve definir as capacidades de registro durante o projeto, e o deployer deve garantir que os registros sejam habilitados, protegidos, revisados e retidos de acordo com um cronograma aprovado. Qualquer lacuna de registro que impeça o monitoramento, a supervisão, a investigação ou a resposta regulatória efetiva deve bloquear a implantação ou desencadear ações corretivas.

1.347 Provas

- Especificação de registro;
- dicionário de dados;
- registros de eventos de amostra;
- configuração de controle de acesso;
- cronograma de retenção;
- Procedimentos de supressão e de retenção legal;
- Controles de integridade e evidências de adulteração;
- Monitorização e revisão de registros;
- ligações de incidentes e ações corretivas;
- Avaliação da privacidade.

1.348 Teste de auditoria

Selecione uma amostra de eventos do sistema de alto risco e confirme que os logs são gerados, completos, vinculados à versão, protegidos contra alterações não autorizadas, acessíveis a revisores autorizados, retidos sob um cronograma aprovado e usados em monitoramento e investigação de incidentes.

1.349 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Artigo 12.º e obrigações aplicáveis do ator em matéria de retenção e acesso a registos.
- GDPR e regras de retenção específicas do setor em que dados pessoais ou registos regulamentados estão envolvidos.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.350 Capítulo 41 Transparência e Instruções de Uso

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 41 linguagem de rascunho.

1.351 Exigência

Os sistemas de IA de alto risco devem ser suficientemente transparentes para permitir que os implementadores interpretem a saída do sistema e usem o sistema adequadamente. Os provedores devem fornecer instruções claras, completas, corretas e acessíveis para uso, contendo as informações exigidas pelo Regulamento (UE) 2024/1689, conforme alterado.

1.352 Explicação em linguagem simples

Um deployer não pode operar um sistema de IA de alto risco de forma responsável sem entender o que o sistema é projetado para fazer, o desempenho, onde pode falhar, que supervisão humana é necessária e quais condições técnicas e organizacionais devem ser mantidas. As instruções de uso são, portanto, parte da evidência de conformidade, não material de marketing comum.

1.353 Conteúdo Necessário

As instruções devem ser dirigidas, conforme aplicável:

1. Identidade do fornecedor e informações de contacto;
2. Identidade do sistema, versão, finalidade pretendida e usos proibidos ou não suportados;
3. características, capacidades, limitações e uso indevido previsível;
4. precisão, robustez, segurança cibernética e restrições de desempenho conhecidas;
5. Dados relevantes, entrada, ambiente, hardware, software e requisitos de dependência;
6. Medidas de supervisão humana, competência do operador, intervenção, substituição e condições de paragem;
7. interpretação de resultados, pontuações, medidas de confiança, avisos e limiares;
8. procedimentos de registro, monitoramento, manutenção, atualização e incidentes;
9. vida útil esperada e serviço ou suporte necessário;
10. mudanças que requeiram reavaliação, revalidação ou consulta do provedor.

1.354 Usabilidade e acessibilidade

As instruções devem ser compreensíveis para os usuários profissionais pretendidos. Linguagem legal ou técnica densa deve ser complementada por orientação operacional, exemplos de fluxo de trabalho, avisos e instruções de escalada. Necessidades de acessibilidade e linguagem devem ser consideradas para a população de implantação real.

1.355 Exemplo GlobalWay

A equipe de recrutamento da GlobalWay recebe instruções controladas descrevendo o uso permitido de suporte à contratação, usos excluídos, entradas de dados validados, limitações de desempenho de subgrupos, requisitos de revisão humana, procedimentos de substituição, escalada de reclamações, expectativas de monitoramento e ações necessárias após as atualizações do fornecedor.

1.356 Atividade de controle

O provedor deve manter as instruções controladas pela versão vinculadas a cada versão do sistema liberada. O deployer deve confirmar antes de usar que as instruções são completas, compreendidas, implementadas operacionalmente e refletidas em treinamento, procedimentos, controles de acesso e monitoramento.

1.357 Provas

- Instruções de utilização aprovadas;
- ligação de versão e liberação;
- Registo de limitação e aviso;
- Procedimentos do operador;
- Registos de formação e competência;
- Registos de reconhecimento ou de aceitação;
- Revisão de acessibilidade;
- Notificações de alteração;
- procedimentos de monitoramento e incidentes.

1.358 Teste de auditoria

Confirme se as instruções atuais foram fornecidas antes do uso, aborde o conteúdo legal aplicável, combine com a versão implantada, sejam compreensíveis para os operadores e implementadas em procedimentos operacionais, treinamento, supervisão e monitoramento.

1.359 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: artigo 13.o e obrigações de prestador e de despachante conexas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.360 Capítulo 42 Supervisão Humana

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 42 linguagem de rascunho.

1.361 Exigência

Os sistemas de IA de alto risco devem ser projetados e desenvolvidos para que as pessoas naturais possam supervisioná-los efetivamente durante o uso. As medidas de supervisão devem ser proporcionais aos riscos, autonomia, contexto e consequências previsíveis do sistema.

1.362 Explicação em linguagem simples

A supervisão humana não é satisfeita colocando uma pessoa perto do processo ou exigindo um clique final. A pessoa atribuída deve ter informações suficientes, competência, autoridade, tempo, acesso ao sistema e capacidade prática para detectar problemas, desafiar saídas, intervir, substituir, interromper o uso e aumentar as preocupações.

Os operadores não devem ser pressionados a aceitar uma saída de IA apenas porque o sistema a produziu ou porque rejeitá-la é inconveniente.

1.363 Design de Supervisão

O plano de supervisão deve definir, conforme aplicável:

1. as decisões ou ações que exijam revisão humana;
2. quem executa a supervisão e quais qualificações são necessárias;
3. informações disponíveis para o revisor;
4. limiares, avisos, indicadores de confiança e limitações conhecidas;
5. intervenção, substituição, rejeição, suspensão e parar a autoridade;
6. caminhos de escalada e tempos de resposta;
7. Requisitos de revisão dupla ou de revisão especializada para casos graves;
8. carga de trabalho, pessoal e tempo necessário para uma revisão significativa;
9. controles contra viés de automação e carimbo de borracha;
10. registro de revisão, substituição, justificativa e escalada;
11. Testes periódicos de se a supervisão permanece eficaz.

1.364 Salvaguarda biométrica especial

Quando a lei exigir a verificação por pelo menos duas pessoas singulares competentes para utilizações específicas de identificação biométrica, o manual deve preservar essa salvaguarda legal e qualquer exceção aplicável. Não deve ser generalizado para todos os sistemas biométricos ou omitido quando legalmente exigido.

1.365 Exemplo GlobalWay

O sistema de recrutamento da GlobalWay pode classificar os pedidos, mas não pode rejeitar um candidato automaticamente. Um recrutador treinado revisa as evidências relevantes, pode desconsiderar a pontuação, registra o motivo da decisão e aumenta os resultados anômalos ou potencialmente discriminatórios para a conformidade com o RH.

1.366 Atividade de controlo

O provedor deve projetar recursos de supervisão eficazes e documentá-los nas instruções de uso. O implantador deve atribuir revisores competentes, conceder-lhes autoridade, estabelecer procedimentos viáveis, monitorar padrões de substituição e escalada e suspender o uso onde a supervisão não pode ser realizada de forma eficaz.

1.367 Provas

- Plano de Supervisão Humana;
- Requisitos de função e competência;
- Registros de treinamento e avaliação;
- Procedimentos do operador;
- interface de aviso e design de aviso;
- sobrepor e parar os controles;
- análise de carga de trabalho e pessoal;
- Registros de revisão e escalada;
- testes de automação-viés;
- Revisão periódica da eficácia.

1.368 Teste de auditoria

Confirme que os revisores entendem as limitações do sistema, podem avaliar independentemente a saída, ter autoridade e tempo para intervir, usar mecanismos de substituição e escalada corretamente e produzir registros que mostrem uma supervisão significativa em vez de nominal.

1.369 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Artigo 14.º e obrigações relacionadas com o deployer.

- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.370 Capítulo 43 Precisão, Robustez, Cibersegurança e Resiliência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 43 linguagem de rascunho.

1.371 Exigência

Os sistemas de IA de alto risco devem atingir um nível adequado de precisão, robustez e segurança cibernética e ter um desempenho consistente durante todo o ciclo de vida. O projeto deve abordar erros, falhas, inconsistências, interferência maliciosa, ciclos de feedback e uso indevido razoavelmente previsível à luz do propósito e risco pretendidos.

1.372 Explicação em linguagem simples

A conformidade não requer desempenho perfeito. Requer metas de desempenho defensáveis, testes baseados em risco, limitações transparentes, design seguro, monitoramento e ação corretiva. As métricas devem refletir o contexto real de implantação, em vez de apenas médias de laboratório.

1.373 Áreas de controle necessárias

O provedor deve abordar, conforme aplicável:

1. Métricas de precisão e desempenho definidas ligadas à finalidade pretendida;
2. Limites de aceitação e limites de decisão;
3. subgrupo e desempenho específico do contexto;
4. robustez ao ruído, dados ausentes, mudança de distribuição e falha de componentes;
5. resiliência a erros, falhas, interrupções e falhas de dependência;
6. proteção contra envenenamento de dados, exemplos contraditórios, injeção imediata, manipulação de modelos, extração e acesso não autorizado;
7. desenvolvimento seguro, testes, gerenciamento de vulnerabilidades e controle de mudanças;
8. Riscos de ciclo de feedback para sistemas que continuam aprendendo ou influenciam dados futuros;
9. Retrocesso, degradação, reversão e comportamento de parada segura;
10. monitoramento, resposta a incidentes e gatilhos de ação corretiva.

1.374 Métricas e divulgação

As métricas de precisão e robustez devem ser documentadas no arquivo técnico e instruções de uso quando necessário. As pontuações agregadas não devem ocultar os modos de falha material, as disparidades entre grupos afetados, as condições de operação inseguras ou a incerteza.

1.375 Exemplo GlobalWay

A GlobalWay valida seu sistema de recrutamento usando conjuntos de dados relevantes para o papel e mede padrões falso-positivos e falso-negativos em grupos candidatos relevantes. Também testa informações ausentes, formatos de currículo incomuns, conteúdo rápido malicioso, interrupções do fornecedor, alterações de modelo e procedimentos de reversão.

1.376 Atividade de controle

O provedor deve aprovar requisitos mensuráveis de desempenho, robustez e segurança cibernética antes de liberar e repetir os testes após mudanças materiais ou ameaças emergentes. O implantador deve monitorar o desempenho do mundo real, manter as condições operacionais necessárias, relatar anomalias graves e suspender o uso quando os limites definidos forem violados.

1.377 Provas

- Requisitos e limiares de desempenho;
- Planos de validação e teste;
- Resultados de subgrupos e casos extremos;
- resultados de robustez e teste de estresse;
- modelo de ameaça e arquitetura de segurança;
- Registros de vulnerabilidade e de testes de penetração;
- Testes de dependência e resiliência;
- dashboards de monitoramento;
- Registros de incidentes e ações corretivas;
- aprovações de liberação e reversão.

1.378 Teste de auditoria

Selecione um sistema de alto risco e verifique se os requisitos de desempenho e segurança estão documentados, os testes refletem o contexto de implantação pretendido, os modos de falha de material são divulgados, vulnerabilidades e anomalias são rastreadas e violações de limiares desencadeiam investigação, correção, restrição ou suspensão.

1.379 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: artigo 15.o e respetivas obrigações de ciclo de vida, monitorização e prestador/empregador.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.380 Capítulo 44 Avaliação da Conformidade

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 44 linguagem de rascunho.

1.381 Exigência

Antes de um sistema de IA de alto risco ser colocado no mercado ou colocado em serviço, o prestador deve concluir o procedimento de avaliação da conformidade aplicável e reter provas de que o sistema satisfaz os requisitos relevantes do Regulamento (UE) 2024/1689, conforme alterado.

1.382 Explicação em linguagem simples

A avaliação da conformidade é o processo estruturado usado para demonstrar que um sistema de IA de alto risco atende aos requisitos legais antes da liberação. A rota de avaliação correta depende da base de classificação, legislação do setor de produtos, uso de normas harmonizadas ou especificações comuns e se a avaliação de terceiros por um organismo notificado é necessária.

O manual não deve assumir que todos os sistemas de alto risco seguem o mesmo caminho. Deve distinguir os sistemas autónomos do Anexo III da IA que é um componente de segurança de, ou em si, um produto regido pela legislação do Anexo I.

1.383 Via de avaliação

O provedor deve documentar:

1. A base de classificação de alto risco;
2. A rota de avaliação da conformidade aplicável;
3. Interação com a legislação relevante do setor de produtos;
4. se se aplica o controlo interno, o envolvimento do organismo notificado ou outro procedimento;
5. normas, especificações comuns e métodos técnicos utilizados;
6. completude de documentação técnica;
7. prontidão do sistema de gestão da qualidade;
8. Testes e provas de validação;
9. desvios identificados, não conformidades e ações corretivas;

10. aprovação do resultado final da avaliação.

1.384 Mudança e reavaliação

Uma nova avaliação da conformidade pode ser necessária após uma modificação substancial ou outra alteração que afete a conformidade. Os provedores devem manter um processo documentado de triagem de alterações e não devem confiar indefinidamente na avaliação de uma versão anterior.

1.385 Exemplo GlobalWay

Antes de lançar um sistema de recrutamento de alto risco sob seu próprio nome, a GlobalWay confirma o caminho aplicável do Anexo III, valida o arquivo técnico e o sistema de gerenciamento de qualidade, resolve lacunas identificadas, documenta a decisão de conformidade e vincula a decisão à versão exata da produção.

1.386 Atividade de controle

O provedor deve estabelecer um portão de conformidade-prontidão antes da liberação. Os proprietários legais, de conformidade, técnicos e de qualidade devem aprovar a classificação, o procedimento, o pacote de evidências, os desvios e o resultado final. Nenhum sistema pode ser colocado no mercado ou colocado em serviço antes que o procedimento aplicável seja concluído.

1.387 Provas

- decisão de classificação;
- Análise da via de conformidade;
- Avaliação do setor do produto aplicável;
- Índice de documentação técnica;
- Evidência de qualidade-gestão-sistema;
- Resultados de teste e validação;
- mapeamento de normas e especificações;
- Registos de organismos notificados, quando aplicável;
- Registos de não conformidade e de ação corretiva;
- Aprovação final da avaliação;
- linkage versão e histórico de reavaliação.

1.388 Teste de auditoria

Confirme se a rota de conformidade correta foi identificada, as evidências necessárias existiam antes do lançamento, qualquer envolvimento do corpo notificado foi concluído quando necessário, não-conformidades não resolvidas foram abordadas e mudanças materiais desencadearam reavaliação.

1.389 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigos 43.o a 44.o e disposições conexas.
- Legislação aplicável do produto do anexo I e normas harmonizadas aplicáveis ou especificações comuns.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.390 Capítulo 45 Declaração de Conformidade e Marcação CE da UE

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 45 linguagem de rascunho.

1.391 Exigência

Sempre que necessário, o prestador deve elaborar uma declaração UE de conformidade por escrito para cada sistema de IA de alto risco e apor a marcação CE em conformidade com o Regulamento (UE) 2024/1689, conforme alterado, e a legislação aplicável do produto.

1.392 Explicação em linguagem simples

A declaração de conformidade é a declaração formal do provedor de que o sistema identificado está em conformidade com os requisitos legais aplicáveis. A marcação CE comunica que as etapas de conformidade necessárias foram concluídas. Nenhum dos itens é um prêmio de marketing, pontuação de qualidade ou garantia de que o sistema pode ser usado com segurança em todos os contextos.

1.393 Controlos da declaração

A declaração deve:

1. identificar o sistema e a versão da IA de forma inequívoca;
2. identificar o fornecedor e, se aplicável, o representante autorizado;
3. declarar que a declaração é emitida sob a exclusiva responsabilidade do prestador;
4. identificar a legislação aplicável da União;
5. Normas de referência relevantes, especificações comuns ou métodos de avaliação;
6. identificar qualquer organismo notificado e certificado, quando aplicável;
7. Incluir o local, a data, o signatário autorizado e a assinatura;
8. permanecem precisas após as alterações e devem ser mantidas durante o período necessário.

1.394 Controles de marcação CE

O fornecedor deve garantir que a marcação CE seja aposta de forma visível, legível e indelevelmente quando necessário, ou seja apresentada digitalmente quando o quadro jurídico o permitir. As regras do setor do produto devem ser coordenadas para que as marcações e declarações não sejam duplicadas ou aplicadas de forma inconsistente.

1.395 Exemplo GlobalWay

Para um sistema de alto risco que a GlobalWay coloca no mercado da União sob seu próprio nome, a equipe de conformidade verifica se a avaliação da conformidade está completa, prepara a declaração para a liberação exata, confirma as referências e assinaturas necessárias e aplica a marcação CE através do processo de liberação de produto aprovado.

1.396 Atividade de controlo

Nenhuma declaração ou marcação CE pode ser emitida até que a evidência de conformidade esteja completa e aprovada. O provedor deve manter modelos controlados, signatários autorizados, vinculação de versão, retenção, retirada e procedimentos de correção.

1.397 Provas

- Declaração de conformidade UE assinada;
- Identificação do sistema e da libertação;
- Registo de avaliação da conformidade;
- Normas e referências de especificação;
- Certificado de organismo notificado, se aplicável;
- Evidência de aprovação e colocação de marcação CE;
- Autorização signatária;
- Histórico de retenção e correção.

1.398 Teste de auditoria

Confirme se a declaração identifica a pessoa jurídica correta e a versão, cita a legislação aplicável e a evidência de avaliação, foi assinada por uma pessoa autorizada e que a marcação CE foi aplicada somente após a aprovação da conformidade.

1.399 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigos 47.º a 48.º e anexos pertinentes.
- Legislação aplicável do produto anexo I.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.400 Capítulo 46 Registo

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 46 linguagem de rascunho.

1.401 Exigência

Os fornecedores e, quando aplicável, os implementadores devem preencher os registos exigidos pelo Regulamento (UE) 2024/1689, conforme alterado, antes de o sistema de IA de alto risco relevante ser colocado no mercado, colocado em serviço ou usado. Os deveres de registo dependem da categoria do sistema, do papel do ator e das disposições aplicáveis de confidencialidade ou aplicação da lei.

1.402 Explicação em linguagem simples

O registo suporta visibilidade e rastreabilidade regulatória. Não é um substituto para classificação, avaliação de conformidade, documentação técnica ou monitoramento. A organização deve determinar quem se registra, quais informações devem ser enviadas, quando o registo deve ocorrer e como as alterações posteriores são refletidas.

1.403 Controlos de registo

O processo de registo deve abordar:

1. Classificação do sistema e base de registo aplicável;
2. Pessoa jurídica responsável e papel de ator;
3. banco de dados ou autoridade através da qual o registo é feito;
4. informações necessárias sobre o sistema, o fornecedor, o deployer e a conformidade;
5. confidencialidade, segurança e tratamento de acesso restrito, quando aplicável;
6. aprovação antes da submissão;
7. ligação à versão exata do sistema e ao registo de conformidade;
8. atualizações após alterações, suspensão, retirada ou desativação;
9. retenção de provas de submissão, reconhecimento e alteração.

1.404 Exemplo GlobalWay

Antes de implantar um sistema de recrutamento de alto risco qualificado, a GlobalWay confirma se os deveres de registo de provedor e de implantador se aplicam, atribui a entidade legal responsável, valida as informações contra o arquivo técnico, registra o reconhecimento de submissão e atualiza o registo após uma mudança de versão material.

1.405 Atividade de controlo

A função de Governança de IA deve manter um registro de registro vinculado ao inventário de IA da empresa. Os portões de implantação devem evitar o uso quando o registro necessário for incompleto, impreciso, expirado ou inconsistente com o sistema implantado.

1.406 Provas

- Decisão de aplicabilidade do registo;
- Dados de submissão aprovados;
- submissão e reconhecimento de banco de dados;
- Aprovação da entidade responsável;
- Ligação sistema-versão;
- Avaliação da confidencialidade;
- Histórico de atualização e alteração;
- Registros de suspensão ou retirada.

1.407 Teste de auditoria

Selecione uma amostra de sistemas de alto risco registrados e confirme que o ator correto completou o registro antes do evento legalmente relevante, as informações enviadas concordam com a documentação técnica e a versão implantada, e alterações materiais posteriores foram atualizadas prontamente.

1.408 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 49.o e disposições pertinentes relativas à base de dados da UE e aos regimes de registo restrito.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.409 Capítulo 47 Avaliação de Impacto dos Direitos Fundamentais

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 47 anterior.

1.410 Exigência

Antes do primeiro uso de sistemas de IA de alto risco especificados, os implementadores que se enquadram no Artigo 27 devem realizar uma avaliação de impacto dos direitos fundamentais e atender aos requisitos de documentação, notificação e revisão associados.

1.411 Explicação em linguagem simples

Uma avaliação de impacto dos direitos fundamentais examina como um uso de IA de alto risco pode afetar as pessoas na prática. É mais amplo do que uma revisão de risco técnico e deve considerar o contexto de implantação, grupos afetados, possíveis danos, supervisão humana, reclamações, mitigação e risco residual.

O dever não se aplica automaticamente a todos os implementadores ou a todos os sistemas de alto risco. A organização deve primeiro determinar se o Artigo 27 se aplica ao ator e ao caso de uso. Mesmo onde não se aplica, uma avaliação voluntária ainda pode ser prudente para impactos significativos de direitos.

1.412 Conteúdo da avaliação

A avaliação deve documentar, conforme aplicável:

1. o deployer, o sistema, a finalidade pretendida e o processo de implantação;
2. o período e a frequência de utilização;
3. categorias de pessoas singulares e grupos susceptíveis de serem afetados;
4. riscos específicos para os direitos fundamentais, incluindo igualdade, dignidade, privacidade, proteção de dados, expressão, devido processo, direitos dos trabalhadores e acesso a serviços;
5. Uso indevido previsível, exclusão, discriminação, efeitos de refrigeração e impactos cumulativos;
6. Supervisão humana, reclamação, contestabilidade e arranjos de remédios;
7. mitigação técnica, organizacional, contratual e processual;
8. Risco residual e decisão de aprovação;
9. Consulta com funções internas relevantes, representantes, especialistas ou partes interessadas afetadas, quando apropriado;
10. A notificação exigida à autoridade de fiscalização do mercado e a coordenação com a avaliação do impacto da proteção de dados, se aplicável.

1.413 Exemplo GlobalWay

Antes de implantar um sistema de recrutamento de alto risco, a GlobalWay avalia como a classificação e a triagem podem afetar os candidatos, incluindo pessoas com deficiências, histórias de carreira não tradicionais, diferenças de idioma e características protegidas. Ele documenta as atenuações, a revisão humana, as rotas de apelo, o monitoramento e a relação com sua avaliação de impacto de proteção de dados GDPR.

1.414 Atividade de controlo

O deployer deve determinar a aplicabilidade do Artigo 27 durante a ingestão e concluir a avaliação antes do primeiro uso. Legal, privacidade, propriedade de RH ou negócios, governança de IA e representantes relevantes do trabalhador ou partes interessadas devem revisar a avaliação de acordo com o contexto de implantação. Mudanças materiais ou novos danos devem desencadear a reavaliação.

1.415 Provas

- Decisão de aplicabilidade do artigo 27.o;
- Avaliação de impacto dos direitos fundamentais concluídos;
- Análise de pessoas e grupos afetados;
- Registo de direitos-riscos;
- mitigação e aprovação de risco residual;
- procedimentos de supervisão humana e reclamação;
- Registo de coordenação DPIA;
- Evidência de notificação de autoridade, quando necessário;
- registos de consulta;
- histórico de revisão e reavaliação.

1.416 Teste de auditoria

Confirme que a avaliação foi concluída antes do primeiro uso, abrange os grupos afetados reais e o contexto de implantação, identifica riscos de direitos concretos, inclui mecanismos operacionais de mitigação e solução, coordena com a avaliação de privacidade e foi atualizada após mudanças materiais ou impactos emergentes.

1.417 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada: Artigo 27.o e obrigações relacionadas com o deployer.
- Artigo 35.o do RGPD onde é necessária uma avaliação de impacto de proteção de dados.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.418 Capítulo 48 Coordenação DPIA

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 48.

1.419 Exigência

Quando o tratamento de dados pessoais for susceptível de resultar num elevado risco para os direitos e liberdades das pessoas singulares, o

responsável pelo tratamento deve concluir uma avaliação do impacto da proteção de dados ao abrigo do RGPD. Quando uma avaliação do impacto dos direitos fundamentais também é exigida nos termos do artigo 27.o do Regulamento (UE) 2024/1689, conforme alterado, as avaliações devem ser coordenadas de modo a que os factos partilhados, a análise das pessoas afetadas, os riscos, as salvaguardas, a consulta, as aprovações e as conclusões de risco residual sejam consistentes.

1.420 Explicação em linguagem simples

A Lei AI não substitui o GDPR. Um uso de IA de alto risco pode exigir uma avaliação de impacto de direitos fundamentais da AI Act e uma DPIA GDPR. Os dois instrumentos têm diferentes bases e escopos legais, mas não devem contradizer uns aos outros ou duplicar evidências desnecessariamente.

1.421 Requisitos de coordenação

A organização deve:

1. identificar o controlador, processador, deployer, provedor e outros atores relevantes;
2. Documentar a finalidade pretendida, os fluxos de dados, as categorias de dados pessoais, as pessoas afetadas e as consequências da decisão;
3. Determinar se o artigo 27.o AI Act e os artigos 35.o a 36.o do RGPD se aplicam;
4. alinhar cenários de risco, análise de probabilidade e gravidade, salvaguardas, supervisão humana, transparência, segurança e monitoramento;
5. manter conclusões jurídicas separadas quando os testes legais forem diferentes;
6. Consultar o responsável pela proteção de dados e o advogado, sempre que necessário;
7. Aumentar o risco residual de consulta de autoridade de supervisão quando se aplica o artigo 36.o do RGPD;
8. Atualize ambas as avaliações após mudanças materiais.

1.422 Exemplo GlobalWay

A GlobalWay implanta um sistema de triagem de recrutamento de alto risco. A equipe de privacidade completa um DPIA cobrindo dados do candidato, criação de perfil, retenção, tomada de decisão automatizada e segurança. A equipe de governança da IA coordena a análise do Artigo 27 para grupos afetados, desequilíbrio de poder, supervisão humana, rotas de reclamações e mitigação. Ambas as avaliações usam a mesma descrição do sistema e fatos de implantação, mas mantêm suas conclusões jurídicas distintas.

1.423 Atividade de controle

As funções de governança de privacidade e IA devem operar um processo de ingestão e referência cruzada de avaliação conjunta. Nenhuma implantação pode prosseguir até que o DPIA necessário e as aprovações de avaliação de impacto dos direitos fundamentais sejam completas e as suposições contraditórias sejam resolvidas.

1.424 Provas

- DPIA;
- Avaliação de impacto dos direitos fundamentais;
- mapa de fluxo de dados;
- análise do papel e da base jurídica;
- Consulta DPO;
- plano de mitigação;
- Aprovação de risco residual;
- Registros de consulta de autoridade de supervisão, quando aplicável;
- Histórico de reavaliação.

1.425 Teste de auditoria

Confirme que a aplicabilidade do DPIA foi avaliada, a aplicabilidade do Artigo 27 foi avaliada separadamente, a evidência sobreposta é consistente, as consultas necessárias ocorreram e as mudanças materiais desencadearam a reavaliação.

1.426 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 27.o
- Regulamento (UE) 2016/679: artigos 35.o a 36.o e, se for caso disso, artigo 22.o
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.427 Capítulo 49 Monitoramento pós-mercado

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 49 anterior.

1.428 Exigência

Os fornecedores de sistemas de IA de alto risco devem estabelecer e documentar um sistema de monitoramento pós-comercialização proporcional que coleta, documenta e analisa ativamente e sistematicamente dados relevantes de desempenho e risco ao longo da vida útil do sistema. O sistema deve ser baseado em um plano de monitoramento pós-comercialização que faça parte da documentação técnica.

1.429 Explicação em linguagem simples

A conformidade não termina quando o sistema é liberado. Os provedores devem continuar a verificar se o sistema funciona como pretendido, permanece em conformidade, interage com segurança com outros sistemas e cria riscos novos ou alterados em uso real.

1.430 Projeto de monitoramento

O plano deve definir:

1. escopo, proprietários e versões do sistema;
2. fontes de dados, incluindo feedback do implantador, reclamações, incidentes, substituições, deriva e telemetria técnica;
3. desempenho, segurança, viés, robustez, segurança cibernética e indicadores de visão humana;
4. limiares e critérios de escalada;
5. frequência de revisão e amostragem;
6. métodos para análise de tendência, subgrupo e interação;
7. gatilhos de ação corretiva e notificação;
8. links para gerenciamento de riscos, documentação técnica, relatórios de incidentes graves e controle de mudanças;
9. Retenção, confidencialidade e requisitos de evidência.

Quando a legislação setorial já exigir um sistema pós-comercialização, o prestador pode integrar os elementos do AI Act nesse sistema onde as condições legais são cumpridas e a proteção equivalente é preservada.

1.431 Exemplo GlobalWay

O provedor da GlobalWay monitora o sistema de recrutamento de produção para disparidades nas taxas de seleção, tendências falso-positivas e falso-negativas, taxas de substituição, reclamações do usuário, deriva do modelo, eventos de segurança e desvios do propósito pretendido. As revisões trimestrais são complementadas por uma escalada imediata quando os limites são excedidos.

1.432 Atividade de controle

O provedor deve aprovar um plano de monitoramento pós-mercado vinculado à versão antes do lançamento, operar o plano durante toda a vida útil do sistema, descobrir documentos e alimentar resultados relevantes em gerenciamento de riscos, ações corretivas, relatórios de incidentes e atualizações de documentação técnica.

1.433 Provas

- Plano de monitorização aprovado;

- Definições e limiares métricos;
- monitoramento de dados e dashboards;
- feedback e reclamações do deployer;
- Análise de tendências e subgrupos;
- Registros de escalada e ação corretiva;
- Atualizações de documentação técnica;
- minutos de revisão de gestão.

1.434 Teste de auditoria

Selecione uma amostra de sistemas de IA de alto risco e verifique se o monitoramento está ativo em vez de puramente reativo, cubra a vida útil implantada e a versão de produção real, use limiares definidos, analise dados relevantes e acione processos documentados de risco, incidente e ação corretiva.

1.435 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 72.o e anexo IV.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.436 Capítulo 50 Relatórios de incidentes graves

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 50 linguagem de rascunho.

1.437 Exigência

Os fornecedores de sistemas de IA de alto risco colocados no mercado da União devem comunicar incidentes graves às autoridades de fiscalização do mercado dos Estados-Membros onde o incidente ocorreu. Os relatórios devem seguir os prazos legais aplicáveis, preservar as provas, apoiar a investigação e conduzir a uma avaliação dos riscos e a medidas corretivas.

1.438 Explicação em linguagem simples

Um incidente grave não pode esperar pela reunião mensal normal de governança. O provedor precisa de um processo operacional que identifique eventos reportáveis, estabeleça ou suspeite razoavelmente de ligação causal, envie informações iniciais oportunas quando os fatos permanecerem incompletos e coordene com implantadores, autoridades, órgãos notificados quando relevante, equipes de privacidade, equipes de segurança e reguladores do setor.

1.439 Prazos de reporte

O processo de incidente deve distinguir pelo menos:

1. o prazo geral: imediatamente após o estabelecimento de umnexo causal ou de uma probabilidade razoável de umnexo e, em qualquer caso, o mais tardar 15 dias após a sensibilização;
2. Infrações generalizadas ou categorias de incidentes graves referidas no artigo 3.o, n.o 49, alínea b): imediatamente e o mais tardar dois dias após a sensibilização;
3. morte de uma pessoa: imediatamente após o estabelecimento ou suspeita de uma relação causal e, o mais tardar, 10 dias após a consciência;
4. Relatórios iniciais incompletos seguidos de relatórios completos quando necessário para a oportunidade.

Os prazos devem ser revistos em relação ao texto alterado atual e às regras setoriais aplicáveis antes da publicação e operação.

1.440 Exemplo GlobalWay

Um sistema de triagem de funcionários de alto risco produz um defeito que exclui sistematicamente os candidatos com uma característica protegida em vários Estados-Membros. A GlobalWay suspende o fluxo de trabalho afetado, preserva o sistema e os registros de decisão, informa o provedor, inicia a avaliação de impacto, determina a autoridade relevante e o cronograma de relatórios e documenta a base para cada decisão de notificação.

1.441 Atividade de controlo

O provedor e o deployer devem manter um procedimento de resposta a incidentes graves com escalonamento 24/7, alocação de papéis, triagem legal, cálculo de prazos, preservação de evidências, informações de contato do regulador, modelos de relatório inicial e suplementar, controles de investigação e vinculação de ação corretiva.

O prestador não deve alterar o sistema afectado de uma forma que possa comprometer a avaliação posterior das causas do incidente antes de informar as autoridades competentes dessa acção.

1.442 Provas

- Ingestão de incidentes e registo de classificação;
- consciencialização e prazos de entrega;
- Avaliação de nexos de causalidade;
- logs, versões, dados e configuração preservados;
- Relatórios regulamentares iniciais e finais;
- autoridade de comunicação;
- Investigação e avaliação de riscos;
- Registros de ação corretiva;

- Distribuidor, provedor e coordenação do organismo notificado;
- gestão e escalada da diretoria.

1.443 Teste de auditoria

Recalcule o prazo de relatório aplicável, verifique a data de conscientização e a análise de link causal, confirme a preservação de evidências e a coordenação da autoridade e teste se a ação corretiva e o monitoramento pós-mercado foram atualizados.

1.444 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 3.o, n.o 49, e artigo 73.o
- Harmonização da União aplicável e legislação setorial, se for caso disso.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.445 Capítulo 51 Ação Corretiva, Retirada e Recall

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 51 da linguagem de rascunho.

1.446 Exigência

Quando um fornecedor tiver motivos para considerar que um sistema de IA de alto risco não está em conformidade com o Regulamento (UE) 2024/1689, conforme alterado, ele deve tomar imediatamente as medidas corretivas necessárias para colocar o sistema em conformidade, retirá-lo, desativá-lo ou recordá-lo, conforme apropriado. Distribuidores, importadores, implantadores, representantes autorizados e autoridades competentes relevantes devem ser informados quando necessário.

1.447 Explicação em linguagem simples

A organização deve determinar as versões e implantações afetadas, conter o risco, proteger as pessoas afetadas, corrigir o sistema sempre que possível e removê-lo ou desativá-lo quando a correção não puder fornecer proteção adequada.

1.448 Processo de ação corretiva

O processo deve incluir:

1. Ingestão e classificação da não conformidade;
2. Contenção imediata e identificação da versão afetada;
3. avaliação de risco, segurança, direitos fundamentais, privacidade e segurança;

4. Critérios de decisão para correção, suspensão, desativação, retirada ou recall;
5. Comunicações a atores da cadeia de valor, pessoas afetadas e autoridades, quando necessário;
6. análise de causa-raiz;
7. validação da ação corretiva antes da reimplantação;
8. documentação técnica, conformidade, gerenciamento de riscos e atualizações de monitoramento;
9. Testes de eficácia e encerramento formal;
10. prevenção de recorrência.

1.449 Exemplo GlobalWay

A GlobalWay descobre que uma liberação de triagem de recrutamento pesa incorretamente uma variável proxy e materialmente prejudica um grupo protegido. A versão afetada está desativada, as decisões pendentes são encaminhadas para revisores humanos treinados, o provedor identifica todas as implantações impactadas, preserva evidências, corrige e retestes o modelo, se comunica com os atores relevantes e avalia se as notificações regulatórias e pessoas afetadas são necessárias.

1.450 Atividade de controle

O provedor deve manter um procedimento documentado de não conformidade e ação corretiva com autoridade definida para suspender o uso da produção. As ações corretivas devem ser baseadas no risco, específicas da versão, validadas independentemente da equipe de implementação, quando apropriado, e vinculadas a processos de incidentes, reclamações, pós-comercialização e gerenciamento de mudanças.

1.451 Provas

- registo de não conformidade;
- inventário do sistema afetado e da versão;
- decisão de contenção e suspensão;
- análise de causa-raiz;
- plano de ação corretiva;
- Resultados de reteste e validação;
- Retirada ou recolha de comunicações;
- Autoridade e notificações da pessoa afetada, quando aplicável;
- Registros técnicos e de conformidade atualizados;
- revisão de eficácia e aprovação de encerramento.

1.452 Teste de auditoria

Confirme que a contenção foi oportuna, que foram identificadas versões e implantações afetadas, que o remédio selecionado foi proporcional, que as comunicações foram completas, que as ações corretivas foram validadas antes da reimplantação e que as evidências de fechamento demonstram eficácia.

1.453 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: disposições relativas ao fornecedor, importador, distribuidor, despachante, pós-mercado, fiscalização do mercado e medidas corretivas, incluindo os artigos 20.o a 26.o e o capítulo IX, conforme aplicável.
- Harmonização aplicável da União e legislação setorial.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.454 Capítulo 52 Gestão da Mudança e Modificação Substancial

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 52 anterior.

1.455 Exigência

As alterações de um sistema de IA de alto risco devem ser avaliadas antes da implementação para determinar se afetam o propósito pretendido, a classificação regulatória, a conformidade, os controles de risco, o desempenho, os dados, a supervisão humana, a segurança cibernética, a documentação ou os papéis do ator. Uma modificação substancial pode transferir as obrigações do provedor para o ator modificador e pode exigir uma avaliação de conformidade renovada e ações de conformidade relacionadas.

1.456 Explicação em linguagem simples

Nem todo patch é uma modificação substancial, mas nenhuma mudança material deve ser considerada inofensiva. A questão legal é se a mudança foi prevista e avaliada pelo provedor original e se afeta a conformidade ou o propósito pretendido. As mudanças técnicas, comerciais, contratuais, de dados e operacionais podem importar.

1.457 Critérios de avaliação da alteração

Avaliar no mínimo:

1. mudança para o propósito pretendido, usuários, população afetada, jurisdição ou consequência de decisão;
2. Retreinamento, ajuste fino, substituição de modelo, alterações de parâmetros ou novas fontes de recuperação;
3. conjunto de dados de material, recurso, limiar, interface ou alterações no fluxo de trabalho;
4. novas integrações, funções autônomas ou usos a jusante;
5. alterações na precisão, robustez, segurança cibernética, viés, segurança ou risco de direitos fundamentais;
6. alterações na supervisão humana, registro, instruções ou transparência;
7. alterações na marca do provedor, alocação contratual ou controle operacional;
8. Se a alteração estava prevista na avaliação original da conformidade e na documentação técnica;
9. Se é necessária uma avaliação renovada da conformidade, registro, declaração, marcação, notificação ou reavaliação do papel do fornecedor.

1.458 Exemplo GlobalWay

A GlobalWay ajusta um modelo de recrutamento de fornecedores usando seus próprios dados históricos de candidatos, altera os limiares de classificação e implanta o resultado sob sua própria marca. O quadro de mudanças não trata isso como configuração de rotina. Ele realiza uma avaliação substancial de modificação e papel de provedor, atualiza os arquivos de risco e governança de dados e bloqueia a liberação até que as decisões legais e de conformidade sejam documentadas.

1.459 Atividade de controle

Cada mudança de produção deve passar por uma avaliação documentada da mudança da IA antes da aprovação. Mudanças de alto impacto exigem revisão legal, conformidade, privacidade, segurança, risco de modelo e proprietário de negócios. O uso de ferramentas de liberação deve evitar a implantação onde questões substanciais de modificação, transferência de papéis, conformidade ou registro permanecem sem solução.

1.460 Provas

- Pedido de alteração e descrição técnica;
- Análise antes e depois da finalidade pretendida;
- Avaliação substancial-modificação;
- reavaliação do fornecedor-função;
- Risco atualizado, dados, supervisão e evidências de segurança cibernética;

- regressão, subgrupo e testes de segurança;
- decisões de conformidade e registo;
- Documentação técnica e instruções atualizadas;
- Plano de aprovação e reversão de liberação;
- resultados de monitoramento pós-mudança.

1.461 Teste de auditoria

Confirme se a organização avaliou o propósito pretendido, previsibilidade, impacto de conformidade, transferência de papéis e consequências de conformidade antes da liberação; verifique se os testes e a documentação correspondem à versão implantada; e confirme se o monitoramento pós-mudança foi realizado.

1.462 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: definição do artigo 3.º de modificação substancial, artigo 25.º e disposições aplicáveis em matéria de conformidade, registo, documentação técnica e pós-comercialização.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As orientações da Comissão sobre modificações substanciais devem ser identificadas como não vinculativas, a menos e até que sejam formalmente adotadas com efeito vinculativo.

1.463 Capítulo 53 Entendendo os papéis da GPAI

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 53 anterior.

1.464 Exigência

As organizações devem determinar se são provedores de um modelo de IA de uso geral, provedores de um sistema de IA construído sobre esse modelo, provedores a jusante, implantadores, representantes autorizados ou atores cuja modificação de um modelo cria obrigações de provedor. A classificação de papéis deve refletir a conduta real, não apenas rótulos contratuais.

1.465 Explicação em linguagem simples

Uma empresa que usa um modelo de terceiros em uma ferramenta interna não é automaticamente o provedor desse modelo. Uma empresa que desenvolve, comissões, lugares no mercado da União ou modifica significativamente um modelo GPAI pode realizar funções de provedor. Uma empresa também pode ser um provedor de sistema ou implantador ao mesmo tempo. Cada função deve ser avaliada separadamente.

1.466 Avaliação do papel

Documento no mínimo:

1. quem desenvolveu ou teve o modelo desenvolvido;
2. sob cujo nome ou marca comercial o modelo é colocado no mercado;
3. quem controla a arquitetura modelo, pesos, treinamento, ajuste fino e liberação;
4. Se uma modificação é menor ou significativa sob a interpretação atual da Comissão;
5. que fornece documentação e informações aos atores a jusante;
6. quem mantém a política de direitos autorais e resumo de conteúdo de treinamento;
7. Se é necessário um representante autorizado;
8. se o modelo satisfaz ou pode satisfazer critérios de risco sistêmico;
9. se um sistema separado-fornecedor ou função de implantador também se aplica.

1.467 Exemplo GlobalWay

A GlobalWay obtém acesso a um modelo GPAI de terceiros por meio de uma API e o usa em um assistente consultor de viagens. A GlobalWay é normalmente um provedor e implantador de sistemas a jusante, não o provedor de modelos. Se a GlobalWay realizar mais tarde um ajuste fino significativo, controlar um novo lançamento de modelo e comercializá-lo sob seu próprio nome, a análise de papel deve ser reaberta.

1.468 Atividade de controlo

As funções de Governança Legal e AI devem aprovar uma avaliação do papel da GPAI antes da aquisição, modificação do modelo, liberação pública ou mudança de contrato material. A avaliação deve ser repetida após alterações na marca, treinamento, ajuste fino, distribuição, licenciamento ou controle operacional.

1.469 Provas

- arquitetura de modelo e sistema;
- Contratos e termos de licença;
- registros de branding e colocação no mercado;
- Histórico de desenvolvimento e modificação;
- folha de cálculo da avaliação do papel;
- Análise jurídica;
- Provedor e documentação a jusante;
- Registros de reavaliação.

1.470 Teste de auditoria

Confirme que o modelo-provedor, o sistema-provedor, o fornecedor a jusante, o deployer e os papéis representativos autorizados foram avaliados separadamente e que as modificações significativas desencadearam a reavaliação.

1.471 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigos 3.º, 51.º a 56.º e anexos conexos.
- Orientações da Comissão Europeia para fornecedores de modelos GPAI, identificadas como orientações não vinculativas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.472 Capítulo 54 Documentação GPAI e Informações a montante

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 54 linguagem de rascunho.

1.473 Exigência

Os fornecedores de modelos de IA de uso geral devem preparar, manter e fornecer a documentação e as informações exigidas pelo Artigo 53 e os anexos aplicáveis para que os provedores a jusante possam entender as capacidades e limitações do modelo e cumprir suas próprias obrigações.

1.474 Explicação em linguagem simples

Os usuários a jusante precisam de mais do que uma descrição de marketing. Eles precisam de informações controladas, atuais e tecnicamente significativas sobre o modelo, seus usos pretendidos e previsíveis, limitações, abordagem de treinamento e avaliação, interfaces, dependências e condições de uso. As informações devem ser suficientes para um provedor a jusante executar riscos, conformidade, transparência, segurança e trabalho de supervisão humana.

1.475 Controlos da documentação

O provedor deve manter, conforme aplicável:

1. Identidade do modelo, versão, data de lançamento e detalhes do provedor;
2. arquitetura, modalidade, capacidades e usos pretendidos;
3. Limitações de uso proibidas, sem suporte e de alto risco;
4. treinamento, ajuste fino, avaliação e informações de teste;

5. limites de desempenho conhecidos, modos de falha e uso indevido previsível;
6. Informações sobre cibersegurança e resiliência;
7. requisitos de integração e controles de interface;
8. Documentação necessária ao Gabinete de IA e às autoridades competentes;
9. Informações necessárias para os fornecedores a jusante;
10. mudar o histórico e atualizar os avisos.

1.476 Exemplo GlobalWay

Antes de integrar um modelo GPAI em seu assistente de viajante, a GlobalWay obtém a documentação do modelo controlado do provedor, notas de lançamento, limitações, informações de segurança, requisitos técnicos de interface e informações de conformidade a jusante. Uma nova versão do modelo não pode ser implantada até que a documentação alterada seja revisada.

1.477 Atividade de controle

O provedor deve operar um processo de documentação GPAI controlado por versão. As informações a jusante devem ser revisadas quanto à integridade, precisão, confidencialidade e usabilidade antes do lançamento. As alterações no modelo de material devem acionar a documentação atualizada e a comunicação oportuna aos provedores a jusante afetados.

1.478 Provas

- documentação técnica do modelo;
- Pacote de informações a jusante;
- versão e registros de lançamento;
- Avisos de alteração;
- Registros de avaliação e limitação;
- logs de distribuição;
- reconhecimentos de destinatários quando utilizados;
- registros de revisão e aprovação.

1.479 Teste de auditoria

Selecione uma versão do modelo e confirme que a documentação necessária existia quando o modelo foi colocado no mercado, corresponde à versão lançada, foi fornecida a provedores relevantes a jusante e foi atualizada após alterações materiais.

1.480 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 53.o e anexos aplicáveis.

- Diretrizes para provedores de GPAI da Comissão Europeia, identificadas como orientações não vinculativas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.481 Capítulo 55 Política de Direitos Autorais e Resumo do Conteúdo de Treinamento

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 55 linguagem de rascunho.

1.482 Exigência

Os fornecedores de modelos de IA de uso geral devem manter uma política de conformidade com a legislação da União em matéria de direitos de autor e direitos conexos, incluindo a identificação e observância de reservas de direitos expressas nos termos do artigo 4.o, n.o 3, da Diretiva (UE) 2019/790, e devem disponibilizar ao público um resumo suficientemente detalhado do conteúdo utilizado para treinar o modelo utilizando o modelo da Comissão, se aplicável.

1.483 Explicação em linguagem simples

A política de direitos autorais e o resumo de conteúdo de treinamento público são controles separados. A política rege como o conteúdo de treinamento é obtido, exibido, documentado e tratado quando os detentores de direitos reservam seus direitos. O resumo público dá visibilidade significativa em categorias e fontes de conteúdo de treinamento sem exigir a divulgação de segredos comerciais protegidos ou cada item individual.

1.484 Requisitos de controlo

O provedor deve documentar:

1. categorias de fontes de conteúdo de treinamento e métodos de aquisição;
2. licença, permissão, domínio público, exceção e análise de reserva de direitos;
3. Medidas para detectar e respeitar reservas de direitos legíveis por máquina;
4. processos de reclamação, desafio e remediação;
5. controles de fornecedores e fornecedores de conjuntos de dados;
6. O método utilizado para preparar o resumo público;
7. revisão de precisão, confidencialidade, dados pessoais e segredos comerciais;
8. acionadores de versão e atualização após a reciclagem de material ou alterações de conjunto de dados.

1.485 Exemplo GlobalWay

A GlobalWay não assume que a declaração de um fornecedor GPAI de que usa “dados publicamente disponíveis” resolve o risco de direitos autorais. A aquisição exige a política de direitos autorais do provedor, resumo de conteúdo de treinamento público, processo de reserva de direitos, rota de reclamação e compromissos de notificação de mudança.

1.486 Atividade de controlo

O provedor deve aprovar e manter uma política de conformidade com os direitos autorais e publicar o resumo de conteúdo de treinamento necessário. As funções legais, de governança de dados e de desenvolvimento de modelo devem revisar as alterações do conjunto de dados de materiais antes do treinamento ou da reciclagem.

1.487 Provas

- Política de Direitos de Autor;
- Registos de origem e de licenças;
- Controlos de detecção de direitos de reserva;
- Contratos conjunto de dados-fornecedor;
- Registros de reclamações e remediação;
- Resumo de formação Comissão-modelo;
- Registo de publicação;
- Histórico de atualização e aprovação.

1.488 Teste de auditoria

Confirme se o provedor aplicou sua política de direitos autorais, documentou a base de uso, respeitou as reservas de direitos aplicáveis, publicou o resumo necessário e atualizou-o após mudanças no treinamento material.

1.489 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 53.o
- Diretiva (UE) 2019/790, incluindo o artigo 4.o, n.o 3.
- Modelo e orientação atual da Comissão, identificados de acordo com o status legal.

1.490 Capítulo 56 GPAI Modelos com Risco Sistémico

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 56 anterior.

1.491 Exigência

Um modelo de IA de uso geral deve ser classificado como um modelo GPAI com risco sistémico quando tenha capacidades de alto impacto nos termos do artigo 51.o ou quando a Comissão o designe como apresentando capacidades equivalentes ou impacto. Os prestadores devem monitorizar os critérios de classificação, notificar a Comissão quando necessário e cumprir as obrigações adicionais aplicáveis aos modelos de risco sistémico.

1.492 Explicação em linguagem simples

O estatuto de risco sistémico pode surgir através de uma presunção estatutária ou de uma decisão da Comissão. O regulamento actual presume capacidades de alto impacto quando a computação de formação cumulativa excede 10-25 operações de ponto flutuante, sujeitas a alterações futuras. O limiar não é o único caminho: a Comissão pode designar um modelo com base nos critérios mais amplos do anexo XIII.

1.493 Processo de classificação e notificação

O provedor deve:

1. Medição e cálculo de treinamento cumulativo de documentos;
2. avaliar as capacidades e o impacto do modelo utilizando ferramentas, benchmarks e critérios do Anexo XIII apropriados;
3. Monitorizar se o limiar será atingido antes da conclusão do treino;
4. Notificar a Comissão sem demora e, o mais tardar, duas semanas após o cumprimento do critério ou o prestador saber que o mesmo será cumprido;
5. Incluir as informações necessárias para apoiar a notificação;
6. Documentar qualquer argumento excepcional e fundamentado de que o modelo não apresenta risco sistémico, apesar de cumprir a presunção;
7. Acompanhar as decisões de designação, rejeição, reavaliação ou remoção da Comissão;
8. Ative os controlos do Artigo 55 quando a classificação de risco sistémico for aplicada.

1.494 Exemplo GlobalWay

A GlobalWay não é a fornecedora do modelo GPAI de terceiros usado em sua plataforma de viagens, mas a devida diligência do fornecedor confirma se o provedor avaliou o status de risco sistémico, completou as notificações necessárias e forneceu informações de segurança e proteção adequadas aos clientes a jusante.

1.495 Atividade de controlo

O fornecedor da GPAI deve manter um processo documentado de classificação de risco sistémico ligado a planos de formação, registos de computação, resultados de avaliação, comunicações da Comissão e portões de lançamento. Nenhum modelo de qualificação pode ser colocado no mercado da União enquanto uma notificação exigida ou uma ação de prontidão do artigo 55 permanece por resolver.

1.496 Provas

- Cálculo de formação-computação;
- capacidade e avaliações de impacto;
- Análise do anexo XIII;
- registos de monitorização de limiares;
- Notificação e carimbo de data e hora da Comissão;
- Submissão de refutação, quando utilizada;
- Decisão ou correspondência da Comissão;
- Artigo 55.o Evidência de prontidão e conformidade.

1.497 Teste de auditoria

Recalcule ou valide a figura da computação-treinamento, inspecione a análise do Anexo XIII, confirme a data de notificação quando necessário e verifique se as obrigações de risco sistémico foram ativadas antes da liberação.

1.498 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigos 51.o a 52.o e anexo XIII.
- Diretrizes para provedores de GPAI da Comissão Europeia, identificadas como orientações não vinculativas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.499 Capítulo 57 Avaliação de Modelo e Teste Adversarial

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 57 anterior.

1.500 Exigência

Os fornecedores de modelos de IA de uso geral com risco sistémico devem realizar avaliações de modelo de acordo com protocolos e ferramentas padronizados que reflitam o estado da arte, incluindo testes contraditórios, quando apropriado, para identificar e mitigar riscos sistémicos.

1.501 Explicação em linguagem simples

A avaliação não é um exercício de benchmark único. O provedor deve testar o que o modelo pode fazer, onde falha, como pode ser mal utilizado, como as salvaguardas podem ser contornadas e se novos lançamentos ou ajuste fino mudam materialmente o risco. Os testes adversos devem incluir tentativas realistas de derrotar controles e expor capacidades perigosas ou não.

1.502 Programa de avaliação

O provedor deve definir:

1. objetivos de avaliação ligados a riscos sistêmicos identificados;
2. capacidade, segurança, robustez, uso indevido e domínios de teste de autonomia;
3. Pontos de avaliação pré-lançamento, pós-lançamento e desencadeados por mudanças;
4. Ensaios independentes ou funcionalmente separados, quando proporcionados;
5. cenários representativos e de teste de stress;
6. Qualificações da equipe vermelha, controles de conflitos e regras de engajamento;
7. critérios de exploração, reprodutibilidade e risco residual;
8. limiares de remediação, reteste e bloqueio de liberação;
9. Manuseio confidencial de descobertas sensíveis;
10. documentação suficiente para supervisão e revisão regulatória.

1.503 Exemplo GlobalWay

Antes de integrar um modelo GPAI de risco sistêmico em sua plataforma de assistência de viagem, a GlobalWay revisa o resumo de avaliação do provedor, testa resistência à injeção imediata, geração prejudicial de documentos de viagem, vazamento de dados sensíveis, orientação de emergência falsa e salvaguardas em torno de conteúdo proibido e registra limitações a jusante e controles de compensação.

1.504 Atividade de controle

O provedor GPAI deve manter uma avaliação documentada e um programa de testes contraditórios vinculado à governança de liberação. Uma liberação não deve prosseguir onde as descobertas não resolvidas excedem os limiares de risco aprovados ou onde os testes não cobrem riscos sistêmicos identificados.

1.505 Provas

- plano de avaliação e catálogo de testes;

- Racionalidade de referência e cenário;
- relatórios de testes contraditórios;
- Qualificações da equipe vermelha e registros de independência;
- constatações e classificações de gravidade;
- Remediação e reteste de provas;
- decisão de liberação e aprovação de risco residual;
- Resultados de avaliação pós-lançamento.

1.506 Teste de auditoria

Confirme que as avaliações abordaram a avaliação de risco atual, incluíram testes contraditórios realistas, usaram critérios de aceitação definidos, resultaram em correção controlada e foram concluídas antes da aprovação da liberação.

1.507 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: Artigo 55.º, n.º 1, alínea a).
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As orientações aplicáveis da Comissão e do AI Office devem ser identificadas como não vinculativas, a menos que sejam legalmente adotadas.

1.508 Capítulo 58 Avaliação e Mitigação do Risco Sistémico

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 58 linguagem de rascunho.

1.509 Exigência

Os fornecedores de modelos de IA de uso geral com risco sistémico devem avaliar e mitigar possíveis riscos sistémicos a nível da União, incluindo as suas fontes, percursos, setores afetados, utilização indevida previsível e materialização em todo o ciclo de vida do modelo.

1.510 Explicação em linguagem simples

O risco sistémico diz respeito a danos que podem se espalhar amplamente, afetar muitas pessoas ou setores, prejudicar os interesses públicos ou criar sérios efeitos transfronteiriços. O provedor deve identificar como as capacidades do modelo, distribuição, integrações, dependências e uso indevido podem criar tal dano e devem implementar salvaguardas proporcionadas ao risco.

1.511 Estrutura de avaliação

A avaliação deve abordar:

1. capacidades do modelo, limitações e evolução previsível;
2. condições de acesso, escala de distribuição e integração a jusante;
3. Vias de utilização abusiva e de evasão;
4. Riscos cibernéticos, biológicos, químicos, radiológicos, de integridade da informação, discriminação, segurança, autonomia e infraestrutura crítica, quando relevante;
5. Riscos de concentração, dependência e falha em cascata;
6. populações, setores, direitos e alcance geográfico afetados;
7. verossimilhança, gravidade, velocidade, reversibilidade e detectável;
8. salvaguardas existentes e riscos residuais;
9. Proprietários, prazos, validação e monitoramento;
10. gatilhos de reavaliação, incluindo novas capacidades, incidentes, avaliações e mudanças materiais.

1.512 Exemplo GlobalWay

A GlobalWay avalia se um modelo GPAI de risco sistêmico usado em fluxos de trabalho de reserva, gerenciamento de interrupções, fraude e assistência aos funcionários poderia propagar orientação de emergência falsa, expor dados sensíveis do viajante, permitir engenharia social em larga escala ou criar falhas operacionais correlacionadas. Aplica controles a jusante enquanto exige evidências do provedor para a mitigação de risco sistêmico a montante.

1.513 Atividade de controle

O provedor deve manter um registro de risco sistêmico específico de versão vinculado a avaliações de modelo, informações de incidentes, controles de segurança cibernética, decisões de liberação e monitoramento pós-comercialização. Os riscos materiais não mitigados devem bloquear a liberação ou exigir restrição documentada, implantação encenada, limitação de acesso ou outras salvaguardas validadas.

1.514 Provas

- Metodologia de risco sistêmico;
- Registo de riscos e análise de cenários;
- mapeamento do setor afetado e da dependência;
- Uso indevido e avaliações de ameaças;
- plano de mitigação e proprietários;
- validação e aprovação de risco residual;
- restrições de liberação e controles de acesso;

- Registros de monitoramento e reavaliação.

1.515 Teste de auditoria

Selecione uma versão do modelo de risco sistêmico e verifique se a avaliação abrange capacidade relevante, uso indevido, dependência e caminhos intersetoriais; que as mitigações são validadas e rastreáveis; e que os riscos residuais foram aprovados no nível apropriado antes da liberação.

1.516 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 55.o, n.o 1, alínea b), e disposições de risco sistêmico conexas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As orientações aplicáveis da Comissão e do AI Office devem ser identificadas como não vinculativas, a menos que sejam legalmente adotadas.

1.517 Capítulo 59 Segurança cibernética e relatórios de incidentes para GPAI de risco sistêmico

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 59 anterior.

1.518 Exigência

Os fornecedores de modelos de IA de uso geral com risco sistêmico devem garantir um nível adequado de proteção de segurança cibernética para o modelo e sua infraestrutura física e devem rastrear, documentar e relatar incidentes graves relevantes e possíveis medidas corretivas ao Escritório de IA e, quando apropriado, às autoridades nacionais competentes.

1.519 Explicação em linguagem simples

Um modelo de risco sistêmico pode criar danos amplos se pesos de modelo, infraestrutura de treinamento, sistemas de implantação ou controles de segurança forem comprometidos. A segurança deve cobrir todo o ciclo de vida do modelo, incluindo desenvolvimento, treinamento, avaliação, liberação, acesso, atualizações, detecção de incidentes e recuperação.

1.520 Áreas de controle de segurança cibernética

O provedor deve abordar:

1. Ambientes seguros de desenvolvimento e formação;
2. Identidade, acesso, privilégio e gestão de segredos;

3. proteção de pesos modelo, conjuntos de dados, códigos e ativos de avaliação;
4. vulnerabilidades de software, hardware, nuvem e cadeia de suprimentos;
5. Ameaças adversas de aprendizado de máquina, incluindo envenenamento, extração, evasão e abuso imediato;
6. registro, monitoramento, detecção de anomalias e prontidão forense;
7. Segmentação, resiliência, backup e recuperação;
8. Divulgação e correção de vulnerabilidades;
9. Coordenação de terceiros e de fornecedores de infraestrutura;
10. Classificação de incidentes, escalada, relatórios e ações corretivas.

1.521 Processo de incidente

O processo deve definir critérios de conscientização e escalada, avaliação causal e de impacto, preservação de evidências de modelo e infraestrutura, responsabilidades de relatórios, contatos de autoridade, relatórios iniciais e suplementares, medidas corretivas e reavaliação de risco pós-incidente.

1.522 Exemplo GlobalWay

A GlobalWay exige que seu fornecedor GPAI de risco sistêmico forneça evidências de proteção de peso, controles de acesso privilegiado, testes de segurança, compromissos de notificação de incidentes e procedimentos de recuperação. A GlobalWay monitora separadamente suas próprias chaves de API, lojas de recuperação, plugins, prompts, logs e integrações a jusante.

1.523 Atividade de controle

O provedor deve operar um programa integrado de segurança de modelo e gerenciamento de incidentes com limites de gravidade definidos, escalonamento 24 horas por dia para eventos críticos, evidências protegidas e restrições de liberação ou serviço quando o risco não puder ser adequadamente controlado.

1.524 Provas

- Arquitetura de segurança cibernética e avaliação de riscos;
- Registros de acesso e privilégio;
- Controles de peso-modelo e proteção de dados;
- resultados de testes de segurança e adversários;
- Registros de vulnerabilidade e remediação;
- Evidências de monitorização e detecção;
- Relatórios de incidentes e comunicações de autoridade;
- evidência de ação corretiva e recuperação;
- reavaliação pós-incidente.

1.525 Teste de auditoria

Confirme que os controles cobrem o modelo e a infraestrutura física, os eventos foram classificados e escalados de forma consistente, as evidências foram preservadas, os relatórios necessários foram enviados e as medidas corretivas foram validadas.

1.526 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redacção que lhe foi dada: artigo 55.º, n.º 1, alíneas c) e d).
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As orientações aplicáveis da Comissão e do AI Office devem ser identificadas como não vinculativas, a menos que sejam legalmente adotadas.

1.527 Capítulo 60 Relatório sobre Energia e Recursos

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 60 linguagem de rascunho.

1.528 Exigência

Os fornecedores de modelos de IA de uso geral devem manter e fornecer as informações técnicas exigidas pelo Regulamento (UE) 2024/1689, conforme alterado, incluindo informações sobre o consumo de energia do modelo, quando aplicável. Os fornecedores de modelos GPAI de risco sistêmico também devem integrar os impactos dos recursos em seus processos mais amplos de risco, monitoramento e governança.

1.529 Explicação em linguagem simples

Os relatórios de energia devem ser baseados em dados mensuráveis e reproduzíveis, não em estimativas de marketing. O provedor deve explicar o que foi medido, sobre qual estágio do ciclo de vida, usando qual método e com quais limitações. Treinamento, ajuste fino, avaliação e inferência podem ter diferentes perfis de recursos e não devem ser combinados sem explicação.

1.530 Quadro-quadro de relatórios

O fornecedor deve documentar, quando aplicável:

1. versão do modelo e escopo de medição;
2. treinamento e computação de ajuste fino;
3. energia consumida durante as fases relevantes de desenvolvimento e avaliação;

4. Energia de inferência estimada ou medida sob condições de utilização definidas;
5. hardware, data center, nuvem e suposições geográficas;
6. Metodologia de medição, ferramentas, limites e incerteza;
7. mudanças materiais entre versões de modelos;
8. Controles de eficiência de recursos e medidas de otimização;
9. Informações fornecidas a fornecedores e autoridades a jusante;
10. retenção e revisão de registros de apoio.

1.531 Exemplo GlobalWay

A GlobalWay pede ao seu fornecedor GPAI informações de energia e computação específicas da versão que possam apoiar relatórios internos de sustentabilidade e decisões de aquisição. A GlobalWay não representa estimativas de fornecedores como medições exatas, a menos que a metodologia e os limites sejam documentados.

1.532 Atividade de controle

O provedor GPAI deve manter uma metodologia de relatório de recursos controlada e repositório de evidências. As divulgações públicas ou a jusante devem ser revisadas para consistência com o escopo de medição subjacente, suposições e incerteza.

1.533 Provas

- Metodologia de energia e computação;
- logs de medição e dados de origem;
- Registros de hardware e infraestrutura;
- comparação modelo-versão;
- Declaração de pressupostos e incerteza;
- Informação técnica a jusante;
- Registros de revisão e aprovação;
- ações de melhoria da eficiência de recursos.

1.534 Teste de auditoria

Selecione uma versão do modelo GPAI e rastreie dados de energia ou recursos relatados para dados de origem, metodologia, suposições de infraestrutura e registros de cálculo. Confirme se as estimativas estão rotuladas, as alterações estão vinculadas à versão e as divulgações não exageram a precisão.

1.535 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 53.o e requisitos de informação técnica em anexo aplicáveis.

- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- Os modelos ou orientações aplicáveis da Comissão e do AI Office devem ser identificados como não vinculativos, a menos que sejam legalmente adotados.

1.536 Capítulo 61 Considerações de código aberto

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 61 linguagem de rascunho.

1.537 Exigência

O estatuto de código aberto não cria uma isenção geral do Regulamento (UE) 2024/1689, conforme alterado. As organizações devem avaliar as condições estatutárias exatas, o papel do ator, o modelo ou a categoria do sistema, se a monetização ou os serviços relacionados estão envolvidos, se o risco sistêmico se aplica e quais obrigações permanecem aplicáveis.

1.538 Explicação em linguagem simples

Uma licença pública ou modelo para download não determina por si só o tratamento legal. A Lei fornece tratamento especial limitado em circunstâncias específicas, mas obrigações importantes ainda podem se aplicar, especialmente para modelos GPAI de risco sistêmico, práticas proibidas, usos de alto risco, deveres de transparência e provedores a jusante que integram, modificam, remarcam ou implantam componentes abertos.

1.539 Questões de avaliação

Documento:

1. A licença e as condições de acesso;
2. se o código fonte, a arquitetura, os pesos e as informações de uso estão genuinamente disponíveis conforme necessário;
3. se o provedor recebe consideração monetária ou outra consideração, incluindo plataforma, suporte, hospedagem ou benefícios relacionados a dados;
4. se o modelo apresenta risco sistêmico;
5. se a organização modifica, ajusta, integra, rebrands ou altera o propósito pretendido;
6. se o sistema resultante é proibido, de alto risco ou regulamentado por transparência;
7. Quais os deveres de documentação, direitos autorais, segurança, incidentes e informações a jusante que permanecem;

8. como vulnerabilidades, atualizações, proveniência e dependências de componentes são governadas.

1.540 Exemplo GlobalWay

A GlobalWay faz o download de um modelo licenciado abertamente e ajusta-o para suporte de triagem de funcionários. A licença não remove a necessidade de avaliar a classificação de alto risco, transferência de papel do provedor, governança de dados, conformidade, supervisão humana, segurança e obrigações de documentação.

1.541 Atividade de controlo

Os componentes de código aberto devem passar por avaliação legal, de segurança, proveniência, licença e função antes do uso. O inventário deve registrar versão, fonte, licença, mantenedores, dependências, modificações, finalidade pretendida, limitações conhecidas e gatilhos de reavaliação.

1.542 Provas

- Registos de licenças e repositórios;
- Análise estatutária de código aberto;
- monetização e avaliação de serviços;
- modelo e classificação do sistema;
- avaliação do papel e da modificação substancial;
- inventário de componentes e proveniência;
- Registos de vulnerabilidade e atualização;
- documentação e aprovações.

1.543 Teste de auditoria

Confirme que a organização não se baseou em uma isenção geral, avaliou as condições estatutárias e os deveres remanescentes, rastreou modificações e dependências e reavaliou a classificação e o papel após mudanças materiais.

1.544 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: disposições pertinentes relativas aos sistemas de IA de código aberto e livre e aos modelos GPAI, incluindo os artigos 2.º e 53.º-55.º, conforme aplicável.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As orientações aplicáveis da Comissão e do AI Office devem ser identificadas como não vinculativas, a menos que sejam legalmente adotadas.

1.545 Capítulo 62 Código de Prática GPAI

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 62 linguagem de rascunho.

1.546 Exigência

Um provedor de IA de uso geral pode usar um código de prática oficialmente avaliado para apoiar a demonstração do cumprimento das obrigações GPAI aplicáveis, mas a participação não remove a responsabilidade do provedor para satisfazer o regulamento. As obrigações legais permanecem controladoras e o provedor deve identificar quaisquer lacunas entre o código, sua implementação e o modelo real e o perfil de risco do provedor.

1.547 Explicação em linguagem simples

Um código de prática pode fornecer uma rota organizada para documentação, direitos autorais, segurança, segurança, avaliação e controles de risco. Não é um substituto para a lei, uma garantia de conformidade ou uma razão para ignorar as fraquezas específicas do modelo. As organizações devem implementar compromissos na prática e reter evidências.

1.548 Abordagem da governação

O provedor deve:

1. identificar quais compromissos de código se aplicam à sua categoria de papel e modelo;
2. Mapear cada compromisso com a obrigação legal relevante;
3. adoção de documentos, reservas, exclusões e interpretação;
4. atribuir proprietários e prazos responsáveis;
5. Integrar compromissos em políticas, liberar portões, testar, lidar com incidentes e monitorar;
6. reter evidência de eficácia operacional;
7. Avaliar se são necessários controles adicionais para além do código;
8. Revisões de pista, avaliações oficiais, orientação da Comissão e desenvolvimentos da aplicação da lei;
9. comunicar com precisão sobre a participação e evitar implicar a aprovação regulatória do modelo.

1.549 Exemplo GlobalWay

A GlobalWay pergunta a um fornecedor GPAI se assinou e implementou o Código de Prática oficial da GPAI, mas também revisa a documentação subjacente, o processo de direitos autorais, controles de risco sistêmico,

evidências de segurança e compromissos de incidentes, em vez de confiar apenas em uma declaração de participação.

1.550 Atividade de controlo

O provedor deve manter uma matriz de controle de código para obrigação e testar periodicamente se os compromissos são implementados. Qualquer desvio, compromisso não aplicável ou método alternativo de conformidade devem ser documentados e aprovados.

1.551 Provas

- registro de participação ou adoção de código assinado;
- mapeamento code-to-article;
- Plano de implementação e proprietários;
- Atualizações de políticas e procedimentos;
- Testes e acompanhamento de provas;
- análise de desvios e meios alternativos;
- registros de revisão e remediação da gestão;
- declarações externas e comunicações de fornecedores.

1.552 Teste de auditoria

Selecione uma amostra de compromissos de código e rastreie cada um para a obrigação legal, controle implementado, evidências operacionais e lacunas identificadas. Confirme que as reivindicações externas não exageram o efeito legal da participação no código.

1.553 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: artigos 53.º a 56.º e disposições relativas à GAGP.
- Código de Prática Oficial da GPAI e avaliação da Comissão, tratados de acordo com seu status legal.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.554 Capítulo 63 Código de Transparência para o Conteúdo Gerado por IA

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 63 anterior.

1.555 Exigência

As organizações podem usar um código de práticas de transparência oficialmente avaliado para apoiar a implementação das obrigações aplicáveis do Artigo 50 para conteúdo gerado ou manipulado por IA. O

código não substitui o Regulamento e a organização deve determinar quais deveres estatutários se aplicam ao seu provedor ou função de implantador, tipo de conteúdo, contexto de publicação e data efetiva.

1.556 Explicação em linguagem simples

Os controles de transparência devem ajudar as pessoas a reconhecer quando o conteúdo é gerado ou manipulado pela IA sem tornar o conteúdo inutilizável ou inacessível. Diferentes deveres se aplicam à marcação técnica por provedores e divulgações por implantadores. Exceções e requisitos de apresentação devem ser avaliados separadamente.

1.557 Abordagem de implementação

A organização deve:

1. Classificar o conteúdo e a obrigação relevante do artigo 50.o;
2. identificar se atua como provedor, deployer, editor, editor ou outro ator relevante;
3. Implementar marcação legível por máquina sempre que necessário e tecnicamente viável;
4. Fornecer uma divulgação clara e voltada para o ser humano, quando necessário;
5. assegurar que as divulgações sejam oportunas, proeminentes, acessíveis e compreensíveis;
6. Exceções de documentos envolvendo autorização legal, contextos artísticos, satíricos, ficcionais ou editoriais, quando aplicável;
7. persistência do teste em exportações, compressão, repostagem e transformações de plataforma;
8. monitorar falsos positivos, falsos negativos, remoção e evasão;
9. compromissos de código de mapa para obrigações legais vinculativas e documentar qualquer implementação alternativa.

1.558 Exemplo GlobalWay

A GlobalWay usa IA generativa para produzir imagens de destino e rascunhos de consultoria de viagens. Requer marcação do lado do provedor, quando aplicável, rótulos de imagens sintéticas publicadas externamente, retém a responsabilidade editorial humana por informações de viagem de interesse público e testa se rótulos e metadados sobrevivem aos fluxos de trabalho de gerenciamento de conteúdo e mídia social.

1.559 Atividade de controle

O proprietário do conteúdo deve concluir uma avaliação de transparência antes da liberação pública do conteúdo gerado ou manipulado por IA aplicável. Os controles de liberação devem verificar a marcação técnica

necessária, a redação da divulgação, a acessibilidade, a análise de exceções e a retenção de evidências.

1.560 Provas

- Artigo 50.o Classificação;
- análise ator-papel;
- especificações de marcação e divulgação;
- screenshots e resultados de testes legíveis por máquina;
- Testes de acessibilidade;
- análise de exceção e editorial-responsabilidade;
- mapeamento código-a-obrigação;
- monitoramento e registros de ação corretiva.

1.561 Teste de auditoria

Confirme se o provedor e os deveres de deployer aplicáveis foram distinguidos, a marcação e a divulgação foram implementadas e testadas, as exceções foram documentadas e as reivindicações externas sobre a participação no código não exageram a conformidade.

1.562 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 50.o e disposições de transparência conexas.
- Código de prática oficial de transparência e avaliação da Comissão, tratados de acordo com o seu estatuto jurídico.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.563 Capítulo 64 Chatbot e Divulgação Humano-Interação

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 64 anterior.

1.564 Exigência

Os provedores devem garantir que os sistemas de IA destinados a interagir diretamente com pessoas naturais sejam projetados e desenvolvidos para que as pessoas envolvidas sejam informadas de que estão interagindo com um sistema de IA, a menos que esse fato seja óbvio para uma pessoa razoavelmente bem informada, observadora e circunspecta no contexto relevante. As exceções aplicáveis devem ser interpretadas de forma restrita e documentada.

1.565 Explicação em linguagem simples

As pessoas não devem ter que adivinhar se estão lidando com um sistema humano ou um sistema de IA. A divulgação deve aparecer cedo o suficiente para influenciar a interação e deve ser compreensível, acessível e proporcional ao contexto.

1.566 Exemplo GlobalWay

O assistente de suporte de viagens da GlobalWay se identifica como um assistente de IA no início da conversa e fornece uma rota visível para um consultor de viagens para reembolsos, problemas de segurança, necessidades de acessibilidade ou respostas de baixa confiança.

1.567 Atividade de controlo

O proprietário do produto deve implementar uma divulgação aprovada antes do lançamento da produção, testá-lo em canais e idiomas suportados e reavaliá-lo após alterações na interface, marca ou caso de uso.

1.568 Provas

- Texto de divulgação aprovado;
- screenshots e capturas de canal;
- Testes de acessibilidade e localização;
- Aprovação da autorização de autorização;
- análise de exceção em que se baseou;
- Monitorização e registos de reclamações.

1.569 Teste de auditoria

Selecione sistemas de IA voltados para o cliente e verifique se a divulgação aparece no ponto correto, permanece compreensível no contexto, é acessível e não é removida pela configuração a jusante.

1.570 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 50.o, n.o 1.
- Diretrizes de transparência do artigo 50 da Comissão Europeia, identificadas como orientações não vinculativas.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.571 Capítulo 65 Marcação de Conteúdo Gerada e Manipulada por AI

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 65 anterior.

1.572 Exigência

Os fornecedores de sistemas de IA, incluindo sistemas de IA de uso geral, que geram conteúdo sintético de áudio, imagem, vídeo ou texto devem garantir que as saídas sejam marcadas em um formato legível por máquina e detectável como artificialmente geradas ou manipuladas, sujeitas às exceções estatutárias e padrão de viabilidade técnica.

1.573 Explicação em linguagem simples

Um rótulo visível pode ajudar os usuários, mas não substitui por si só o dever de marcação legível por máquina no nível do provedor quando o artigo 50.o, n.o 2, se aplica.

1.574 Exemplo GlobalWay

A GlobalWay usa um sistema generativo para criar imagens de destino e resumos de itinerário. O provedor fornece metadados de proveniência legíveis por máquina, e a GlobalWay verifica se seu fluxo de trabalho de publicação não remove a marcação.

1.575 Atividade de controlo

O provedor e o editor a jusante devem manter controles para marcação de saída, preservação por meio de exportação e transformação, testes de eficácia, exceções documentadas e correção quando as marcas são perdidas ou ineficazes.

1.576 Provas

- Especificação técnica de marcação;
- resultados de testes de detecção e robustez;
- testes de exportação e transformação;
- Documentação do fornecedor;
- análise de exceção;
- monitoramento e registros de ação corretiva.

1.577 Teste de auditoria

Gerar saídas representativas, processá-las através de fluxos de trabalho normais de publicação e verificar se a marcação legível por máquina permanece detectável e que qualquer exceção reivindicada é documentada e válida.

1.578 Controle de data efetiva

Os sistemas colocados no mercado antes dessa data recebem apenas a transição limitada aplicável ao artigo 50.o, n.o 2, que termina em 2 de dezembro de 2026.

1.579 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: n.o 2 do artigo 50.o
- Regulamento (UE) n.o 2026/1744 Disposição transitória para sistemas pré-existentes.
- Artigo 50.o Diretrizes e código de transparência, identificados de acordo com o seu estatuto jurídico.

1.580 Capítulo 66 Deepfake Disclosure

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 66.

1.581 Exigência

Os implementadores de sistemas de IA que geram ou manipulam conteúdo de imagem, áudio ou vídeo que constitua um deepfake devem divulgar que o conteúdo foi gerado ou manipulado artificialmente. A divulgação deve ser clara, oportuna e apropriada ao meio, sujeita às acomodações estatutárias para trabalhos artísticos, criativos, satíricos, fictícios ou análogos.

1.582 Explicação em linguagem simples

As pessoas devem ser capazes de reconhecer quando a mídia realista foi criada ou alterada pela IA. O contexto artístico ou fictício pode afetar a forma como a divulgação é apresentada, mas não justifica a ocultação da natureza artificial do conteúdo.

1.583 Exemplo GlobalWay

A GlobalWay publica um vídeo promocional gerado por IA com um viajante fictício. O vídeo e a página que o acompanha afirmam claramente que a filmagem foi gerada artificialmente, preservando a apresentação criativa.

1.584 Atividade de controlo

O proprietário do conteúdo deve classificar o conteúdo deepfake antes da publicação, aplicar uma divulgação aprovada, preservar marcas legíveis por máquina no nível do provedor e obter revisão legal para qualquer exceção reivindicada ou apresentação modificada.

1.585 Provas

- registro de classificação de conteúdo;
- Divulgação aprovada;
- screenshots de publicação;
- metadados de proveniência;
- Análise jurídica para apresentação especial;
- monitoramento e registros de retirada.

1.586 Teste de auditoria

Revise uma amostra de mídia sintética ou manipulada e verifique se a classificação de deepfake, a colocação de divulgação, a acessibilidade e a preservação da proveniência são apoiadas por evidências.

1.587 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 50.o, n.o 4.
- Diretrizes de transparência do artigo 50 da Comissão Europeia, identificadas como orientações não vinculativas.

1.588 Capítulo 67 Divulgações de Texto Geradas por IA

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 67.

1.589 Exigência

Os agentes que utilizam um sistema de IA para gerar ou manipular texto publicado com a finalidade de informar o público sobre questões de interesse público devem divulgar que o texto foi gerado artificialmente ou manipulado, a menos que o conteúdo tenha sido submetido a revisão humana ou controle editorial e uma pessoa detenha a responsabilidade editorial pela publicação.

1.590 Explicação em linguagem simples

A obrigação visa informações de interesse público, não todos os rascunhos internos ou mensagens comerciais de rotina. A exceção de revisão humana requer controle editorial genuíno e responsabilidade responsável, não um clique de aprovação superficial.

1.591 Exemplo GlobalWay

A GlobalWay usa a IA para elaborar um boletim público de segurança de viagens. Se um editor qualificado revisar, verificar, revisar e aceitar a responsabilidade pela publicação final, a exceção de divulgação de texto do Artigo 50(4) pode ser aplicada. O registro editorial é mantido.

1.592 Atividade de controle

A função de comunicação deve classificar o texto de interesse público, documentar se a IA o gerou ou manipulou materialmente, aplicar uma divulgação, a menos que as condições de controle editorial sejam atendidas e manter o registro de revisão.

1.593 Provas

- Classificação conteúdo-finalidade;

- Registro de geração de IA;
- Divulgação ou decisão de controle editorial;
- editor responsável nomeado;
- fact-check e revisão de provas;
- captura de publicação.

1.594 Teste de auditoria

Amostra de comunicações públicas assistidas por IA e verifique se a classificação de interesse público, decisões de divulgação, revisão humana e responsabilidade editorial são documentadas e credíveis.

1.595 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigo 50.º, n.º 4.
- Diretrizes de transparência do artigo 50 da Comissão Europeia, identificadas como orientações não vinculativas.

1.596 Capítulo 68 Emoção-Reconhecimento e Divulgação Biométrica-Categorização

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 68 linguagem de rascunho.

1.597 Exigência

Os operadores de sistemas de reconhecimento de emoções ou de categorização biométrica devem informar as pessoas singulares expostas do funcionamento do sistema e tratar os dados pessoais em conformidade com a legislação de proteção de dados aplicável da União. Este direito de transparência não legaliza uma utilização proibida nos termos do artigo 5.º ou de outra forma ilegal.

1.598 Explicação em linguagem simples

Uma notificação é necessária quando o artigo 50.º, n.º 3, se aplica, mas a notificação por si só não é suficiente. A organização deve primeiro determinar se o uso é proibido, de alto risco ou restrito pelo direito de proteção de dados, emprego, igualdade, consumidor ou setor.

1.599 Exemplo GlobalWay

GlobalWay considera o uso de uma ferramenta de reconhecimento de emoção durante o treinamento dos funcionários. A proposta é examinada primeiro contra a proibição do local de trabalho. Como o uso pretendido não se encaixa em uma exceção médica ou de segurança documentada, é rejeitado em vez de tratado como permitido apenas porque um aviso poderia ser exibido.

1.600 Atividade de controle

O deployer deve completar a triagem de prática proibida, análise de base legal, revisão de proteção de dados e design de transparência antes da implantação. Os avisos devem explicar a operação do sistema em termos claros e acessíveis e ser fornecidos antes da exposição, sempre que possível.

1.601 Provas

- Avaliação de práticas proibidas;
- finalidade e análise de base legal;
- DPIA ou avaliação de privacidade;
- Notificação aprovada;
- Testes de acessibilidade e localização;
- registros de implantação e monitoramento.

1.602 Teste de auditoria

O reconhecimento de emoções e a categorização biométrica da amostra usam e verificam se a legalidade foi estabelecida antes do projeto de divulgação, os avisos eram oportunos e compreensíveis e os controles de dados pessoais foram implementados.

1.603 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada: artigos 5.o e 50.o, n.o 3.
- GDPR e outras leis aplicáveis da União ou dos Estados-Membros.
- Diretrizes de transparência do artigo 50 da Comissão Europeia, identificadas como orientações não vinculativas.

1.604 Capítulo 69 Acessibilidade e avisos compreensíveis

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 69 anterior.

1.605 Exigência

Os avisos de transparência exigidos pela Lei de IA devem ser fornecidos de forma clara e distinguível e, quando aplicável, o mais tardar na primeira interação ou exposição. As organizações também devem cumprir os requisitos aplicáveis de acessibilidade, proteção do consumidor, igualdade e idioma.

1.606 Explicação em linguagem simples

Um aviso tecnicamente presente ainda pode falhar se estiver oculto, ilegível, mal cronometrado, inacessível ou escrito em linguagem que o público-alvo não possa entender.

1.607 Exemplo GlobalWay

A GlobalWay testa as divulgações de IA para compatibilidade com o leitor de tela, navegação por teclado, contraste, apresentação móvel, linguagem simples e idiomas de viajante suportados. Os avisos críticos não são enterrados apenas em termos e condições.

1.608 Atividade de controlo

O proprietário do aviso deve aplicar um padrão documentado de acessibilidade e compreensão, testar avisos com canais e usuários representativos e corrigir falhas antes do lançamento.

1.609 Provas

- Padrão de aviso aprovado;
- Resultados dos testes de acessibilidade;
- Revisão de legibilidade e compreensão;
- registros de localização;
- screenshots e gravações de interação;
- histórico de defeitos e remediação.

1.610 Teste de auditoria

Inspecione os avisos representativos em todos os canais e verifique o tempo, a proeminência, a acessibilidade, a qualidade da linguagem e a consistência com a função AI real.

1.611 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada: artigo 50.o, n.o 5, e direitos aplicáveis do artigo 50.o.
- Lei de acessibilidade, igualdade e proteção ao consumidor aplicável da União.
- Diretrizes de transparência do artigo 50 da Comissão Europeia, identificadas como orientações não vinculativas.

1.612 Capítulo 70 Testando e Monitorando as Revelações de Transparência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 70 anterior.

1.613 Exigência

As organizações devem testar e monitorar as medidas de transparência necessárias durante todo o ciclo de vida para confirmar que as divulgações, rótulos e marcações legíveis por máquina permanecem precisas, oportunas, acessíveis e eficazes após alterações no sistema, interface, fluxo de trabalho de conteúdo, idioma, canal ou dependência do provedor.

1.614 Explicação em linguagem simples

Uma divulgação pode se degradar após o lançamento. Os redesenhos de interface podem ocultar avisos, ferramentas de exportação podem retirar metadados de proveniência, traduções podem mudar o significado e integrações a jusante podem ignorar os rótulos necessários.

1.615 Exemplo GlobalWay

A GlobalWay realiza testes de lançamento e monitoramento trimestral em seu chatbot, gerador de itinerários, fluxo de trabalho de conteúdo de marketing e boletins públicos de viagens. Falhas criam defeitos rastreados e podem bloquear a publicação ou desencadear a reversão.

1.616 Atividade de controle

O proprietário do controle deve definir casos de teste, amostragem, critérios de sucesso, limiares de escalada e gatilhos de reteste para cada obrigação do Artigo 50. As falhas materiais devem levar à contenção, correção, preservação de evidências e avaliação regulatória, quando apropriado.

1.617 Provas

- plano de teste de divulgação e marcação;
- resultados de testes automatizados e manuais;
- cobertura de canal e idioma;
- Testes de conservação da proveniência;
- Monitoramento de métricas e reclamações;
- defeitos, remediação e provas de reteste;
- ligação mudança-gestão.

1.618 Teste de auditoria

Selecione controles de transparência representativos e verifique se o teste abrange o fluxo de trabalho de produção real, as falhas são detectadas e remediadas e as alterações desencadeiam a reavaliação e o teste de regressão.

1.619 Controle de data efetiva

O artigo 50.o é aplicável a partir de 2 de agosto de 2026, sob reserva da transição limitada que termina em 2 de dezembro de 2026 para sistemas pré-existentes qualificados nos termos do artigo 50.o, n.o 2.

1.620 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: artigo 50.o
- Regulamento (UE) n.o 2026/1744 disposições transitórias.
- Artigo 50.o Diretrizes de transparência e código de transparência da Comissão Europeia, identificados de acordo com o seu estatuto jurídico.

1.621 Capítulo 71 AI Vendor Due Diligence

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 71 linguagem de rascunho.

1.622 Exigência

As organizações devem realizar a devida diligência proporcionada antes de adquirir, integrar ou expandir materialmente um sistema de IA de terceiros ou modelo de IA de uso geral. A revisão deve determinar o papel legal do fornecedor, o papel do cliente, as obrigações aplicáveis da AI Act, a disponibilidade de evidências, as limitações operacionais e a capacidade do fornecedor de apoiar a conformidade durante todo o ciclo de vida.

1.623 Explicação em linguagem simples

A IA de compra não transfere a responsabilidade do cliente. Um deployer ainda precisa de informações suficientes para usar o sistema de forma legal e segura, enquanto um provedor, importador, distribuidor ou fabricante de produtos pode ter deveres adicionais. A due diligence deve testar reivindicações em vez de depender de material de marketing.

1.624 Áreas de due-diligência

Avaliar no mínimo:

1. Pessoa jurídica, propriedade, jurisdições e papel do AI Act;
2. propósito pretendido, restrições de uso proibido e casos de uso suportados;
3. de alto risco, transparência e classificação GPAI;
4. Documentação técnica, instruções, cartões de modelo ou de sistema e provas de conformidade;
5. Procedência de dados, governança, qualidade, privacidade e controles de propriedade intelectual;

6. precisão, robustez, segurança cibernética, viés, acessibilidade e capacidades de visão humana;
7. registro, monitoramento, relatórios de incidentes, manipulação de vulnerabilidades e ações corretivas;
8. subcontratados, serviços em nuvem, componentes de código aberto e dependências de concentração;
9. direitos de alteração-notificação, auditoria, garantia, acesso a dados, retenção e saída;
10. capacidade financeira, operacional e regulatória para apoiar o produto.

1.625 Exemplo GlobalWay

Antes de comprar uma plataforma de recrutamento de IA, a GlobalWay verifica a declaração de propósito pretendido do fornecedor, a análise de classificação do anexo III, instruções de uso, testes de subgrupos, controles de revisão humana, processo de incidente, fontes de dados, subcontratados e obrigações contratuais de notificação de mudança.

1.626 Atividade de controle

A aquisição pode não aprovar um fornecedor de IA material até que Legal, Conformidade, Segurança, Privacidade e o proprietário da empresa concluam uma revisão documentada em nível de risco e resolvam ou aceitem formalmente lacunas identificadas. A due diligence deve ser atualizada após mudança material, incidente, resultado de garantia adversa, ação regulatória ou renovação do contrato.

1.627 Provas

- questionário de fornecedor preenchido;
- análise de papel e classificação;
- documentação e atestados do fornecedor;
- Relatórios de teste e garantia;
- revisão de segurança e privacidade;
- análise legal e de conformidade;
- registro de gap-remediação ou risco-aceitação;
- histórico de aprovação e reavaliação.

1.628 Teste de auditoria

Confirme que a devida diligência precedeu o uso, abordou o papel real do fornecedor e a classificação do sistema, testou as principais alegações com evidências, documentou lacunas não resolvidas e foi atualizado após gatilhos relevantes.

1.629 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: fornecedor, despachante, importador, distribuidor, fabricante de produtos, de alto risco, GPAI, transparência e provisões da cadeia de fornecimento.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.630 Capítulo 72 Cláusulas contratuais

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 72 linguagem de rascunho.

1.631 Exigência

Os contratos para sistemas, modelos, dados e serviços materiais de IA devem alocar responsabilidades com clareza suficiente para apoiar a conformidade, o acesso a evidências, o controle operacional, a resposta a incidentes, o gerenciamento de mudanças e a saída. A linguagem do contrato não pode substituir os papéis legais do ator ou eliminar as obrigações impostas por lei.

1.632 Explicação em linguagem simples

Um contrato deve tornar o modelo operacional exequível. Deve definir o que o fornecedor fornecerá, o que o cliente deve fazer, quais evidências estão disponíveis, como as mudanças e incidentes são tratados e o que acontece quando o sistema se torna não compatível ou não mais suportável.

1.633 Áreas mínimas da cláusula

Endereço conforme aplicável:

1. descrição do sistema ou modelo, finalidade pretendida, usos permitidos e usos proibidos;
2. papéis de partido e reconhecimento de que a classificação legal depende da conduta real;
3. conformidade com a IA aplicável, privacidade, segurança cibernética, produto, emprego e direito do consumidor;
4. Documentação técnica, instruções, registros de conformidade, informações de transparência e provas de auditoria;
5. Procedência de dados, processamento permitido, retenção, exclusão, confidencialidade e propriedade intelectual;
6. precisão, níveis de serviço, robustez, segurança, acessibilidade e requisitos de supervisão humana;
7. Registo, monitorização, reclamação, vulnerabilidade, incidente grave e cooperação em ações corretivas;

8. direitos de aviso prévio e de aprovação para alterações de modelo, dados, recurso, subcontratante, localização e termos;
9. direitos de auditoria, teste, acesso ao regulador, preservação de registros e correção;
10. suspensão, desativação, retirada, assistência de transição, portabilidade e saída segura.

1.634 Exemplo GlobalWay

O contrato da GlobalWay para um sistema de triagem de recrutamento exige que o fornecedor forneça instruções atuais e evidências de conformidade, notifique a GlobalWay antes que o modelo material ou as alterações de dados, preservem registros relevantes, apoiem a investigação de incidentes, restrinjam usos proibidos e forneçam suporte de exportação e transição se o serviço for suspenso.

1.635 Atividade de controle

Os desvios que afetem evidências, auditorias, incidentes, alterações, dados ou direitos de saída exigem direitos legais, de conformidade, segurança, privacidade e aprovação comercial documentados.

1.636 Provas

- Acordos e cronogramas executados;
- Lista de verificação da cláusula;
- matriz de papel e responsabilidade;
- desvios aprovados;
- termos de processamento de dados e de segurança;
- Alterações e notificações de incidentes;
- registros de auditoria e remediação;
- Plano de Saída e Transição.

1.637 Teste de auditoria

Selecionar contratos de IA material e verificar se as cláusulas correspondem ao serviço real, papéis do ator, classificação de risco e dependências operacionais; confirmar que os avisos necessários, entregas de evidências, auditorias e direitos de correção são exercidos na prática.

1.638 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: cooperação aplicável na cadeia de valor, documentação, informações, monitoramento, incidentes, ações corretivas e disposições de acesso a registros.
- Os termos do contrato não substituem as obrigações legais.

1.639 Capítulo 73 Revisão da documentação do fornecedor

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 73 linguagem de rascunho.

1.640 Exigência

As organizações devem revisar a documentação fornecida pelo provedor antes da implantação e após a mudança material para determinar se ela é completa, atual, internamente consistente, aplicável ao uso pretendido e suficiente para apoiar as obrigações legais e operacionais da organização.

1.641 Explicação em linguagem simples

Instruções de uso, resumos técnicos, registros de conformidade, cartões de modelo, relatórios de teste e materiais de segurança devem ser verificados contra a versão implantada, a configuração real e o caso de uso.

1.642 Critérios de revisão

Confirme conforme aplicável:

1. Identidade, papel, sistema ou versão do modelo, e finalidade pretendida;
2. aplicabilidade dos documentos ao produto exato e liberação;
3. Declarações de classificação de alto risco, transparência, GPAI e risco sistêmico;
4. instruções, limitações, métricas de desempenho, limiares e uso indevido previsível;
5. Supervisão humana, registro, monitoramento e procedimentos de incidentes;
6. dados, privacidade, segurança, robustez, viés e evidências de acessibilidade;
7. Avaliação da conformidade, declaração, registro e marcação de provas, sempre que necessário;
8. pressupostos materiais, exclusões, limitações não resolvidas e responsabilidades do cliente;
9. controle de documentos, aprovação, idioma, acessibilidade e status de atualização;
10. contradições entre reivindicações contratuais, técnicas, de garantia e de marketing.

1.643 Exemplo GlobalWay

A GlobalWay recebe um cartão modelo de fornecedor e um pacote de conformidade para um sistema de recrutamento. A revisão identifica que o

cartão modelo cobre uma versão anterior e omite a configuração de limiar usada pela GlobalWay. A implantação permanece bloqueada até que a documentação específica da versão seja fornecida.

1.644 Atividade de controle

O proprietário do sistema deve manter um índice de documentação do provedor e obter aprovação de Legal, Compliance, Segurança, Privacidade e revisores técnicos relevantes antes do uso da produção. A documentação ausente, obsoleta ou contraditória deve resultar em remediação, uso restrito, controles de compensação ou rejeição.

1.645 Provas

- Índice de documentação do fornecedor;
- Mapeamento de versão e configuração;
- checklist de revisão concluída;
- lacunas e contradições identificadas;
- esclarecimentos e substituições de fornecedores;
- Decisões e aprovações de risco;
- Histórico de atualização e reavaliação.

1.646 Teste de auditoria

Selecione uma amostra de sistemas de IA de terceiros e confirme que os documentos do provedor correspondem à liberação implantada e ao uso pretendido, que as lacunas foram resolvidas antes da aprovação e que as mudanças materiais desencadearam uma revisão renovada.

1.647 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: informações aplicáveis do fornecedor, instruções, documentação técnica, conformidade, transparência, GPAI e disposições relativas à cadeia de valor.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.648 Capítulo 74 Cartões Modelo, Cartões de Sistema e Limitações

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 74 linguagem de rascunho.

1.649 Exigência

As organizações devem usar cartões-modelo, cartões de sistema e documentação equivalente como evidência estruturada sobre o propósito pretendido, capacidades, limitações, avaliação, riscos e uso responsável.

Esses artefatos não devem ser tratados como substitutos para documentação técnica estatutária, instruções de uso, registros de conformidade ou evidência de gerenciamento de risco onde forem necessários.

1.650 Explicação em linguagem simples

Um cartão modelo descreve o modelo. Um cartão de sistema descreve o sistema implantado mais amplo, incluindo integrações, prompts, fluxos de dados, salvaguardas e processos humanos. Ambos são úteis apenas quando são precisos, específicos da versão e explícitos sobre limitações.

1.651 Conteúdo Necessário

Documento aplicável:

1. Identidade do modelo e do sistema, proprietário, fornecedor, versão e data de lançamento;
2. Usos pretendidos e excluídos;
3. treinamento, ajuste, avaliação e informações de dados relevantes;
4. idiomas, populações, ambientes e jurisdições suportados;
5. métricas de desempenho, limiares, incerteza e modos de falha conhecidos;
6. vieses, segurança, privacidade, segurança, robustez e riscos de uso indevido;
7. Supervisão humana, recuo, escalada e requisitos de monitoramento;
8. dependências, integrações e suposições a jusante;
9. Classificação legal e transparência aplicável ou obrigações de alto risco;
10. mudar a história e as limitações não resolvidas.

1.652 Exemplo GlobalWay

O cartão de sistema de assistência de viagem da GlobalWay documenta o modelo GPAI de terceiros, fontes de recuperação, idiomas, integrações de reservas, ações autônomas proibidas, regras de escalada humana, riscos de alucinações, métricas de monitoramento e a configuração exata da produção.

1.653 Atividade de controle

Os proprietários de produtos e modelos de risco devem aprovar cartões de modelo e sistema controlados por versão antes de liberá-los e atualizá-los após alterações materiais, incidentes significativos, novos resultados de avaliação ou uso pretendido alterado. As limitações devem ser refletidas em instruções, treinamento, interfaces de usuário e monitoramento.

1.654 Provas

- Cartões de modelo e sistema aprovados;
- Mapeamento da versão;
- Relatórios de avaliação;
- Registro de limitação e risco;
- Instruções do usuário e treinamento;
- história de mudança;
- monitoramento e registros de incidentes.

1.655 Teste de auditoria

Selecione um sistema de IA implantado e verifique se seus cartões correspondem à versão e arquitetura reais, descreva limitações e dependências de materiais e sejam consistentes com a documentação técnica, instruções, controles e desempenho de produção observado.

1.656 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: documentação técnica aplicável, transparência, instruções, informações GPAI, gestão de riscos e disposições pós-comercialização.
- Os cartões de modelo e de sistema são artefatos de suporte, a menos que a lei ou contrato vinculante lhes dê uma função legal específica.

1.657 Capítulo 75 Direitos de Auditoria e Notificação de Incidentes

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 75 linguagem de rascunho.

1.658 Exigência

Os acordos de fornecedores de material de IA devem fornecer auditoria, garantia, acesso à informação, notificação de incidentes, suporte à investigação e direitos de correção suficientes para permitir que cada parte cumpra suas responsabilidades legais e operacionais. Os direitos devem ser proporcionais ao risco e viáveis na prática.

1.659 Explicação em linguagem simples

Uma cláusula de auditoria que não pode produzir evidências não é um controle eficaz. O cliente precisa de acesso oportuno a registros relevantes e cooperação quando um evento significativo ocorre, enquanto protege a confidencialidade legítima, segurança e interesses de propriedade intelectual.

1.660 Requisitos de controle

Os contratos e procedimentos devem definir:

1. escopo de auditoria, frequência, aviso, eventos desencadeantes e revisores qualificados;
2. Acesso a políticas, evidências técnicas, resultados de testes, registros, certificações e registros de correção;
3. Condições de confiança para relatórios de garantia independentes;
4. aviso rápido de incidentes graves, eventos de segurança, investigações regulatórias, não conformidade material e degradação significativa do serviço;
5. conteúdo necessário, timestamps, atualizações, análise de causa raiz e relatórios de ação corretiva;
6. Preservação de evidências e cooperação com autoridades, pessoas afetadas e outros atores da cadeia de valor;
7. direitos de emergência para restringir, suspender, desativar ou isolar o serviço;
8. Prazos de remediação, validação, escalonamento e direitos de rescisão;
9. confidencialidade, privilégio, revisão segura e salvaguardas de minimização de dados;
10. flow-down e prestação de contas do subcontratado.

1.661 Exemplo GlobalWay

Depois que um fornecedor relata resultados anômalos de recrutamento, a GlobalWay invoca seus direitos de informações sobre incidentes, obtém registros de versão e configuração, preserva registros relevantes, valida a população afetada, confirma se é necessário relatórios regulatórios e rastreia ações corretivas antes da restauração do serviço.

1.662 Atividade de controle

A gerência do fornecedor deve manter uma auditoria baseada em risco e um cronograma de notificação de incidentes. Fornecedores de alto risco exigem rotas de notificação testadas, contatos atuais, procedimentos de acesso a evidências e autoridade de escalada. Os direitos contratuais devem ser exercidos periodicamente em vez de não testados.

1.663 Provas

- Cláusulas de auditoria e notificação executadas;
- relatórios de garantia do fornecedor;
- Planos e relatórios de auditoria;
- Avisos de incidentes e timestamps;
- Evidências preservadas e registros de investigação;

- planos de remediação e validação;
- decisões de escalada, suspensão e encerramento;
- Evidência de garantia de subcontratação.

1.664 Teste de auditoria

Confirme que os direitos contratuais cobrem as evidências e eventos relevantes, os prazos de notificação foram cumpridos, as investigações receberam cooperação adequada, a correção foi validada e as limitações de acesso não resolvidas foram escaladas.

1.665 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: documentação aplicável, manutenção de registos, monitorização, incidentes graves, acções correctivas, acesso à autoridade e disposições de cooperação para a cadeia de valor.
- Privacidade aplicável, segurança cibernética, segurança do produto e lei de notificação do setor.

1.666 Capítulo 76 - Risco de Dependência de Nuvem, API e Modelo

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 76 linguagem de rascunho.

1.667 Exigência

As organizações devem identificar e gerenciar dependências de nuvem material, API, modelo, dados, componentes de software e subprocessadores que afetam seus sistemas de IA. A Lei de IA da UE não cria um programa autónomo de risco de dependência para todos os operadores, mas o provedor, implantador, importador, distribuidor, fabricante de produtos, gerenciamento de qualidade, gerenciamento de riscos, segurança cibernética, monitoramento, incidente, documentação e deveres de cooperação aplicáveis exigem visibilidade e controle suficientes sobre as dependências relevantes.

1.668 Explicação em linguagem simples

Um serviço de IA pode depender de vários componentes externos, mesmo quando aparece para os usuários como um único sistema. Uma mudança de provedor, interrupção, substituição de modelo, depreciação de API, mudança de roteamento regional, subprocessador indocumentado ou perda de logs pode alterar a classificação legal, segurança, precisão, acessibilidade, privacidade, segurança, supervisão humana ou continuidade. Contratar um componente não remove as próprias obrigações legais da organização.

1.669 Requisitos de dependência-governança

Para cada dependência material, documento e avaliação:

1. componente, fornecedor, subprocessador, finalidade, proprietário e criticidade;
2. modelo, API, software, dados e versões de configuração;
3. locais de processamento e suporte, fluxos de dados, retenção e acordos de transferência;
4. disponibilidade, níveis de serviço, capacidade de recuperação, cotas e limites de taxa;
5. processos de notificação de mudança, liberação, depreciação e mudança de emergência;
6. segurança, acesso privilegiado, segredos, separação de inquilinos e gestão de vulnerabilidades;
7. registro, monitoramento, acesso a evidências e capacidade de notificação de incidentes;
8. concentração, lock-in, substituição e risco de ponto único de falha;
9. Reajuste testado, modo de segurança, apenas para humanos ou acordos de suspensão controlada;
10. gatilhos para reavaliação, revalidação, revisão de transparência ou análise de modificação substancial.

1.670 Exemplo GlobalWay

O serviço de assistência ao viajante da GlobalWay depende de um modelo hospedado, plataforma em nuvem, API de tradução, provedor de identidade, banco de dados de recuperação e serviço de monitoramento. Depois de uma atualização não anunciada do modelo reduz a precisão multilíngue e omite restrições de acessibilidade, a GlobalWay restringe as funções afetadas, encaminha casos para consultores treinados, preserva a versão e as evidências de saída, exige a investigação do provedor e revalida o serviço antes da restauração.

1.671 Atividade de controle

Dependências materiais devem ser registradas na documentação de inventário e arquitetura de IA. Dependências altas ou críticas devem ser monitoradas para mudança e interrupção, testadas antes das mudanças na produção material e apoiadas por arranjos de continuidade e escalada aprovados. Dependências críticas desconhecidas ou evidências obrigatórias indisponíveis são bloqueadores de liberação ou operação contínua.

1.672 Provas

- inventário de dependência e arquitetura;
- registros de provedores e subprocessadores;

- Histórico de versão e configuração;
- Contratos, níveis de serviço e avisos de alteração;
- avaliações de localização e transferência de dados;
- revisões de segurança e acesso;
- Resultados de teste, regressão e revalidação;
- monitoramento, interrupção e registros de incidentes;
- Exercícios de fallback e continuidade;
- aceitação de riscos e decisões de responsabilidade do proprietário.

1.673 Teste de auditoria

Confirme se as dependências materiais são completas e atuais; versões, regiões, subprocessadores e proprietários são conhecidos; mudanças materiais desencadearam revisão e testes apropriados; arranjos de continuidade foram exercidos; evidências permaneceram acessíveis; e riscos de dependência não resolvidos foram escalados para tomadores de decisão autorizados.

1.674 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: artigos 9.º-17.º, 20.º-26.º, 72.º-74.º, 78.º-82.º e anexos conexos, consoante o papel e a classificação do sistema.
- Regulamento (UE) 2016/679 e outros requisitos aplicáveis em matéria de privacidade, cibersegurança, segurança dos produtos, proteção do consumidor e requisitos do setor.
- As práticas de gestão de dependências neste capítulo são métodos de governança e garantia usados para apoiar os deveres legais aplicáveis; eles não são um catálogo de controle estatutário autônomo.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.675 Capítulo 77 Governança de Código Aberto e Componente

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 77 anterior.

1.676 Exigência

As organizações devem avaliar modelos, sistemas, software, conjuntos de dados e componentes de IA de código aberto contra as condições específicas do Regulamento (UE) 2024/1689, conforme alterado, em vez de tratar o status de código aberto como uma exclusão geral. A avaliação deve considerar o papel do ator, comercialização, integração a jusante, uso de alto risco, tratamento GPAI, segurança cibernética, modificação substancial, licenciamento, proveniência e suporte.

1.677 Explicação em linguagem simples

Uma vez que um componente aberto é integrado em um produto, modificado, colocado no mercado, usado sob o nome de uma organização, ou implantado em um contexto regulamentado, diferentes deveres podem surgir.

1.678 Requisitos de governação

Manter os controles para:

1. Componente e proveniência do modelo;
2. termos de licença, restrições, atribuição e compatibilidade;
3. identidade do mantenedor, histórico de liberação e status de suporte;
4. vulnerabilidades, incidentes e avisos de segurança conhecidos;
5. dados de treinamento, conjunto de dados e disponibilidade de documentação;
6. propósito pretendido, limitações e usos proibidos ou não suportados;
7. Consequências de modificação e integração a jusante;
8. Avaliação do papel do fornecedor e avaliação substancial da modificação;
9. de alto risco, transparência e classificação GPAI;
10. Fixação, teste, monitoramento, substituição e saída da versão.

1.679 Exemplo GlobalWay

O GlobalWay integra um modelo de linguagem de código aberto em um fluxo de trabalho interno de suporte a viagens. Antes do uso da produção, ele registra a versão e a licença do modelo, revisa a proveniência e as limitações, testa a segurança e o desempenho, avalia se a implantação de ajuste fino ou de marca própria altera seu papel legal e documenta um caminho de saída se o projeto não for suportado.

1.680 Atividade de controle

Nenhum componente de IA de código aberto pode entrar em produção sem registro de inventário, revisão legal e de segurança, aprovação de licença, testes específicos de versão, análise de papel e classificação e um proprietário de manutenção responsável. Forquilhas de material, ajuste fino, retreinamento ou reaproveitamento devem desencadear a reavaliação.

1.681 Provas

- software e modelo de lista de materiais;
- registro de licença e atribuição;
- Procedência e revisão do mantenedor;
- Avaliação de vulnerabilidade e segurança;

- registro de finalidade pretendida e limitação;
- avaliação do papel e da classificação;
- Testes e provas de aprovação;
- Plano de monitoramento e substituição.

1.682 **Teste de auditoria**

Confirme que as versões exatas são inventariadas, que a licença e a proveniência foram revisadas, que o papel legal e a classificação foram avaliados, que vulnerabilidades e limitações são monitoradas e que modificações materiais desencadearam a reavaliação.

1.683 **Referências jurídicas primárias**

- Regulamento (UE) 2024/1689, conforme alterado: escopo aplicável, código aberto, GPAI, função de provedor, modificação substancial, segurança cibernética e provisões de alto risco.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.684 **Capítulo 78 Monitoramento contínuo do fornecedor**

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 78 linguagem de rascunho.

1.685 **Exigência**

As organizações devem monitorar fornecedores materiais de IA durante todo o relacionamento para confirmar que o papel legal, a classificação do sistema ou modelo, a documentação, o status de conformidade, o desempenho, a segurança, os incidentes, as alterações e a capacidade de serviço permanecem aceitáveis. O monitoramento deve ser proporcional ao risco e vinculado à reavaliação, à ação corretiva, à suspensão e à saída.

1.686 **Explicação em linguagem simples**

Um fornecedor que passou a due diligence no ano passado pode não mais apresentar o mesmo risco. Mudança de modelos, provedores reorganizam, subprocessadores são adicionados, a orientação evolui, os incidentes ocorrem e a qualidade do suporte pode diminuir. O monitoramento contínuo é, portanto, um controle do ciclo de vida, em vez de uma tarefa de aquisição única.

1.687 **Áreas de monitorização**

Monitor no mínimo:

1. A pessoa jurídica, a propriedade, a jurisdição e as alterações no papel do AI Act;
2. alterações de classificação de alto risco, transparência, GPAI e risco sistêmico;
3. modelo, sistema, dados, propósito pretendido e mudanças de serviço;
4. status de conformidade, registro, certificação e garantia;
5. Documentação técnica, instruções, limitações e notas de lançamento;
6. indicadores de desempenho, viés, robustez, segurança cibernética, disponibilidade e suporte;
7. incidentes, reclamações, vulnerabilidades, ações regulatórias e medidas corretivas;
8. mudanças de subcontratado, hospedagem, região, concentração e continuidade;
9. conformidade do contrato, resultados de auditoria, remediação e exceções não resolvidas;
10. Risco de fim de suporte, deterioração financeira, aquisição ou interrupção do serviço.

1.688 Exemplo GlobalWay

A GlobalWay revisa seu fornecedor de plataforma de recrutamento trimestralmente e após qualquer evento material. A revisão inclui avisos de lançamento de modelo, desempenho de subgrupo, incidentes, avisos de segurança, alterações de documentação, subcontratados, níveis de serviço e desenvolvimentos regulatórios. As violações de limite desencadeiam revisão ou suspensão aprimoradas.

1.689 Atividade de controle

A gerência do fornecedor deve atribuir um nível de monitoramento e cadência de revisão a cada fornecedor de AI material. Os resultados do monitoramento devem ser documentados, avaliados pelo risco, aprovados e vinculados à gestão de questões. Mudanças ou eventos críticos devem desencadear reavaliação imediata sem esperar pela próxima revisão agendada.

1.690 Provas

- plano e nível de monitoramento do fornecedor;
- Registros periódicos de revisão;
- Alterações e notificações de incidentes;
- métricas de serviço, desempenho e segurança;
- Garantia e atualizações regulatórias;
- reavaliação de riscos e emissão de registros;
- decisões de remediação, suspensão ou saída;
- revisão e aprovação da gestão.

1.691 Teste de auditoria

Selecione fornecedores de IA material e confirme que o monitoramento ocorreu na cadência definida, cobriu mudanças legais e operacionais, identificou violações de limiar, desencadeou reavaliação oportuna e produziu ação documentada através do fechamento.

1.692 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: disposições aplicáveis relativas ao prestador, ao deployer, à cadeia de valor, à monitorização, ao incidente, à acção correctiva, à documentação e às alterações.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.693 Capítulo 79 Saída, portabilidade e planeamento de continuidade

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 79 linguagem de rascunho.

1.694 Exigência

As organizações devem planejar a suspensão, substituição, migração ou término seguro de serviços materiais de IA sem perder evidências necessárias, interromper processos regulamentados, expor as pessoas afetadas a riscos não gerenciados ou impedir a conformidade contínua. O planeamento de saída deve abordar portabilidade, continuidade, retenção, exclusão, validação e responsabilidade.

1.695 Explicação em linguagem simples

Uma relação de fornecedor pode terminar por causa de falha de desempenho, ação regulatória, eventos de segurança, disputas comerciais, aquisição, insolvência ou mudança estratégica. A organização deve ser capaz de parar ou substituir o serviço de forma controlada, em vez de se tornar dependente de um sistema inseguro ou não suportado.

1.696 Requisitos de saída

O plano de saída deve abordar:

1. Autoridade de suspensão e paragem de emergência;
2. serviço, modelo, configuração, dados, prompt e inventário de fluxo de trabalho;
3. exportação de registros necessários, decisões, documentação e evidências de auditoria;

4. retenção necessária para conformidade, incidentes, reclamações, investigações e obrigações legais;
5. retorno, transferência e exclusão verificada de dados;
6. mapeamento de migração, testes, validação e reversão;
7. continuidade da supervisão humana e das salvaguardas das pessoas afetadas;
8. Reavaliação do fornecedor de substituição, papel, classificação e finalidade pretendida;
9. comunicações de usuário, autoridade, cliente e pessoa afetada, quando necessário;
10. Dependência residual, licença, propriedade intelectual e questões de subcontratantes;
11. revogação final do acesso e encerramento da segurança;
12. acompanhamento pós-saída e lições aprendidas.

1.697 Exemplo GlobalWay

A GlobalWay decide substituir um fornecedor de triagem de recrutamento após disparidades de desempenho não resolvidas. Suspende a classificação automatizada, encaminha decisões para revisores humanos treinados, exporta registros e documentação necessários, valida o sistema de substituição contra critérios aprovados, preserva evidências de investigação e verifica a exclusão de dados que não são mais necessários.

1.698 Atividade de controle

Cada fornecedor de IA material deve ter um plano de saída documentado e periodicamente testado antes da aprovação da produção. Os serviços de alto risco exigem soluções de emergência definidas, testes de exportação de evidências, critérios de validação de substituição e autoridade executiva para suspender ou encerrar o uso.

1.699 Provas

- Plano de saída e continuidade aprovado;
- mapa de inventário e dependência;
- registro de exportação e retenção de evidências;
- certificação de devolução e eliminação de dados;
- Resultados de migração e validação;
- Comunicações e aprovações;
- Evidência de acesso-revogação;
- Revisão pós-saída e decisão de risco residual.

1.700 Teste de auditoria

Confirme que os registros necessários foram preservados, o manuseio de dados foi verificado, os controles de substituição foram validados antes do uso da produção, os processos afetados permaneceram protegidos e o acesso e as dependências foram fechados adequadamente.

1.701 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: documentação aplicável, manutenção de registros, monitoramento, incidente, ação corretiva, implantador, provedor, cadeia de valor e disposições de acesso à autoridade.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor e requisitos de retenção do setor.

1.702 Capítulo 80 Integração do GDPR

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 80 linguagem de rascunho.

1.703 Exigência

As organizações que processam dados pessoais através de sistemas de IA devem cumprir a Lei de IA da UE e a lei de proteção de dados aplicável em paralelo. O cumprimento de um regime não estabelece conformidade com o outro. A organização deve identificar o controlador, processador, controlador conjunto, provedor, implantador, importador, distribuidor ou outro papel relevante e mapear cada obrigação para o mesmo sistema, modelo, finalidade de processamento, fluxo de dados e versão de produção.

1.704 Explicação em linguagem simples

A Lei de IA da UE rege os riscos do sistema de IA e do modelo, papéis, acesso ao mercado, práticas proibidas, requisitos de alto risco, transparência e supervisão. O GDPR rege o processamento legal de dados pessoais, direitos dos sujeitos de dados, responsabilidade, segurança, transferências internacionais e tomada de decisão automatizada. Uma implantação única de IA pode desencadear regimes e leis nacionais ou setoriais adicionais.

1.705 Avaliação integrada

Documento no mínimo:

1. O papel da AI Act e o papel do RGPD de cada entidade jurídica;
2. a finalidade pretendida e cada finalidade de tratamento de dados pessoais;
3. Base legal e, se aplicável, condições do artigo 9.o ou do artigo 10.o;

4. fontes de dados, categorias, destinatários, locais, retenção e transferências;
5. Direitos de transparência em ambos os regimes;
6. direitos dos titulares de dados e vias de reclamação ou explicação da pessoa afetada;
7. DPIA, avaliação de impacto dos direitos fundamentais, conformidade e dependências de gestão de risco;
8. análise automatizada de tomada de decisão nos termos do artigo 22.o do RGPD;
9. segurança, registro, monitoramento, violação e coordenação de incidentes graves;
10. gatilhos de mudança que requerem reavaliação.

1.706 Exemplo GlobalWay

A GlobalWay implanta um sistema de recrutamento de IA em vários Estados-Membros da UE. Ele documenta separadamente suas obrigações de implantação sob a Lei AI, suas responsabilidades de controlador sob o GDPR, as funções de provedor e processador do fornecedor, a base legal para o processamento de dados do candidato, salvaguardas do Artigo 22, limites de retenção, revisão humana e a relação entre o DPIA e a avaliação de impacto dos direitos fundamentais da AI Act.

1.707 Atividade de controle

Legal, Privacidade e Governança de IA devem aprovar conjuntamente um mapa regulatório integrado antes do uso da produção. O mapa deve vincular cada requisito a um proprietário responsável, controle, fonte de evidências e gatilho de revisão. Conflitos ou incerteza devem ser escalados para aconselhamento qualificado em vez de resolvidos assumindo que uma lei substitui a outra.

1.708 Provas

- mapa de papel e obrigação integrado;
- registros de atividades de processamento;
- Análise de base legal e de categoria especial;
- Avaliação de impacto DPIA e direitos fundamentais;
- Avisos de privacidade e avisos de transparência de IA;
- Procedimento relativo aos direitos dos titulares de dados;
- Contratos e termos de processamento de dados;
- segurança, incidentes e procedimentos de violação;
- revisão e mudar a história.

1.709 Teste de auditoria

Verifique se as funções do AI Act e GDPR foram identificadas separadamente, bases legais e tratamento do Artigo 22 foram documentados, avisos e processos de direitos são consistentes e mudanças na finalidade, dados, modelo, fornecedor ou jurisdição desencadearam reavaliação.

1.710 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, conforme alterado, incluindo os artigos 2.º, 10.º, 13.º, 26.º, 27.º e 50.º, conforme aplicável.
- Regulamento (UE) 2016/679, incluindo os artigos 5.º, 6.º, 9.º, 12.º a 22.º, 25.º, 30.º, 32.º a 36.º e 44.º a 49.º, conforme aplicável.
- Textos EUR-Lex consolidados atuais controlam resumos e rascunhos anteriores.

1.711 Capítulo 81 Privacidade por Design e Minimização de Dados

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 81 linguagem de rascunho.

1.712 Exigência

Os sistemas de IA que processam dados pessoais devem incorporar princípios de privacidade e proteção de dados em design, desenvolvimento, configuração, implantação, monitoramento e aposentadoria. Os dados pessoais devem ser adequados, relevantes e limitados ao que é necessário para o propósito documentado, enquanto os requisitos de governança, precisão, gerenciamento de riscos e evidências do AI Act são atendidos.

1.713 Explicação em linguagem simples

Mais dados não são automaticamente melhores ou legais. As equipes devem justificar por que cada elemento de dados, recurso, campo alerta, log, anotação e período de retenção é necessário. O design de aprimoramento de privacidade deve ser considerado antes da coleta e antes das alterações do modelo ou do fluxo de trabalho, não adicionado apenas após a implantação.

1.714 Controles de design

A organização deve implementar:

1. Testes de propósito e necessidade documentados para cada elemento de dados pessoais;
2. recurso e revisão proxy-variável;
3. Limites de recolha e retenção;

4. acesso baseado em funções e menos privilégio;
5. pseudonimização, agregação, mascaramento ou dados sintéticos, quando apropriado;
6. separação de dados de treinamento, validação, teste e produção;
7. preservação da privacidade de logs e monitoramento;
8. controles contra memorização, divulgação ou reidentificação não intencionais;
9. fluxos de trabalho de eliminação, correção, restrição e portabilidade, quando aplicável;
10. reavaliação após novas fontes de dados, recursos, atualizações de modelo, integrações ou propósitos.

1.715 Exemplo GlobalWay

O sistema de assistência de viagem da GlobalWay não retém números de passaporte, dados de cartão de pagamento ou informações de saúde em prompts apenas porque esses campos existem em sistemas upstream. A revisão do projeto confirma quais atributos são necessários, mascara valores sensíveis, limita o conteúdo do log e define períodos de retenção alinhados com as necessidades legais e operacionais.

1.716 Atividade de controle

A Engenharia de Privacidade e a Governança de IA devem aprovar uma revisão de privacidade por design antes do lançamento da produção e após mudanças materiais. A revisão deve documentar a necessidade, a proporcionalidade, as decisões de minimização, as salvaguardas técnicas, os riscos residuais e as trocas não resolvidas.

1.717 Provas

- inventário de dados e mapa de fluxo;
- avaliação de propósito e necessidade;
- Racionalidade de seleção de características;
- cronograma de retenção;
- projeto do acesso-controle;
- pseudonimização ou ocultação de provas;
- resultados dos testes de privacidade;
- Procedimentos de eliminação e tratamento de direitos;
- aprovações de design-revisão e histórico de mudanças.

1.718 Teste de auditoria

Confirme que a necessidade foi documentada, dados excessivos ou obsoletos foram removidos, as salvaguardas funcionam como projetadas e as mudanças materiais desencadearam uma revisão renovada.

1.719 Referências jurídicas primárias

- Regulamento (UE) 2016/679: artigos 5.o, n.o 1, alíneas c), 25.o e 32.o, com outras disposições aplicáveis.
- Regulamento (UE) n.o 2024/1689, alterado: artigos 9.o, 10.o, 12.o, 15.o, 26.o e anexo IV, conforme aplicável.
- Textos EUR-Lex consolidados atuais controlam resumos e rascunhos anteriores.

1.720 Capítulo 82 Categoria Especial e Dados Pessoais Sensíveis

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 82 linguagem de rascunho.

1.721 Exigência

As organizações devem identificar e controlar o processamento de categorias especiais de dados pessoais, dados biométricos, dados de infração criminal e outras informações confidenciais usadas ou expostas a sistemas de IA. O processamento requer uma base legal válida sob o GDPR, uma condição aplicável do Artigo 9 ou Artigo 10, quando relevante, salvaguardas apropriadas e conformidade com as restrições e condições da Lei de IA.

1.722 Explicação em linguagem simples

Os dados sensíveis podem criar riscos aumentados de discriminação, privacidade, segurança e direitos fundamentais. A Lei de IA da UE não cria uma permissão geral para usar esses dados. Suas disposições limitadas para detecção e correção de viés em sistemas de IA de alto risco devem ser interpretadas de forma restrita e operadas com as salvaguardas exigidas pela Lei de IA e pela lei de proteção de dados.

1.723 Requisitos de controlo

A avaliação deve abordar:

1. categorias exatas de dados e se os atributos inferidos estão envolvidos;
2. Base legal e artigo 9.o ou artigo 10.o;
3. necessidade e proporcionalidade;
4. se o AI Act permite, restringe ou proíbe a prática relevante;
5. limitação de acesso, segregação, criptografia, pseudonimização e exclusão;
6. Propósito, escopo, duração e salvaguardas de detecção de vieses em que o artigo 10.o, n.o 5, da Lei de IA é invocado;

7. Categorização biométrica, reconhecimento de emoções, identificação biométrica remota ou outros gatilhos proibidos / de alto risco;
8. transparência e direitos das pessoas afetadas;
9. Transferências transfronteiriças e acesso de fornecedores;
10. Auditoria e reavaliação após a mudança.

1.724 Exemplo GlobalWay

A GlobalWay avalia se os dados de assistência de viagem relacionados à saúde e as informações de incapacidade inferida são necessários para um serviço proposto. Impede o uso para a classificação dos funcionários, restringe o acesso, documenta a condição do GDPR, separa a assistência operacional da análise e rejeita qualquer tentativa de reutilizar os dados para um propósito incompatível.

1.725 Atividade de controlo

Nenhum uso de IA envolvendo dados de categoria especial, biométricos ou de infração criminal pode prosseguir sem aprovação legal e de privacidade por escrito. A decisão deve identificar a condição estatutária exata, salvaguardas, período de retenção, modelo de acesso, usos secundários proibidos e gatilhos de revisão.

1.726 Provas

- inventário de dados sensíveis;
- A base jurídica e a análise do artigo 9.o/10;
- Avaliação da necessidade e da proporcionalidade;
- Classificação AI Act e revisão de práticas proibidas;
- acesso, criptografia e evidências de segregação;
- Registros de retenção e exclusão;
- Avisos e procedimentos de direitos;
- avaliações de fornecedor e transferência;
- aprovações e reavaliação do histórico.

1.727 Teste de auditoria

Confirme se a categoria de dados, condição legal, tratamento do AI Act, salvaguardas, acesso, retenção e restrições de uso secundário estão documentadas e operando de forma eficaz.

1.728 Referências jurídicas primárias

- Regulamento (UE) 2016/679: artigos 5.o, 6.o, 9.o, 10.o, 25.o, 32.o e 35.o
- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: artigos 5.o, 9.o, 10.o, 26.o e disposições biométricas e de transparência pertinentes.

- Textos EUR-Lex consolidados atuais controlam resumos e rascunhos anteriores.

1.729 Capítulo 83 Tomada de Decisão Automatizada

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 83 linguagem de rascunho.

1.730 Exigência

As organizações devem avaliar se uma decisão apoiada por IA ou gerada por IA é baseada exclusivamente no processamento automatizado e produz efeitos legais ou efeitos igualmente significativos em uma pessoa natural. Quando o Artigo 22 do GDPR se aplica, a organização deve identificar uma exceção válida, implementar salvaguardas adequadas e garantir que o processo de decisão real corresponda ao modelo documentado de revisão humana.

1.731 Explicação em linguagem simples

Chamar um processo de “human-in-the-loop” não o remove do Artigo 22 se o revisor humano rotineiramente aceita a saída do sistema sem autoridade significativa, informações, tempo ou competência para alterar o resultado. A avaliação deve examinar a realidade operacional, não os rótulos.

1.732 Critérios de avaliação

Documento no mínimo:

1. a decisão, as pessoas afetadas e as consequências;
2. se o processamento é apenas automatizado na prática;
3. O papel e a substância de qualquer intervenção humana;
4. se o efeito é legal ou similarmente significativo;
5. A exceção prevista no artigo 22.o, n.o 2, se for caso disso;
6. restrições que envolvam dados de categoria especial;
7. informações sobre a lógica, o significado e as consequências previstas;
8. direitos à intervenção humana, expressar uma opinião e contestar a decisão;
9. testes para precisão, discriminação, consistência e sobrepor a eficácia;
10. Interação com AI Act de alto risco, transparência, supervisão humana e obrigações de direitos fundamentais.

1.733 Exemplo GlobalWay

A GlobalWay usa um sistema de IA para classificar os candidatos a emprego. Os recrutadores devem revisar evidências relevantes de inscrição, entender as limitações do sistema, registrar razões para decisões e ter autoridade para se afastar do ranking. A GlobalWay testa se os revisores exercem julgamento genuíno em vez de recomendações de carimbo de borracha.

1.734 Atividade de controle

Quando o Artigo 22 se aplica, a liberação deve ser bloqueada, a menos que a exceção legal e as salvaguardas sejam documentadas, os avisos estejam completos, os canais de contestação e revisão humana estejam operacionais e o monitoramento demonstre envolvimento humano significativo onde reivindicado.

1.735 Provas

- Avaliação de decisão automatizada;
- Artigo 22.o Análise jurídica;
- Mapa do fluxo de trabalho e dos direitos de decisão;
- Instruções do revisor e provas de competência;
- avisos e materiais de explicação;
- concurso, apelo e registros de intervenção humana;
- sobreposição e monitorização dos resultados;
- testes de viés, precisão e consistência;
- aprovações e reavaliação do histórico.

1.736 Teste de auditoria

Confirme que o processo documentado corresponde à prática real, a intervenção humana é significativa onde se baseia, os direitos da pessoa afetada são operacionais e decisões de alto risco ou significativas recebem supervisão e testes apropriados.

1.737 Referências jurídicas primárias

- Regulamento (UE) 2016/679: artigos 13.o-15.o e 22.o, com o considerando 71.o e a jurisprudência aplicável.
- Regulamento (UE) n.o 2024/1689, alterado: artigos 13.o, 14.o, 26.o, 27.o e disposições pertinentes do anexo III.
- Textos EUR-Lex consolidados atuais e interpretações autorizadas do Tribunal de Justiça controlam resumos.

1.738 Capítulo 84 Ciclo de vida seguro para o desenvolvimento da IA

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 84 da linguagem de rascunho.

1.739 Exigência

Os fornecedores e organizações que desenvolvem, integram, configuram ou modificam materialmente os sistemas de IA devem incorporar segurança, segurança, privacidade, robustez, governança de dados, supervisão humana, documentação e controle de mudanças durante todo o ciclo de vida. Os controles devem ser proporcionais ao propósito pretendido do sistema, classificação de risco, uso indevido previsível, dependências da cadeia de valor e ambiente de produção.

1.740 Explicação em linguagem simples

A revisão de segurança não pode ser adiada até o final do desenvolvimento. Ameaças específicas de IA podem entrar através de dados, modelos, prompts, ferramentas, APIs, integrações, logs, pipelines de implantação e uso a jusante. O ciclo de vida deve produzir evidências de que os controles foram projetados, testados, aprovados, monitorados e atualizados para a versão de produção real.

1.741 Controles de ciclo de vida

O ciclo de vida seguro deve incluir:

1. Ingestão, finalidade pretendida, papel e classificação de risco;
2. Requisitos de segurança e caso de abuso;
3. arquitetura, fluxo de dados e revisão de confiança;
4. Procedência de dados, integridade, qualidade e controles de acesso;
5. Codificação segura, dependência, modelo e controles de infraestrutura;
6. Prompt, recuperação, agente, ferramenta e salvaguardas API;
7. privacidade, viés, segurança, robustez e testes de supervisão humana;
8. testes contraditórios e gestão de vulnerabilidades;
9. critérios de liberação, segregação de deveres, aprovações e reversão;
10. registro, monitoramento, resposta a incidentes e feedback pós-mercado;
11. Documentação vinculada à versão e retenção de evidências;
12. aposentadoria, exclusão de dados, eliminação de modelo e planejamento de continuidade.

1.742 Exemplo GlobalWay

A GlobalWay desenvolve um assistente de política de viagens de IA que pode consultar sistemas de reservas e elaborar recomendações de viajantes. O ciclo de vida seguro limita as permissões da ferramenta, valida as fontes de recuperação, testa a injeção imediata e o vazamento de dados, requer aprovação humana para ações consequentes, registra as versões de produção e bloqueia a liberação até que os portões de segurança e conformidade estejam completos.

1.743 Atividade de controle

A engenharia deve operar um ciclo de vida de IA seguro documentado com portões obrigatórios apropriados ao risco. Sistemas de alto risco ou materiais exigem aprovação independente de segurança, privacidade, legal e governança de IA. As exceções devem identificar o proprietário, a lógica, os controles compensadores, a data de validade e o risco residual.

1.744 Provas

- padrão de ciclo de vida e portas de controle;
- modelo de ameaça e casos de abuso;
- Revisões de arquitetura e fluxo de dados;
- Registros de desenvolvimento seguro e dependência;
- Planos de teste e resultados;
- Registros de vulnerabilidade e remediação;
- aprovações e registros de exceções;
- Documentação técnica ligada à versão;
- Evidências de monitoramento e revisão pós-liberação;
- Registros de aposentadoria e descarte.

1.745 Teste de auditoria

Selecione uma amostra de lançamentos de IA de produção. Trace cada lançamento através de entrada, design, desenvolvimento, teste, aprovação, implantação e monitoramento. Confirme que os portões necessários foram concluídos, as exceções foram autorizadas e vinculadas ao tempo e as evidências correspondem à versão implantada.

1.746 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: artigos 9.º-15.º, 17.º, 20.º, 24.º-26.º, 55.º, 72.º-73.º e anexo IV, conforme aplicável.
- Regulamento (UE) 2016/679: artigos 25.º, 32.º, 35.º e disposições de responsabilidade conexas em que os dados pessoais são tratados.
- Textos EUR-Lex consolidados atuais controlam resumos e rascunhos anteriores.

1.747 Capítulo 85 Modelagem de Ameaças

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 85 da linguagem de rascunho.

1.748 Exigência

As organizações devem realizar modelagem proporcional de ameaças para sistemas de IA e componentes de IA de uso geral, onde a segurança, segurança, resiliência, privacidade, direitos fundamentais ou riscos operacionais podem ser afetados materialmente por uso indevido malicioso ou acidental.

1.749 Explicação em linguagem simples

A modelagem de ameaças de IA identifica como atacantes, insiders, usuários, dependências, pipelines de dados, prompts, modelos, ferramentas e interfaces podem causar resultados prejudiciais. Deve cobrir todo o ciclo de vida e ser atualizado quando o sistema, modelo, finalidade pretendida, dados, ambiente de implantação ou alterações no cenário de ameaças.

1.750 m escopo de modelagem de ameaças

Avaliar no mínimo:

1. ativos, limites de confiança, atores e superfícies de ataque;
2. pipelines de treinamento, ajuste fino, recuperação, prompt e inferência;
3. Intoxicação de dados, injeção imediata, manipulação de modelo, extração e roubo;
4. uso de ferramentas não autorizadas, escalada de privilégios e abuso de agentes;
5. dependências de cadeia de suprimentos, API, plug-in, código aberto e nuvem;
6. vazamento de privacidade, memorização, exposição a informações confidenciais e inversão de modelo;
7. bypass de segurança, geração de conteúdo nocivo, evasão e uso indevido;
8. registro, monitoramento, detecção, contenção, reversão e recuperação;
9. Consequências pessoais, operacionais e regulatórias afetadas;
10. Risco residual, suposições e controles necessários.

1.751 Exemplo GlobalWay

Antes de liberar um agente de assistência de viagem de IA que pode acessar sistemas de reserva, a GlobalWay mapeia as permissões de ferramenta do

agente, canais de alerta, APIs externas, entradas de usuários, armazenamento de dados e caminhos de escalada. A revisão identifica injeção imediata, alterações não autorizadas de itinerário, vazamento de dados e substituição de modelo de fornecedor como cenários prioritários.

1.752 Atividade de controle

Os proprietários de sistemas e segurança devem completar um modelo de ameaça vinculado à versão antes do lançamento da produção e após a mudança material. As descobertas de alto risco devem ser atribuídas controles, proprietários, prazos, testes de validação e critérios de bloqueio de liberação.

1.753 Provas

- Modelo de ameaça aprovado;
- Arquitetura e diagramas de fluxo de dados;
- inventário de ativos e de confiança;
- Casos de abuso e árvores de ataque;
- decisões de mapeamento de controle e risco residual;
- validação e resultados da equipe vermelha;
- Registros de reavaliação desencadeados por mudanças.

1.754 Teste de auditoria

Selecione uma amostra de sistemas de IA material e verifique se os modelos de ameaça refletem a arquitetura implantada, as dependências atuais, cenários de uso indevido realistas, mitigações atribuídas, eficácia de controle testada e aceitação documentada de risco residual.

1.755 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado: disposições aplicáveis em matéria de gestão de riscos, precisão, robustez, cibersegurança, pós-comercialização, incidentes e risco sistêmico.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- Estruturas e orientações de segurança reconhecidas não são vinculativas, a menos que sejam incorporadas por outro requisito vinculativo.

1.756 Capítulo 86 Injeção e Manipulação de Modelos

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 86 linguagem de rascunho.

1.757 Exigência

Os sistemas de IA que processam instruções, conteúdo recuperado, saídas de ferramentas, arquivos, conteúdo da web ou dados fornecidos pelo usuário devem implementar controles proporcionados contra injeção rápida, sequestro de instruções, fugas de prisão, manipulação de contexto, execução de ferramentas inseguras e ataques relacionados à manipulação de modelos.

1.758 Explicação em linguagem simples

Um sistema de IA pode tratar o conteúdo hostil como instruções confiáveis. Os controles devem impedir que informações não confiáveis mudem o propósito pretendido do sistema, substituindo salvaguardas, expondo informações confidenciais ou causando ações não autorizadas.

1.759 Requisitos de controle

Implementar conforme apropriado:

1. Separação de sistema, desenvolvedor, usuário, recuperado e conteúdo gerado por ferramentas;
2. ferramenta de menor privilégio e acesso a dados;
3. Listas de permissões, aplicação de políticas e confirmação de ações;
4. Procedência de conteúdo e rotulagem de confiança;
5. filtragem de entrada e saída com limitações conhecidas documentadas;
6. isolamento ou sandboxing de conteúdo não confiável;
7. aprovação humana para ações consequentes ou irreversíveis;
8. detecção de anomalias, registro de registros, limites de taxa e controles de sessão;
9. Testes contraditórios para injeção direta e indireta;
10. falha segura, reversão, resposta a incidentes e escalada do fornecedor.

1.760 Exemplo GlobalWay

O assistente de viagem da GlobalWay lê descrições externas de hotéis e e-mails. Uma página maliciosa contém instruções ocultas pedindo ao agente para revelar os dados do viajante e alterar uma reserva. O sistema trata o conteúdo externo como não confiável, bloqueia o acesso a dados não relacionados, requer confirmação do usuário para alterações de reserva e registra a tentativa de manipulação.

1.761 Atividade de controle

Os sistemas habilitados para prompt devem passar por testes documentados de injeção e manipulação antes do lançamento e após o modelo material, pronta, ferramenta, recuperação ou alterações de integração. Caminhos de alto impacto não resolvidos devem bloquear o uso da produção.

1.762 Provas

- arquitetura de prompt e ferramenta;
- design de confiança e privilégio;
- casos de teste e resultados contraditórios;
- política e configuração de filtragem;
- Registros de ação-confirmação;
- registros de ataques e registros de incidentes;
- Remediação e reteste de evidências.

1.763 Teste de auditoria

Selecione sistemas habilitados para prompt e verifique se os cenários de injeção direta e indireta foram testados, os privilégios são limitados, as ações consequentes exigem autorização apropriada, as tentativas de ataque são detectáveis e a correção foi validada.

1.764 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: gestão de riscos, supervisão humana, precisão, robustez, cibersegurança, registo, monitorização e disposições relativas a incidentes.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.765 Capítulo 87 Envenenamento e Formação de Dados Risco de Dados

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 87 anterior.

1.766 Exigência

As organizações devem proteger os dados de treinamento, validação, teste, ajuste fino, recuperação e feedback contra alterações não autorizadas, contaminação maliciosa, falha de proveniência, degradação da qualidade e viés oculto que possam prejudicar a conformidade, segurança ou desempenho.

1.767 Explicação em linguagem simples

O envenenamento de dados pode ser deliberado ou acidental. Uma pequena quantidade de dados manipulados pode criar comportamentos ocultos, resultados tendenciosos, precisão degradada ou fraquezas de segurança. Os controles devem cobrir fontes de dados, transformações, rótulos, acesso, linhagem, aprovações e ciclos de feedback pós-implante.

1.768 Requisitos de controle

Implementar conforme apropriado:

1. Controles de origem e proveniência aprovados;
2. controle de acesso, segregação de deveres e mudança de registro;
3. verificações de integridade, hashes, versionamento e dutos reprodutíveis;
4. Testes de anomalia, duplicação, outlier e qualidade de etiqueta;
5. análise de subgrupos e representatividade;
6. due diligence do fornecedor e do conjunto de dados de código aberto;
7. quarentena e revisão de feedback do usuário ou dados de produção antes da reutilização;
8. testes de backdoor, gatilho e envenenamento direcionado;
9. Reversão, reciclagem e identificação da versão afetada;
10. retenção de conjuntos de dados, decisões, transformações e evidências de validação.

1.769 Exemplo GlobalWay

Antes de usar, a equipe valida a proveniência, detecta registros duplicados e manipulados, revisa a representação de grupos protegidos, separa o feedback da produção dos dados de reciclagem aprovados e bloqueia a entrada de dados não revisados no pipeline.

1.770 Atividade de controle

Nenhum conjunto de dados pode entrar em um treinamento de IA material ou pipeline de ajuste fino sem propriedade documentada, proveniência, integridade, qualidade, uso legal e aprovação de risco. Mudanças materiais exigem reteste e autorização de liberação vinculada à versão.

1.771 Provas

- Registros de inventário e proveniência de conjuntos de dados;
- Registros de acesso e alteração;
- resultados de testes de integridade e qualidade;
- análise de subgrupos e representatividade;
- garantia do conjunto de dados do fornecedor;

- resultados de testes de envenenamento e backdoor;
- Registros de reciclagem e reversão;
- aprovação e liberação de evidências.

1.772 Teste de auditoria

Verifique a proveniência aprovada, acesso controlado, transformações reprodutíveis, testes de integridade e envenenamento, limitações de qualidade documentadas e ligação entre a versão do conjunto de dados, a versão do modelo e a decisão de lançamento.

1.773 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: dados e governança de dados aplicáveis, gerenciamento de riscos, precisão, robustez, segurança cibernética, documentação técnica e disposições pós-mercado.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.774 Capítulo 88 Extração e Roubo de Modelo

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 88 linguagem de rascunho.

1.775 Exigência

As organizações devem implementar salvaguardas proporcionadas contra cópia de modelos não autorizados, extração, inversão, roubo de peso, divulgação do sistema confidencial e consultas abusivas que possam comprometer a propriedade intelectual, segurança, privacidade, segurança ou conformidade regulamentar.

1.776 Explicação em linguagem simples

Os atacantes podem recriar o comportamento do modelo através de consultas repetidas, roubar pesos ou artefatos, inferir informações de treinamento confidenciais ou explorar o acesso privilegiado. A proteção requer controles técnicos, contratuais, de monitoramento e incidentes compatíveis com o valor e o risco do modelo.

1.777 Requisitos de controle

Implementar conforme apropriado:

1. acesso mínimo-privilegiado a pesos, pontos de verificação, código, prompts e configuração;
2. autenticação forte, gerenciamento de segredos, criptografia e isolamento do ambiente;

3. Controles de taxa de consulta, volume, padrão e abuso de conta;
4. Detecção de anomalias para extração e comportamento de inversão;
5. Controlos de minimização e de informação de confiança, sempre que justificados;
6. Técnicas de marca d'água, impressão digital, canário ou proveniência, quando eficazes;
7. Controles seguros de distribuição e acesso de fornecedores;
8. monitoramento de funcionários e contratados de acordo com a lei aplicável;
9. preservação, contenção, rotação de credenciais e resposta a violações;
10. escalada legal, contratual e regulatória.

1.778 Exemplo GlobalWay

A GlobalWay opera um modelo proprietário de preços de viagem por meio de uma API. O monitoramento identifica uma conta recém-criada fazendo consultas sistemáticas de limites em alto volume. A conta é limitada e suspensa, os registros são preservados, as credenciais e os caminhos de acesso são revisados e o incidente é avaliado para roubo de modelo, exposição à privacidade e notificação do fornecedor.

1.779 Atividade de controle

Os proprietários de segurança devem monitorar indicadores de extração, testar controles de acesso privilegiado e manter um manual de incidentes cobrindo artefatos roubados, endpoints expostos e consultas suspeitas.

1.780 Provas

- Classificação de modelos de ativos;
- Registros de controle de acesso e privilégio;
- API e configuração de limite de taxa;
- Regras e alertas de detecção de anomalias;
- resultados dos testes de extração;
- Incidente e registros forenses;
- Evidência de rotação e contenção de credenciais;
- Registros de resposta contratual e legal.

1.781 Teste de auditoria

Selecione modelos de alto valor e verifique se os pesos e artefatos são controlados por acesso, os endpoints são monitorados quanto ao comportamento de extração, a atividade anormal é investigada, os procedimentos de incidentes são testados e o risco residual é documentado.

1.782 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: segurança cibernética aplicável, robustez, confidencialidade, gerenciamento de riscos, monitoramento, incidentes e disposições de risco sistêmico.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.783 Capítulo 89 Registro, Monitoramento e Gerenciamento de Vulnerabilidades

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 89 linguagem de rascunho.

1.784 Exigência

As organizações devem manter processos proporcionais de registro, monitoramento, identificação de vulnerabilidade, triagem, remediação, divulgação e verificação de sistemas de IA e sua infraestrutura de suporte durante todo o ciclo de vida.

1.785 Explicação em linguagem simples

A segurança da IA depende de ver o que aconteceu, detectar comportamentos anormais, entender versões e dependências afetadas e corrigir fraquezas rapidamente. O logging deve suportar a responsabilidade sem coletar dados pessoais ou confidenciais desnecessários.

1.786 Requisitos de controle

Implementar conforme apropriado:

1. eventos, decisões, acessos, alterações, erros, substituições e registros de segurança ligados à versão;
2. sincronização de tempo, proteção de integridade, retenção e controle de acesso;
3. monitoramento para uso indevido, deriva, saídas anômalas, padrões de ataque e falha de controle;
4. modelo, dependência, API, contêiner, biblioteca, prompt e entrada de vulnerabilidade de configuração;
5. a severidade, a exploração, a exposição, a pessoa afetada e a triagem de impacto regulatório;
6. Prazos de remediação, controles compensatórios e aprovação de exceções;
7. procedimentos coordenados de divulgação e notificação de fornecedores;
8. validação, teste de regressão e evidência de encerramento;

9. ligação a incidentes, monitoramento pós-comercialização, ações corretivas e controle de mudanças;
10. métrica e escalção para deficiências atrasadas ou sistêmicas.

1.787 Exemplo GlobalWay

A GlobalWay monitora uma plataforma de assistência de viagem para chamadas de ferramentas anormais, repetidas tentativas de bypass de salvaguarda, alterações na versão do modelo, anomalias de acesso e componentes vulneráveis de terceiros. Uma vulnerabilidade crítica da API desencadeia isolamento, escalada de fornecedores, controles de compensação, validação de patches e revisão pós-incidente.

1.788 Atividade de controle

Os proprietários de sistemas, engenharia e segurança devem operar um processo documentado de gerenciamento de vulnerabilidades que cubra toda a pilha de serviços de IA. A exposição crítica não resolvida deve bloquear a liberação ou acionar a suspensão, a menos que seja formalmente aprovada sob uma decisão excepcional de risco com limite de tempo.

1.789 Provas

- padrão de registro e cronograma de retenção;
- catálogo de eventos monitorados;
- Registros de alerta e investigação;
- Inventário de vulnerabilidade e justificativa de gravidade;
- registros de remediação e exceção;
- Notificações do fornecedor;
- resultados dos testes de patch e regressão;
- Validação de fechamento e métricas.

1.790 Teste de auditoria

Confirme que os logs estão completos e protegidos, o monitoramento abrange o comportamento específico da IA relevante, as vulnerabilidades foram classificadas e corrigidas de acordo com os cronogramas aprovados e o fechamento foi apoiado independentemente por evidências.

1.791 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado: disposições aplicáveis em matéria de registo, gestão de riscos, precisão, robustez, cibersegurança, monitorização, incidentes, medidas corretivas e risco sistémico.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.792 Capítulo 90 Continuidade dos negócios e recuperação de desastres

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 90 anterior.

1.793 Exigência

As organizações devem manter arranjos proporcionados de continuidade e recuperação para sistemas de IA materiais para que interrupções, corrupção, falha do fornecedor, incidentes cibernéticos, comportamento inseguro ou perda de serviços de suporte não criem danos não gerenciados ou impeçam a conformidade.

1.794 Explicação em linguagem simples

A organização deve preservar a tomada de decisão segura, supervisão humana, registros, integridade de modelo e dados, configurações aprovadas e proteções de pessoas afetadas enquanto o serviço de IA estiver degradado ou indisponível.

1.795 Requisitos de continuidade

O plano deve abordar:

1. processos críticos, dependências, prioridades de recuperação e tolerâncias de impacto;
2. degradação segura, recuo manual, suspensão e desligamento de emergência;
3. objetivos de tempo de recuperação e ponto de recuperação;
4. backup de modelo, prompt, configuração, dados, log e documentação;
5. validação da integridade antes da restauração;
6. nuvem, API, provedor de modelo, identidade, rede e dependências de fonte de dados;
7. fornecedores alternativos, regiões, endpoints ou processos humanos;
8. Comando de incidentes, comunicações, autoridade e notificações de pessoas afetadas, quando necessário;
9. teste de recuperação, reversão, reconciliação e monitoramento pós-restauração;
10. lições aprendidas e ações corretivas.

1.796 Exemplo GlobalWay

O serviço de triagem de recrutamento da GlobalWay torna-se indisponível após a interrupção de um fornecedor. A classificação automatizada é suspensa, os revisores treinados usam um processo manual aprovado, as decisões pendentes são rastreadas, as evidências necessárias são

preservadas e o fluxo de trabalho da IA é restaurado apenas após a validação de versão, dados, configuração e controle.

1.797 Atividade de controle

Todo sistema de IA material deve ter um plano de continuidade e recuperação vinculado à versão antes da aprovação da produção. Sistemas de alto risco exigem alternativas manuais testadas, autoridade de suspensão definida, procedimentos de conservação de evidências e exercícios de recuperação que abrangem cenários de fornecedores e falhas cibernéticas.

1.798 Provas

- análise de impacto nos negócios e dependência;
- Plano de continuidade e recuperação;
- Registros de backup e restauração;
- procedimento manual de fallback;
- cenários de exercício e resultados;
- Testes de integridade e reconciliação;
- registros de comunicação e escalada;
- ações de remediação e lições aprendidas.

1.799 Teste de auditoria

Verifique se os planos cobrem ativos e dependências específicas da IA, se a recuperação manual protege as pessoas afetadas, se os objetivos de recuperação foram testados, se os sistemas restaurados foram validados antes do uso e se as lacunas identificadas foram corrigidas.

1.800 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689: disposições aplicáveis em matéria de gestão de riscos, supervisão humana, precisão, robustez, cibersegurança, registo, monitorização, incidentes, medidas corretivas e risco sistémico.
- Resiliência setorial aplicável e lei de continuidade.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.801 Capítulo 91 Red-Team and Penetração-Teste Governança

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 91 linguagem de rascunho.

1.802 Exigência

As organizações devem governar as atividades de testes de equipe vermelha, adversários e penetração da IA para que os testes sejam autorizados, proporcionados, competentes, baseados em evidências, legalmente compatíveis e conectados às decisões de correção e liberação.

1.803 Explicação em linguagem simples

Os sistemas de IA de teste podem revelar falhas de segurança, segurança, viés, privacidade, manipulação, uso indevido e supervisão. Testes mal governados podem expor dados, interromper serviços, criar conteúdo prejudicial ou violar leis e contratos. mbito, autoridade, salvaguardas, evidências e acompanhamento devem, portanto, ser explícitos.

1.804 Requisitos de governação

Defina no mínimo:

1. objetivos, escopo, sistemas, versões, ambientes e ações proibidas;
2. autorização por escrito, regras de engajamento e condições de parada;
3. independência, competência, conflitos e confidencialidade do testador;
4. salvaguardas de segurança, emprego, propriedade intelectual e manipulação de dados;
5. cenários que abrangem injeção rápida, envenenamento, evasão, extração, uso inseguro de ferramentas, saídas prejudiciais, viés e bypass de controle;
6. restrições e monitoramento de testes de produção;
7. captura de provas, critérios de gravidade, reprodutibilidade e identificação da versão afetada;
8. Remediação de propriedade, prazos, compensação de controles e retestes;
9. escalada de descobertas críticas, incidentes ou eventos reportáveis;
10. aprovação de fechamento e lições aprendidas.

1.805 Exemplo GlobalWay

A GlobalWay autoriza uma equipe vermelha independente a testar um agente de assistência de viagem em um ambiente isolado. A equipe avalia injeção rápida indireta, alterações de reservas não autorizadas, vazamento de dados, escalada de privilégios e bypass de salvaguarda. Descobertas críticas bloqueiam a liberação até que a correção e o reteste independente estejam completos.

1.806 Atividade de controle

Os sistemas de IA de materiais devem passar por testes contraditórios baseados em risco antes do lançamento e após mudanças significativas. Os testes devem ser regidos por regras aprovadas de engajamento e vinculados ao gerenciamento de vulnerabilidades, resposta a incidentes, gerenciamento de riscos, documentação técnica e portões de liberação.

1.807 Provas

- Plano de teste e autorização aprovados;
- Qualificações de testador e avaliação de independência;
- Regras de engajamento e condições de parada;
- cenários, métodos e dados de teste;
- Racionalidade das constatações e da gravidade;
- Remediação e compensação de controles;
- provas de reteste e de encerramento;
- registros de escalonamento executivo.

1.808 Teste de auditoria

Confirme a autorização, escopo, competência, salvaguardas, cenários realistas específicos de IA, qualidade de evidência, correção oportuna, reteste independente e decisões de liberação consistentes com risco não resolvido.

1.809 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: gestão de risco aplicável, governança de dados, supervisão humana, precisão, robustez, segurança cibernética, avaliação de modelos, teste de adversários, monitoramento e provisões de incidentes.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- As normas e orientações de teste de segurança não são vinculativas, a menos que sejam incorporadas por outro requisito vinculativo.

1.810 Capítulo 92 Avaliação de Risco Inerente

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior do capítulo 92.

1.811 Exigência

As organizações devem avaliar o risco inerente de cada sistema ou modelo de IA antes de confiar na mitigação de controles. A avaliação deve ser específica para o propósito pretendido, papel legal, versão de produção,

população afetada, jurisdição, consequência da decisão, contexto de implantação e estágio do ciclo de vida.

1.812 Explicação em linguagem simples

Risco inerente é a exposição que existe antes que os controles sejam considerados. É um conceito de gerenciamento de risco empresarial, não uma classificação legal da AI Act. Um sistema pode estar legalmente fora da categoria de alto risco e ainda apresentar um risco significativo de privacidade, discriminação, segurança, operacional ou reputação.

1.813 Dimensões da avaliação

Avaliar no mínimo:

1. gravidade e probabilidade de dano;
2. escala e número de pessoas afetadas;
3. reversibilidade e detectável;
4. Vulnerabilidade dos grupos afetados;
5. Impacto nos direitos fundamentais, segurança, privacidade, segurança, igualdade, autonomia e acesso a serviços;
6. consequência da decisão e grau de automação;
7. complexidade do modelo, opacidade, incerteza e dependência;
8. sensibilidade, proveniência, qualidade e representatividade dos dados;
9. uso indevido previsível, condições anormais e efeitos de interação;
10. dependências geográficas, setoriais, legais e de fornecedores;
11. incerteza, lacunas de evidências e suposições.

1.814 Exemplo GlobalWay

A GlobalWay avalia um sistema de triagem de recrutamento de IA antes de analisar os controles existentes. A avaliação inerente considera as consequências do emprego, a vulnerabilidade do candidato, a discriminação potencial por procuração, a sensibilidade dos dados, o viés de automação, a dependência do fornecedor, os limites de explicabilidade e o número de Estados-Membros onde o sistema funcionará.

1.815 Atividade de controle

A função de risco de IA deve manter uma metodologia de risco inerente aprovada e exigir uma avaliação completa antes da aquisição, aprovação de desenvolvimento, piloto ou expansão de material. A classificação inerente não deve ser reduzida porque os controles são planejados, mas ainda não implementados ou testados.

1.816 Provas

- Metodologia e critérios de notação aprovados;
- Identificador de sistema e versão;
- registro de propósito pretendido e de papel legal;
- análise de impacto, probabilidade, escala, reversibilidade e incerteza;
- Análise da pessoa afetada e do grupo vulnerável;
- revisor, data de aprovação e suposições;
- gatilhos de reavaliação e história.

1.817 Teste de auditoria

Confirme que o risco inerente foi avaliado antes dos controles, corresponde à versão real e ao contexto de uso, abrange todas as dimensões de risco material, a incerteza dos documentos e foi reavaliado após a mudança relevante.

1.818 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689: disposições aplicáveis em matéria de gestão de riscos, direitos fundamentais, governação de dados, supervisão humana, robustez, monitorização e obrigação do actor.
- Igualdade aplicável, emprego, privacidade, segurança cibernética, segurança de produtos, proteção ao consumidor e direito do setor.
- A terminologia de risco inerente à empresa é uma prática de gerenciamento e não deve ser apresentada como uma classificação estatutária do AI Act.

1.819 Capítulo 93 Risco dos Direitos Fundamentais

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 93 anterior.

1.820 Exigência

As organizações devem identificar, avaliar, mitigar, monitorar e documentar os riscos que um sistema de IA pode criar para os direitos fundamentais. Quando o Artigo 27 se aplica, o implantador deve completar a avaliação de impacto dos direitos fundamentais necessários antes da primeira utilização e atualizá-lo quando as condições relevantes mudarem materialmente.

1.821 Explicação em linguagem simples

A análise dos direitos fundamentais pergunta como o sistema pode afetar as pessoas, não apenas se o modelo é tecnicamente preciso. A revisão deve considerar dignidade, privacidade, proteção de dados, igualdade, não

discriminação, liberdade de expressão e informação, direitos dos trabalhadores, proteção do consumidor, acesso a serviços, remédio eficaz e os direitos das crianças e pessoas com deficiência, quando relevante.

1.822 Requisitos de avaliação

Avaliar no mínimo:

1. Pessoas afetadas e grupos vulneráveis;
2. direitos relevantes e potenciais interferências;
3. gravidade, escala, duração, reversibilidade e probabilidade;
4. grau de automação e dependência humana;
5. riscos de dados, proxy, acessibilidade e representatividade;
6. mecanismos de aviso, contestabilidade, explicação, reclamação e remédio;
7. mitigação, risco residual e monitoramento;
8. Consulta e contributo das partes interessadas, quando adequado;
9. links para DPIA, igualdade, trabalho, consumidor, segurança e avaliações do setor;
10. gatilhos de mudança e reavaliação.

1.823 Exemplo GlobalWay

Antes de implantar a triagem de recrutamento em vários Estados-Membros, a GlobalWay avalia os riscos para a igualdade, privacidade, direitos dos trabalhadores, acesso ao emprego, acomodação para deficientes e contestabilidade efetiva. Ele documenta as mitigações, a autoridade de revisão humana, os avisos dos candidatos, as rotas de reclamação e os limites de monitoramento.

1.824 Atividade de controle

O deployer deve completar uma revisão de impacto de direitos antes do uso da produção, usando o processo legal do Artigo 27, quando aplicável, e um processo equivalente proporcional para outros sistemas de materiais. Riscos graves de direitos não resolvidos devem bloquear a liberação ou desencadear a escalada executiva e legal.

1.825 Provas

- avaliação de direitos e impacto;
- Decisão de aplicabilidade do artigo 27.o;
- Análise da pessoa afetada e do grupo vulnerável;
- registros de consulta;
- mitigação e registro de risco residual;
- procedimentos de notificação, explicação, reclamação e solução;
- histórico de aprovação e reavaliação.

1.826 Teste de auditoria

Verifique se os direitos e grupos relevantes foram identificados, a aplicabilidade do Artigo 27 foi avaliada corretamente, as mitigações foram implementadas antes do uso, o risco residual foi aprovado dentro da autoridade e a reavaliação ocorreu após a mudança material.

1.827 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: Artigo 27.o e disposições aplicáveis em matéria de gestão de riscos, de gestão de dados, de supervisão humana, de transparência, de deployer, de monitorização e de explicação.
- Carta dos Direitos Fundamentais da União Europeia.
- Igualdade aplicável, emprego, deficiência, proteção ao consumidor, privacidade e direito do setor.

1.828 Capítulo 94 Risco para a segurança

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 94 anterior em conflito.

1.829 Exigência

As organizações devem identificar, avaliar, controlar e monitorar os riscos de segurança decorrentes do uso pretendido, uso indevido razoavelmente previsível, interação do sistema, falha de componentes, dependência humana, condições ambientais e mudança no ciclo de vida. A análise de segurança deve ser coordenada com a Lei de IA aplicável, segurança de produtos, setor, ocupacional e direitos de proteção ao consumidor.

1.830 Explicação em linguagem simples

O risco de segurança é mais amplo do que a lesão física. Dependendo do contexto, a IA pode contribuir para danos físicos, psicológicos, operacionais, sociais ou de acesso a serviços. A análise deve examinar o sistema sociotécnico completo em vez do modelo isoladamente.

1.831 Requisitos de avaliação

Avaliar no mínimo:

1. perigos, situações perigosas e uso indevido razoavelmente previsível;
2. gravidade, probabilidade, exposição, detectável e reversibilidade;
3. interação homem-máquina e viés de automação;
4. modos de falha, modos degradados, casos de borda e falhas de dependência;
5. riscos de dados, modelo, software, hardware, rede e integração;

6. Parada de emergência, fallback, recuperação e comportamento de estado seguro;
7. populações afetadas e pessoas vulneráveis;
8. Validação sob condições representativas e adversas;
9. Incidente, reclamação e sinais pós-mercado;
10. controle de mudança e gatilhos de reavaliação.

1.832 Exemplo GlobalWay

A GlobalWay revisa uma ferramenta de interrupção de viagens de IA que recomenda redirecionar viajantes vulneráveis durante o clima severo. A avaliação de segurança abrange recomendações imprecisas, alternativas inacessíveis, dados de transporte obsoletos, viés de automação, interrupções do sistema, escalada de emergência e a capacidade de funcionários treinados para substituir recomendações.

1.833 Atividade de controle

Sistemas de IA críticos e de alto impacto devem ter documentado a análise de riscos, critérios de aceitação, verificação, validação, medidas de supervisão humana, procedimentos de fallback e monitoramento pós-comercialização antes do lançamento da produção. Riscos graves de segurança não resolvidos devem bloquear a implantação.

1.834 Provas

- Análise de perigos e riscos;
- avaliação de modo de falha e uso indevido;
- Validação e resultados de testes de stress;
- revisão de fatores humanos;
- Procedimentos de emergência e recuperação;
- Registros de incidentes e pós-mercado;
- Decisões de aceitação e reavaliação de segurança.

1.835 Teste de auditoria

Verifique se os perigos e o uso indevido foram identificados, os controles foram testados em condições realistas e degradadas, os mecanismos de reversão e substituição funcionam, o monitoramento detecta riscos emergentes e as mudanças materiais desencadeiam a reavaliação.

1.836 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: artigos 9.º, 14.º, 15.º, 72.º e 73.º e obrigações relevantes do ator.
- Harmonização da União aplicável, segurança dos produtos, segurança ocupacional, proteção do consumidor e legislação do setor.

- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.837 Capítulo 95 Riscos e Discriminação

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior do capítulo 95 da linguagem de rascunho.

1.838 Exigência

As organizações devem identificar e mitigar os riscos de que um sistema de IA possa produzir discriminação ilegal, desvantagem injustificada, exclusão, resultados inacessíveis ou desempenho sistematicamente pior para grupos protegidos ou vulneráveis. A avaliação deve refletir o contexto legal e factual aplicável, em vez de depender de uma única métrica estatística.

1.839 Explicação em linguagem simples

As viés podem surgir a partir de dados, rótulos, amostragem, proxies, objetivos, comportamento do modelo, limiares, práticas do usuário, barreiras de acessibilidade, loops de feedback ou o processo de decisão circundante. A precisão agregada igual não prova tratamento igual, enquanto uma disparidade numérica não determina por si só ilegalidade legal.

1.840 Requisitos de avaliação

Avaliar no mínimo:

1. Grupos protegidos e vulneráveis relevantes para a jurisdição e o caso de uso;
2. Representação, medição, rotulagem e riscos históricos;
3. variáveis proxy e características correlacionadas;
4. desempenho de subgrupos, taxas de erro, calibração e efeitos interseccionais;
5. Acessibilidade e requisitos de acomodação razoável;
6. limiar, classificação e consequências do fluxo de trabalho;
7. viés de qualidade e automação de revisão humana;
8. mecanismos de reclamação, desafio, explicação e remédio;
9. loops de feedback e deriva pós-implante;
10. revisão legal de métricas propostas, mitigações e disparidades residuais.

1.841 Exemplo GlobalWay

A GlobalWay testa um sistema de classificação de recrutamento em grupos candidatos relevantes e famílias de trabalho. Ele revisa taxas falso-

negativas, variáveis proxy, barreiras de acesso a incapacidade, limiares de classificação, padrões de substituição humana e se as acomodações estão disponíveis. Um resultado estatisticamente melhorado não é aceito até que Legal e RH confirmem que o processo permanece legal e operacionalmente justo.

1.842 Atividade de controlo

Os sistemas de alto impacto devem ser submetidos a testes documentados de pré-implantação e subgrupos recorrentes usando métodos legais e tecnicamente apropriados. As disparidades materiais exigem análise, mitigação, validação e aprovação da causa raiz. O risco grave de discriminação não resolvida deve bloquear ou suspender o uso.

1.843 Provas

- análise de grupo protegido e de contexto jurídico;
- dados e revisão de proxy variável;
- testes de subgrupos e interseccionais;
- Avaliação de acessibilidade e alojamento;
- Resultados de mitigação e validação;
- análise de revisão e substituição humana;
- reclamações e tendências de monitoramento;
- aprovações legais e de gestão.

1.844 Teste de auditoria

Verifique se grupos relevantes e requisitos legais foram identificados, testando subgrupos e resultados significativos cobertos, as mitigações foram validadas, a acessibilidade foi abordada e o monitoramento detecta disparidade emergente.

1.845 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, conforme alterado: práticas proibidas aplicáveis, de alto risco, governança de dados, supervisão humana, precisão, monitoramento e disposições de direitos fundamentais.
- Carta dos Direitos Fundamentais da União Europeia.
- Igualdade da União e dos Estados-Membros, emprego, deficiência, defesa do consumidor e direito do setor.

1.846 Capítulo 96 Risco para a privacidade e a proteção de dados

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 96 linguagem de rascunho.

1.847 Exigência

As organizações devem identificar, avaliar, mitigar e monitorar os riscos de privacidade e proteção de dados decorrentes do desenvolvimento e uso da IA. A conformidade com o AI Act e o GDPR devem ser coordenados, mas avaliados separadamente, porque os dois regimes impõem diferentes papéis, gatilhos, deveres e requisitos de evidência.

1.848 Explicação em linguagem simples

Um sistema de IA pode cumprir com suas obrigações de AI Act e ainda violar a lei de proteção de dados. A revisão de privacidade deve examinar por que os dados pessoais são processados, cujos dados estão envolvidos, se os dados são necessários, quanto tempo são retidos, quem os recebe, como as pessoas exercem direitos e se as restrições ou salvaguardas automatizadas de tomada de decisão se aplicam.

1.849 Requisitos de avaliação

Avaliar no mínimo:

1. funções de controlador, controlador conjunto, processador e destinatário;
2. propósito, base legal, compatibilidade, necessidade e proporcionalidade;
3. Dados de categoria especial e de infração penal;
4. minimização, precisão, proveniência e retenção de dados;
5. transparência e direitos dos titulares de dados;
6. definição de perfis e decisões exclusivamente automatizadas com efeitos legais ou igualmente significativos;
7. aplicabilidade DPIA, consulta e alto risco residual;
8. transferências internacionais, subprocessadores e localização de dados;
9. segurança, confidencialidade, re-identificação, memorização de modelos e vazamento;
10. treinamento, ajuste fino, prompt, log, saída e dados de loop de feedback;
11. Processos de eliminação, correção, restrição, objeção e contestabilidade;
12. Alinhamento com documentação técnica do AI Act, governança de dados, registro, monitoramento e controles de incidentes.

1.850 Exemplo GlobalWay

A GlobalWay avalia um serviço de triagem de recrutamento que processa perfis de candidatos e transcrições de entrevistas. Ele documenta funções

de controlador e processador, base legal, minimização, retenção, controles de dados de categorias especiais, conclusões do DPIA, salvaguardas de decisão automatizada, transferências internacionais, avisos de candidatos e fluxos de trabalho de exclusão.

1.851 Atividade de controle

Nenhum sistema de IA que processe dados pessoais pode entrar em produção até que a Privacidade confirme a análise do papel, base legal, DPIA necessária, minimização de dados, retenção, transparência, manuseio de direitos, segurança e controles contratuais. Modelo material, dados, finalidade, fornecedor ou alterações de jurisdição exigem reavaliação.

1.852 Provas

- fluxo de dados e mapa de papel;
- lícita-base e avaliação de propósito;
- DPIA e registros de consulta;
- registros de atividades de processamento;
- Avisos de privacidade e procedimentos de direitos;
- cronograma de retenção e exclusão;
- Contratos de transferência e de subcontratação;
- testes de segurança e vazamento;
- história de mudança e reavaliação.

1.853 Teste de auditoria

Verifique se os papéis e a base legal correspondem ao processamento real, se a decisão do DPIA é suportável, se questões de categoria especial e decisões automatizadas foram abordadas, se os direitos podem ser exercidos na prática, se a retenção é imposta e se as mudanças materiais desencadearam a reavaliação.

1.854 Referências jurídicas primárias

- Regulamento (UE) 2016/679, incluindo os artigos 5.o, 6.o, 9.o, 12.o a 22.o, 25.o, 28.o, 30.o, 32.o, 35.o a 36.o e o capítulo V, conforme aplicável.
- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: regras aplicáveis em matéria de dados, transparência, exploração madeireira, implementação, monitorização e disposições relativas aos direitos fundamentais.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.855 Capítulo 97 Risco de Cibersegurança

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 97 linguagem de rascunho.

1.856 Exigência

As organizações devem identificar, avaliar, mitigar, testar e monitorar os riscos de segurança cibernética que afetam os sistemas de IA, modelos, dados, interfaces, infraestrutura, usuários e serviços dependentes durante todo o ciclo de vida. Os controles devem abordar ameaças de segurança convencionais e caminhos de ataque específicos da IA.

1.857 Explicação em linguagem simples

Os sistemas de IA expandem a superfície de ataque. Os atacantes podem manipular prompts, dados de veneno, evitar a detecção, extrair modelos, roubar credenciais, explorar APIs, comprometer dependências ou induzir ações de ferramentas inseguras. A segurança, portanto, requer controles coordenados entre software, modelos, dados, identidade, infraestrutura, fornecedores e operações.

1.858 Requisitos de avaliação

Avaliar no mínimo:

1. ativos, limites de confiança, usuários, privilégios e fluxos de dados;
2. injeção imediata, injeção imediata indireta, jailbreaks e uso de ferramentas inseguras;
3. envenenamento por dados de treinamento, manipulação de fontes de recuperação e abuso de loop de feedback;
4. exemplos contraditórios, evasão, extração de modelo, inversão e inferência de associação;
5. segredos, credenciais, APIs, plugins, agentes e integrações privilegiadas;
6. confidencialidade, integridade, disponibilidade, autenticidade e resiliência;
7. vulnerabilidades de modelo, biblioteca, contêiner, nuvem e fornecedor;
8. registro, detecção, resposta a incidentes, reversão e preservação de evidências;
9. negação de serviço, exaustão de capacidade e falha de dependência;
10. desenvolvimento seguro, controle de mudanças, patches e divulgação de vulnerabilidades;
11. vazamento de dados, memorização de modelos, filtragem de saída e controle de acesso;
12. mudança de material e gatilhos de reavaliação pós-incidente.

1.859 Exemplo GlobalWay

GlobalWay ameaça-modelos um agente de assistência de viagens que pode ler itinerários e iniciar alterações de reserva. Ele identifica injeção imediata indireta através de conteúdo externo, contas de serviço superprivilegiadas, vazamento de dados sensíveis, plugins maliciosos e interrupções do provedor de modelo. A liberação é bloqueada até que a redução de privilégio, isolamento de conteúdo, confirmação de transação, monitoramento e controles de fallback sejam validados.

1.860 Atividade de controlo

Os sistemas de IA de materiais devem passar por revisão de arquitetura de segurança baseada em risco, modelagem de ameaças, desenvolvimento seguro, testes contraditórios, gerenciamento de vulnerabilidades e verificações de prontidão de incidentes antes da produção e após mudanças significativas. Achados críticos não resolvidos exigem escalada executiva documentada e proibição de liberação, a menos que uma exceção legal e limitada por tempo seja aprovada.

1.861 Provas

- modelo de ameaça e inventário de superfície de ataque;
- arquitetura de segurança e diagramas de fluxo de dados;
- Registros de desenvolvimento seguro e revisão de código;
- scans de vulnerabilidade e inventários de dependência;
- resultados contraditórios e de testes de penetração;
- Evidência de identidade, acesso e gerenciamento de segredos;
- Procedimentos de monitorização e de resposta a incidentes;
- registros de remediação, reteste e fechamento.

1.862 Teste de auditoria

Sistemas de IA de materiais selecionados e verificar se os modelos de ameaça cobrem ataques específicos e convencionais de IA, controles correspondem à arquitetura e privilégios reais, descobertas críticas foram remediadas e retestadas, monitoramento detecta eventos relevantes e mudanças materiais desencadearam reavaliação.

1.863 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: disposições aplicáveis em matéria de gestão de riscos, gestão de dados, precisão, robustez, cibersegurança, monitorização, incidentes e GPAI.
- Requisitos aplicáveis em matéria de cibersegurança e sector da União e dos Estados-Membros.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.864 Capítulo 98 Risco de Explicabilidade e Transparência

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 98 linguagem de rascunho.

1.865 Exigência

As organizações devem identificar e gerenciar os riscos que surgem quando o comportamento, as limitações, os resultados, as divulgações ou a lógica de decisão da IA são insuficientemente compreensíveis para provedores, implantadores, operadores, pessoas afetadas, auditores ou autoridades desempenharem suas responsabilidades.

1.866 Explicação em linguagem simples

A transparência não é um documento ou uma explicação. Diferentes públicos precisam de informações diferentes. Os provedores podem dever instruções e informações técnicas; os implantadores podem dever avisos ou explicações; os operadores precisam de informações de supervisão utilizáveis; as pessoas afetadas podem precisar de comunicação clara e rotas para desafiar as decisões.

1.867 Requisitos de avaliação de risco

Avaliar no mínimo:

1. público-alvo e contexto de decisão;
2. Artigo 13.o Instruções e informações do fornecedor;
3. Artigo 50.o Interação, conteúdo sintético, declarações deepfake e divulgação de texto de interesse público, quando aplicável;
4. Artigo 86.o Direitos de explicação, se aplicável;
5. Limitações do modelo ou do sistema, incerteza, confiança e usos não suportados;
6. rastreabilidade de entrada, versão, configuração e saída para a ação resultante;
7. acessibilidade, linguagem, tempo, proeminência e compreensão;
8. risco de resumos enganosos, falsa precisão ou alegações causais não suportadas;
9. Limites de segredo comercial e de segurança que devem ser equilibrados sem derrotar os deveres legais;
10. consistência entre documentação técnica, avisos, interfaces, treinamento e operação real.

1.868 Exemplo GlobalWay

A GlobalWay usa uma ferramenta de recrutamento de IA para apoiar a triagem de candidatos. Os candidatos recebem um aviso claro de que a IA é usada, enquanto os revisores treinados recebem instruções sobre limitações, desempenho de subgrupo, autoridade de substituição e dependência proibida. Quando um direito de explicação se aplica, a GlobalWay fornece informações significativas sobre o papel do sistema e os principais fatores relevantes para a decisão sem apresentar uma justificativa inventada ou enganosa.

1.869 Atividade de controlo

Cada sistema de IA material deve ter um plano de transparência específico do público-alvo aprovado antes do lançamento. Avisos, instruções, procedimentos de explicação, rótulos de interface e treinamento devem ser controlados por versão, testados para compreensão e acessibilidade e atualizados após a mudança material.

1.870 Provas

- avaliação do público e da transparência;
- Instruções e avisos aprovados;
- procedimento de explicação e modelos;
- Testes de acessibilidade e compreensão;
- screenshots de interface e registros de divulgação;
- treinamento do operador e registros de limitação;
- reclamações, pedidos e registros de resposta;
- versão e mudar a história.

1.871 Teste de auditoria

Verifique se cada público recebe informações precisas, oportunas e acessíveis; as explicações correspondem à operação real do sistema; as divulgações são proeminentes e a versão atual; e os pedidos de reclamações ou explicações são tratados de forma consistente.

1.872 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: artigos 13.º, 50.º e 86.º e disposições conexas, conforme aplicável.
- Disposições de transparência e decisão automatizada aplicáveis ao GDPR.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.873 Capítulo 99 Risco de Autonomia Humana

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 99 linguagem de rascunho.

1.874 Exigência

As organizações devem identificar e mitigar os riscos de que os sistemas de IA prejudiquem a escolha, julgamento, dignidade, agência, contestabilidade ou controle humano significativo. A supervisão humana eficaz deve ser real, competente, oportuna e apoiada pela autoridade e pelo design do sistema.

1.875 Explicação em linguagem simples

Uma pessoa não está significativamente no controle apenas porque um ser humano aparece em algum lugar no fluxo de trabalho. Os operadores podem diferir automaticamente para saídas, falta de tempo ou informações para desafiá-los, ou ser incapaz de parar o sistema. As pessoas afetadas podem não entender que a IA influenciou um resultado ou pode não ter nenhuma maneira prática de contestá-lo.

1.876 Requisitos de avaliação

Avaliar no mínimo:

1. o grau de automação e a consequência da decisão;
2. risco de viés de automação, excesso de dependência, descrição e complacência;
3. competência do operador, carga de trabalho, tempo, informação e independência;
4. autoridade para desconsiderar, reverter, substituir, suspender ou parar o sistema;
5. coerção, manipulação, decepção, padrões escuros e personalização exploradora;
6. Aviso significativo, escolha, canais alternativos e consentimento, quando relevante;
7. vias de contestabilidade, reclamação, revisão e remédio;
8. impactos na dignidade, privacidade, igualdade, expressão, associação e devido processo;
9. Pessoas vulneráveis e desequilíbrios de poder;
10. Retrocesso seguro e continuidade quando a automação é limitada ou desativada.

1.877 Exemplo GlobalWay

O sistema de recrutamento da GlobalWay classifica os candidatos, mas não pode rejeitar os candidatos automaticamente. Os revisores recebem as

evidências subjacentes, limitações e autoridade de substituição, e devem documentar razões para decisões adversas. Os candidatos podem solicitar revisão humana através de um canal acessível, e a GlobalWay monitora se os revisores simplesmente seguem rankings sem julgamento independente.

1.878 Atividade de controle

Os fluxos de trabalho de IA de material devem definir direitos de decisão, pontos obrigatórios de revisão humana, requisitos de competência, mecanismos de substituição e parada, rotas de contestabilidade e indicadores de viés de automação. Os controles devem ser testados sob condições realistas de carga de trabalho e pressão de tempo.

1.879 Provas

- Plano de Supervisão Humana;
- direitos de decisão e matriz de escalada;
- formação do operador e avaliação da competência;
- anular, reverter e parar logs;
- Testes de carga de trabalho e usabilidade;
- avisos, alternativas e procedimentos de reclamação;
- registros de revisão humana e remédios;
- Automatização-viés monitoramento e ações corretivas.

1.880 Teste de auditoria

Confirme se os revisores têm informações, competência, tempo e autoridade adequados; as substituições são tecnicamente eficazes; as pessoas afetadas podem contestar os resultados; e o monitoramento detecta o carimbo de borracha ou outra perda de controle humano significativo.

1.881 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, com as alterações: práticas proibidas aplicáveis, supervisão humana, transparência, implementador, direitos fundamentais e disposições de explicação.
- Emprego aplicável, igualdade, proteção do consumidor, acessibilidade e lei de proteção de dados.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.882 Capítulo 100 Risco Operacional e Resiliência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 100 linguagem de rascunho.

1.883 Exigência

As organizações devem identificar e gerenciar riscos operacionais e de resiliência que possam causar um sistema de IA ou processo dependente a

falhar, degradar, produzir resultados não confiáveis ou tornar-se indisponíveis. Os controles devem apoiar a continuidade, a recuperação segura e a preservação de evidências.

1.884 Explicação em linguagem simples

Um sistema de IA pode falhar mesmo sem um ataque cibernético. Limites de capacidade, feeds de dados ruins, interrupções no modelo, deriva de configuração, latência, falhas de dependência ou controle de mudanças fracas podem interromper as operações ou produzir decisões prejudiciais. A resiliência requer alternativas testadas e prioridades claras de recuperação.

1.885 Requisitos de avaliação

Avaliar no mínimo:

1. processos críticos, níveis de serviço e tolerâncias de impacto;
2. modelo, API, nuvem, dados, rede, identidade e dependências de fornecedores;
3. riscos de capacidade, latência, taxa de transferência, tempo limite e limite de taxa;
4. Falha de pipeline de dados, dados obsoletos, mudança de esquema e degradação da integridade;
5. configuração, versão, prompt e deriva de fonte de recuperação;
6. Monitorização da cobertura e dos limiares de alerta;
7. soluções alternativas manuais, canais alternativos e modos degradados seguros;
8. backup, restauração, reversão, failover e objetivos de recuperação;
9. prontidão do operador, comunicações e autoridade de decisão;
10. retenção, coordenação de incidentes e validação pós-recuperação.

1.886 Exemplo GlobalWay

O serviço de assistência em viagens de IA da GlobalWay depende de um modelo de terceiros, APIs de reservas, serviços de identidade e dados de perfil do cliente. A GlobalWay define um modo seguro de somente leitura, bloqueia alterações de reservas automatizadas durante falhas de dependência, encaminha solicitações urgentes para agentes humanos e testa a recuperação antes de restaurar o serviço normal.

1.887 Atividade de controle

Os serviços de IA de material devem ter documentado os planos de continuidade e recuperação alinhados ao impacto nos negócios. Os planos devem incluir desligamento seguro, fallback, monitoramento de dependência, validação de recuperação e exercícios periódicos que cobrem cenários de falha realistas específicos da IA.

1.888 Provas

- Avaliação do impacto nos negócios e da dependência;
- Definições de nível de serviço e tolerância ao impacto;
- Planos de continuidade, recuo e recuperação;
- resultados dos testes de backup, reversão e failover;
- Registos de monitorização e capacidade;
- relatórios de exercícios e ações corretivas;
- Comunicações de interrupção e aprovações de recuperação;
- evidência de validação pós-recuperação.

1.889 Teste de auditoria

Confirme se as dependências críticas são conhecidas, os processos de fallback são utilizáveis, os objetivos de recuperação são testados, as versões restauradas e os dados são validados e as lacunas de resiliência não resolvidas são escaladas.

1.890 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, conforme alterado: disposições aplicáveis em matéria de gestão de riscos, precisão, robustez, cibersegurança, supervisão humana, monitorização, incidentes e medidas corretivas.
- Resiliência operacional aplicável, segurança cibernética, segurança do produto e requisitos do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.891 Capítulo 101 Risco de Terceiros

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 101 linguagem de rascunho.

1.892 Exigência

As organizações devem identificar e gerenciar riscos criados por fornecedores de IA, provedores de modelos, serviços em nuvem, provedores de dados, integradores, subprocessadores, componentes de código aberto e outras dependências. Os acordos de terceiros devem apoiar as próprias responsabilidades legais e operacionais de cada ator regulamentado.

1.893 Explicação em linguagem simples

Um contrato de fornecedor não remove a responsabilidade do cliente. A organização ainda precisa de evidências, controle, aviso, cooperação, continuidade e direitos de saída suficientes para usar o sistema de IA de forma legal e segura. O risco também pode surgir de subcontratados ou dependências ocultas várias camadas abaixo do fornecedor direto.

1.894 Requisitos de avaliação

Avaliar no mínimo:

1. Pessoa jurídica exata, jurisdição, propriedade e papel do AI Act;
2. propósito pretendido, classificações, usos suportados e usos proibidos;
3. Documentação técnica, instruções, conformidade, registro e provas de garantia;
4. fontes de dados, proveniência, privacidade, propriedade intelectual e retenção;
5. segurança, robustez, precisão, viés, acessibilidade e controles de supervisão;
6. subcontratados, nuvem, APIs, modelos, componentes e dependências de concentração;
7. Notificação de alteração, transparência da versão e gatilhos de modificação substancial;
8. Notificação de incidentes, investigação, preservação de evidências e ação corretiva;
9. direitos de auditoria, de acesso à informação, de cooperação com a autoridade e de reparação;
10. continuidade, portabilidade, suspensão, terminação e exclusão de dados verificados.

1.895 Exemplo GlobalWay

A GlobalWay adquire uma plataforma de recrutamento de IA. Ele identifica o papel de provedor do fornecedor e o papel de deployer da GlobalWay, revisa documentação e testes, mapeia subprocessadores e dependências de modelos, negocia mudanças e avisos de incidentes e estabelece um processo manual de devolução e exportação de evidências antes do uso da produção.

1.896 Atividade de controle

Os fornecedores de IA de material devem passar por due diligence, contratação, aprovação, monitoramento e reavaliação em níveis de risco. Os contratos devem bloquear o uso da produção quando as evidências necessárias estiverem ausentes, as funções legais não forem resolvidas, os riscos críticos permanecerem inalterados ou os controles de continuidade e saída forem inadequados.

1.897 Provas

- mapa de inventário e dependência do fornecedor;
- avaliação do papel e da classificação;
- questionário de due-diligência e provas de apoio;
- Revisões de segurança, privacidade, legais e de conformidade;

- Contrato executado e termos de fluxo para baixo;
- Monitorização, incidentes e alteração de registos;
- Relatórios de auditoria e auditoria;
- continuidade e resultados dos testes de saída.

1.898 Teste de auditoria

Selecione fornecedores de materiais e verifique se a devida diligência precedeu o uso, os papéis e as dependências são precisos, as evidências são vinculadas à versão, os direitos contratuais são operacionais, as mudanças e os incidentes desencadearam a reavaliação e os riscos não resolvidos foram escalados ou bloqueados.

1.899 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: disposições aplicáveis do fornecedor, do deployer, do importador, do distribuidor, do representante autorizado, do fabricante do produto, do GPAI, da documentação, do acompanhamento, do incidente, da ação corretiva e da cadeia de valor.
- Proteção de dados aplicável, segurança cibernética, segurança de produtos, direito do consumidor, emprego e setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.900 Capítulo 102 Risco Legal, Financeiro e Reputacional

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 102 linguagem de rascunho.

1.901 Exigência

As organizações devem identificar e gerenciar exposições legais, regulatórias, contratuais, financeiras e de reputação decorrentes do desenvolvimento, aquisição, implantação, operação, mudança, incidente e aposentadoria da IA. As estimativas de risco devem ser baseadas em evidências e não devem substituir a análise legal.

1.902 Explicação em linguagem simples

As falhas da IA podem criar várias formas distintas de danos de uma só vez. Uma decisão discriminatória pode levar a ações regulatórias, litígios, custos de correção, reivindicações contratuais, interrupção operacional e perda de confiança. Essas exposições devem ser avaliadas separadamente antes de serem agregadas.

1.903 Requisitos de avaliação

Avaliar no mínimo:

1. deveres aplicáveis da AI Act, papéis de ator e exposição à aplicação da lei;
2. Proteção de dados, emprego, igualdade, consumidor, segurança de produtos, propriedade intelectual, segurança cibernética, acessibilidade e direito do setor;
3. responsabilidade civil, violação contratual, indenização, garantia e considerações de seguro;
4. investigação, notificação, remediação, recall, retirada e custos de monitoramento;
5. interrupção de negócios, perda de receita, retrabalho, substituição e custos de continuidade;
6. multas e penalidades usando limites legais atuais e suposições específicas de fatos;
7. impactos de clientes, funcionários, parceiros, reguladores, investidores e confiança pública;
8. cenários de escalada de mídia, reclamação, litígio e partes interessadas;
9. custos de concentração, insolvência do fornecedor e saída;
10. incerteza, suposições, confiança e necessidades de revisão de conselho.

1.904 Exemplo GlobalWay

A GlobalWay avalia um incidente de disparidade de sistema de recrutamento. Estima separadamente o custo de investigação e remediação, potenciais reivindicações de emprego e proteção de dados, engajamento do regulador, recuperação de fornecedores, interrupção de negócios e impacto na reputação. Não apresenta a multa legal máxima como a perda esperada.

1.905 Atividade de controlo

Os riscos e incidentes de IA de materiais devem receber avaliação documentada de Legal, Compliance, Finanças, Risco, Comunicações e proprietário de negócios. As estimativas de alto impacto devem declarar suposições, fontes, incerteza e uso de decisões. As declarações públicas e as comunicações do regulador exigem revisão e aprovação apropriadas.

1.906 Provas

- análise de aplicabilidade legal e regulamentar;
- exposição e avaliação de cenários;
- pressupostos financeiros e apoio ao cálculo;
- Revisão de contratos e seguros;

- Registros de custos de incidentes e remediação;
- Plano de comunicação e comunicação das partes interessadas;
- aconselhamento ou registo de escalada;
- decisões executivas e do conselho.

1.907 Teste de auditoria

Confirme que as categorias de exposição foram avaliadas separadamente, os cálculos usam suposições suportáveis, conclusões legais recebidas revisão qualificada, penalidades máximas não foram apresentadas como resultados esperados e as decisões refletem incerteza e mitigação.

1.908 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: execução aplicável, sanção penal, fiscalização do mercado, incidentes, medidas corretivas e disposições relativas à obrigação do actor.
- União aplicável e Estado-Membro civil, contratual, proteção de dados, emprego, igualdade, consumidor, segurança de produtos, propriedade intelectual, segurança cibernética e direito do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.909 Capítulo 103 Aceitação e Exceções Residuais de Risco

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 103 linguagem de rascunho.

1.910 Exigência

O risco residual de IA pode ser aceito apenas por meio de um processo documentado, autorizado e com tempo limitado que identifique o risco restante, pessoas afetadas, restrições legais, controles compensatórios, monitoramento, escalada e condições de fechamento. Os deveres legais obrigatórios não podem ser dispensados por meio da aceitação interna do risco.

1.911 Explicação em linguagem simples

Aceitação de risco não é permissão para ignorar a lei ou deixar um problema sério não resolvido indefinidamente. É uma decisão de governança tolerar um risco restante definido por um período ou propósito limitado após os controles necessários e obrigações legais terem sido abordados.

1.912 Requisitos de aceitação

O registro deve identificar:

1. sistema ou modelo, versão, caso de uso, proprietário, papel de ator e jurisdição;
2. Risco original, controles implementados e risco residual;
3. pessoas afetadas, danos potenciais, probabilidade, gravidade e incerteza;
4. deveres legais aplicáveis e confirmação de que nenhum está sendo dispensado;
5. Compensação de controles e restrições operacionais;
6. Autoridade de aceitação correspondente ao nível de risco;
7. Data de início, data de validade, frequência de revisão e critérios de encerramento;
8. Indicadores de monitoramento, limiares e gatilhos de escalada;
9. proprietário de remediação, marcos, recursos e data-alvo;
10. condições que exijam suspensão imediata ou reavaliação.

A aceitação do risco não deve substituir os controles de práticas proibidas, avaliação de conformidade exigida, registro, relatórios de incidentes graves, ações corretivas, cooperação com autoridades ou outras obrigações obrigatórias.

1.913 Exemplo GlobalWay

A GlobalWay identifica uma limitação temporária no desempenho de subgrupos para uma linguagem de baixo volume em uma ferramenta de suporte não automatizada. O uso é restrito, as saídas exigem verificação humana treinada, os limiares de monitoramento são estabelecidos, a remediação é financiada e um proprietário de risco sênior aprova uma exceção de 60 dias. A exceção expira automaticamente, a menos que seja reavaliada de forma independente.

1.914 Atividade de controle

A organização deve manter um registro de exceção centralizado com limiares de aprovação, critérios de revisão legal, expiração automática, monitoramento, escalada e validação de fechamento. Riscos residuais altos ou sensíveis aos direitos fundamentais exigem revisão executiva e podem exigir suspensão em vez de aceitação.

1.915 Provas

- Avaliação de risco residual;
- revisão legal e de conformidade;
- Design e testes de controle de compensação;

- Evidência de aceitação e autoridade assinada;
- Entrada de registro de exceção;
- Monitorização e resultados limiares;
- Plano de remediação e registros de progresso;
- decisão de expiração, renovação, suspensão ou encerramento.

1.916 Teste de auditoria

Confirme que a autoridade de aceitação correspondia ao risco, os deveres legais não foram dispensados, os controles de compensação operados, o monitoramento ocorreu, a expiração foi aplicada, a correção progrediu e o fechamento ou renovação recebeu revisão independente.

1.917 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: práticas proibidas aplicáveis, gestão de riscos, conformidade, registro, monitoramento, incidentes, ações corretivas, cooperação de autoridade e disposições de obrigação do ator.
- Legislação aplicável da União e dos Estados-Membros relevante para o caso de utilização.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.918 Capítulo 104 Projeto de Biblioteca de Controle

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 104 linguagem de rascunho.

1.919 Exigência

As organizações devem manter uma biblioteca de controle de IA estruturada que traduz obrigações legais aplicáveis, tratamentos de risco, decisões de governança, salvaguardas técnicas e práticas operacionais em controles claros, atribuíveis, testáveis e produtores de evidências.

1.920 Explicação em linguagem simples

Uma biblioteca de controle é a ponte operacional entre lei, política, risco e execução diária. Os controles devem indicar quem realiza a atividade, o que deve ser feito, quando deve ocorrer, quais sistemas e versões são cobertos, quais evidências são retidas e como as falhas são escaladas.

1.921 Requisitos de design

Cada registro de controle deve incluir:

1. Identificador e título únicos de controlo;
2. Fontes legais, regulatórias, contratuais, políticas e de risco vinculadas;

3. Objetivo e risco abordado;
4. ator regulamentado, empresário, proprietário do controle e operador;
5. escopo por sistema, modelo, versão, geografia, fornecedor e estágio do ciclo de vida;
6. atividade de controle, gatilho, frequência e tempo;
7. Classificação preventiva, de detetive, corretiva ou de governança;
8. Método de execução manual, automatizado ou híbrido;
9. entradas, saídas, sistemas e dependências necessárias;
10. requisitos padrão de evidência, retenção e acesso;
11. exceção, escalada e processo de controle compensatório;
12. procedimentos de projeto e teste de eficácia operacional;
13. histórico de mudança, aprovação e data da próxima revisão.

1.922 Exemplo GlobalWay

A GlobalWay cria um controle para sistemas de recrutamento de alto risco que exigem confirmação de classificação de pré-lançamento, procedimentos de supervisão humana aprovados, resultados de validação, documentação do provedor, prontidão de registro e aprovação de liberação executiva. O registro de controle identifica evidências, frequência, proprietários e etapas de teste.

1.923 Atividade de controle

A função de Governança de IA deve manter uma biblioteca mestra controlada, mapear todas as obrigações e riscos materiais de IA para um ou mais controles, evitar controles duplicados ou contraditórios e exigir revisão após mudança regulatória, sistema, modelo, fornecedor, propósito ou organizacional.

1.924 Provas

- Metodologia de controle-biblioteca aprovada;
- registro de controle mestre;
- mapeamentos source-to-control;
- A propriedade e os registros RACI;
- narrativas e procedimentos de controle;
- Especificações de prova;
- testes de scripts e resultados;
- Exceção e mudança de registros.

1.925 Teste de auditoria

Selecione uma amostra de obrigações legais e riscos materiais de IA. Trace cada um para um controle aprovado, proprietário responsável, procedimento operacional, evidência retida e método de teste. Confirme

que os controles obsoletos são aposentados e as mudanças materiais desencadeiam a reavaliação.

1.926 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: governança aplicável, gerenciamento de qualidade, gerenciamento de riscos, documentação, manutenção de registros, monitoramento, incidentes, ações corretivas e disposições específicas do ator.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- Estruturas e padrões de controle não são vinculantes, a menos que sejam incorporados por lei, contrato, certificação ou política organizacional.

1.927 Capítulo 105 Mapeamento Artigo-para-Controlo

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 105 anterior.

1.928 Exigência

As organizações devem manter mapeamentos rastreáveis das disposições aplicáveis da Lei de IA da UE e outros requisitos vinculativos para os controles, procedimentos, evidências, sistemas, modelos, atores e proprietários responsáveis usados para demonstrar conformidade.

1.929 Explicação em linguagem simples

Uma lista de citações não é um mapa de conformidade. Um mapeamento útil mostra como cada elemento legal aplicável é implementado, quem é responsável, onde as evidências são armazenadas e como as lacunas são identificadas. O mapeamento também deve distinguir a lei obrigatória de orientações, padrões e práticas voluntárias.

1.930 Requisitos de mapeamento

Para cada requisito aplicável, registro:

1. fonte legal, artigo, parágrafo, anexo e status de emenda;
2. Data efectiva e tratamento transitório;
3. gatilho, escopo, exceção e ator regulamentado;
4. Declaração de obrigação em língua simples;
5. identificadores de política, norma, procedimento e controle vinculados;
6. sistemas, modelos, versões, fornecedores e jurisdições cobertos;
7. proprietário responsável e performer operacional;
8. Evidência requerida e local de retenção;

9. Procedimento de teste, frequência e resultado mais recente;
10. gap, interpretação, dependência ou status de revisão de conselho;
11. história de mudança e gatilho de próxima revisão.

1.931 Exemplo GlobalWay

A GlobalWay mapeia os requisitos de supervisão humana do Artigo 14 para seu sistema de recrutamento de alto risco para procedimentos de supervisão aprovados, treinamento do usuário, controles de interface, autoridade de parada, registro de substituição, testes de eficácia e evidência de liberação retida.

1.932 Atividade de controle

A Governança Legal e de IA deve manter conjuntamente o mapeamento. Requisitos novos ou alterados, mudanças no sistema, mudanças no papel do ator, mudanças no propósito pretendido, incidentes, resultados de auditoria e alterações no fornecedor devem desencadear a revisão. Os requisitos aplicáveis não mapeados são bloqueadores de liberação.

1.933 Provas

- inventário de obrigatoriedade legal aprovado;
- matriz article-to-control;
- avaliações de ator e aplicabilidade;
- Registo efectivo da data;
- Procedimentos vinculados e índices de evidências;
- Testes e registos de lacunas;
- Histórico de revisão e aprovação legal;
- atualizações de mudanças regulatórias.

1.934 Teste de auditoria

Selecione uma amostra de artigos aplicáveis e elementos anexos. Trace cada elemento legal através do mapeamento para controles, evidências, proprietários, sistemas e resultados de testes. Confirme se as exclusões e decisões de não aplicabilidade são documentadas e suportáveis.

1.935 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada, incluindo os artigos e anexos aplicáveis.
- Se for caso disso, o Regulamento (UE) 2026/1744.
- O texto consolidado atual do EUR-Lex controla versões anteriores e resumos secundários.

1.936 Capítulo 106 Controle de Propriedade e Frequência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 106 linguagem de rascunho.

1.937 Exigência

Todo controle material de IA deve ter claramente atribuído responsabilidade, responsabilidade operacional, autoridade de escalada, frequência de execução, desencadeando eventos, obrigações de evidência e cobertura de backup. A propriedade e a frequência devem refletir deveres legais, risco do sistema, estágio do ciclo de vida, velocidade de mudança e criticidade de controle.

1.938 Explicação em linguagem simples

É improvável que um controle sem proprietário opere, e um controle realizado no intervalo errado pode não gerenciar o risco. A revisão anual não é suficiente para modelos em rápida mudança, sistemas de alto risco, incidentes ativos ou mudanças orientadas por fornecedores.

1.939 Requisitos de propriedade

Defina para cada controle:

1. executivo ou função responsável;
2. proprietário do controle responsável pelo design e desempenho;
3. Operador responsável pela execução;
4. revisor ou aprovador onde a segregação é necessária;
5. Evidência de custódia;
6. autoridade de escalonamento e de aceitação de risco;
7. Proprietário de backup qualificado e acordos de continuidade;
8. salvaguardas de conflito de interesses e independência.

1.940 Requisitos de frequência

O tempo de controle pode ser:

- Contínua ou orientada para eventos;
- por transação, decisão, lançamento, modelo ou conjunto de dados;
- diária, semanal, mensal, trimestral ou anual;
- antes da implantação, após a mudança, após o incidente ou na renovação do contrato.

A frequência deve ser reavaliada quando o risco, a lei, o comportamento do sistema, a escala, as condições do fornecedor ou os resultados de monitoramento mudam.

1.941 Exemplo GlobalWay

A GlobalWay atribui a revisão de log do sistema de recrutamento ao proprietário operacional semanal, análise mensal de viés e desempenho, revisão trimestral de garantia do fornecedor e controles de classificação e liberação antes de cada mudança de versão material. Incidentes sérios desencadeiam uma escalada imediata fora do cronograma de rotina.

1.942 Atividade de controle

A governança da IA deve aprovar o modelo de propriedade e frequência, monitorar execuções perdidas ou tardias, exigir delegação documentada e escalar controles órfãos, atrasados, ineficazes ou repetidamente falhos. Os controles críticos podem não depender de um único indivíduo sem cobertura de backup.

1.943 Provas

- registro de propriedade de controle;
- RACI e registros de delegação;
- Racionalidade de frequência aprovada;
- calendário de execução e agendas automatizadas;
- Evidência de conclusão e revisão;
- relatórios de excesso de controle;
- escalonamento e backup de registros;
- história de mudança de frequência.

1.944 Teste de auditoria

Confirme se os proprietários são atuais e competentes, as frequências correspondem aos riscos e gatilhos, as execuções ocorreram no tempo, as evidências foram revisadas e os controles perdidos foram escalados e corrigidos.

1.945 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689: disposições aplicáveis em matéria de gestão da qualidade, gestão de riscos, supervisão humana, monitorização, manutenção de registos, incidentes, ações corretivas e responsabilidade do actor.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.946 Capítulo 107 Padrões de Evidência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 107 linguagem de rascunho.

1.947 Exigência

As evidências de conformidade devem ser autênticas, completas, precisas, oportunas, atribuíveis, ligadas à versão, protegidas, recuperáveis e suficientes para demonstrar o projeto e o funcionamento dos controles e deveres legais relevantes da IA.

1.948 Explicação em linguagem simples

Uma captura de tela, certificado ou título da política não é evidência confiável automaticamente. As evidências devem mostrar o que aconteceu, para qual sistema e versão, quem realizou e revisou a atividade, quando ocorreu, quais critérios foram aplicados e se exceções ou falhas foram resolvidas.

1.949 Critérios de qualidade de evidência

As evidências devem satisfazer:

1. relevância para a exigência e controle exatos;
2. identificação do sistema, modelo, conjunto de dados, configuração, liberação e jurisdição;
3. Fonte confiável e criador responsável;
4. Data, hora, período e frequência de execução;
5. integridade, incluindo exceções e resultados negativos;
6. proteção da integridade e histórico de mudanças;
7. aprovação do revisor e segregação quando necessário;
8. retenção alinhada com as necessidades legais, contratuais, incidentes e de auditoria;
9. privacidade, privilégio e controles de acesso;
10. Reprodutibilidade ou validação independente, quando apropriado;
11. indexação pesquisável e recuperação oportuna;
12. tratamento documentado de estimativas, amostras, suposições e limitações.

1.950 Exemplo GlobalWay

A GlobalWay mantém o plano de teste aprovado, a versão do conjunto de dados, a versão do modelo, os resultados do subgrupo, a assinatura do revisor, as decisões de exceção, as evidências de correção e a aprovação de liberação para seu sistema de recrutamento. Uma reivindicação de marketing do fornecedor não é aceita como evidência sem documentação ou testes de suporte.

1.951 Atividade de controle

A organização deve publicar um padrão de evidência de IA, definir evidências aceitáveis por tipo de controle, manter um registro de evidências, proteger registros de alteração ou exclusão não autorizada e rejeitar atestados não suportados ou resumos não verificáveis.

1.952 Provas

- Norma de evidência aprovada;
- Registo de provas e metadados;
- registros de sistema-fonte;
- aprovações e assinaturas de revisores;
- integridade e logs de acesso;
- cronogramas de retenção;
- registros de exceção e deficiência;
- resultados do teste de recuperação.

1.953 Teste de auditoria

Verifique a confiabilidade, a integridade, a atribuição, a ligação da versão, os carimbos de data e hora, as aprovações, a proteção da integridade, a retenção, a acessibilidade e a consistência com o resultado do controle reivindicado.

1.954 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: documentação técnica, manutenção de registros, gestão da qualidade, monitoramento, incidentes, ações corretivas, conformidade e disposições de acesso à autoridade.
- Privacidade aplicável, segurança cibernética, emprego, segurança do produto e requisitos de retenção do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.955 Capítulo 108 Testes de controle

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 108 linguagem de rascunho.

1.956 Exigência

Os controles de IA devem ser testados usando procedimentos documentados e baseados em risco que avaliem a eficácia do projeto e a eficácia operacional. Os testes devem ser suficientemente independentes, competentes, baseados em evidências, reproduzíveis e vinculados às decisões de remediação e liberação.

1.957 Explicação em linguagem simples

Um controle pode parecer adequado no papel, mas falha na prática. Os testes devem confirmar que o controle foi devidamente projetado, implementado para os sistemas e versões corretas, realizado por pessoal autorizado, apoiado por evidências confiáveis e eficaz ao longo do período revisado.

1.958 Requisitos de ensaio

Um teste de controle deve definir:

1. controle objetivo e requisito ou risco vinculado;
2. população, escopo, sistemas, versões, atores e período;
3. Critérios de design-efetividade;
4. Critérios de eficácia operacional;
5. Método de amostragem e raciocínio;
6. Evidência esperada e confiabilidade da fonte;
7. Competência do testador, independência e conflitos;
8. Procedimentos, re-performance, observação, inquérito, inspeção ou validação técnica;
9. Critérios de exceção e gravidade;
10. Causa raiz, impacto, controle compensatório e expectativas de remediação;
11. requisitos de reteste e encerramento;
12. relatórios e limites de escalada.

1.959 Exemplo GlobalWay

A GlobalWay testa seu controle de supervisão humana revisando o projeto do procedimento, registros de treinamento, permissões de interface, registros de substituição e parada, decisões amostradas, revisão de supervisores e evidências de que exceções não resolvidas de alta gravidade bloquearam a liberação ou o uso contínuo.

1.960 Atividade de controle

A função de garantia deve manter uma metodologia aprovada de teste de controle de IA, priorizar controles críticos e de alto risco, evitar a autoavaliação onde a independência é necessária e rastrear todas as exceções por meio de fechamento validado.

1.961 Provas

- Metodologia de ensaio aprovada;
- Planos de teste anuais e baseados em eventos;
- populações e seleções de amostras;

- Papéis de trabalho e resultados técnicos;
- registros de exceção e gravidade;
- Respostas de gestão;
- Remediação e reteste de provas;
- relatórios finais e aprovações de encerramento.

1.962 Teste de auditoria

Inspecione uma amostra de testes de controle concluídos. Confirme que o escopo, a população, a amostragem, as evidências, os procedimentos, as conclusões, a gravidade, a correção e o reteste foram suportáveis e que falhas críticas não resolvidas afetaram a implantação ou as decisões de risco.

1.963 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado: disposições aplicáveis em matéria de gestão da qualidade, gestão dos riscos, conformidade, supervisão humana, robustez, cibersegurança, monitorização, incidentes e medidas corretivas.
- Os testes internos não substituem a avaliação da conformidade, o envolvimento do organismo notificado ou a revisão da autoridade quando legalmente exigido.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.964 Capítulo 109 Classificação de Deficiência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 109 linguagem de rascunho.

1.965 Exigência

Deficiências de controle de IA, não conformidades legais, lacunas de documentação, incidentes e resultados adversos devem ser classificados de forma consistente de acordo com o impacto, probabilidade, significado legal, pessoas afetadas, criticidade do sistema, duração, escopo, detectável e urgência de correção.

1.966 Explicação em linguagem simples

Nem todas as questões têm a mesma consequência. Um rótulo de documento ausente difere de uma salvaguarda fracassada que afeta as decisões de emprego. A classificação deve apoiar a rápida escalada, correção proporcional, análise regulatória, decisões de liberação e relatórios de gerenciamento transparentes.

1.967 Fatores de classificação

Avaliar no mínimo:

1. Obrigação legal aplicável e ator regulamentado;
2. sistema, modelo, versão, processo e jurisdição afetados;
3. Danos reais e potenciais à saúde, segurança, direitos fundamentais, privacidade ou outros interesses protegidos;
4. número e vulnerabilidade das pessoas afetadas;
5. duração, recorrência e alcance geográfico;
6. Criticidade e disponibilidade de controles compensatórios;
7. integridade dos dados, segurança, viés, desempenho ou consequências de transparência;
8. Implicações de notificação de incidentes, ação corretiva, conformidade ou notificação de autoridade;
9. probabilidade de impacto contínuo ou expandido;
10. complexidade de correção e sensibilidade ao tempo;
11. consciencialização da gestão, ocorrência prévia e status em atraso;
12. qualidade e incerteza residual.

1.968 Modelo de gravidade

A organização pode usar categorias como críticas, altas, moderadas e baixas, mas as definições devem ser aprovadas, aplicadas de forma consistente e vinculadas à escalada obrigatória, correção, validação e regras de aceitação de risco.

1.969 Exemplo GlobalWay

A GlobalWay classifica uma disparidade de subgrupos do sistema de recrutamento combinada com uma revisão humana ineficaz como alta gravidade porque pode afetar oportunidades de emprego e direitos fundamentais. O sistema é restrito enquanto a população afetada, a causa raiz e a correção são avaliadas.

1.970 Atividade de controle

Governança da IA, Legal, Risco, Segurança, Privacidade e proprietários de empresas relevantes devem usar uma taxonomia de deficiência comum. Questões críticas e altas exigem uma rápida escalada executiva, salvaguardas provisórias documentadas, análise de relatórios legais e validação de fechamento independente.

1.971 Provas

- Metodologia de gravidade aprovada;
- Registro de deficiência e não conformidade;

- impacto e análise jurídica;
- registros do sistema afetado e da população;
- decisões de compensação-controle;
- Registros de escalada e notificação;
- planos de remediação e datas de vencimento;
- aprovações de reteste e fechamento.

1.972 Teste de auditoria

Confirme que a classificação considerou os fatores necessários, questões semelhantes receberam tratamento consistente, escalonamento e prazos correspondentes à gravidade, relatórios legais foram avaliados e o fechamento foi validado de forma independente quando necessário.

1.973 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: não conformidade aplicável, gestão de riscos, monitorização, incidentes, medidas corretivas, vigilância do mercado e disposições de sanções.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor e lei de notificação do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.974 Capítulo 110 Gestão da Ação Corretiva

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 110 linguagem de rascunho.

1.975 Exigência

As organizações devem gerenciar ações corretivas de IA por meio de um processo documentado que contenha risco imediato, determine a causa raiz e o escopo afetado, atribua proprietários responsáveis, estabeleça prazos, valide a correção, atualize os controles e a documentação relacionados e evite a recorrência.

1.976 Explicação em linguagem simples

Fechar um problema significa mais do que registrar que o trabalho foi concluído. A organização deve mostrar que o dano ou a exposição foi contido, a verdadeira causa foi abordada, os sistemas afetados e as pessoas foram consideradas, a correção funcionou e os processos relacionados foram atualizados.

1.977 Requisitos de ação corretiva

Cada registro de ação deve incluir:

1. deficiência, incidente, reclamação, descoberta de auditoria ou gatilho regulatório;
2. sistemas, modelos, versões, dados, fornecedores, decisões e jurisdições afetados;
3. Contenção imediata e salvaguardas provisórias;
4. legal, relatórios, conformidade e análise de pessoas afetadas;
5. análise de causa-raiz e fator contribuinte;
6. tarefas de remediação, proprietários responsáveis, recursos e prazos;
7. Critérios de validação e revisor independente;
8. regressão, viés, segurança, privacidade, segurança e testes de desempenho como relevantes;
9. Atualizações de avaliações de risco, documentação técnica, controles, procedimentos, treinamento, avisos e contratos;
10. Decisão de risco residual e de aceitação de risco;
11. Reteste, aprovação de encerramento e período de monitoramento;
12. lições aprendidas e prevenção de recorrência.

1.978 Exemplo GlobalWay

Depois de identificar disparidades de classificação inexplicadas em um sistema de recrutamento, a GlobalWay suspende recomendações automatizadas, preserva evidências, avalia os candidatos afetados, corrige dados e problemas de modelo, fortalece a revisão humana, testa novamente os resultados dos subgrupos, atualiza a documentação e o treinamento e monitora a liberação corrigida antes da restauração completa.

1.979 Atividade de controle

O processo de ação corretiva deve priorizar questões por gravidade, proibir extensões de prazo não suportadas, escalar ações de alto risco atrasadas, exigir fechamento baseado em evidências e reabrir ações quando a validação falhar ou ocorrer recorrência.

1.980 Provas

- Registo de acções correctivas;
- registros de contenção e impacto;
- análise de causa-raiz;
- plano de remediação e propriedade;
- Provas de ensaio e validação;
- Documentação e controles atualizados;
- Registros de risco-aceitação e aprovação;
- monitoramento de fechamento e pós-remediação.

1.981 Teste de auditoria

Confirme que a contenção foi oportuna, a causa raiz foi suportável, o escopo foi completo, a correção abordou a causa, o teste da eficácia verificada, os artefatos relacionados foram atualizados e a autoridade de fechamento foi apropriada.

1.982 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: disposições aplicáveis relativas ao prestador, ao deployer, à monitorização, ao incidente grave, à acção correctiva, à retirada, à recolha, à vigilância do mercado, à gestão da qualidade e à documentação.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor e requisitos do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.983 Capítulo 111 Monitoramento Contínuo da Conformidade

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 111 linguagem de rascunho.

1.984 Exigência

As organizações devem monitorar continuamente os sistemas de IA, modelos, controles, fornecedores, obrigações legais e resultados operacionais materiais para que a não conformidade emergente, degradação, incidentes, impactos de direitos, fraquezas de segurança e mudanças regulatórias sejam identificadas e abordadas prontamente.

1.985 Explicação em linguagem simples

A conformidade não é uma aprovação única. Sistemas de IA, dados, modelos, usuários, fornecedores e leis mudam. O monitoramento deve, portanto, detectar quando as suposições aprovadas não correspondem mais à operação real.

1.986 Requisitos de monitorização

O quadro de monitorização deverá abranger:

1. versão do sistema e modelo, configuração e alterações de propósito pretendido;
2. desempenho, precisão, robustez, segurança, viés e resultados de subgrupos;
3. atividade de supervisão humana, substituições, escaladas e sobreposição à eficácia;

4. avisos de transparência, compreensão do usuário, reclamações e contestabilidade;
5. privacidade, qualidade dos dados, retenção, segurança, vulnerabilidades e anomalias de acesso;
6. alterações do fornecedor, incidentes, resultados de garantia e deterioração do serviço;
7. integridade de registro, integridade de evidências e retenção de registros;
8. alterações legais, regulamentares, normas e orientações;
9. operação de controle, exceções, ações atrasadas e falhas repetidas;
10. dados pós-mercado, incidentes, quase erros e eficácia de ação corretiva.

1.987 Exemplo GlobalWay

A GlobalWay monitora seu serviço de triagem de recrutamento para deriva de resultados de subgrupos, padrões de substituição de revisores, alterações no modelo de fornecedor, tendências de reclamações, falhas de registro, eventos de segurança e alterações nos requisitos legais. As violações de limite desencadeiam investigação e possível suspensão.

1.988 Atividade de controle

Cada sistema de IA material deve ter aprovado indicadores de monitoramento, limiares, proprietários, frequência de revisão, fontes de dados, caminhos de escalada e ações de resposta. A evidência de monitoramento deve estar ligada ao sistema e versão exatos e revisada por pessoal responsável.

1.989 Provas

- Plano de monitorização e catálogo métrico;
- dashboards e registros de dados de origem;
- Configuração de limiar e alerta;
- Registros de revisão e escalada;
- Incidentes, reclamações e registros quase inexistentes;
- Monitoramento do fornecedor e da mudança regulatória;
- ações corretivas e validação;
- Revisão periódica de monitoramento-efetividade.

1.990 Teste de auditoria

Verifique se o monitoramento abrange riscos legais e operacionais, os dados são confiáveis e ligados à versão, os limites são justificados, os alertas são revisados prontamente, as escalações são documentadas e os problemas identificados resultam em ação apropriada.

1.991 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689, conforme alterado: disposições aplicáveis em matéria de gestão da qualidade, gestão dos riscos, exploração madeireira, deployer, fornecedor, monitorização pós-mercado, incidentes graves, ação corretiva e vigilância do mercado.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.992 Capítulo 112 Planejamento de Auditoria

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 112 anterior.

1.993 Exigência

O planejamento de auditoria de IA deve ser baseado em risco, independente, orientado por evidências e alinhado aos deveres legais aplicáveis, papéis de atores, classificações de sistemas, estágios do ciclo de vida, jurisdições, fornecedores, incidentes e descobertas anteriores. O universo de auditoria deve incluir sistemas e modelos em vez de depender apenas de processos organizacionais.

1.994 Explicação em linguagem simples

Um plano de auditoria eficaz responde o que será revisado, por que é importante, quais critérios legais e operacionais se aplicam, quais evidências são necessárias, quem realizará o trabalho e como as lacunas de cobertura serão gerenciadas.

1.995 Requisitos de planejamento

O plano de auditoria deve definir:

1. o universo de auditoria de IA e a ligação do inventário do sistema;
2. funções legais, classificações, jurisdições e requisitos aplicáveis;
3. Risco inerente e residual, materialidade e resultados de garantia prévia;
4. escopo, objetivos, critérios, exclusões e limitações;
5. estágios do ciclo de vida, versões, fornecedores e fluxos de dados no escopo;
6. necessária competência técnica, jurídica, de privacidade, segurança e operacional;
7. independência, conflitos e uso de especialistas;
8. Estratégia, fontes de evidência e métodos de teste;
9. cronograma, marcos, rotas de relatórios e gatilhos de escalada;

10. coordenação com avaliação de conformidade, revisão regulatória, privacidade, segurança e garantia externa;
11. tratamento de questões abertas, incidentes, reclamações e mudanças regulatórias;
12. Revisão de qualidade e aprovação do programa de auditoria.

1.996 Exemplo GlobalWay

A GlobalWay prioriza auditorias de sistemas de recrutamento, assistência ao viajante e detecção de fraude com base na classificação, impacto da pessoa afetada, dependência do fornecedor, histórico de incidentes, mudança de modelo e maturidade de controle. O plano atribui especialistas legais, de privacidade, segurança e ciência de dados, quando necessário.

1.997 Atividade de controle

As decisões de cobertura e adiamentos devem ser justificados, o risco deve ser aceito quando necessário e revisitado após grandes incidentes, mudanças materiais ou desenvolvimentos legais.

1.998 Provas

- universo de auditoria AI;
- modelo de avaliação e priorização de risco;
- Planos de auditoria anuais e em curso aprovados;
- escopo e critérios de engajamento;
- registros de competência e independência;
- Estratégia de amostragem e teste;
- avaliações de coordenação e confiança;
- aprovações de cobertura-gap e adiamento.

1.999 Teste de auditoria

Revise o processo de planejamento de auditoria. Confirme se o universo está completo, a priorização reflete o risco real de IA, links de escopo para critérios legais e versões do sistema, a competência necessária está disponível, exclusões são justificadas e lacunas materiais são escaladas.

1.1000 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: governança aplicável, gestão da qualidade, conformidade, documentação, monitoramento, incidentes, ações corretivas e disposições de revisão de autoridade.
- A auditoria interna não substitui a avaliação da conformidade legalmente exigida, o envolvimento do organismo notificado ou a revisão da autoridade competente.

1.1001 Capítulo 113 Teste de Eficácia de Design

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 113 linguagem de rascunho.

1.1002 Exigência

Os testes de eficácia de projeto devem determinar se cada controle de IA, individual e coletivamente, é adequadamente projetado para prevenir, detectar, corrigir ou escalar o risco legal e operacional relevante quando implementado como pretendido.

1.1003 Explicação em linguagem simples

Um controle pode existir no papel e ainda ser incapaz de alcançar seu propósito. O teste de design examina se o controle tem o gatilho certo, proprietário, autoridade, entradas, lógica, frequência, evidência, escalada e relacionamento com outros controles.

1.1004 Requisitos de teste de projeto

Para cada controle, avalie:

1. O dever legal, risco ou objetivo abordado;
2. escopo entre sistemas, modelos, versões, atores e jurisdições;
3. Acionar, frequência, tempo e natureza preventiva ou de detetive;
4. Proprietário responsável, competência, autoridade e segregação de deveres;
5. insumos necessários, qualidade dos dados, ferramentas e dependências;
6. critérios de decisão, limiares, exceções e caminhos de escalada;
7. Retenção de provas e rastreabilidade;
8. ligação aos controles a montante e a jusante;
9. capacidade de lidar com o uso indevido, mudança, falha e condições de incidente previsíveis;
10. alinhamento com políticas, documentação técnica, contratos e procedimentos operacionais.

1.1005 Exemplo GlobalWay

A revisão confirma que a classificação, gestão de risco, governança de dados, supervisão humana, testes, evidências de fornecedores e aprovação legal são entradas obrigatórias e que questões críticas não resolvidas bloqueiam a implantação.

1.1006 Atividade de controle

Os proprietários de controle devem documentar os objetivos de controle e os atributos de design antes da implementação. Revisores independentes devem questionar se o controle poderia alcançar o resultado pretendido sob condições normais, alteradas e de falha.

1.1007 Provas

- Descrição e objetivo do controle;
- mapeamento legal e de risco;
- fluxo de processo e lógica de decisão;
- RACI e requisitos de competência;
- limiares e projeto de escalada;
- especificação de evidência;
- análise de dependência e modo de falha;
- revisão e aprovação do projeto.

1.1008 Teste de auditoria

Rastreie cada um para o dever legal e risco relevante, inspecione o projeto documentado, caminhe através de cenários normais e de exceção e determine se o controle poderia razoavelmente atingir seu objetivo declarado se operado como projetado.

1.1009 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: gestão da qualidade, gestão de riscos, gestão de dados, documentação, supervisão humana, precisão, robustez, cibersegurança, monitorização, incidentes e disposições de ação corretiva.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1010 Capítulo 114 Teste de Eficácia Operacional

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 114 anterior em conflito.

1.1011 Exigência

Os testes de eficácia operacional devem determinar se os controles de IA operaram de forma consistente, completa, precisa, oportuna e por pessoal competente autorizado durante todo o período em análise.

1.1012 Explicação em linguagem simples

Um controle bem projetado pode falhar na prática. Os testes operacionais examinam transações, lançamentos, decisões, incidentes, mudanças e

registros reais para confirmar que o controle funcionou repetidamente e que as exceções foram tratadas corretamente.

1.1013 Requisitos de ensaio

O testador deve avaliar:

1. O período de revisão definido e a população relevante;
2. integridade e confiabilidade da população utilizada para amostragem;
3. Prova de que o controle operou com a frequência exigida;
4. pontualidade, precisão e integridade da execução;
5. autorização, competência e independência do performer;
6. aplicação de limites, aprovações e regras de escalada;
7. tratamento de exceções, substituições, falhas e evidências ausentes;
8. consistência entre sistemas, modelos, versões, fornecedores e jurisdições;
9. Remediação e reteste de falhas identificadas;
10. Se os controles de compensação operaram onde o controle primário falhou.

1.1014 Exemplo GlobalWay

A GlobalWay testa uma amostra de aprovações de liberação de IA ao longo de seis meses. O testador verifica que cada liberação amostrada usou a versão do modelo aprovada, completou as revisões legais e técnicas necessárias, resolveu problemas de bloqueio, obteve aprovação autorizada e reteve evidências antes da implantação da produção.

1.1015 Atividade de controle

Os proprietários de controle devem reter evidências suficientes para reconstruir a operação. Os testadores independentes devem usar populações confiáveis, amostras defensáveis, critérios claros de exceção e conclusões documentadas apoiadas pelas evidências revisadas.

1.1016 Provas

- validação da população e da completude;
- registro amostra-seleção;
- Evidências de controle executadas;
- timestamps, aprovações e identidade do revisor;
- registros de exceção e escalada;
- Compensação-controle de evidências;
- Remediação e reteste de resultados;
- Conclusão de testes e revisão de qualidade.

1.1017 Teste de auditoria

Teste uma amostra baseada em risco ao longo do período de revisão, documente todos os desvios, avalie se as falhas são isoladas ou sistêmicas e determine se o controle operou efetivamente.

1.1018 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: gestão da qualidade, documentação, manutenção de registos, gestão de riscos, monitorização, incidentes, medidas corretivas e disposições de governação aplicáveis.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1019 Capítulo 115 Avaliação de Amostras e Evidências

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 115 linguagem de rascunho.

1.1020 Exigência

As organizações que realizam auditoria interna, testes de conformidade, garantia de controle, revisão de conformidade-prontidão ou testes de resposta regulatória devem usar uma metodologia documentada, baseada em risco, amostragem e avaliação de evidências, capaz de produzir suporte suficiente, confiável, relevante e reproduzível para suas conclusões. Quando a amostragem apoiar uma obrigação estatutária, avaliação de conformidade, revisão de corpo notificado, solicitação de autoridade competente ou outra atividade de garantia legalmente exigida, a metodologia deve ser apropriada para esse fim e não restringir.

1.1021 Explicação em linguagem simples

Uma amostra pequena ou conveniente pode criar falsa confiança. O revisor deve entender a população inteira, selecionar itens usando um método defensável, avaliar a qualidade das evidências e considerar se os desvios identificados indicam uma falha mais ampla. Os métodos detalhados de amostragem neste capítulo são práticas de garantia; eles não são apresentados como uma fórmula de amostragem autônoma imposta diretamente pela Lei de IA da UE.

1.1022 Requisitos de amostragem

A metodologia deve abordar:

1. O objetivo de auditoria, o dever legal, o controle e a asserção que estão sendo testados;
2. definição da população, completude e precisão;

3. período, sistemas, modelos, versões, papéis, jurisdições, fornecedores, incidentes e exceções conhecidas cobertas;
4. Método de seleção baseado em risco, estatístico, aleatório, direcionado ou julgador;
5. tamanho da amostra e raciocínio;
6. inclusão de itens de alto risco, incomuns, fracassados, alterados, substituídos, reclamados ou relacionados a incidentes;
7. tratamento de evidências ausentes, contraditórias, alteradas, inacessíveis ou não verificáveis;
8. Limites de extrapolação e avaliação das taxas de desvio;
9. critérios de expansão quando são encontradas falhas ou a confiabilidade da população não pode ser estabelecida;
10. documentação suficiente para desempenho independente;
11. preservação da evidência de origem e da ligação da versão;
12. onde a amostra não pode suportar a conclusão pretendida.

1.1023 Critérios de qualidade de evidência

As evidências devem ser avaliadas quanto à origem, autenticidade, integridade, data, ligação à versão, integridade, consistência, independência do revisor, relevância para o controle ou declaração legal testada e reprodutibilidade. As evidências retidas para fins legais, de conformidade, incidentes, monitoramento ou acesso à autoridade também devem satisfazer os requisitos aplicáveis de manutenção de registros, acessibilidade, retenção e confidencialidade.

1.1024 Exemplo GlobalWay

A GlobalWay testa os controles de supervisão humana em todas as decisões de recrutamento. A amostra inclui aprovações de rotina, substituições, resultados adversos, reclamações, versões de modelos diferentes, várias unidades de negócios e decisões tomadas após uma atualização do fornecedor. Quando duas exceções revelam que uma nova versão do modelo ignorou a regra de escalada aprovada, a GlobalWay expande a amostra, preserva os registros relevantes, suspende o fluxo de trabalho afetado e inicia a ação corretiva.

1.1025 Atividade de controle

As equipes de garantia devem validar as populações antes da amostragem, lógica de seleção de documentos, preservar evidências de origem e expandir os testes quando as exceções sugerem fraqueza sistêmica ou quando a confiabilidade da população não pode ser estabelecida. A amostragem nunca deve ser usada para evitar a produção de registros que uma autoridade competente, organismo notificado, autoridade de vigilância de mercado ou outro revisor legalmente autorizado possa exigir.

1.1026 Provas

- definição e validação da população;
- plano de amostragem e raciocínio;
- lista de itens selecionados;
- Provas de origem e verificações de integridade;
- ligação de versão e liberação;
- análise de exceção e causa raiz;
- Testes expandidos quando necessário;
- sign-off e conclusão do revisor;
- revisão da qualidade do papel de trabalho;
- registros de escalada e ação corretiva.

1.1027 Teste de auditoria

Confirme se a população estava completa, o método de seleção correspondeu ao risco e objetivo, as evidências eram confiáveis e ligadas à versão, as exceções foram avaliadas e expandidas adequadamente, as conclusões não excederam as evidências e a metodologia não limitou o acesso a registros legalmente exigido.

1.1028 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo os artigos 11.o, 12.o, 17.o, 18.o, 19.o, 43.o, 72.o, 74.o, 78.o e 79.o, e o anexo IV, conforme aplicável ao ator, ao sistema, à atividade de garantia e ao gatilho legal.
- Regulamento (UE) n.o 2026/1744, sempre que as suas alterações afetem as obrigações, datas ou procedimentos aplicáveis do AI Act.
- Avaliação de conformidade aplicável, organismo notificado, fiscalização do mercado, autoridade competente, privacidade, segurança cibernética, segurança do produto, emprego, proteção do consumidor e requisitos específicos do setor.
- A metodologia de amostragem neste capítulo é uma prática de garantia e não é uma fórmula de amostragem estatutária autônoma prescrita pelo AI Act.
- O texto consolidado atual do EUR-Lex controla resumos e rascunhos mais antigos.

1.1029 Capítulo 116 Validação técnica

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 116 linguagem de rascunho.

1.1030 Exigência

Os fornecedores de sistemas de IA de alto risco devem estabelecer e documentar a validação e os testes adequados ao propósito e aos riscos pretendidos do sistema, incluindo as informações exigidas pelo artigo 11 e pelo anexo IV e os requisitos de desempenho, robustez, segurança cibernética e supervisão humana aplicáveis ao sistema. Outras organizações que desenvolvem, adquirem, integram ou implantam sistemas de IA materiais devem aplicar validação técnica proporcional antes da liberação e após a mudança material, para que possam demonstrar que a configuração de produção opera dentro dos limites aprovados e que suas próprias funções operacionais podem ser cumpridas.

1.1031 Explicação em linguagem simples

A Lei de IA da UE não impõe um procedimento de validação universal em todos os sistemas e atores de IA. O dever exato depende da classificação e do papel. Para sistemas de IA de alto risco, os provedores devem manter o gerenciamento de risco, documentação técnica, testes, precisão, robustez, segurança cibernética e evidência de gerenciamento de qualidade. Os agentes e outros atores da cadeia de valor precisam de evidências de validação suficientes para usar o sistema de acordo com instruções, supervisão de exercícios, operação de monitoramento e reavaliar alterações. A validação não deve testar apenas a produção real, a produção do laboratório.

1.1032 Requisitos de validação

O plano de validação deve abordar, conforme aplicável:

1. o ator regulamentado, a classificação, o propósito pretendido e o gatilho legal;
2. sistema, modelo, dados, prompt, ferramenta, software, firmware e versão de configuração;
3. mau uso e condições operacionais razoavelmente previsíveis;
4. precisão, robustez, confiabilidade, consistência e limites de erro;
5. dados de teste representativos e contextualmente apropriados e métricas de desempenho;
6. Subgrupo, acessibilidade e desempenho específico do contexto, quando relevante;
7. Supervisão humana, superação, parada, escalada e controles de falha segura;
8. Segurança cibernética, abuso, vazamento, manipulação e resistência à dependência;
9. registro, rastreabilidade, monitoramento, captura de evidências e vinculação de versão;

10. integração, latência, disponibilidade, failover e comportamento de modo degradado;
11. Critérios de aceitação, limitações não resolvidas, ação corretiva e risco residual;
12. revisão independente e decisão de liberação autorizada.

1.1033 Exemplo GlobalWay

A GlobalWay valida um sistema de recomendação de interrupção de viagens usando dados equivalentes à produção, condições de rede degradadas, itinerários incomuns, entradas multilíngues, cenários de ultrapassagem humana e simulações de falha do fornecedor. Ele registra as funções do provedor e do implantador, a versão de produção testada, instruções aplicáveis, limitações, critérios de aceitação, desvios não resolvidos e a base para a liberação.

1.1034 Atividade de controle

Um sistema de IA de alto risco não deve ser liberado por seu provedor até que os requisitos aplicáveis de gerenciamento de risco, documentação, teste, conformidade e gerenciamento de qualidade sejam satisfeitos. A GlobalWay não deve colocar nenhum sistema de IA material em produção até que obtenha e avalie evidências de validação suficientes para seu papel real, uso pretendido, responsabilidades de supervisão e risco. As mudanças materiais exigem reavaliação proporcional e, quando aplicável, revalidação e atividade de conformidade renovada.

1.1035 Provas

- Avaliação legal-função e classificação;
- Plano de validação aprovado;
- versão e registro de configuração;
- dados de teste, justificativa de representatividade e descrição do ambiente;
- métricas, resultados de testes, logs e registros de defeitos;
- critérios de aceitação, limitações e exceções;
- Revisão e aprovação independentes;
- Provas de conformidade e de libertação, se aplicável;
- Registros de monitoramento e revalidação pós-lançamento.

1.1036 Teste de auditoria

Confirme que a validação cobriu a versão de produção real, correspondeu ao ator e à classificação, usou dados e métricas apropriados, testou riscos legais e operacionais relevantes, limitações e desvios documentados e vinculou os resultados às decisões de conformidade, liberação, monitoramento e reavaliação, conforme aplicável.

1.1037 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada, incluindo os artigos 9.o-15.o, 16.o, 26.o, 43.o, 72.o e o anexo IV, conforme aplicável.
- Regulamento (UE) n.o 2026/1744, sempre que as suas alterações afectem os requisitos, datas de aplicação ou procedimentos pertinentes.
- Normas harmonizadas aplicáveis e especificações comuns, quando legalmente disponíveis e relevantes; caso contrário, não devem ser descritas como leis vinculativas apenas porque são referências de validação úteis.
- O texto consolidado atual do EUR-Lex controla resumos e rascunhos mais antigos.

1.1038 Capítulo 117 Testes de viés, supervisão e transparência

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 117 linguagem de rascunho.

1.1039 Exigência

As organizações devem testar o viés, a supervisão humana e a transparência na medida exigida pelo seu papel legal, a classificação do sistema de IA, a finalidade pretendida, as pessoas afetadas e a lei aplicável. Os provedores de sistemas de IA de alto risco devem abordar a governança de dados, a gestão de riscos, a precisão, a supervisão humana, a transparência e as obrigações de documentação técnica. Os agentes devem operar sistemas de acordo com as instruções, atribuir supervisão humana competente, monitorar o uso, manter registros relevantes, quando aplicável, transparência e uso.

1.1040 Explicação em linguagem simples

A Lei de IA da UE não cria um único “teste de viés” universal para todos os sistemas de IA. Requer controles diferentes, dependendo do ator e do risco. Um sistema pode parecer preciso em geral enquanto funciona mal para grupos ou contextos específicos. A revisão humana pode existir no papel, mas falha porque os revisores não têm tempo, autoridade, informação, competência ou capacidade prática para intervir. A transparência também pode falhar se os avisos forem imprecisos, tardios, inacessíveis ou inconsistentes com o comportamento real do sistema.

1.1041 Requisitos de ensaio

Teste, conforme aplicável:

1. o ator, a classificação, o propósito pretendido, a população e o gatilho legal;
2. relevância, representatividade, integridade e adequação das populações de dados e testes;
3. desempenho geral e de subgrupos, distribuição de erros e falha específica do contexto;
4. Variáveis de proxy, discriminação indireta, barreiras de acessibilidade e impacto díspare previsível;
5. competência do revisor, carga de trabalho, informações, autoridade, vies de automação e conflitos;
6. sobreposição, escalada, parada, apelo, contestabilidade e mecanismos de segurança;
7. timing, redação, idioma, acessibilidade e canal de entrega;
8. Consistência entre avisos, instruções de uso, documentação técnica, operação real e registros;
9. limitações materiais, uso indevido previsível e usos não suportados;
10. Remediação, reteste, tratamento de risco residual e decisões de liberação ou uso continuado.

1.1042 Exemplo GlobalWay

A GlobalWay testa um sistema de triagem de recrutamento em famílias de trabalho, idiomas, faixas etárias, acomodações relacionadas à deficiência e grupos de candidatos relevantes. Também observa se os recrutadores entendem as limitações do sistema, desafiam as recomendações quando apropriado, usam as rotas de substituição e escalada e fornecem aos candidatos informações legalmente apropriadas e um processo de revisão prática. A GlobalWay avalia separadamente se os requisitos de GDPR, igualdade, emprego e acessibilidade se aplicam.

1.1043 Atividade de controle

O GlobalWay requer testes documentados de vies, supervisão e transparência antes da liberação ou implantação de sistemas com impacto material humano ou direitos fundamentais e após mudanças significativas nos dados, modelo, finalidade, população, fluxo de trabalho, instruções ou design de aviso. Um teste falho deve desencadear contenção, ação corretiva, reavaliação e reteste antes da liberação ou uso contínuo, a menos que uma medida provisória autorizada e legalmente suportável seja documentada.

1.1044 Provas

- Avaliação legal do papel, classificação e caso de uso;
- plano de teste e raciocínio populacional;
- evidência de qualidade e representatividade dos dados;

- métricas gerais, de subgrupos e de resultados;
- simulações e observações operacionais;
- testes de aviso, instrução, acessibilidade e compreensão;
- Exceções, limitações e reclamações;
- Remediação e reteste de resultados;
- aprovação, escalonamento e registros de risco residual.

1.1045 Teste de auditoria

Confirme que os testes combinaram o ator e o gatilho legal, usaram populações e cenários relevantes, avaliaram a eficácia operacional em vez de projetar sozinhos, documentaram disparidades e falhas de supervisão, testaram a transparência e a acessibilidade exigidas legalmente e verificaram a correção antes da liberação ou do uso continuado.

1.1046 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo os artigos 4.o, 9.o, 10.o, 1315, 26.o, 27.o, 50.o, 72.o e 86.o, conforme aplicável.
- Regulamento (UE) 2016/679, incluindo os artigos 5.o, 12.o a 15.o, 21.o, 22.o, 25.o e 35.o a 36.o, nos casos em que estejam envolvidos dados pessoais, definição de perfis ou tomada de decisão automatizada.
- Igualdade aplicável, emprego, acessibilidade, proteção ao consumidor e direito setorial específico.
- Regulamento (UE) n.o 2026/1744, sempre que as suas alterações afetem as obrigações ou as datas de aplicação da Lei de IA em causa.
- Os métodos de teste neste capítulo são práticas de garantia operacional e não devem ser deturpados como uma fórmula de teste estatutária universal.
- Textos oficiais consolidados atuais controlam resumos e rascunhos mais antigos.

1.1047 Capítulo 118 Comentários sobre a prontidão de conformidade

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 118 linguagem de rascunho.

1.1048 Exigência

Os fornecedores de sistemas de IA de alto risco devem concluir o procedimento de avaliação da conformidade aplicável ao sistema antes de colocá-lo no mercado ou colocá-lo em serviço, sujeito às datas de aplicação relevantes e às regras de transição. As revisões internas de conformidade e prontidão devem verificar se o provedor identificou a rota legal correta e

reuniu evidências completas, atuais e vinculadas à versão para os requisitos de alto risco aplicáveis, sistema de gerenciamento de qualidade, documentação técnica, declaração, registro, marcação, monitoramento pós-mercado e obrigações de cadeia de valor.

1.1049 Explicação em linguagem simples

Uma revisão de prontidão é um controle interno. Não substitui a avaliação de conformidade legalmente exigida, o envolvimento do corpo notificado, o procedimento do setor de produtos, a revisão de vigilância de mercado ou a decisão de autoridade competente. Seu objetivo é identificar lacunas antes da avaliação ou liberação formal e impedir que um sistema seja apresentado como conforme quando o processo legal aplicável não for concluído.

1.1050 Requisitos de revisão

Confirmar, conforme aplicável:

1. Identidade do fornecedor, representante autorizado, fabricante do produto, importador, distribuidor e outras funções relevantes do ator;
2. Finalidade prevista, versão do sistema, classificação de alto risco e se se aplica o artigo 6.o, n.o 1, o artigo 6.o, n.o 2, o anexo I ou o anexo III;
3. A rota de conformidade aplicável nos termos do artigo 43.o, incluindo a aplicação da legislação sectorial sobre produtos ou a participação de organismos notificados;
4. A data, a transição e a posição de alteração aplicáveis nos termos do artigo 113.o e do Regulamento (UE) 2026/1744;
5. O cumprimento dos artigos 9.o15.o e das obrigações do prestador previstas nos artigos 16.o, se for caso disso;
6. Gestão da qualidade, gestão de riscos, gestão de dados, gestão de dados, documentação técnica, registro, instruções, supervisão, precisão, robustez e provas de cibersegurança;
7. Evidências de validação e teste ligadas à versão de produção;
8. Declaração de conformidade da UE, marcação CE e prontidão para registro quando legalmente exigido;
9. Acompanhamento pós-comercialização, prevenção de incidentes graves, medidas corretivas e medidas de retenção de registros;
10. informações sobre a cadeia de valor, suporte contratual e evidências representativas autorizadas;
11. não conformidades não resolvidas, desvios, ações corretivas e decisões de risco residual;
12. aprovação formal para submeter-se à avaliação da conformidade ou liberação após a conclusão do processo legalmente exigido.

1.1051 Exemplo GlobalWay

Antes de lançar um sistema de alocação de funcionários de alto risco sob seu próprio nome, a GlobalWay confirma que assumiu o papel de provedor. Ele identifica se o sistema se enquadra no Anexo III, confirma a rota e a data de conformidade aplicáveis, verifica a documentação do Anexo IV, o SGQ e as evidências de teste, completa as etapas de registro e declaração, quando aplicável, e estabelece monitoramento pós-comercialização antes do lançamento.

1.1052 Atividade de controlo

A conformidade deve operar um portão de prontidão documentado antes que qualquer sistema de alto risco seja submetido para avaliação de conformidade ou liberado. Falta de evidência obrigatória, um ator não resolvido ou questão de classificação, uma rota de conformidade incorreta ou uma avaliação legalmente exigida incompleta é um bloqueador de liberação. A aprovação interna não deve ser descrita como certificação ou avaliação de conformidade, a menos que tenha o status legal exigido pelo procedimento aplicável.

1.1053 Provas

- análise de ator, classificação e aplicabilidade;
- Memorando de conformidade-rota e data de aplicação;
- checklist de prontidão;
- índice de documentação técnica e mapeamento do anexo IV;
- QMS, gestão de risco, testes e provas de validação;
- instruções, registros, supervisão e monitoramento de evidências;
- Registos de organismos notificados ou de avaliação sectorial, se aplicável;
- Registos de declaração, registro e marcação;
- log de lacunas, ações corretivas e evidências de fechamento;
- liberação e aprovação pós-mercado.

1.1054 Teste de auditoria

Confirme que a revisão de prontidão identificou o ator correto, classificação, rota e data de aplicação; não substituiu a avaliação externa ou setorial necessária; testou evidências completas e ligadas à versão; e bloqueou a liberação até que lacunas obrigatórias e etapas de conformidade fossem resolvidas.

1.1055 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada, incluindo os artigos 6.º, 9.º, 22.º, 43.º, 47.º, 49.º, 71.º, 73, 113.º, anexos I, III, IV, VI e VII, conforme aplicável.

- Regulamento (UE) n.º 2026/1744, incluindo alterações que afetem as datas, o âmbito e os procedimentos de aplicação.
- Legislação de harmonização aplicável da União constante do anexo I e requisitos de avaliação da conformidade sectorial conexos.
- As normas harmonizadas e as especificações comuns devem ser identificadas pelo seu estatuto jurídico real e disponibilidade; os critérios de prontidão interna não devem ser apresentados como lei vinculativa por si mesmos.
- O texto consolidado atual do EUR-Lex controla resumos e rascunhos mais antigos.

1.1056 Capítulo 119 Auditoria Interna

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla sobre o conflito anterior Capítulo 119 linguagem de rascunho.

1.1057 Exigência

A Lei de IA da UE não impõe uma função de auditoria interna autônoma e universal em todas as organizações. As organizações que mantêm auditoria interna, garantia independente ou revisão de terceira linha comparável devem usá-la para fornecer garantia baseada em risco sobre a governança da IA, conformidade legal, design de controle, eficácia operacional, qualidade de evidência, gerenciamento de questões e relatórios de gerenciamento. A auditoria interna deve permanecer independente das atividades que analisa e não substitui a avaliação de conformidade, o envolvimento do corpo notificado, a supervisão de autoridade competente, a nível de mercado ou de mercado.

1.1058 Explicação em linguagem simples

A auditoria interna deve testar se o ambiente de controle da IA realmente funciona, não apenas se existem políticas. Seu escopo e amostragem devem refletir o papel legal, a classificação do sistema, a jurisdição, o estágio do ciclo de vida, a dependência do fornecedor, as pessoas afetadas, incidentes, reclamações, alterações e descobertas anteriores. A existência de um forte programa de auditoria interna pode apoiar a governança e a qualidade das evidências, mas não prova por si só a conformidade legal.

1.1059 Requisitos de auditoria

Definir, conforme apropriado:

1. Um mandato aprovado, independência organizacional e acesso irrestrito a evidências relevantes, sujeito a controles legais de confidencialidade e privilégio;
2. pessoal multidisciplinar competente e acesso a especialistas técnicos, legais, de privacidade, segurança, acessibilidade e setor;

3. um universo e plano de auditoria de IA baseado em risco;
4. cobertura de sistemas, modelos, versões, papéis de ator, jurisdições, fornecedores e estágios do ciclo de vida;
5. métodos de design-efetividade e operacional-efetividade;
6. validação da população, amostragem defensável e critérios de qualidade de evidência;
7. validação técnica, reprodutibilidade e revisão especializada quando necessário;
8. gradação, análise de causa-raiz, escalada e resposta de gerenciamento;
9. Rastreamento de remediação e validação de encerramento independente;
10. Reportar ao conselho de administração, ao comitê de auditoria ou a outro órgão de governança apropriado;
11. acompanhamento, garantia de qualidade e melhoria periódica do programa;
12. onde o gerenciamento restringe o escopo, o acesso a evidências ou a correção oportuna.

1.1060 Exemplo GlobalWay

A Auditoria Interna GlobalWay amostras de sistemas de recrutamento, assistência ao viajante e fraude de alto risco. Testa decisões de ator e classificação, controles de provedores e implantadores, evidências de fornecedores, supervisão humana, registro, monitoramento, transparência, incidentes e fechamento de ações corretivas. Confirma separadamente que seu trabalho não substitui qualquer avaliação de conformidade ou revisão de autoridade necessária.

1.1061 Atividade de controle

O comitê de auditoria aprova um plano de auditoria de IA baseado em risco e recebe resultados significativos, correção atrasada, risco residual aceito, tendências recorrentes de falha de controle, limitações de escopo e incerteza jurídica não resolvida. A administração deve preservar a propriedade da conformidade e correção, mesmo quando a Auditoria Interna fornece garantia.

1.1062 Provas

- Carta de auditoria, declaração de independência e plano;
- universo de auditoria de IA e avaliação de risco;
- competência, suporte especializado e registros de conflitos;
- documentos de trabalho, validação da população e raciocínio de amostragem;
- resultados, base jurídica e relatórios;

- respostas de gestão e planos de ação;
- Remediação e validação de encerramento independente;
- relatórios de auditoria-comitê ou conselho de administração;
- Registros de escopo-limitação e escalada;
- Revisão de garantia de qualidade interna.

1.1063 Teste de auditoria

Revise o programa de auditoria interna. Confirme que seu mandato e a linha de relatório apoiam a independência, seu escopo reflete riscos reais de IA e papéis regulamentados, suas evidências e amostras são suficientes, seus revisores têm competência apropriada, questões significativas são escaladas e o fechamento é validado de forma independente. Confirme que os relatórios não descrevem a auditoria interna como substituindo a avaliação da conformidade, a revisão do corpo notificado ou a supervisão regulatória.

1.1064 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo as disposições aplicáveis sobre gestão da qualidade, documentação técnica, manutenção de registros, avaliação da conformidade, monitorização pós-comercialização, medidas corretivas, cooperação e acesso à autoridade.
- Regulamento (UE) n.o 2026/1744, sempre que as suas alterações afetem as obrigações, procedimentos ou datas relevantes.
- Os padrões profissionais de auditoria interna e de garantia não são vinculativos, a menos que sejam incorporados através de outro requisito legal, contratual ou setorial vinculativo.
- A estrutura de auditoria interna neste capítulo é uma prática de governança e garantia, não uma função autônoma universal expressamente mandatada pelo AI Act.
- Textos oficiais consolidados atuais controlam resumos e rascunhos mais antigos.

1.1065 Capítulo 120 Preparação para Exame Regulatório

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 120 linguagem de rascunho.

1.1066 Exigência

As organizações sujeitas ao Ato de Inteligência Artificial da UE devem ser capazes de fornecer às autoridades competentes, às autoridades de fiscalização do mercado, ao Escritório de Inteligência Artificial e a outros órgãos legalmente autorizados as informações, registros, acesso, explicações e cooperação exigidas pela lei aplicável. As práticas de

preparação para exames neste capítulo são medidas de governança que apoiam esses deveres; elas não são um regime de exame estatutário separado.

1.1067 Explicação em linguagem simples

Um regulador pode solicitar documentos, registros, evidências técnicas, registros de incidentes, avaliações de risco, explicações, acesso a sistemas ou cooperação com testes. A organização deve ser capaz de responder com precisão, segurança, consistência e dentro do prazo legal aplicável sem improvisar ou fornecer evidências incompletas ou contraditórias.

1.1068 Requisitos de prontidão

Manter no mínimo:

1. um mapa atual de entidades jurídicas, funções, sistemas, modelos, versões e jurisdições;
2. Os proprietários e suplentes de respostas regulatórias nomeados;
3. Um índice verificado de documentação técnica, registros, declarações, registros, registros de monitoramento, incidentes, reclamações, ações corretivas e contratos;
4. Procedimentos para preservar privilégios, confidencialidade, segredos comerciais, dados pessoais e informações sensíveis à segurança durante o cumprimento dos deveres de divulgação;
5. Evidência-integridade, cadeia-de-custodia, controle de versão e procedimentos legais;
6. verificação de autoridade e identidade antes da divulgação;
7. Controles seguros de transferência, acesso e trilhos de auditoria;
8. Verificação de fatos, revisão legal e aprovação executiva de submissões, quando apropriado;
9. Procedimentos para entrevistas, demonstrações, acesso no local, testes e perguntas de acompanhamento;
10. a escalada de problemas quando os registros estão faltando, inconsistentes, inacessíveis ou potencialmente imprecisos;
11. ações corretivas pós-exame e lições aprendidas.

1.1069 Exemplo GlobalWay

A GlobalWay recebe um pedido de informação sobre um sistema de alocação de funcionários de alto risco. Sua equipe de resposta verifica a autoridade, preserva registros relevantes, reúne o arquivo técnico vinculado à versão, registros, resultados de monitoramento, histórico de incidentes, evidências de fornecedores e aprovações de liberação e documenta todas as ações de divulgação e acompanhamento.

1.1070 Atividade de controlo

Os exercícios devem verificar a disponibilidade de evidências, a propriedade da resposta, a divulgação segura, a consistência factual e a escalada de lacunas não resolvidas.

1.1071 Provas

- Procedimento de regulação-resposta e matriz de responsabilidade;
- registro de verificação de autoridade;
- índice de evidência e divulgação;
- Registros legais e de preservação;
- Aprovações de submissão e correspondência;
- Registros de transferência e acesso seguros;
- registros de preparação de entrevistas e demonstrações;
- log de lacunas, ações corretivas e lições aprendidas.

1.1072 Teste de auditoria

Confirme que a organização verificou a autoridade, preservou e produziu evidências precisas ligadas à versão, protegeu informações legalmente sensíveis adequadamente, cumpriu prazos aplicáveis e corrigiu as fraquezas identificadas.

1.1073 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, alterado pelo Regulamento (UE) 2026/1744, quando aplicável: disposições sobre documentação, registros, registos, registo, fiscalização do mercado, poderes de autoridade, acesso a dados e documentação, testes, cooperação, investigações e execução.
- Regulamento (UE) 2016/679 e outros requisitos aplicáveis de confidencialidade, privacidade legal-profissional-privilegio, segurança cibernética, emprego, segurança do produto e requisitos do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1074 Capítulo 121 - Achados, Remediação e Encerramento

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 121 linguagem de rascunho.

1.1075 Exigência

As organizações devem abordar não conformidades identificadas, falhas de controle, incidentes, reclamações, observações de autoridade e outras deficiências relacionadas à IA por meio de contenção oportuna, análise de causa raiz, correção proporcional, validação, atualizações de documentação

e encerramento responsável. O fluxo de trabalho detalhado neste capítulo é uma prática de governança e garantia, a menos que uma disposição legal específica, decisão de autoridade, obrigação de avaliação de conformidade, contrato ou regra do setor torne um passo obrigatório.

1.1076 Explicação em linguagem simples

O encerramento requer evidências de que o problema foi contido, a causa foi abordada, os sistemas afetados e as pessoas foram consideradas, a correção trabalhada, documentação relacionada e controles foram atualizados e o risco residual foi aceito pela autoridade adequada.

1.1077 Requisitos de reparação

Cada registro de descoberta deve incluir:

1. fonte, data, gravidade, relevância legal e obrigação afetada;
2. sistemas, modelos, versões, dados, fornecedores, decisões, pessoas e jurisdições afetados;
3. Contenção imediata e salvaguardas provisórias;
4. Reportabilidade, notificação, retirada, recall, suspensão e análise da pessoa afetada, quando aplicável;
5. causa raiz e fatores contribuintes;
6. ações corretivas e preventivas, proprietários, recursos e prazos;
7. Critérios de validação, revisor independente e plano de reteste;
8. Atualizações de avaliações de risco, documentação técnica, registros, procedimentos, treinamento, avisos, contratos e monitoramento;
9. Risco residual e decisão de exceção;
10. aprovação de fechamento, período de monitoramento e critérios de reabertura.

1.1078 Exemplo GlobalWay

A GlobalWay suspende recomendações automatizadas, preserva evidências, avalia os candidatos afetados, determina por que os controles de mudança falharam, restaura a configuração aprovada, testa novamente o sistema, atualiza a documentação e os controles do fornecedor e monitora a liberação corrigida antes do fechamento.

1.1079 Atividade de controle

Todas as descobertas materiais devem ser registradas em um registro controlado, atribuídas a proprietários responsáveis, priorizadas pelo risco, escaladas quando vencidas e fechadas somente após validação baseada em evidências. Descobertas de alto risco e regulatórias exigem revisão independente do fechamento.

1.1080 Provas

- registo de resultados;
- registos de contenção e impacto;
- análise de causa-raiz;
- plano de remediação e aprovações;
- validação e reteste de provas;
- Documentação e controlos atualizados;
- decisão de risco residual;
- resultados de aprovação e monitoramento de fechamento.

1.1081 Teste de auditoria

Confirme que a gravidade era suportável, a contenção era oportuna, a causa raiz e o escopo afetado estavam completos, a correção abordou a causa, a validação foi independente quando apropriado, os artefatos relacionados foram atualizados e o fechamento não ocorreu antes da eficácia ser demonstrada.

1.1082 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: prestador, despachante, gestão da qualidade, monitorização, incidente grave, ação corretiva, retirada, recall, vigilância do mercado, documentação e disposições de cooperação de autoridade.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor, requisitos contratuais e do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1083 Capítulo 122 Al Gabinete e Autoridades Nacionais

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 122 anterior.

1.1084 Exigência

As organizações devem identificar quais autoridades nacionais e da UE podem ter jurisdição sobre suas atividades de IA e devem cooperar com essas autoridades na medida exigida pela lei aplicável. Os procedimentos internos de mapeamento e resposta das autoridades são práticas de governança que apoiam a conformidade legal; eles não alteram a alocação legal de poderes.

1.1085 Explicação em linguagem simples

A responsabilidade pode envolver o Gabinete de IA da Comissão Europeia, autoridades nacionais competentes, autoridades de fiscalização do mercado,

autoridades de proteção de dados, reguladores de segurança de produtos, reguladores do setor, autoridades trabalhistas, autoridades de consumo ou tribunais. A autoridade correta depende do papel, tipo de sistema, setor, jurisdição e questão da IA.

1.1086 Requisitos de governação

Manter no mínimo:

1. Um mapa de jurisdição e autoridade para cada sistema material de IA;
2. identificação de funções de provedor, de implantador, importador, distribuidor, representante autorizado e GPAI;
3. proprietários nomeados para correspondência regulamentar e escalada;
4. Procedimentos para verificação de autoridade, mandato e escopo de solicitação;
5. coordenação entre equipes Jurídicas, Compliance, Privacidade, Segurança, Produto, RH, Compras e operacionais;
6. controles para submissões consistentes em várias autoridades;
7. preservação e divulgação de evidências seguras;
8. acompanhamento de prazos, compromissos, ações corretivas e pedidos de acompanhamento;
9. procedimentos para conflitos de lei, sobreposição de jurisdição e escalada de aconselhamento;
10. revisão periódica quando leis, papéis, produtos ou jurisdições operacionais mudam.

1.1087 Exemplo GlobalWay

A GlobalWay mapeia a responsabilidade por um sistema de recrutamento utilizado em vários Estados-Membros, identificando as autoridades nacionais relevantes de fiscalização do mercado e de trabalho, as autoridades de proteção de dados para questões de dados pessoais e o Gabinete de IA, onde as obrigações do modelo GPAI ou a coordenação a nível da União podem ser relevantes.

1.1088 Atividade de controlo

Legal e Compliance devem manter um mapa de autoridade atual e verificá-lo antes de enviar notificações, registros, relatórios de incidentes ou respostas. A jurisdição incerta deve ser escalada em vez de adivinhada.

1.1089 Provas

- Registro de autoridade e jurisdição;
- Avaliação legal-função;
- matriz reguladora-contato;

- Registro de correspondência e submissão;
- Registros de verificação de autoridade;
- Registos de escalonamento e de aconselhamento jurídico;
- rastreamento de ação corretiva;
- Histórico de revisão periódica.

1.1090 Teste de auditoria

Confirme que a organização identificou autoridades relevantes com base em funções e atividades reais, encaminhou as submissões corretamente, preservou evidências consistentes, cumpriu os prazos aplicáveis e escalou a jurisdição incerta ou sobreposta adequadamente.

1.1091 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, alterado pelo Regulamento (UE) 2026/1744, se aplicável: disposições que estabelecem o Gabinete de IA, o Conselho Europeu de Inteligência Artificial, as autoridades nacionais competentes, as funções de fiscalização do mercado, a cooperação, a supervisão e a execução.
- Regulamento (UE) 2019/1020 e outros quadros de supervisão aplicáveis da União e nacionais.
- Textos oficiais consolidados atuais e medidas nacionais de designação aplicáveis controlam resumos mais antigos.

1.1092 Capítulo 123 Autoridades de fiscalização do mercado

** Status legal: ** Corrigido o mestre inglês para consolidação. Este arquivo controla o conflito anterior Capítulo 123 linguagem de rascunho.

1.1093 Exigência

Provedores, implantadores, importadores, distribuidores, representantes autorizados e outros atores relevantes devem cooperar com as autoridades de fiscalização do mercado na medida exigida pela Lei de Inteligência Artificial da UE, Regulamento (UE) 2019/1020 e legislação nacional aplicável. Os controles de prontidão interna neste capítulo apoiam esses deveres e não limitam os poderes estatutários de uma autoridade.

1.1094 Explicação em linguagem simples

As autoridades de fiscalização do mercado podem examinar se um sistema de IA cumpre os requisitos aplicáveis, solicitar registros e informações, obter acesso, realizar avaliações ou testes, exigir ações corretivas, restringir disponibilidade ou uso ou coordenar com outras autoridades. As organizações devem ser capazes de identificar sistemas e versões afetados, preservar evidências e responder de forma legal e precisa.

1.1095 Requisitos de prontidão

Manter no mínimo:

1. Um inventário actual dos sistemas de IA regulamentados e dos operadores económicos responsáveis;
2. conformidade, declaração, registro, marcação e registros pós-mercado aplicáveis;
3. documentação técnica, registros, gerenciamento de riscos, SGQ, monitoramento e evidências de incidentes;
4. Procedimentos para pedidos de autoridade, acesso, testes, entrevistas e visitas ao local;
5. Preservação e divulgação seguras de registros, incluindo salvaguardas de segredo comercial e de dados pessoais compatíveis com a lei;
6. identificação rápida de modelos afetados, versões do sistema, clientes, implantações e jurisdições;
7. procedimentos de ação corretiva, suspensão, retirada, recall e comunicação;
8. escalada por suspeita de incumprimento, incidentes graves ou risco sistémico;
9. acompanhamento de instruções de autoridade, prazos, compromissos e provas de encerramento;
10. coordenação com organismos notificados, fornecedores, clientes e outras autoridades, quando legalmente relevante.

1.1096 Exemplo GlobalWay

A GlobalWay verifica o pedido, preserva a versão de produção relevante e registra, fornece o arquivo técnico e a evidência de monitoramento, coordena com o provedor e o organismo notificado, onde aplicável, e rastreia todas as ações corretivas e prazos.

1.1097 Atividade de controlo

Os sistemas de IA de materiais devem ter pacotes de evidências vinculados à versão e proprietários de respostas nomeados capazes de apoiar o acesso da autoridade, testes, ações corretivas e comunicações.

1.1098 Provas

- sistema e inventário econômico-operador;
- Registos de conformidade e registo;
- ndice de evidência técnica e pós-comercialização;
- correspondência de autoridade e logs de acesso;
- registros de preservação e divulgação;
- Registros de ação corretiva e restrição;

- comunicações com clientes e pessoas afetadas;
- Evidências de encerramento e acompanhamento.

1.1099 Teste de auditoria

Confirme se os sistemas e versões afetados foram identificados, as evidências foram completas e precisas, a divulgação foi segura, as instruções de autoridade foram rastreadas e as ações corretivas foram implementadas e validadas dentro dos prazos aplicáveis.

1.1100 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, alterado: vigilância do mercado, acesso à autoridade, testes, avaliação, cooperação, ação corretiva, restrição, retirada, recall e disposições de execução.
- Regulamento (UE) 2019/1020, conforme aplicável.
- Textos oficiais consolidados atuais e medidas nacionais de implementação ou designação aplicáveis controlam resumos mais antigos.

1.1101 Capítulo 124 Investigações e Pedidos de Informação

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 124 linguagem de rascunho.

1.1102 Exigência

As organizações devem responder a investigações legalmente válidas e solicitações de informações dentro do escopo, maneira e prazo exigido pela lei aplicável. Os controles internos de investigação-resposta são práticas de governança que suportam precisão, preservação, cooperação, confidencialidade e responsabilidade; eles não estreitam ou expandem os poderes estatutários de uma autoridade.

1.1103 Explicação em linguagem simples

Uma investigação pode envolver documentos, registros, informações de origem, modelo ou acesso ao sistema, entrevistas, testes, explicações, incidentes, reclamações, contratos ou evidências sobre pessoas afetadas. Uma resposta apressada ou descoordenada pode criar problemas legais, factuais, de privacidade, segurança e credibilidade.

1.1104 Requisitos de resposta

Manter no mínimo:

1. Procedimentos para verificar a autoridade requerente, base jurídica, âmbito, prazo e método de entrega;

2. Medidas imediatas de preservação e de manutenção legal;
3. identificação de sistemas, modelos, versões, dados, fornecedores, decisões, pessoas e jurisdições afetados;
4. uma equipe de resposta com representação jurídica, conformidade, privacidade, segurança, técnica, registros e negócios;
5. coleta de fatos, verificação de origem, controle de versão e cadeia de custódia;
6. controles de privilégio, segredos comerciais, dados pessoais, informações comerciais confidenciais e material sensível à segurança consistente com a lei;
7. Divulgação segura, registro de acesso e aprovação de submissão;
8. Procedimentos para entrevistas, demonstrações, testes técnicos e perguntas de acompanhamento;
9. escalada de evidências ausentes, contraditórias, inacessíveis ou potencialmente imprecisas;
10. acompanhamento de compromissos, ações corretivas, prazos e monitoramento pós-investigação.

1.1105 Exemplo GlobalWay

A GlobalWay recebe um pedido relativo a suposta discriminação em um sistema de triagem de recrutamento. Ela preserva as versões relevantes do modelo, registros de candidatos, registros, evidências de revisão humana, documentação do fornecedor, reclamações e resultados de validação; verifica os fatos; coordena a divulgação legal; e registra todas as ações de submissão e acompanhamento.

1.1106 Atividade de controle

Nenhum funcionário pode fornecer representações técnicas, legais ou factuais não verificadas em nome da organização fora do processo de resposta aprovado.

1.1107 Provas

- solicitação e registro de verificação de autoridade;
- Registro legal de retenção e preservação;
- recolha de provas e registo da cadeia de custódia;
- Cronologia de fatos e números;
- Registros de revisão e aprovação;
- Pacote de submissão e logs de transferência segura;
- entrevistas e registros de testes;
- compromissos, ações corretivas e evidências de fechamento.

1.1108 Teste de auditoria

Inspecione investigações anteriores ou solicitações simuladas. Confirme que a organização verificou autoridade e escopo, preservou evidências prontamente, produziu informações precisas ligadas à versão, protegeu material sensível adequadamente, cumpriu prazos aplicáveis e acompanhou compromissos e correção ao fechamento.

1.1109 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: poderes de autoridade aplicáveis, acesso à documentação e dados, testes, investigação, cooperação, vigilância do mercado, monitoramento, incidentes, ações corretivas e disposições de aplicação.
- Regulamento (UE) 2019/1020 e direito processual nacional aplicável.
- Regulamento (UE) 2016/679 e outros requisitos aplicáveis de confidencialidade, segurança cibernética, privilégio, emprego, segurança de produtos e requisitos do setor.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1110 Capítulo 125 Multas Administrativas e Exposição

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 125 linguagem de rascunho.

1.1111 Exigência

As organizações devem entender e governar a exposição a multas administrativas e outras consequências da aplicação da lei da UE AI e leis relacionadas. A exposição fina depende da disposição legal violada, do ator regulamentado, dos fatos, do tamanho e do volume de negócios da organização, da gravidade e duração da infração, cooperação, ação corretiva, infrações anteriores e outros fatores considerados pela autoridade competente.

1.1112 Explicação em linguagem simples

Os tetos de penalidade não são resultados automáticos. As autoridades avaliam a infração e as circunstâncias específicas. As organizações não devem reduzir a exposição à aplicação de uma única porcentagem ou assumir que o pagamento de uma multa resolve outras consequências, como ordens corretivas, retirada, recall, suspensão, litígio, reivindicações contratuais ou danos à reputação.

1.1113 Requisitos de avaliação da exposição

Avaliar no mínimo:

1. a disposição legal e a obrigação do ator potencialmente violada;

2. a categoria fina máxima aplicável e a base de cálculo;
3. O volume de negócios anual mundial e as considerações do grupo empresarial, sempre que legalmente relevante;
4. gravidade, duração, escopo, intenção, negligência e pessoas afetadas;
5. Infrações anteriores e falhas de controlo repetido;
6. cooperação, preservação de evidências, notificação e remediação;
7. ganhos obtidos ou perdas evitadas;
8. sobrepor-se ao GDPR, ao consumidor, ao emprego, à segurança cibernética, à segurança dos produtos, à concorrência e à aplicação do setor;
9. Medidas não monetárias, incluindo restrição, retirada, recall, suspensão ou exposição à remoção do mercado;
10. Limites de seguro, alocação contratual, indenização e recuperação;
11. implicações contábeis, de divulgação e de reservas legais;
12. Conselho e Escalada Executiva.

1.1114 Exemplo GlobalWay

A GlobalWay identifica que um sistema de recrutamento de alto risco pode ter sido implantado sem evidência de conformidade completa. Legal avalia as disposições aplicáveis do AI Act, papel do ator, possível categoria fina, candidatos afetados, avisos prévios, status de remediação, exposição relacionada ao GDPR e o risco de suspensão ou ordens corretivas antes de aconselhar os executivos.

1.1115 Atividade de controlo

Legal e Compliance devem manter uma matriz atual de exposição à aplicação da lei ligada ao inventário de IA, papel do ator, disposições aplicáveis, registros de incidentes e deficiências e limiares de escalada. A exposição estimada deve ser claramente rotulada como preliminar e não deve ser apresentada como uma decisão de autoridade prevista.

1.1116 Provas

- Avaliação legal-exposição;
- Análise de categoria fina aplicável;
- Registros de rotatividade e entidade;
- evidência de incidente, reclamação e correção;
- Correspondência;
- Conselho de Administração e Escalada Executiva;
- análise contábil e de divulgação;
- lições aprendidas e controle de atualizações.

1.1117 Teste de auditoria

Selecione questões significativas de conformidade com a IA e confirme que a Legal identificou o ator correto, a provisão, a categoria fina, os fatores agravantes e atenuantes, os regimes de aplicação relacionados, as consequências não monetárias, a escalada e o status de correção.

1.1118 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo os artigos 99.o a 101.o e outras disposições aplicáveis em matéria de execução.
- Regulamento (UE) n.o 2026/1744, incluindo alterações que afetem a execução e a aplicação, quando aplicável.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.
- Regimes legais relacionados devem ser avaliados separadamente; a exposição cumulativa ou paralela depende dos fatos e da lei aplicável.

1.1119 Capítulo 126 Escalação Executiva

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 126 linguagem de rascunho.

1.1120 Finalidade

Este capítulo define como os riscos materiais de IA, incidentes, falhas de conformidade, questões regulatórias e deficiências de controle não resolvidas devem ser escalados para a gerência sênior e o conselho.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1121 Exigência

As organizações devem operar um processo documentado de escalonamento executivo baseado em risco para questões legais, de segurança, direitos fundamentais, segurança cibernética, operacionais, financeiras e de reputação. A escalada executiva é um controle de governança que suporta deveres estatutários, mas não é, por si só, uma obrigação autônoma da Lei de IA da UE, a menos que esteja ligada a um dever específico do ator, processo de gerenciamento de qualidade, requisito de relatório de incidentes, ação corretiva, atividade de monitoramento pós-mercado, obrigação de conformidade, ou solicitação.

A escalada deve ocorrer cedo o suficiente para que os líderes autorizados restrinjam, suspendam, corrijam, divulguem, retirem, lembrem ou aceitem o risco antes que o dano ou a não conformidade aumente.

1.1122 Explicação em linguagem simples

A escalada não é simplesmente encaminhar um e-mail. É uma transferência controlada de uma decisão material para uma pessoa com autoridade, informação, independência e recursos para agir. Os executivos precisam de informações oportunas e prontas para a decisão quando um problema de IA pode exigir suspensão, notificação, remediação, retirada, recall, comunicação com o cliente, engajamento regulatório ou aceitação de risco residual significativo.

A escalada atrasada, incompleta ou informal pode transformar uma questão de controle gerenciável em um incidente grave ou questão de execução. A escalada deve, portanto, ser baseada em limiares definidos, em vez de julgamento informal sozinho.

1.1123 gatilhos de escalada

Escalar proporcionalmente quando houver:

- suspeita de prática de IA proibida;
- um incidente grave ou risco credível de danos significativos;
- uma preocupação material de direitos fundamentais, segurança, discriminação, privacidade ou segurança cibernética;
- incerteza de classificação de alto risco que afeta a implantação;
- Falha nos critérios de conformidade, validação ou desempenho técnico;
- incapacidade de fornecer a supervisão humana necessária;
- desvio de modelo significativo ou comportamento inesperado;
- Falha do fornecedor de material ou alteração não aprovada;
- um inquérito regulamentar, investigação, inspeção ou pedido de informação urgente;
- Um prazo regulamentar ou obrigação de notificação não cumpridos;
- destruição, ocultação, falsificação ou preocupação com a integridade;
- Resultados repetidos ou atrasados de alta gravidade;
- Uma exceção fora do apetite de risco aprovado;
- Possível exposição financeira ou de reputação.

1.1124 Níveis de escalação

1.1124.1 Escalada operacional

Use a escalada operacional para questões que podem ser contidas e resolvidas pelo produto, tecnologia, risco, conformidade ou proprietário do negócio responsável dentro das tolerâncias aprovadas.

1.1124.2 Escalada executiva

Escalada de uso executivo para questões materiais que exigem autoridade multifuncional, recursos adicionais, restrição de implantação, remediação do cliente, estratégia legal, aceitação de risco significativo ou engajamento regulatório.

1.1124.3 Escalada do Conselho ou Comissão

Use a escalação do conselho ou comitê para assuntos envolvendo apetite de risco empresarial, incidentes graves, práticas proibidas, grande exposição regulatória, impacto financeiro significativo, falha de gerenciamento repetida ou decisões estratégicas sobre continuação, retirada ou recall.

1.1125 Requisitos mínimos de escalada

Defina no mínimo:

1. Limites de gravidade e urgência;
2. gatilhos legais, de segurança, direitos, privacidade, segurança cibernética, financeiros, de reputação e operacionais;
3. executivos responsáveis e suplentes;
4. Factos, incertezas e provas exigidos;
5. sistemas, versões, atores, jurisdições, fornecedores, serviços e pessoas afetados;
6. Autoridade de contenção imediata e de paragem;
7. Notificação, conformidade, ação corretiva, retirada e implicações de recall;
8. Prazos de decisão e canais de comunicação;
9. salvaguardas de conflito de interesses e independência;
10. decisão, dissidência, raciocínio, proprietário e registros de prazo;
11. Critérios de escalonamento do conselho de administração ou da comissão;
12. requisitos de verificação e encerramento de acompanhamento.

1.1126 Pacote de escalada exigido

Fornecer:

- uma declaração concisa;
- sistema, modelo, versão, proprietário e jurisdições;
- desencadeamento de evento e cronograma;
- pessoas, direitos e serviços empresariais afetados;
- fatos conhecidos, suposições, incertezas e lacunas de evidências;
- obrigações legais, políticas, contratuais e de risco aplicáveis;
- Classificação de risco atual e potenciais consequências;

- contenção já realizada;
- opções de decisão e trocas;
- Ação recomendada;
- proprietário responsável e prazo exigido;
- Implicações de comunicação e notificação.

1.1127 Opções de decisão

Os líderes autorizados podem:

- continuar com o monitoramento aprimorado;
- Restringir usuários, dados, geografia ou funcionalidade;
- Requer revisão humana adicional;
- suspender a implantação ou operação;
- Voltar para uma versão conhecida;
- Notificar pessoas, clientes, parceiros, seguradoras ou autoridades afetadas;
- Validação ou investigação independente da comissão;
- terminar ou substituir um fornecedor;
- Aceitar o risco residual dentro da autoridade delegada;
- retirar ou recuperar o sistema.

1.1128 Disciplina de comunicação

Os registros de escalação devem ser factuais, concisos, rastreáveis e sinceros sobre a incerteza. Evite minimizar o problema, exagerar a certeza ou apresentar um resultado preferencial como a única opção. As comunicações sensíveis devem seguir requisitos legais, de confidencialidade, gerenciamento de registros e privilégios.

Nenhuma escalada pode ser fechada apenas porque a questão foi discutida. O encerramento requer decisões documentadas, ações concluídas, evidências verificadas e aprovação responsável.

1.1129 Exemplo de GlobalWay Travel Services

GlobalWay detecta que um sistema de alocação de funcionários está produzindo resultados adversos inexplicáveis após uma atualização do fornecedor. O problema é escalado para Legal, Compliance, RH, Segurança, o executivo responsável e o comitê de risco. Recomendações automatizadas são suspensas na pendência de análise de impacto, investigação de fornecedores, salvaguardas de funcionários e uma decisão de liberação documentada.

O comitê executivo recebe a versão afetada, fatos conhecidos, perguntas abertas, implicações legais, status de contenção, opções de decisão e prazos responsáveis. O assunto permanece aberto até que as ações corretivas

sejam validadas de forma independente e o comitê aprove qualquer reinicialização.

1.1130 Atividades de controle

- Definir limiares de materialidade e níveis de escalada.
- Atribuir direitos de decisão e alternativas.
- Mantenha caminhos de emergência para assuntos graves.
- Exigir um pacote de escalonamento padronizado.
- Registro de decisões, lógica, condições e dissidência.
- Acompanhe as ações e prazos necessários.
- Escale a correção atrasada ou ineficaz.
- Exigir provas verificadas antes do encerramento.
- Reveja o desempenho da escalada após incidentes e exercícios.

1.1131 Provas

- política de escalada, padrão e limiares;
- matriz de autoridade e de direitos de decisão;
- registro de incidente ou deficiência;
- registros de escalada e briefing packs;
- atas de reuniões, decisões e registros de dissidência;
- Restrições, suspensões, rollback, retiradas ou aprovações de recall;
- Evidência de contenção e comunicação;
- relatórios do executivo e do conselho;
- proprietários de ações e rastreadores de prazo;
- decisões de notificação e correspondência do regulador;
- Evidência de encerramento e validação;
- Revisões pós-incidente;
- exercícios de escalada e registros de treinamento.

1.1132 Testes de auditoria

1. Selecione problemas materiais de IA e confirme que a escalada ocorreu dentro de limites e cronogramas definidos.
2. Verificar se os tomadores de decisão tinham autoridade apropriada, independência e informações suficientes.
3. Confirme os briefing em pacotes de fatos distintos, suposições, incertezas e lacunas de evidências.
4. Trace as decisões de contenção, remediação, notificação, retirada, recall e evidência de fechamento.
5. Confirme que as descobertas atrasadas de alta gravidade foram intensificadas.
6. Revisar se o relatório do conselho ou do comitê atendeu aos critérios estabelecidos.

7. Teste os caminhos de escalada de emergência por meio de simulação ou registros.
8. Confirmar o fechamento foi apoiado por evidências verificadas, em vez de apenas discussão.
9. Confirmar as aulas de escalada resultou em melhorias de limiar, processo, controle ou treinamento.

1.1133 Métricas

- tempo desde a detecção até a escalada executiva;
- tempo de escalada para decisão;
- problemas materiais não escalados a tempo;
- Ações executivas atrasadas;
- Sistemas restritos, suspensos, retirados ou recuperados;
- Repetir problemas após decisão executiva;
- AI-reportável importa;
- Exercícios de escalada de emergência concluídos;
- escaladas com pacotes de evidências incompletas;
- As escalações foram encerradas sem validação independente.

1.1134 Lista de verificação de gestão

- Os limiares de materialidade são claros e compreendidos?
- Questões urgentes podem chegar a um executivo autorizado imediatamente?
- O pacote de escalada distingue fatos, suposições e incógnitas?
- Os líderes recebem alternativas realistas, incluindo suspensão, retirada e recall?
- Decisões, dissidência, condições, proprietários e prazos são documentados?
- O conselho recebe assuntos que excedem a autoridade de gestão ou arriscam o apetite?
- O fechamento é apoiado por evidências verificadas?

1.1135 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: governança aplicável, gestão da qualidade, gestão de riscos, relatório de incidentes, ação corretiva, monitoramento pós-mercado, provedor, implementador, conformidade e disposições de cooperação de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- A mecânica de escalonamento executivo neste capítulo são controles de governança, não deveres estatutários autônomos, a menos que estejam vinculados a uma obrigação legal específica.

1.1136 Especificação AI Executive Escalation Ladder

Mostrar a gravidade do gatilho, tempo de resposta, evidência necessária, autoridade de decisão, opções de contenção, decisões de notificação, rastreamento de remediação, validação e fechamento.

Alt text: AI escalonamento executivo escada movendo questões materiais de propriedade operacional para executivos e tomadores de decisão do conselho, com gatilhos de gravidade, evidência, contenção, notificação, remediação, validação e encerramento.

1.1137 Capítulo 127 Notificação regulamentar

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 127 linguagem de rascunho.

1.1138 Finalidade

Este capítulo explica como as organizações devem identificar, avaliar, aprovar e entregar notificações regulatórias relativas a incidentes graves, descumprimento, ações corretivas, restrições de mercado e outros assuntos de IA reportáveis.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1139 Exigência

As organizações devem identificar e cumprir todas as obrigações de notificação aplicáveis da Lei de IA da UE e das leis relacionadas. As obrigações de notificação diferem por ator regulamentado, evento, provisão, autoridade, regra de tempo, requisito de conteúdo e regime legal; não há um único prazo de notificação universal de AI.

As organizações devem manter um processo de notificação documentado que identifique as autoridades aplicáveis, gatilhos legais, prazos de relatório, conteúdo necessário, autoridade de aprovação, canais de comunicação, requisitos de conservação de evidências e compromissos de acompanhamento. Os deveres potenciais de notificação devem ser avaliados imediatamente quando um incidente material de IA ou falha de conformidade for identificado.

1.1140 Explicação em linguagem simples

Um problema material de IA pode desencadear uma notificação a uma autoridade de vigilância do mercado, ao Escritório de IA, outra autoridade competente, uma autoridade de proteção de dados, uma autoridade de segurança cibernética, clientes, trabalhadores, pessoas afetadas ou outros organismos. A organização deve determinar qual dever se aplica, quem

deve notificar, quando o relógio começar, quais informações são necessárias e como as atualizações serão gerenciadas.

A obrigação aplicável pode depender do papel da organização, da classificação do sistema, do tipo e gravidade do dano, onde o sistema é usado e qual autoridade tem jurisdição. A organização deve se mover rapidamente sem apresentar informações não verificadas ou enganosas. Os relatórios iniciais podem ser preliminares onde a lei aplicável permite relatórios encenados, mas devem distinguir claramente fatos conhecidos, avaliações razoáveis, suposições e perguntas não resolvidas.

1.1141 Potenciais gatilhos de notificação

Avaliar se a notificação pode ser necessária após:

- um incidente grave;
- morte, ferimentos graves ou risco significativo para a saúde ou segurança;
- perturbação grave e irreversível da infra-estrutura crítica;
- Violação de obrigações destinadas a proteger os direitos fundamentais;
- suspeita de prática de IA proibida;
- Incumprimento material envolvendo um sistema de IA de alto risco;
- ação corretiva, restrição, suspensão, recall ou retirada;
- Compromisso de segurança cibernética que afete a segurança, integridade, disponibilidade ou conformidade da IA;
- uma solicitação de autoridade, investigação, inspeção ou ação de fiscalização do mercado;
- uma alteração substancial que afete o estatuto regulamentar;
- um fornecedor de material, modelo, dados ou falha de componentes;
- Privacidade relacionada, proteção ao consumidor, segurança de produtos, emprego, segurança cibernética ou deveres de notificação do setor.

1.1142 Avaliação da notificação

Para cada notificação potencial, determine e documente:

1. O regime jurídico e o gatilho exato;
2. O agente regulamentado responsável;
3. a autoridade receptora competente ou a parte afetada;
4. o prazo e o evento que inicia o relógio;
5. Os factos iniciais exigidos e se é permitida a elaboração de relatórios encenados;
6. Incidentes graves, segurança, direitos, privacidade, segurança, conformidade ou implicações de risco de mercado;

7. sistemas, modelos, versões, ambientes, jurisdições, fornecedores e pessoas afetados;
8. o cronograma do evento e a data de detecção;
9. Consequências conhecidas e potenciais;
10. evidência disponível, ausente, preservada ou sujeita a privilégio;
11. ações corretivas e de contenção;
12. Se se aplicam regimes de notificação paralelos;
13. autoridade de aprovação e canal de submissão;
14. Atualizações suplementares, corretivas e de encerramento;
15. registros demonstrando pontualidade, integridade e entrega.

1.1143 Mapeamento de autoridade e jurisdição

Mantenha um registro atual de:

- Autoridades nacionais competentes;
- Autoridades de fiscalização do mercado;
- O Gabinete de IA, se aplicável;
- Autoridades notificadoras e organismos notificados, se for caso disso;
- Proteção de dados, segurança de produtos, consumidor, emprego, setor e autoridades de segurança cibernética;
- canais de contato de autoridade;
- requisitos de idioma, formato e autenticação;
- responsabilidades legais e de ator;
- escalada e contatos de conselho externo;
- Prazos de notificação aplicáveis e regras de início do relógio.

1.1144 Conteúdo da notificação

Uma notificação deve incluir, conforme aplicável e legalmente exigido:

- organização de relatórios e informações de contato;
- papel da organização na cadeia de valor da IA;
- sistema de IA afetado e propósito pretendido;
- versões de sistema, modelo e componentes;
- data do evento, data de detecção e cronologia;
- Descrição do incidente ou do incumprimento;
- pessoas, locais, direitos e serviços afetados;
- danos conhecidos ou potenciais;
- contenção imediata;
- análise técnica e organizacional;
- fornecedores e dependências envolvidas;
- plano de ação corretiva;
- Limitações de evidências e perguntas abertas;

- Atualizações planejadas e contato responsável.

1.1145 Timeliness e relatórios encenados

Quando os fatos completos não estiverem disponíveis antes de um prazo, envie uma notificação preliminar aprovada quando legalmente apropriado e forneça atualizações verificadas. Não demore apenas para obter um relatório perfeito. Ao mesmo tempo, não especule, esconda a incerteza ou faça admissões sem suporte.

Os cálculos devem identificar o evento desencadeador, o fuso horário, a entidade legal responsável, fins de semana ou regras de feriados públicos, quando aplicável, e qualquer obrigação de fornecer relatórios provisórios ou suplementares.

1.1146 Coordenação entre regimes

Um incidente de IA também pode desencadear obrigações sob a proteção de dados, segurança cibernética, segurança do produto, emprego, proteção do consumidor, contratos, seguros ou regulamentação do setor. Coordene mensagens, fatos, cronogramas e ações corretivas para que as submissões sejam consistentes, respeitando o escopo de cada regime, regras de privilégio, destinatário e prazo.

Os deveres de notificação relacionados devem ser avaliados separadamente; o cumprimento de um regime não satisfaz automaticamente outro.

1.1147 Exemplo de GlobalWay Travel Services

A GlobalWay recebe evidências de que um sistema de gerenciamento de funcionários de alto risco pode ter contribuído para um sério impacto nos direitos fundamentais após uma atualização do fornecedor. Legal determina o ator do AI Act aplicável e a rota de relatórios, avalia o GDPR paralelo e as obrigações de emprego, preserva registros, versões do sistema e registros de decisão e restringe recomendações automatizadas.

A GlobalWay submete a notificação inicial necessária usando fatos verificados, identifica perguntas abertas e medidas de contenção e fornece relatórios suplementares à medida que a investigação estabelece populações afetadas, causa raiz, remediação e evidências que apoiam qualquer reinicialização segura.

1.1148 Atividades de controle

- Manter uma árvore de decisão de notificação e matriz de gatilho.
- Manter uma autoridade, jurisdição, ator e registro de prazo.
- Ative a revisão legal e executiva imediatamente após eventos materiais.

- Preservar versões do sistema, logs, comunicações e evidências de decisão.
- Use modelos controlados e fluxos de trabalho de aprovação.
- Separe fatos verificados de suposições e perguntas não resolvidas.
- Coordenar os regimes de notificação relacionados.
- Acompanhamento de reconhecimentos, questões regulatórias, relatórios suplementares, correções e compromissos.
- Validar a ação corretiva antes do fechamento.
- Revisão perdida, tardia, rejeitada ou corrigida de notificações para melhoria do processo.

1.1149 Provas

- Política de notificação, árvore de decisão e matriz de gatilho;
- registro de autoridade, autoridade, ator e prazo;
- Avaliações de incidentes e cronologia;
- Análises legais e registros de privilégios;
- registros de sistema, modelo, log e conservação de evidências;
- Elaboração e envio de notificações;
- Registos de aprovação;
- confirmações e confirmações de entrega;
- Correspondência do regulador;
- Relatórios suplementares, corretivos e de encerramento;
- Evidência de ação corretiva;
- rastreadores de compromisso e prazo;
- registros aprendidos por lições.

1.1150 Testes de auditoria

1. Selecione incidentes graves e problemas de conformidade com o material e verifique se os deveres de notificação foram avaliados prontamente.
2. Confirme se o gatilho legal, ator, destinatário, jurisdição, prazo e evento de início do relógio foram documentados.
3. Recalcular prazos e comparar timestamps de submissão com provas de entrega.
4. Compare fatos enviados com evidências de origem, registros do sistema e cronogramas de incidentes.
5. Verificar relatórios preliminares identificados incertezas e obrigações de acompanhamento.
6. Revise a consistência das notificações de IA, privacidade, segurança cibernética, produto, emprego, consumidor e setor.
7. Trace questões e compromissos do regulador através do fechamento verificado.

8. Confirmar notificações tardias, perdidas, rejeitadas ou corrigidas foram escaladas e remediadas.
9. Verifique se o fechamento foi apoiado por ações corretivas concluídas e evidências retidas.

1.1151 Métricas

- Incidentes materiais avaliados para notificação;
- tempo desde a detecção até a avaliação legal;
- Notificações enviadas a tempo;
- Notificações tardias ou perdidas;
- Relatórios preliminares aguardando atualização;
- Submissões inconsistentes entre regimes;
- compromissos do regulador devidos;
- Notificações que requeiram correção ou reapresentação;
- tempo para o encerramento validado;
- eventos em que o início do relógio de notificação foi contestado ou incerto.

1.1152 Lista de verificação de gestão

- Que regime legal, autoridade, ator e pessoa jurídica são responsáveis?
- Que prazo se aplica, e quando o relógio começou?
- Os fatos conhecidos estão separados de suposições e incógnitas?
- Todos os regimes de notificação relevantes foram considerados separadamente?
- As ações corretivas e de contenção estão claramente documentadas?
- Os fatos apresentados são consistentes com evidências de fontes preservadas?
- Os compromissos de acompanhamento são de propriedade e rastreados?
- O fechamento é suportado por correspondência do regulador e correção verificada?

1.1153 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo disposições aplicáveis relativas a incidentes graves, ações corretivas, vigilância do mercado, prestador, despachante, GPAI, conformidade e cooperação com autoridades.
- Regulamento (UE) 2026/1744, se aplicável.
- Deveres de notificação relacionados sob proteção de dados, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor e direito do setor devem ser avaliados separadamente.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1154 Especificação AI Regulatory Notification Decision Flow

Criar um fluxo de decisão desde a detecção de incidentes até a avaliação da gravidade e do gatilho legal, mapeamento do ator e da jurisdição, identificação da autoridade, cálculo do prazo, preservação de evidências, notificação preliminar ou final, coordenação do regime paralelo, relatórios de acompanhamento, ação corretiva, validação e fechamento.

Alt text: Alt text:** A AI regulador-notificação decisão fluxo de detecção de incidentes e avaliação de gatilho legal através de mapeamento de ator e autoridade, controle de prazo, preservação de evidências, submissão, coordenação de regime paralelo, relatórios de acompanhamento, ação corretiva, validação e encerramento.

1.1155 Capítulo 128 Preservação de Evidências e Detenção Legal

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 128 linguagem de rascunho.

1.1156 Finalidade

Este capítulo explica como as organizações devem preservar as evidências relacionadas à IA e implementar os recursos legais quando um litígio, investigação, execução, um incidente grave, uma reclamação ou uma disputa material é razoavelmente antecipado.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1157 Exigência

As organizações devem preservar os registros exigidos pela Lei de IA da UE e outras leis aplicáveis e devem implementar retenções legais quando litígios, investigações, execução, incidentes, reclamações ou disputas forem razoavelmente antecipados. Uma retenção legal é um controle de processo legal, não uma obrigação autônoma da Lei de AI da UE, mas apoia o cumprimento da documentação, registro, manutenção de registros, acesso à autoridade, incidente, ação corretiva e deveres de monitoramento pós-mercado.

1.1158 Explicação em linguagem simples

As evidências de IA podem ser distribuídas entre serviços em nuvem, provedores de modelos, repositórios de código-fonte, plataformas de monitoramento, sistemas de emissão de bilhetes, aplicativos de negócios, comunicações de funcionários e sistemas de terceiros. A exclusão de rotina,

a rotação de logs, a aposentadoria do modelo ou a substituição do fornecedor devem parar quando evidências relevantes podem ser necessárias. A preservação deve cobrir documentos e artefatos técnicos juntos para que decisões, comportamento do modelo, contexto do sistema e ações humanas possam ser reconstruídas.

1.1159 Eventos de gatilho

Considere a preservação ou uma retenção legal após:

- um inquérito regulamentar, inspeção ou pedido de informação;
- Litígios ameaçados ou arquivados;
- um incidente grave ou alegação credível de dano;
- uso suspeito de uma prática de IA proibida;
- a discriminação, privacidade, segurança, emprego ou reclamação do consumidor;
- Um compromisso de cibersegurança que afete a operação de IA ou a integridade das provas;
- Um relatório de denunciante ou investigação interna;
- uma disputa de fornecedor material, interrupção ou mudança de modelo;
- uma revisão dirigida pelo executivo ou pelo conselho;
- uma reivindicação de seguro antecipada;
- restrição do sistema, suspensão, recall, retirada ou ação corretiva principal.

1.1160 Requisitos de preservação

Defina no mínimo:

1. obrigações estatutárias, regulamentares, contratuais e de retenção de políticas;
2. gatilhos legais, autoridade de decisão e rotas de escalada;
3. custodiantes, sistemas, modelos, versões, repositórios, ambientes e fornecedores em escopo;
4. logs, prompts, saídas, conjuntos de dados, código, configuração, documentação e comunicações relevantes;
5. preservação de metadados, autenticidade, integridade, contexto e cadeia de custódia;
6. Suspensão da eliminação, rotação, substituição, eliminação arquivística e reforma do modelo;
7. Captura rápida de evidências voláteis, efêmeras ou controladas externamente;
8. Avisos de preservação, reconhecimentos e verificação de terceiros;

9. privacidade, minimização de dados, confidencialidade, privilégio, segurança e controles de acesso;
10. requisitos de coleta, exportação, indexação, reprodutibilidade e revisão;
11. revisão periódica, expansão, modificação e liberação autorizada do porão;
12. documentação de evidências indisponíveis, lacunas de preservação, medidas de compensação e remediação;
13. Disposição segura após a liberação legal.

1.1161 mbito de aplicação

Preservar conforme relevante:

- Registros de inventário, propriedade, papel e classificação de IA;
- Binários modelo, pesos, versões, identificadores, somas de verificação e metadados de liberação, quando disponíveis;
- código fonte, scripts, prompts, instruções do sistema, configuração de recuperação e definições de ferramentas;
- treinamento, afinação, validação, teste e dados de produção quando legal;
- linhagem de dados, proveniência, qualidade, representatividade, viés e registros de pré-processamento;
- Registros, alertas de monitoramento, saídas, substituições, aprovações e interações do usuário;
- Registros de implantação, liberação, reversão e gerenciamento de mudanças;
- avaliações de risco, impacto, privacidade, segurança, legal e conformidade;
- documentação técnica, instruções de uso e registros de registro;
- instruções de supervisão humana, ações de revisores e registros de decisão;
- Contratos de fornecedores, avisos, atestados, registros de incidentes e comunicações;
- Reclamações, tickets, investigações, ações corretivas e evidências de fechamento;
- e-mails, mensagens, atas de reunião, decisões executivas e correspondência do regulador.

1.1162 Desafios de preservação específicos da IA

Endereço:

- modelos de fornecedores em rápida mudança e artefatos proprietários inacessíveis;

- prompts efêmeros, sessões temporárias e curtos períodos de retenção de log;
- fontes de recuperação dinâmica e conjuntos de dados continuamente atualizados;
- Chamadas de ferramentas de agentes, ações de API externas e alterações no sistema a jusante;
- Limites de não-determinismo e reprodutibilidade do modelo;
- Nuvem distribuída, armazenamento regional e restrições transfronteiriças;
- restrições de privacidade e dados de categoria especial;
- Alterações de componentes de código aberto e substituição de dependência;
- uso de ferramentas de IA pessoais ou não aprovadas.

1.1163 Preservação do fornecedor

Contratos e procedimentos de incidentes devem apoiar a preservação rápida do fornecedor de versões de modelos relevantes, registros, documentação, subprocessadores, mudanças de serviço e evidências de incidentes. Grave qualquer limitação na capacidade da organização de obter ou preservar evidências controladas pelo fornecedor e aumentar as lacunas materiais.

1.1164 Integridade e cadeia de custódia

Manter:

- fonte, custodiante e sistema de registro;
- data de coleta, método e coletor;
- identificadores de arquivo, objeto, modelo e versão;
- Os hashes ou outros controles de integridade, se for caso disso;
- metadados originais e relações contextuais;
- Controles seguros de localização e de acesso;
- histórico de acesso, transferência, exportação e produção;
- transformações, redações ou conversões de formato;
- Revisor, aprovação e registros de lançamento.

Preserva separadamente cópias originais de trabalho.

1.1165 Privacidade, confidencialidade e privilégio

A preservação não remove a privacidade, confidencialidade, segurança cibernética, sigilo profissional ou obrigações de privilégio. Limite o acesso, aplique limites legais de coleta, proteja dados confidenciais, redações de documentos e obtenha revisão legal e de privacidade para transferências

transfronteiriças, dados de categoria especial, dados de funcionários e evidências controladas por fornecedores.

1.1166 Exemplo de GlobalWay Travel Services

Depois que os viajantes alegam bloqueio discriminatório pelo sistema de detecção de fraude da GlobalWay, o advogado emite um porão cobrindo a versão do modelo implantado, configuração de recursos, decisões de transação, substituições humanas, testes de subgrupos, reclamações, avisos de mudança de fornecedor e comunicações internas.

A GlobalWay descobre que os registros de aplicativos normalmente giram após 30 dias. Ele suspende a exclusão, exporta registros relevantes com verificações de integridade, obtém confirmação de preservação do fornecedor e documentos de que um artefato de modelo proprietário histórico não está disponível. A limitação é divulgada, escalada e considerada no plano de investigação e correção.

1.1167 Atividade de controle

A organização deve testar se evidências de IA tecnicamente voláteis podem realmente ser preservadas, vinculadas à versão correta e reproduzidas o suficiente para investigação, auditoria ou revisão de autoridade.

1.1168 Provas

- cronograma de retenção e procedimento legal;
- Mapas de fontes de evidência e de sistemas;
- manter avisos, mudanças de escopo e reconhecimentos;
- Listas de custódia, repositório, fornecedor e sistema;
- Registros de preservação, coleta e exportação;
- hashes, metadados e registros de cadeia de custódia;
- confirmações de preservação de fornecedores e limitações divulgadas;
- registros de acesso, redação e produção;
- revisões periódicas;
- registros de exceção, lacuna e remediação;
- aprovações de liberação e disposição.

1.1169 Teste de auditoria

Confirme se os gatilhos foram identificados prontamente, o escopo incluiu evidências técnicas e humanas relevantes, a exclusão e a substituição foram suspensas, evidências voláteis e controladas pelo fornecedor foram abordadas, integridade e custódia foram protegidas, controles de privacidade e privilégio foram aplicados, lacunas foram divulgadas e a liberação foi autorizada e documentada.

1.1170 Métricas

- tempo do gatilho para a ação de preservação;
- custódios, sistemas, fornecedores e fontes de evidência em espera;
- Agradecimentos perdidos ou atrasados;
- evidências perdidas antes da preservação;
- lacunas de conservação do fornecedor;
- Fontes de log com retenção inadequada;
- Exceções da cadeia de custódia;
- acesso não autorizado a provas mantidas;
- aberto por idade;
- retenções liberadas aguardando disposição verificada.

1.1171 Lista de verificação de gestão

- Sabemos onde reside a evidência material da IA?
- Podemos parar a exclusão, a rotação, a aposentadoria do modelo e o fornecedor substituir rapidamente?
- Os registros de modelo, prompt, dados, log, configuração e decisão humana são preservados juntos?
- Podemos demonstrar autenticidade, integridade, contexto e cadeia de custódia?
- Privacidade, confidencialidade, privilégio e restrições transfronteiriças são protegidas?
- As limitações dos fornecedores e as lacunas de evidências são divulgadas e escaladas?
- A liberação de retenção é controlada e verificada?

1.1172 Especificação AI Evidence Preservation Map

Crie um mapa conectando eventos de gatilho à ativação legal, custodiantes, modelos, dados, prompts, logs, código, fornecedores, comunicações, coleta, validação de integridade, armazenamento seguro, revisão, produção e liberação autorizada.

Alt text: Mapa de conservação de evidências de IA que liga gatilhos legais a guardiões e fontes de evidências técnicas, seguido de coleta, validação de integridade, armazenamento seguro, revisão controlada, produção e liberação autorizada.

1.1173 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: documentação técnica, registro, manutenção de registros, gerenciamento de qualidade, monitoramento, incidentes, ações corretivas e disposições de acesso à autoridade.

- Regulamento (UE) 2016/679 e outras leis de privacidade, emprego, probatório e procedimentos aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.
- Os deveres de posse legal dependem da lei processual e substantiva aplicável e não devem ser apresentados como um requisito universal independente da Lei de Inteligência Artificial da UE.

1.1174 Capítulo 129 Primeiros 30 dias

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 129 linguagem de rascunho.

1.1175 Finalidade

Este capítulo fornece um plano prático de implementação de primeiros 30 dias para estabelecer controle, visibilidade, responsabilidade e redução imediata de risco em todas as atividades de IA de uma organização.

1.1176 Exigência

As organizações devem usar esse período para estabelecer aplicabilidade legal, papéis de ator, proibições e deveres imediatamente aplicáveis, propriedade da governança, integridade do inventário, triagem de risco, preservação de evidências e prioridades urgentes de correção.

1.1177 Explicação em linguagem simples

O primeiro mês deve criar controle sobre o escopo e a exposição urgente. Não é hora de declarar total conformidade. A administração deve saber quais sistemas de IA e modelos GPAI existem, quais usos podem ser proibidos ou de alto risco, quem os possui, quais dados eles usam, quais fornecedores estão envolvidos, quem pode ser afetado e onde é necessária restrição, suspensão ou escalada imediata.

1.1178 Dias 15: mobilizar

- nomear um patrocinador executivo e líder do programa responsável;
- Estabelecer um grupo de direção multifuncional;
- Definir Legal, Compliance, Risco, Privacidade, Segurança, Tecnologia, Compras, RH, Auditoria Interna e participação nos negócios;
- Aprovar um mandato provisório de governação da IA;
- Estabelecer a decisão, a escalada, a paragem e a autoridade de notificação;
- identificar entidades jurídicas, jurisdições, setores e serviços comerciais relevantes;
- confirmar a linha de base legal atual e as datas aplicáveis;
- preservar registros e decisões críticas existentes.

1.1179 Dias 610: descubra

Lançar um inventário rápido cobrindo sistemas de produção, pilotos, provas de conceito, sombra AI, recursos de fornecedores incorporados, uso de IA geradora de funcionários, serviços habilitados para GPAI, decisões automatizadas de alto impacto, modelos, fontes de dados, provedores, dependências, proprietários, grupos afetados, jurisdições, incidentes, reclamações e descobertas não resolvidas.

Use entrevistas, registros de compras, inventários de software, registros de nuvem e rede, registros de despesas, registros de fornecedores e atestados de unidades de negócios para melhorar a integridade.

1.1180 Dias 1115: triagem

Priorizar suspeitas de práticas proibidas, casos de emprego e uso de serviços essenciais, sistemas biométricos ou relacionados à segurança, sistemas que afetam grupos vulneráveis, IA geradora voltada para o público, processamento de dados sensíveis, sistemas sem supervisão humana significativa, sistemas com incidentes ou alterações materiais e serviços de fornecedores sem documentação adequada ou garantia contratual.

1.1181 Dias 1620: estabilizar

Aplicar medidas provisórias como suspensão, restrição funcional ou geográfica, revisão humana obrigatória, limites de dados sensíveis, avisos de transparência temporária, preservação de evidências, bloqueio de ferramentas não aprovadas, escalada do fornecedor, congelamento de mudanças, procedimentos de parada segura e decisões documentadas de risco residual.

1.1182 Dias 21-25: estabelecer governança mínima

Aprovar versões provisórias da política de IA, regras de uso aceitável, processo de admissão e aprovação, padrão de inventário, tela de prática proibida, métodos de classificação de ator e papel e risco, procedimentos de incidentes e notificação, due diligence do fornecedor, expectativas de retenção de evidências, requisitos de alfabetização de IA e autoridade de exceção.

1.1183 Dias 2630: planeje o programa

Crie roteiros prioritários de 90 dias e 12 meses, cobrindo lacunas legais e de controle, correção específica do sistema, datas regulatórias, necessidades de recursos e competência, proprietários responsáveis, dependências, garantia e testes, relatório de cadência, orçamento, requisitos de tecnologia e opções de saída ou suspensão.

1.1184 Exemplo de GlobalWay Travel Services

O GlobalWay começa com um inventário rápido e descobre 42 casos de uso de IA, incluindo 11 não conhecidos anteriormente pela governança central. Ele identifica papéis de ator, suspende um piloto de força de trabalho sem suporte, restringe uma ferramenta de recrutamento pendente de classificação e revisão de viés, adiciona avisos de IA a dois chatbots de viajantes, preserva evidências de uma queixa aberta e congela uma atualização do modelo de fornecedor até que a avaliação de mudança seja concluída.

Até o dia 30, a GlobalWay tem um patrocinador executivo, escritório de programas, inventário triaged, política provisória, rastreador de remediação urgente, decisões documentadas de uso de parada e roteiros aprovados de 90 dias e 12 meses.

1.1185 Atividade de controle

O executivo responsável deve aprovar o escopo dos primeiros 30 dias, proprietários, decisões urgentes, questões legais não resolvidas e transição para o plano de 31 a 90 dias. Os relatórios de progresso devem distinguir a conclusão verificada e as evidências retidas do trabalho planejado ou parcialmente concluído.

1.1186 Provas

- nomeações de fretamento e governança do programa;
- registro atual da base legal;
- Atestados rápidos de inventário e de unidades de negócio;
- Ator-papel, aplicabilidade e avaliações de práticas proibidas;
- Critérios e resultados de risco-triagem;
- Suspensão, restrição e decisões de controle interino;
- Avaliações de incidentes, reclamações e fornecedores;
- Registos de conservação de provas;
- Políticas e procedimentos provisórios;
- Registo de remediação urgente;
- relatórios do executivo e do conselho;
- Roteiros aprovados de 90 dias e 12 meses.

1.1187 Teste de auditoria

Confirme que ele estabeleceu um inventário suportável, identificou riscos legais e operacionais urgentes, atribuiu proprietários responsáveis, documentou salvaguardas provisórias e decisões de parada de uso, preservou evidências críticas, escalou a exposição ao material e não deturpou o trabalho planejado como conformidade concluída.

1.1188 Métricas

- Sistemas de IA e modelos GPAI identificados;
- Casos de uso recém-descobertos de Shadow-AI;
- unidades de negócios que completam atestados;
- Sistemas urgentes triados;
- Sistemas suspensos, restritos ou congelados;
- Sistemas sem proprietários responsáveis;
- Evidências críticas e lacunas na documentação de fornecedores;
- Ações de primeiro mês atrasadas;
- Prática proibida e revisões de alto risco pendentes;
- decisões de classificação legal não resolvidas.

1.1189 Lista de verificação de gestão

- Quem é responsável pelo programa e pelas decisões urgentes?
- Sabemos onde os serviços habilitados para AI e GPAI estão sendo usados?
- Quais casos de uso requerem suspensão ou restrição imediata?
- Os registros críticos, versões, decisões e registros são preservados?
- Os papéis dos atores, as jurisdições, os grupos afetados e os fornecedores foram identificados?
- Os proprietários, prazos, dependências e caminhos de escalada são designados?
- O conselho entende a maior exposição material e incerteza?
- As ações concluídas são apoiadas por evidências em vez de afirmações de status?

1.1190 Especificação First 30 Days AI Governance Sprint

Crie um sprint de 30 dias dividido em mobilização, descobrir, triagem, estabilizar, estabelecer governança e aprovar o roteiro. Mostre patrocínio executivo, preservação de evidências, revisão legal, escalada do fornecedor e autoridade urgente de uso de parada como controles transversais.

**** Texto Alt:**** 30 dias de sprint de governança de IA movendo-se da mobilização e descoberta através de triagem, estabilização, governança mínima e um roteiro de implementação aprovado, com supervisão executiva, revisão legal, preservação de evidências e escalada urgente por toda parte.

1.1191 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, alterado pelo Regulamento (UE) n.º 2026/1744, se aplicável.

- As disposições aplicáveis do AI Act dependem do papel do ator, da classificação do sistema, da finalidade pretendida, do contexto de uso, da jurisdição e da data de aplicação.
- Este capítulo é uma orientação de implementação e não substitui a análise legal de prazos e deveres legais exatos.
- O texto oficial consolidado atual controla os resumos mais antigos.

1.1192 Capítulo 130 Dias 3190

Estado legal: Mestre inglês corrigido para consolidação. Este capítulo é um roteiro de implementação, não um cronograma estatutário. Ele controla sobre a língua anterior do capítulo 130.

1.1193 Finalidade

Este capítulo fornece um plano prático de implementação para os dias 31 a 90, passando do controle inicial e triagem para governança repetível, avaliação formal de risco, remediação priorizada e responsabilidade mensurável.

1.1194 Exigência

As organizações devem usar os dias 31-90 para converter a triagem inicial de IA em governança repetível, avaliação de risco, operação de controle, remediação, treinamento e relatórios de gerenciamento. A sequência deve ser ajustada às funções legais da organização, datas efetivas aplicáveis, maturidade de controle existente e perfil de risco.

1.1195 Explicação em linguagem simples

A Lei de IA da UE não exige que as organizações concluam essas atividades no prazo de 90 dias. O roteiro é um método de implementação recomendado. As obrigações vinculativas surgem da Lei, conforme alterada, e de outras leis aplicáveis - não deste cronograma interno. O segundo e o terceiro meses devem parar de depender de planilhas únicas e decisões informais, incorporando ingestão, classificação, revisão, aprovação, monitoramento e escalada em operações comerciais normais.

1.1196 Dias 3145: validar escopo e responsabilidade

- conciliar o inventário rápido com aquisição, nuvem, software, segurança, dados, RH, finanças e registros de negócios;
- confirmar entidades legais, sistemas, versões, fins pretendidos, fornecedores, jurisdições e populações afetadas;
- Atribuir negócios, técnicos, riscos, dados, privacidade, segurança e proprietários legais;

- Prestador de documentos, implementador, importador, distribuidor, representante autorizado e funções de fabricante de produtos, se for caso disso;
- estabelecer atestados de inventário recorrentes e verificações de qualidade de dados;
- Restringir, suspender ou escalar sistemas sem proprietário e sem documentos de acordo com o risco.

1.1197 Dias 4660: avaliar e classificar

Realizar avaliações proporcionadas que abranjam:

- Aplicação do Ato de IA da UE e papel de ator;
- triagem de prática proibida;
- Classificação de alto risco;
- obrigações de transparência;
- Dependências GPAI e necessidades de informação a jusante;
- privacidade e impactos dos direitos fundamentais;
- Segurança cibernética, resiliência e risco operacional;
- supervisão humana;
- risco de terceiros, concentração e saída;
- Risco substancial de modificação.

Registrar a incerteza e exigir revisão legal ou especializada qualificada onde as conclusões são contestadas.

1.1198 Dias 61-75: estabelecer controles de linha de base

Implementar e operacionalizar controles para:

- Ingestão e aprovação;
- inventário e propriedade;
- governança de dados;
- documentação técnica;
- validação e testes;
- Avisos de transparência;
- supervisão humana;
- registro e monitoramento;
- gestão de incidentes e reclamações;
- due diligence e contratação de fornecedores;
- Gestão da mudança;
- retenção de provas e retenção legal;
- exceções e aceitação de risco residual.

Integre controles-chave em processos de aquisição, desenvolvimento, liberação, privacidade, segurança, RH, gerenciamento de registros e fluxos de trabalho de terceiros.

1.1199 Dias 76-90: trem, teste e relatório

- atividades de alfabetização de IA baseadas em funções;
- estabelecer indicadores-chave de risco, controle e conformidade;
- iniciar auto-avaliações de controle;
- identificar e priorizar lacunas de evidências;
- testes selecionados controles de alta prioridade;
- definir padrões de severidade e remediação de problemas;
- estabelecer dashboards executivos e de bordo;
- aprovar as necessidades de recursos, orçamento e tecnologia;
- confirmar os meses 4-12 plano de garantia.

1.1200 Método de priorização

Priorizar a remediação usando:

- Classificação legal e data efetiva;
- potencial impacto na segurança ou nos direitos fundamentais;
- escala, sensibilidade e população afetada;
- controle de fraqueza e qualidade de evidência;
- histórico de incidente, reclamação ou execução;
- velocidade de mudança do sistema;
- dependência do fornecedor e da concentração;
- facilidade de redução imediata do risco;
- Viabilidade de restrição segura, suspensão ou saída.

1.1201 Exemplo de GlobalWay Travel Services

Durante os dias 31 a 90, a GlobalWay valida seu inventário de 42 sistemas e identifica quatro recursos de IA incorporados adicionais. Completa avaliações de papel e risco para sistemas críticos, estabelece portões de entrada e liberação, emite cláusulas obrigatórias de fornecedores, treina proprietários de produtos e supervisores de consultores de viagens e inicia relatórios executivos mensais.

Sua ferramenta de recrutamento permanece restrita até que as lacunas de viés, supervisão, privacidade e documentação de fornecedores sejam fechadas. O assistente de viajante prossegue sob controles aprimorados de monitoramento e escalada humana.

1.1202 Atividade de controle

A administração deve aprovar o roteiro, atribuir proprietários responsáveis, priorizar obrigações vinculativas e riscos materiais, desvios de documentos do cronograma e evitar que os marcos do roteiro sejam representados como prazos legais.

1.1203 Provas

- Registros validados de inventário e propriedade;
- Avaliação do papel, aplicabilidade e classificação;
- biblioteca de controle e sobreposições;
- procedimentos aprovados e portões de fluxo de trabalho;
- due-diligência do fornecedor e contratação de arquivos;
- Registos de formação e competência;
- auto-avaliações e resultados de testes;
- registro de emissão e remediação;
- dashboards e minutos de governança;
- Garantia aprovada e plano de recursos.

1.1204 Teste de auditoria

Confirmar que a organização distinguiu prazos estatutários de marcos internos, integridade de inventário validada, decisões de papel e classificação apoiadas, controles incorporados em fluxos de trabalho reais, pessoal relevante treinado, rastreou métricas do painel para dados de origem confiáveis e atribuiu correção responsável para lacunas materiais.

1.1205 Métricas

- taxa de validação do inventário;
- sistemas com avaliações de função e classificação concluídas;
- Sistemas críticos com controles mapeados;
- Avaliações atrasadas;
- Sistemas sem evidência necessária;
- formação completa por função;
- deficiências de alta gravidade;
- Remediação tardia;
- Contratos de fornecedores sem cláusulas exigidas;
- taxa de passagem do controle-teste.

1.1206 Lista de verificação de gestão

- O inventário é completo o suficiente para decisões legais e de risco?
- As decisões de ator-papel e classificação de risco são aprovadas?
- Os controles do ciclo de vida estão operando em fluxos de trabalho reais?

- As pessoas relevantes são treinadas para suas responsabilidades?
- A administração pode ver lacunas materiais, incerteza e ações atrasadas?
- A próxima fase de garantia é financiada, detida e programada?
- As datas do roteiro interno estão claramente separadas dos prazos legais?

1.1207 Especificação Dias 3190 Modelo Operacional Build

Crie um roteiro de três estágios mostrando validar e atribuir, avaliar e classificar, implementar, treinar, testar e relatar. Conecte inventário, biblioteca de controle, integração de fluxo de trabalho, remediação e supervisão executiva.

**** Texto Alt:**** Dias 31-90 Implementação de IA roadmap progredindo de inventário validado e prestação de contas através de classificação, implementação de controle, treinamento, testes, remediação e relatórios executivos.

1.1208 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado pelo Regulamento (UE) n.o 2026/1744, se aplicável.
- Datas efetivas aplicáveis, disposições transitórias, obrigações do ator e controle de leis específicas do setor sobre este roteiro recomendado.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1209 Capítulo 131 Meses 46

Estado legal: Mestre inglês corrigido para consolidação. Este capítulo é um roteiro de implementação recomendado, não um cronograma estatutário. Ele controla a língua anterior do capítulo 131.

1.1210 Finalidade

Este capítulo fornece um plano prático de implementação para os meses 4 a 6, enfatizando a estabilidade do modelo operacional, maturidade de controle no nível do sistema, validação técnica, qualidade das evidências, remediação, governança do fornecedor e desafio independente.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1211 Exigência

As organizações devem usar meses 4-6 para estabilizar o modelo operacional de governança de IA, fechar lacunas de alta prioridade, expandir a garantia, melhorar a qualidade das evidências e preparar os

sistemas afetados para obrigações legais, de registro, notificação, monitoramento e conformidade aplicáveis.

A Lei de IA da UE não exige a conclusão dessas atividades no prazo de seis meses. As obrigações vinculativas surgem das funções reguladas reais da organização, classificações do sistema, fins pretendidos, datas de aplicação e outras leis aplicáveis - não deste cronograma interno.

1.1212 Explicação em linguagem simples

Esta fase move o programa da implementação inicial para a operação repetível. Políticas, inventários, classificações e projetos de controle devem agora ser testados contra sistemas reais, lançamentos, incidentes, fornecedores e decisões de negócios. Controles fracos devem ser corrigidos antes que se normalizem.

Os marcos internos devem permanecer alinhados às funções legais reais da organização, datas efetivas aplicáveis, obrigações setoriais e evidências de prontidão operacional.

1.1213 Mês 4: aprofundar a implementação do nível do sistema

Para sistemas prioritários:

- Finalizar o propósito pretendido, uso indevido previsível e restrições de uso;
- aplicabilidade completa, papel, classificação, risco, privacidade, segurança e avaliações de direitos fundamentais;
- Obrigações vinculativas de mapas e requisitos internos aos controles;
- Índices técnicos completos de documentação e de provas;
- Definir e testar procedimentos de supervisão humana;
- Estabelecer registros, monitorização, monitorização pós-comercialização e acionadores de incidentes, quando aplicável;
- confirmar a evidência do fornecedor, direitos de auditoria, aviso de alteração, preservação e disposições de saída;
- Risco residual do documento, controles de compensação, autoridade de aprovação e datas de revisão;
- formalizar a gestão de mudanças e revisão substancial de modificação.

1.1214 Mês 5: validar e testar

Realizar testes proporcionados de:

- design de controle e eficácia operacional;
- Precisão, taxas de erro e critérios de aceitação;

- desempenho, risco de discriminação e controles de viés;
- robustez, segurança cibernética, resiliência e resistência ao uso indevido;
- cenários de injeções imediatas e de abuso de ferramentas a agentes, se for caso disso;
- Avisos de transparência e comunicações entre pessoas afetadas;
- eficácia de revisão humana, autoridade de intervenção, substituição e mecanismos de parada;
- procedimentos de reversão, suspensão, reversão, recuperação e continuidade;
- qualidade, proveniência, linhagem, relevância e representatividade;
- documentação, registro, integridade, integridade e reprodutibilidade;
- Monitoramento de fornecedores e reconciliação de versões.

Os critérios de aceitação falhados devem desencadear correção documentada, restrição, suspensão, reversão ou escalada de risco. Um teste falhado não deve ser fechado apenas porque a administração discutiu ou aceitou uma explicação não suportada.

1.1215 Mês 6: institucionalizar a garantia

- estabelecer testes e monitoramento de controle recorrentes;
- avaliações de design de conduta direcionada e de eficiência operacional;
- Realizar auditoria interna ou desafio independente de sistemas selecionados;
- validar repositórios de evidências, retenção, preservação e recuperação;
- Realizar uma simulação de exame regulamentar ou de pedido de informação de autoridade;
- Resposta a incidentes de teste, avaliação de incidentes graves, notificação regulatória e procedimentos legais;
- avaliar a prontidão para avaliação da conformidade, registro, declaração, marcação CE e acesso à autoridade, quando aplicável;
- analisar a concentração, dependência, auditabilidade, portabilidade e prontidão de saída do fornecedor;
- validar relatórios de executivos e conselhos contra evidências confiáveis de fontes;
- relatar deficiências sistêmicas, ações atrasadas e questões legais não resolvidas;
- atualizar o roteiro de implementação com base em descobertas, desenvolvimentos legais e prioridades de negócios.

Uma revisão de prontidão não substitui uma avaliação de conformidade legalmente exigida, registro, declaração, marcação, notificação ou outro processo legal.

1.1216 Disciplina de remediação

Cada deficiência material deve incluir:

- declaração clara de emissão e causa raiz;
- sistemas, modelos, versões, pessoas, jurisdições e obrigações afetados;
- gravidade, exposição e risco residual;
- Contenção imediata e controles intermédios;
- Proprietário responsável e autoridade de decisão;
- Data-alvo e dependências;
- método de validação e reteste;
- Critérios de caminho de escalada e de extensão;
- Evidências de encerramento e verificação independente, quando apropriado.

Extensões repetidas, exceções ou retestes fracassados devem receber desafio independente e escalada executiva.

1.1217 Exemplo de GlobalWay Travel Services

A GlobalWay completa avaliações detalhadas para seus sistemas de recrutamento, fraude, assistência a interrupções e preços dinâmicos. A validação técnica identifica comportamento de abstenção fraco no assistente de interrupção, desempenho inconsistente de subgrupos no modelo de fraude e evidências incompletas da versão do fornecedor.

A GlobalWay restringe os recursos afetados, implementa a remediação, os retestes e submete os resultados a uma equipe de revisão independente. Ele também realiza um pedido regulatório simulado e descobre que a documentação técnica e a evidência de monitoramento pós-mercado ainda não podem ser reconciliadas com a versão do fornecedor implantada. A administração adia uma liberação até que a documentação, o monitoramento, as evidências do fornecedor e as lacunas de supervisão humana sejam fechadas.

1.1218 Atividades de controlo

- Aplicação, papel, classificação e avaliações de impacto completos no nível do sistema.
- Implementar e testar controles de ciclo de vida para sistemas prioritários.
- Validar critérios técnicos e operacionais de aceitação antes da liberação ou uso continuado.

- Manter a gestão disciplinada da deficiência e da ação corretiva.
- Fortalecer o monitoramento do fornecedor, acesso a evidências, aviso de mudança e prontidão de saída.
- Processos de incidentes de exercício, continuidade, regulamentação, notificação e preservação.
- Distinguir obrigações estatutárias de marcos do programa interno.
- Exigir o fechamento baseado em evidências antes que as restrições ou os blocos de liberação sejam removidos.
- Escalar temas sistêmicos para executivos e para o conselho.
- Refresque prioridades com base em testes, incidentes, mudanças legais e descobertas.

1.1219 Provas

- Registro atualizado de inventário e classificação;
- avaliações completas do sistema e mapeamentos de obrigação de controle;
- ndices de documentação técnica e de provas;
- planos de validação, critérios de aceitação e resultados;
- papéis de trabalho de teste de controle e relatórios de revisão independente;
- Remediação, restrição, suspensão, reversão e reteste de registros;
- monitoramento, garantia, contrato e evidência de versão do fornecedor;
- Registros de formação e competência;
- Resultados de exercícios e simulação;
- Registros de incidentes, notificações e testes legais;
- Avaliações da conformidade-prontidão, se aplicável;
- Aprovações de risco residual e exceção;
- relatórios do executivo e do conselho;
- Roteiro de implementação atualizado.

1.1220 Testes de auditoria

1. Selecione sistemas prioritários e verifique se as avaliações de aplicabilidade, papel, classificação, impacto e controle são completas, aprovadas e rastreáveis.
2. Os critérios de validação foram definidos antes do teste e refletem falhas realistas, mau uso, direitos, segurança e cenários de segurança.
3. O rastreamento falhou nos testes de contenção, restrição, remediação, reteste e decisões de liberação autorizadas.
4. Revise a qualidade, integridade, retenção e reconciliação das evidências com o sistema implantado e a versão do fornecedor.

5. Teste se o monitoramento do fornecedor, direitos de auditoria, aviso de mudança, suporte a incidentes, preservação e controles de saída estão operando.
6. Inspeção a garantia independente de competência, escopo, independência e conclusões documentadas.
7. Confirmar que as revisões de prontidão não substituíram por conformidade legalmente exigida ou processos regulatórios.
8. Verifique se as descobertas sistêmicas mudaram a governança, a alocação de recursos, os controles ou as prioridades do roteiro.
9. Confirmar que o relatório de gestão distingue a evidência completa do trabalho planejado ou atrasado.

1.1221 Métricas

- Sistemas prioritários plenamente avaliados;
- taxa de validação e conclusão do teste de controle;
- Critérios de aceitação falhados;
- Sistemas restritos, suspensos, revertidos ou aguardando reteste;
- Achados de alta gravidade abertos e atrasados;
- Repetir falhas de controle e repetidas exceções;
- Sistemas com índices de evidência completos e atuais;
- fornecedores críticos com garantia atual e evidência de versão;
- revisões de prontidão concluídas e lacunas não resolvidas;
- Exercícios concluídos e ações corretivas decorrentes;
- tempo médio para remediar e retestar;
- ações legais, de conformidade, de notificação ou de monitoramento em atraso.

1.1222 Lista de verificação de gestão

- Os sistemas prioritários são totalmente documentados, classificados, controlados e rastreáveis para a produção?
- Os testes técnicos refletem cenários realistas de falha, uso indevido, discriminação, segurança e direitos?
- Os critérios falhados podem bloquear, restringir, suspender ou reverter a implantação?
- Os resultados são corrigidos e validados independentemente onde o material?
- As evidências exigidas podem ser produzidas rapidamente e reconciliadas com o sistema e a versão corretos?
- Os riscos de fornecedor, concentração, portabilidade e continuidade são adequadamente testados?
- Os deveres estatutários são claramente distintos dos objetivos do roteiro interno?

- Os relatórios do executivo e do conselho refletem evidências reais e exposição não resolvida?

1.1223 Especificação Meses 46 Garantia Construção

Crie um roteiro mostrando a avaliação do nível do sistema, mapeamento de obrigação de controle, implementação de controle, validação técnica, testes independentes, remediação, exercícios regulatórios e incidentes, relatórios executivos e atualização do roteiro. Mostre restrição, suspensão, reversão e reteste conforme os caminhos necessários após critérios fracassados.

**** Texto Alt:**** Meses 46 roadmap de garantia de IA movendo-se de avaliações e controles no nível do sistema através de validação técnica, testes independentes, remediação, exercícios, relatórios executivos e prioridades atualizadas, com restrição e retestes após critérios fracassados.

1.1224 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado, incluindo provedor, implantador, alto risco, transparência, GPAI, gerenciamento de qualidade, gerenciamento de riscos, documentação, registro, supervisão, monitoramento, incidentes, ação corretiva, conformidade, registro e disposições de cooperação de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Datas efetivas aplicáveis, disposições transitórias, requisitos de avaliação da conformidade, legislação setorial e controle de obrigações do ator sobre este roteiro recomendado.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1225 Capítulo 132 Meses 712

Estado legal: Mestre inglês corrigido para consolidação. Este capítulo é um roteiro de implementação recomendado, não um cronograma estatutário. Ele controla a linguagem anterior do capítulo 132.

1.1226 Finalidade

Este capítulo fornece um plano prático de implementação para os meses de 7 a 12, com foco na adoção em toda a empresa, prontidão regulatória, garantia sustentável, melhoria da maturidade e integração em operações comerciais normais.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1227 Exigência

As organizações devem usar meses 7 a 12 para amadurecer a governança da IA, completar a correção de prioridade, estender a cobertura de

garantia, validar a eficácia operacional e institucionalizar o monitoramento, relatórios, resposta regulatória e melhoria contínua.

A Lei de IA da UE não exige que este roteiro seja concluído dentro de doze meses. As obrigações vinculativas, datas efetivas, requisitos de conformidade, registro, notificação, monitoramento e expectativas de autoridade devem ser rastreadas separadamente de acordo com os papéis legais reais da organização, classificações do sistema, fins pretendidos e jurisdições.

1.1228 Explicação em linguagem simples

Os últimos seis meses do roteiro do primeiro ano são sobre escala e durabilidade. A governança deve trabalhar em unidades de negócios, entidades jurídicas, países, tecnologias e fornecedores. O primeiro ano deve terminar com um modelo operacional defensável, em vez de uma coleção de projetos desconectados ou esforços de correção únicos.

A gerência deve ser capaz de demonstrar que o programa é apoiado por propriedade responsável, evidências atuais, controles repetíveis, desafio independente, escalada testada e melhoria contínua financiada.

1.1229 78 meses: escala e padronizar

- Estender a linha de base de controlo através de unidades de negócio materiais e entidades jurídicas;
- aplicar papel, risco, setor, jurisdição, tecnologia e sobreposições populacionais;
- Integrar a entrada, classificação, aprovação e revisão de mudança em ferramentas de aquisição e desenvolvimento;
- padronizar repositórios de evidências, identificadores, vinculação de versões e convenções de nomenclatura;
- Automatizar inventário, monitoramento e coleta de evidências somente quando a confiabilidade for testada;
- estabelecer atestados recorrentes de unidades de negócios e de proprietários de sistemas;
- expandir atividades de alfabetização de AI baseadas em funções e avaliação de competência;
- reconciliar inventários de sistemas com registros de aquisição, nuvem, segurança, dados, RH, finanças e fornecedores;
- Confirmar que as alterações materiais desencadeiam a reavaliação e a análise de modificação substancial, quando aplicável.

1.1230 Meses 910: reforçar o monitoramento e a garantia

- operacionalizar o monitoramento contínuo de conformidade e controle;

- definir deriva, desempenho, incidente, reclamação, mudança de fornecedor, mudança de modelo e gatilhos de mudança legal;
- validar a monitorização pós-comercialização, a avaliação de incidentes graves, a reclamação e os processos de ação corretiva, quando aplicável;
- expandir a cobertura de auditoria interna e de garantia independente;
- Realizar revisões temáticas em vários sistemas, entidades, fornecedores ou domínios de risco;
- avaliar dependências de controle, risco de concentração, portabilidade e prontidão de saída;
- O executivo de teste e o conselho de administração que reportam a qualidade contra a evidência de origem;
- conduzir exercícios regulatórios, incidentes, continuidade, retenção legal, notificação e saída do fornecedor;
- validar o encerramento da ação corretiva e a escalada de exceção repetida;
- Supervisão humana, intervenção, sobreposição, escalada e autoridade de uso de parada em condições operacionais realistas.

1.1231 Meses 11-12: demonstrar prontidão e melhorar a maturidade

- Realizar uma avaliação de prontidão e maturidade da empresa;
- Atualizar o inventário de IA, o mapa do papel do ator, o registro de classificação e o registro de obrigação aplicável;
- Confirmar que são abordadas obrigações de alto risco, GPAL, transparência, prática proibida, monitoramento e outras obrigações aplicáveis;
- reconciliar inventários do sistema, documentação, versões implantadas, registros de monitoramento e evidências de fornecedores;
- rever prazos regulamentares, disposições transitórias e interpretações legais não resolvidas;
- avaliar riscos residuais, exceções aceitas, remediação atrasada e temas sistêmicos;
- Realizar auditoria interna ou garantia independente sobre áreas selecionadas de alto risco;
- validar a prontidão para a avaliação de conformidade, registro, declaração, marcação CE, notificação e interação com a autoridade;
- Aprovar o ano-duas prioridades, pessoal, tecnologia, treinamento, garantia e orçamento;
- atualizar políticas, controles, treinamento, monitoramento e planos de incidentes;

- relatar a eficácia do programa, a exposição não resolvida e as necessidades de decisão para os executivos e o conselho.

Uma avaliação de prontidão não substitui qualquer avaliação de conformidade legalmente exigida, registro, declaração, marcação, notificação ou processo de autoridade.

1.1232 Modelo operacional sustentável

O modelo operacional alvo deve incluir:

- um comitê executivo e de governo responsável;
- política central, metodologia e controle de propriedade;
- negócios distribuídos, sistema, dados e responsabilidade técnica;
- Incorporação legal, conformidade, privacidade, segurança, dados, aquisição, RH, registros, continuidade e participação em auditoria;
- Processos confiáveis de inventário, papel, aplicabilidade e classificação;
- portões de ciclo de vida e controles de mudança;
- validação técnica, monitoramento e gerenciamento de incidentes;
- emissão, exceção, risco residual, reclamação e gerenciamento de ações corretivas;
- supervisão do fornecedor, acesso a evidências, gerenciamento de concentração e planejamento de saída;
- garantia independente e capacidade de resposta regulamentar;
- treinamento financiado, competência, tecnologia e melhoria contínua.

1.1233 Critérios de preparação para o final do ano

Confirme que:

- todos os sistemas de materiais têm proprietários responsáveis e registros atuais de propósito pretendido;
- A triagem de práticas proibidas está completa e as questões não resolvidas são escaladas;
- papel, alto risco, GPAI, transparência e outras classificações são atuais;
- Documentação obrigatória, registros, avaliações e evidências são recuperáveis e vinculados à versão;
- Os procedimentos de supervisão humana, incidente, notificação, preservação, continuidade e paragem são testados;
- fornecedores críticos são monitorados e controlados contratualmente;
- alterações materiais desencadear reavaliação;
- Os resultados, as exceções, as reclamações e os riscos residuais são ativamente regidos;

- Os executivos e o conselho recebem relatórios confiáveis e úteis para a decisão;
- As duas prioridades do ano abordam as lacunas legais, técnicas, operacionais e de controle remanescentes.

1.1234 Exemplo de GlobalWay Travel Services

Até o mês 12, a GlobalWay integrou a entrada de IA nos fluxos de trabalho de aquisição e desenvolvimento, implementou um registro centralizado de evidências, expandiu o monitoramento em todos os sistemas críticos e concluiu auditorias internas de ferramentas de recrutamento e detecção de fraudes.

Uma revisão de prontidão de fim de ano identifica a retenção inconsistente de evidências em duas unidades de negócios, fraquezas na documentação regional do fornecedor e avisos de transparência multilíngue incompletos. A GlobalWay requer ação corretiva e atrasa a implantação mais ampla de um modelo de fornecedor até que os controles de monitoramento, incidente, versão e saída sejam validados. Os itens restantes se tornam prioridades financiadas do ano-dois, com controles intermediários documentados e relatórios trimestrais do conselho.

1.1235 Actividades de controle

- Escalar a governança entre entidades materiais e unidades de negócios.
- Padronize controles confiáveis, evidências, identificadores e vinculação de versão.
- Automatize o inventário, monitoramento e coleta de evidências somente após testes de confiabilidade.
- Expandir monitoramento, revisão temática, auditoria interna e garantia independente.
- Exercício regulatório, incidente, notificação, preservação, continuidade e prontidão de saída do fornecedor.
- Reconciliar documentação e versões do sistema implantado.
- Valide o fechamento de ações corretivas e a escalada de exceções repetidas.
- Realize avaliações formais de preparação, maturidade e risco residual no final do ano.
- Aprovar o ano dois recursos e prioridades.
- Relatório de eficácia, risco não resolvido, remediação atrasada e a decisão precisa ser tomada pelo conselho.

1.1236 Provas

- Registros de controle-implantação da empresa;
- Registros atualizados de inventário, papel, classificação e obrigação;

- atestados de unidade de negócio e de proprietário do sistema;
- resultados automatizados de inventário, monitoramento e testes de confiabilidade de evidências;
- Registos de formação e competência;
- Relatórios temáticos, de auditoria interna e de garantia independente;
- monitoramento, incidente, reclamação, notificação, alteração e registros de ação corretiva;
- Remediação, concentração, continuidade e evidência de saída do fornecedor;
- Resultados de exercícios regulatórios, incidentes, legais e de continuidade;
- Avaliações de prontidão e maturidade;
- relatórios de risco, exceção e remediação de fim de ano;
- materiais, decisões e aprovações;
- roteiro do ano dois, plano de pessoal e orçamento.

1.1237 Testes de auditoria

1. Confirme que a governança e os controles operam em entidades materiais, unidades de negócios, jurisdições e fornecedores.
2. Teste inventário automatizado, monitoramento ou resultados de evidências para integridade, precisão, pontualidade e rastreabilidade.
3. Revise a garantia temática e independente, incluindo a validação do fechamento da ação corretiva.
4. Reconciliar sistemas de produção selecionados para fins aprovados, classificação, documentação, versão implantada, monitoramento e registros de fornecedores.
5. Verifique se mudanças significativas de modelo, dados, finalidade, fornecedor ou jurisdição desencadearam reavaliação.
6. Os exercícios de prontidão identificaram fraquezas realistas e que as ações corretivas foram concluídas e retestadas.
7. Avaliar a maturidade e as conclusões de fim de ano contra as evidências atuais de apoio.
8. Confirmar risco não resolvido, remediação atrasada e exceções aceitas foram escaladas para o nível de governança apropriado.
9. Verifique se as revisões de prontidão não substituíram os processos regulamentares ou de conformidade legalmente exigidos.
10. Confirmar ano-duas prioridades endereço identificado jurídica, técnica, fornecedor, evidências e controle fraquezas.

1.1238 Métricas

- Inventário empresarial e cobertura de propriedade;
- taxa de avaliação atual do papel e da classificação;
- Controles por entidade e unidade de negócios;

- Exceções automatizadas de cobertura de evidências e confiabilidade;
- Sistemas de alto risco ou de outra forma regulamentados com evidência de prontidão atual;
- Monitoramento de alertas, reclamações e incidentes investigados no prazo;
- resultados de auditoria, resultados repetidos e ações corretivas atrasadas;
- Exercícios regulatórios, incidentes, continuidade e saída do fornecedor concluídos;
- Exceções atrasadas e extensões repetidas;
- pontuação de maturidade por domínio;
- documentação do fornecedor não resolvida e lacunas de versão;
- duas ações financiadas, atribuídas e programadas.

1.1239 Lista de verificação de gestão

- A governança da IA tornou-se parte das operações normais?
- Os controles variam entre entidades, jurisdições, tecnologias e fornecedores?
- Podemos demonstrar prontidão com evidências atuais, recuperáveis e ligadas à versão?
- O monitoramento e a garantia estão identificando problemas reais e impulsionando ações corretivas?
- Mudanças significativas provocaram reavaliação?
- O conselho entende o risco residual, exceções aceitas, ações atrasadas e lacunas não resolvidas?
- O programa do ano dois é financiado e priorizado?
- Os deveres estatutários são claramente distintos dos marcos internos do primeiro ano?

1.1240 Figura Transformação da governança da IA de doze meses

Crie uma linha do tempo desde o controle inicial e a triagem através de inventário validado, implementação de controle, garantia técnica, escala corporativa, monitoramento contínuo, exercícios regulatórios e de incidentes, preparação para o final do ano, revisão de maturidade e planejamento do segundo ano. Mostrar reavaliação após mudanças significativas e loops de ação corretiva após a garantia falhada.

- 12 meses de tempo de transformação da governança da IA progredindo do controle inicial e triagem através da avaliação do sistema, controles, garantia, escalabilidade da empresa, monitoramento contínuo, exercícios regulatórios, preparação para o final do ano, revisão de maturidade e planejamento do segundo ano, com ciclos de reavaliação e ação corretiva.

1.1241 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado, incluindo disposições aplicáveis de ator, alto risco, transparência, GPAI, gerenciamento de qualidade, gerenciamento de risco, documentação, registro, supervisão, monitoramento, incidente, ação corretiva, conformidade, registro e cooperação de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Datas efetivas aplicáveis, disposições transitórias, legislação setorial, requisitos de conformidade e controle de deveres do ator sobre este roteiro recomendado.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1242 Capítulo 133 Roteiro de prontidão de alto risco

Estado legal: Mestre inglês corrigido para consolidação. Este capítulo é um roteiro de prontidão recomendado. Ele não substitui a rota de avaliação de conformidade legalmente exigida, envolvimento do corpo notificado, registro, declaração, marcação ou supervisão de autoridade. Ele controla a linguagem anterior do capítulo 133.

1.1243 Finalidade

Este capítulo fornece um roteiro prático para organizações que preparam sistemas de IA que podem se qualificar como de alto risco sob a Lei de IA da UE.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1244 Exigência

As organizações que atuam como provedores, implantadores, importadores, distribuidores, representantes autorizados, fabricantes de produtos ou outros atores regulamentados devem identificar sistemas de IA potencialmente de alto risco cedo, confirmar a classificação legal aplicável e os deveres do ator, atribuir proprietários responsáveis, implementar controles de ciclo de vida necessários, manter evidências técnicas e de governança completas e verificar a prontidão antes de colocar um sistema no mercado ou colocá-lo em serviço.

As rotas de conformidade, registro, declaração, marcação, monitoramento e obrigações de relatórios também variam de acordo com a categoria do sistema, a interface do produto, o propósito pretendido, a jurisdição, a data de lançamento e a data efetiva aplicável.

1.1245 Explicação em linguagem simples

É um programa coordenado que abrange classificação, análise de papéis, gerenciamento de riscos, governança de dados, documentação técnica, registros, transparência, supervisão humana, precisão, robustez, segurança cibernética, gerenciamento de qualidade, atividades de conformidade, registro, controles de implantação, monitoramento pós-mercado, incidentes, ações corretivas e mudanças.

Revisões internas de prontidão são úteis, mas não podem substituir uma avaliação de conformidade legalmente exigida, processo de corpo notificado, registro, declaração, marcação CE, decisão de autoridade ou outra obrigação legal.

1.1246 Fase 1: Identificar e classificar

- validar o inventário de IA;
- determinar a finalidade pretendida, o uso real, o uso indevido razoavelmente previsível e as populações afetadas;
- Prestador de mapas, implementador, importador, distribuidor, representante autorizado, fabricante de produtos e funções de fornecedor;
- Avaliar o artigo 6.o, n.o 1, e as rotas de produtos ou componentes de segurança do anexo I;
- Avaliar os casos de utilização do n.o 2 do artigo 6.o e do anexo III;
- Documentar qualquer análise de exceção do artigo 6.o, n.o 3, e a ressalva da definição de perfis;
- exclusões de revisão, condições especiais e sobreposições legais específicas do setor;
- identificar entidades jurídicas, jurisdições, datas de lançamento e datas efetivas aplicáveis;
- fundamentação legal do documento, suposições, evidências, aprovadores e gatilhos de reavaliação.

Sistemas potencialmente de alto risco devem permanecer sujeitos a controles de precaução até que a incerteza de classificação seja resolvida.

1.1247 Fase 2: estabelecer a governança

- Nomear proprietários responsáveis de negócios, técnicos, legais, de risco, dados, segurança, conformidade, privacidade, compras e registros;
- definir a decisão, escalada, parada de uso, liberação e autoridade de risco residual;
- Estabelecer responsabilidades de gestão da qualidade nos casos em que se apliquem deveres de prestador;
- Aprovar o plano de gestão de riscos e a metodologia de avaliação;

- identificar pessoal competente de supervisão humana e suplentes;
- definir funções independentes de validação, conformidade, auditoria e garantia;
- Estabelecer evidências de fornecedores, aviso de mudança, suporte a incidentes, preservação e expectativas de direito de auditoria;
- criar um registro de prontidão de alto risco com proprietários, dependências, prazos e status de evidência.

1.1248 Fase 3: implementar controles centrais

Implementar e evidenciar, conforme aplicável:

- Gestão contínua de riscos;
- controles de dados e governança de dados;
- Documentação técnica alinhada com os requisitos do anexo IV;
- manutenção automática de registros e registro;
- Informações de transparência e instruções de utilização;
- design de visão humana, competência, intervenção, substituição e mecanismos de parada;
- controles de precisão, robustez, resiliência, segurança e segurança cibernética;
- processos de gestão da qualidade;
- mudança, configuração, liberação, reversão e controles substanciais de modificação;
- fornecedor, componente, código aberto, nuvem e governança de API;
- Processos de reclamação, incidente, incidente grave, ação corretiva, retirada, recall e resposta à autoridade;
- retenção, preservação, integridade e vinculação de versão.

1.1249 Fase 4: validar a prontidão

Realizar proporcional e documentado:

- Revisão de design-efetividade;
- Testes de eficácia operacional;
- Validação técnica contra critérios de aceitação predefinidos;
- precisão, erro, subgrupo, discriminação e testes de viés;
- Supervisão humana, escalada, substituição e testes de parada de uso;
- Segurança cibernética, robustez, resiliência e testes de mau uso previsíveis;
- qualidade dos dados, linhagem, proveniência e revisão de representatividade;
- Documentação-para-produção e reconciliação modelo-versão;
- Evidência, integridade, recuperabilidade e revisão de reprodutibilidade;

- Revisão de fornecedor-evidência e dependência;
- avaliação de conformidade-prontidão sem tratá-lo como o próprio processo de conformidade.

Os critérios falhados devem desencadear correção, restrição, suspensão, reversão ou escalada. Um critério falhado não pode ser dispensado sem justificativa legal, técnica, de risco e aprovação documentada.

1.1250 Fase 5: concluir as etapas de autorização legal aplicáveis

Antes de colocar o sistema no mercado ou colocá-lo em serviço, conforme aplicável:

- determinar a via de avaliação da conformidade legalmente exigida;
- identificar se o envolvimento do organismo notificado é necessário;
- Completar a avaliação da conformidade aplicável;
- Registo completo, sempre que necessário;
- Preparar e aprovar a declaração UE de conformidade, quando aplicável;
- Aplicar a marcação CE, quando aplicável;
- Aprovar documentação técnica e instruções de utilização;
- verificar a entrega do fornecedor ao operador e as informações a jusante;
- prontidão do verificador e deveres de deployer aplicáveis;
- Resolver ou governar formalmente os resultados residuais consistentes com restrições legais;
- aprovar a monitorização pós-comercialização, incidentes, notificações, ações corretivas e planos de mudança;
- autoridade de liberação de registros, condições, restrições e evidências.

Nenhum comitê interno pode renunciar a um requisito legalmente obrigatório de conformidade, registo, declaração, marcação ou notificação.

1.1251 Fase 6: operar e monitorar

Após a implantação:

- desempenho do monitor, deriva, incidentes, reclamações, substituições e uso indevido previsível;
- validar a eficácia contínua da supervisão humana;
- manter registros de logs, documentação, evidências e registros de versão necessários;
- Operar monitorização pós-comercialização, quando aplicável;
- avaliar e relatar incidentes graves dentro das regras aplicáveis;

- investigar a não conformidade e implementar ações corretivas;
- reavaliar após modelo material, dados, finalidade, fornecedor, jurisdição ou alterações de controle;
- Realizar análises de modificação substancial, quando relevante;
- suspender, restringir, recordar, retirar ou interromper o uso quando necessário;
- Solicitações de autoridade de apoio, inspeções, atividade de fiscalização do mercado e acompanhamento regulatório;
- revisão se o uso do deployer permanece consistente com instruções, propósito pretendido e controles aprovados.

1.1252 prontidão específica do deployer

Sempre que a organização atue como um deployer, confirme, conforme aplicável:

- uso de acordo com instruções e finalidade aprovada;
- Supervisão humana competente;
- Relevância e adequação de dados de entrada e de dados quando sob controle do deployer;
- Monitorização e escalada de incidentes;
- retenção e acesso a logs sob controle do deployer;
- Obrigações de informação do trabalhador ou do representante;
- obrigações de avaliação de impacto dos direitos fundamentais;
- Coordenação de avaliação de impacto de proteção de dados;
- Cooperação com autoridades e acesso à informação;
- Controles que impedem a expansão de propósito, população ou fluxo de trabalho não aprovado.

1.1253 Exemplo de GlobalWay Travel Services

A GlobalWay trata seu sistema de triagem de recrutamento como potencialmente de alto risco. Confirma o propósito pretendido, mapeia as funções de provedor e implantador, documenta a justificativa de classificação do Anexo III, estabelece um arquivo de gerenciamento de risco, realiza testes de subgrupo e supervisão e reconcilia a versão implantada com a documentação técnica.

Um teste de escalada humana falha, e a documentação do fornecedor não suporta a versão do modelo implantado. Os blocos da GlobalWay liberam, exigem correção e reteste, atualizam o pacote de evidências do fornecedor e confirmam a rota de conformidade e registro aplicável antes da autorização. Os controles pós-lançamento incluem monitoramento, manuseio de reclamações, retenção de registros, comunicação com o trabalhador, avaliação de mudanças e escalada de incidentes graves.

1.1254 Atividades de controle

- Mantenha um registro de prontidão de alto risco.
- Atribua proprietários responsáveis, dependências, prazos e caminhos de escalada.
- Mapear todos os deveres legais aplicáveis a um controle, proprietário de evidências e versão do sistema.
- Exigir validação legal, técnica, de risco e de conformidade qualificada antes da liberação.
- Impedir que as revisões internas de prontidão substituam processos estatutários.
- Acompanhe descobertas, restrições e condições de aprovação não resolvidas.
- Verifique a entrega do provedor para o operador e a prontidão do deployer.
- Reavaliar após alterações, incidentes, reclamações, atualizações de fornecedores ou desenvolvimentos legais.
- Manter a prontidão pós-mercado, incidente, ação corretiva, preservação e resposta regulatória.

1.1255 Provas

- Aplicação, papel e avaliações de classificação de alto risco;
- análise de propósito pretendido e data efetiva;
- Plano de prontidão de alto risco e registro;
- Registos de gestão da qualidade e gestão dos riscos;
- evidência de governança de dados;
- Documentação técnica e índice de versão;
- registro de registros, transparência, instruções de uso e evidências de supervisão humana;
- validação, critérios de aceitação e relatórios de teste;
- Decisão de rota de conformidade e registros de conformidade completos;
- Registos de organismos notificados, quando aplicável;
- registro, declaração e evidência de marcação CE, quando aplicável;
- registros de entrega do provedor ao operador;
- aprovação e condições de liberação;
- monitoramento pós-comercialização, incidentes, notificações, reclamações e registros de ações corretivas;
- alterações e avaliações substanciais de modificação;
- desdobrável-controle e provas FRIA, quando aplicável.

1.1256 Testes de auditoria

1. A classificação é atual, legalmente suportada e baseada no propósito pretendido e no uso real.

2. Confirme se a organização identificou os deveres corretos do ator regulamentado e datas efetivas.
3. Trace cada obrigação de alto risco aplicável a um controle, proprietário de evidências e versão implantada.
4. Confirme se a documentação técnica e a evidência do fornecedor correspondem ao sistema colocado no mercado ou colocado em serviço.
5. Revise a cobertura de validação para precisão, risco de discriminação, supervisão, robustez, resiliência, segurança, segurança cibernética e uso indevido previsível.
6. Os critérios de rastreamento falharam para restrição, remediação, reteste e decisões de liberação autorizadas.
7. Verifique se a rota de conformidade aplicável foi concluída e não substituída por uma revisão interna.
8. Confirmar os requisitos de registo, declaração, marcação e organismo notificado foram satisfeitos quando aplicável.
9. Obrigações de entrega e implantação de provedor-a-implantador de teste.
10. Verifique os processos de monitoramento pós-comercialização, incidente, reclamação, ação corretiva e resposta à autoridade.
11. Confirmar mudanças materiais desencadear reavaliação e análise de modificação substancial.

1.1257 Métricas

- Sistemas potencialmente de alto risco identificados;
- Sistemas de alto risco confirmados pelo papel e rota do ator;
- classificação e avaliações de data efetiva completas;
- controles de prontidão completos;
- Evidências e lacunas de ligação de versão;
- Critérios de validação com falha;
- sistemas bloqueados, restritos, suspensos ou aguardando reteste;
- avaliações de conformidade completas;
- As ações de registo, declaração e marcação completam, quando aplicável;
- aprovações de implantação com condições;
- Remediação tardia e repetidas exceções;
- Mudanças materiais aguardando reavaliação;
- itens de monitoramento, reclamação, incidente e ação corretiva em atraso.

1.1258 Lista de verificação de gestão

- Identificamos todos os sistemas potencialmente de alto risco e a rota legal correta?

- A classificação é legalmente defensável e baseada no texto oficial atual?
- O provedor, o deployer, e outros deveres do ator são distinguidos?
- Todos os controles de ciclo de vida obrigatórios são implementados e evidenciados?
- O sistema implantado corresponde à documentação técnica e do fornecedor aprovada?
- Os critérios falhados podem bloquear a implantação ou o uso continuado?
- O processo de conformidade correto foi concluído?
- Os requisitos de registo, declaração, marcação e organismo notificado são abordados quando aplicável?
- O monitoramento, incidentes, reclamações, ações corretivas e mudanças são regidas após a liberação?
- As provas exigidas podem ser produzidas prontamente para uma autoridade?

1.1259 Especificação de Figura Modelo de Portão de Prontidão de AI de Alto Risco

Crie portas sequenciais para aplicabilidade e classificação, análise ator-função, governança, implementação de controle, validação técnica, rota de conformidade, etapas de autorização legal, aprovação de implantação, handoff do deployer e monitoramento pós-mercado. Mostre a integridade da evidência, a vinculação da versão, a responsabilidade da administração e os caminhos de parada de critérios fracassados como requisitos transversais.

Alt text: Alt text:** Portas de prontidão de IA de alto risco que progridem de papéis de classificação e ator através de governança, controles, validação, conformidade, registo e liberação, entrega do implantador e monitoramento pós-mercado, com evidências, vinculação de versão, responsabilidade e caminhos de parada após critérios fracassados.

1.1260 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado, incluindo os artigos 6.o, 8.o-27.o, 43.o, 47.o-49.o, 72.o-73.o e os anexos I, III, IV, VI, VII e VIII, conforme aplicável.
- Regulamento (UE) 2026/1744, se aplicável.
- A aplicabilidade das secções 1 a 3 do capítulo III deve seguir o actual calendário transitório alterado para a rota relevante do artigo 6.o.
- A segurança dos produtos, a proteção de dados, o emprego, a segurança cibernética, o consumidor e a legislação específica do setor podem impor deveres adicionais.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.1261 Capítulo 134 Roteiro de preparação da GPAI

**** Status legal: **** Corrigido o mestre inglês para consolidação. Este capítulo é um roteiro de prontidão recomendado. Ele não substitui os deveres obrigatórios do provedor, obrigações de risco sistêmico, supervisão do AI Office ou códigos e padrões aplicáveis. Ele controla a linguagem anterior do capítulo 134.

1.1262 Finalidade

Este capítulo fornece um roteiro prático para organizações que desenvolvem, colocam no mercado, modificam, integram, distribuem ou dependem de modelos e sistemas de IA de uso geral.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1263 Exigência

As organizações devem determinar seu papel legal na cadeia de valor da GPAI e implementar controles proporcionais se são um provedor de modelo GPAI, provedor de sistema de IA a jusante, implantador, importador, distribuidor, representante autorizado ou provedor de um modelo GPAI com risco sistêmico.

1.1264 Explicação em linguagem simples

As obrigações GPAI diferem das obrigações do sistema de alto risco. Uma empresa que usa um modelo de terceiros não é automaticamente o provedor do modelo, mas o ajuste fino, o rebranding, a modificação substancial, o desenvolvimento do sistema a jusante ou a colocação de um modelo ou sistema no mercado sob seu próprio nome podem criar deveres adicionais. A designação de risco sistêmico cria uma avaliação aprimorada, gerenciamento de riscos, segurança cibernética, relatórios de incidentes e obrigações de informação.

1.1265 Fase 1: mapear a cadeia de valor GPAI

Documento:

- Nomes de modelo e de sistema, versões, fornecedores, licenças e arranjos de hospedagem;
- Prestador, fornecedor a jusante, despachante, importador, distribuidor e funções representativas autorizadas;
- Status de código aberto e quaisquer limites de isenções;
- jurisdições, setores, usuários e pessoas afetadas;
- ajuste fino, recuperação, uso de ferramentas, agentes, plug-ins e integrações do sistema;

- branding, revenda, modificação substancial e cenários com rótulo branco;
- processos críticos de negócios e usos de alto risco a jusante.

1.1266 Fase 2: determinar a aplicabilidade e o papel

Avaliar:

1. se o artefato é um modelo GPAI, um sistema de IA usando GPAI, ou ambos;
2. Que entidade coloca o modelo ou sistema no mercado da UE;
3. se a organização modificou, renomeou ou alterou substancialmente o modelo ou sistema;
4. Se uma isenção de código aberto é relevante e se as suas condições são cumpridas;
5. Se se aplicam critérios de risco sistémico ou designação;
6. Sejam igualmente aplicáveis obrigações a jusante de alto risco, transparência, privacidade, segurança dos produtos ou do setor;
7. A alocação contratual reflete as funções legais e operacionais reais.

1.1267 Fase 3: documentação e informações a jusante

Manter registos proporcionados e controlados pela versão que abrangem:

- capacidades do modelo, limitações, usos pretendidos e previsíveis;
- Modelo técnico e documentação do sistema;
- Integração, configuração, ajuste fino e arquitetura de recuperação;
- avaliação, validação e resultados da equipe vermelha;
- Informações necessárias para os fornecedores a jusante;
- Política de conformidade com direitos autorais e evidências de implementação;
- resumos de conteúdos de formação necessários, se aplicável;
- segurança, incidentes, alterações e registos de lançamento;
- Contatos e procedimentos para autoridades, fornecedores e parceiros a jusante.

1.1268 Fase 4: avaliação de risco e controle

Endereço:

- capacidade e risco de mau uso previsível;
- alucinação, falta de confiabilidade e confiança inadequada;
- privacidade, confidencialidade e vazamento de dados;
- injeção rápida, abuso de ferramentas e risco de ação antrópica;
- Cibersegurança e exposição à cadeia de fornecimento de software;
- viés, discriminação e acessibilidade;

- Propriedade intelectual e risco de conteúdo;
- concentração, continuidade e dependência do fornecedor;
- Utilização a jusante em contextos de alto risco ou relevantes para a segurança;
- modelo, provedor, licença, dados e alterações de integração.

1.1269 Fase 5: prontidão de risco sistêmico, quando aplicável

Para modelos GPAI com risco sistêmico, estabeleça processos aprimorados para:

- avaliações padronizadas de modelos;
- Testes contraditórios e desafio independente;
- Identificação, avaliação e mitigação de riscos sistêmicos;
- Rastreamento e denúncia de incidentes graves;
- salvaguardas de cibersegurança e resiliência;
- Informação sobre energia e recursos, sempre que legalmente exigido;
- Cooperação com o Gabinete de IA e as autoridades competentes;
- supervisão executiva e do conselho de risco sistêmico material.

1.1270 Fase 6: preparação para integração a jusante

Antes da implantação do material:

- validar a informação do fornecedor e os direitos contratuais;
- avaliar as utilizações previstas e previsíveis;
- definir usos proibidos e restrições técnicas;
- prompts de teste, recuperação, ferramentas, agentes e escalada humana;
- Implementar o registro, monitoramento e resposta a incidentes;
- estabelecer controles de versão e mudança de modelo;
- verificar a transparência e as comunicações entre pessoas afetadas;
- avaliar sobreposições de alto risco, privacidade, segurança, produto e setor;
- manter planos de saída, substituição, portabilidade e continuidade.

1.1271 Exemplo de GlobalWay Travel Services

A GlobalWay integra modelos GPAI de terceiros em um serviço de assistente de consultoria de viagens e resumo de documentos. Ele registra versões e fornecedores de modelos, revisa informações técnicas a jusante, restringe dados sensíveis do viajante, recupera testes e chamadas de ferramentas, requer aprovação humana para reembolsos e decisões sensíveis à segurança e monitora as alterações do provedor.

Antes de oferecer o assistente a clientes corporativos sob a marca GlobalWay, Legal reavalia se a GlobalWay se tornou um provedor a jusante com documentação adicional, transparência, contrato ou deveres no nível do sistema. Os contratos exigem notificação de mudança, cooperação com incidentes, acesso a evidências e suporte de saída.

1.1272 Atividades de controle

- Mantenha um modelo GPAI completo e registro de integração.
- Documentar e aprovar avaliações de papel e aplicabilidade.
- Obter, revisar e reter a documentação do provedor e downstream.
- Implemente direitos autorais, privacidade, segurança, transparência e controles de dados.
- Valide integrações de alto impacto, agentes e habilitadas por ferramentas.
- Monitorar mudanças de modelo, provedor, licença, legal e código de prática.
- Estabelecer controles de risco sistêmico, quando aplicável.
- Reavaliar as alterações materiais antes da liberação ou do uso continuado.
- Retenha evidências apoiando decisões, divulgações e informações a jusante.

1.1273 Provas

- Inventário GPAI e avaliação de funções;
- documentação de modelo e integração;
- Prestador e informações a jusante;
- Política de direitos autorais e resumo de conteúdo de treinamento, quando aplicável;
- análise de código aberto;
- Registros de avaliação ou designação de risco sistêmico;
- avaliação, testes contraditórios, segurança cibernética e evidências de incidentes;
- Contratos de fornecedores e notificações de alteração;
- Registros de monitoramento, liberação e reavaliação;
- AI Office, implementando-ato, padrão e registros de monitoramento de código de prática.

1.1274 Testes de auditoria

1. Verifique se os modelos e integrações GPAI são completamente inventariados e versionados.
2. Revise determinações de papéis, marca, modificação e suposições de código aberto.

3. Confirme se o provedor necessário e a documentação a jusante são mantidos e atualizados.
4. Teste direitos autorais, privacidade, segurança, transparência e controles de fornecedores.
5. Revise avaliações para uso indevido, viés, confiabilidade, injeção imediata e risco de ação de ferramentas.
6. Confirmar o modelo ou as alterações de integração desencadear reavaliação antes da liberação.
7. Verifique os controles de risco sistêmico aprimorados, quando aplicável.
8. Confirmar códigos ou orientações não vinculativas não são representados como lei vinculativa.

1.1275 Métricas

- Modelos e integrações GPAI inventariados;
- avaliações de funções atuais;
- lacunas de documentação do fornecedor;
- Integrações de alto impacto validadas;
- mudanças de modelo aguardando revisão;
- Avaliação e resultados da equipe vermelha;
- Incidentes e eventos de uso indevido;
- pedidos de informação a jusante em atraso;
- Ações de risco sistêmico em atraso;
- fornecedores críticos sem planos de saída testados.

1.1276 Lista de verificação de gestão

- Conhecemos todos os modelos de material GPAI e integração em uso?
- Nossos papéis legais e de cadeia de suprimentos são apoiados por evidências?
- Temos o fornecedor atual e documentação técnica?
- Os controles de direitos autorais, privacidade, segurança e transparência estão operando?
- Os usos de alto impacto e agentes foram tecnicamente validados?
- As mudanças de modelo, provedor, licença e integração desencadeiam reavaliação?
- As questões de risco sistêmico são escaladas prontamente quando relevantes?

1.1277 Especificação da figura GPAI Value-Chain Readiness Map

Crie um mapa conectando provedores de modelos a montante, provedores de sistemas a jusante, implantadores, importadores, distribuidores, usuários e pessoas afetadas. Mostre documentação, direitos autorais, avaliação,

segurança, transparência, risco sistêmico, mudança, monitoramento, incidentes e controles de saída em toda a cadeia.

** Mapa de prontidão da GPAI mostrando provedores de modelos, provedores de sistemas a jusante, implantadores, importadores, distribuidores, usuários e pessoas afetadas conectadas por documentação, avaliação, segurança, transparência, mudança, monitoramento, incidentes e controles de continuidade.

1.1278 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada: disposições GPAI aplicáveis, incluindo os artigos 51.º a 56.º e disposições de supervisão e execução conexas, mais os anexos XI a XIII, quando aplicável.
- Regulamento (UE) 2026/1744, se aplicável.
- As decisões, atos de implementação, normas harmonizadas e códigos de prática aplicáveis do AI Office devem ser identificados por status legal; o material não vinculativo não deve ser representado como lei.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.1279 Capítulo 135 Transparency Readiness Roteiro

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 135 linguagem de rascunho.

1.1280 Finalidade

Este capítulo fornece um roteiro prático para identificar, projetar, implementar, testar e manter obrigações de transparência para sistemas de IA e conteúdo gerado ou manipulado por IA.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1281 Exigência

As organizações devem identificar quais deveres de transparência se aplicam a cada sistema, ator, caso de uso, saída e contexto de implantação e, em seguida, implementar controles para que os avisos, divulgações, marcações e instruções exigidos sejam precisos, oportunos, acessíveis, compreensíveis, tecnicamente eficazes e consistentes com o comportamento real do sistema.

1.1282 Explicação em linguagem simples

Os deveres diferem por função e uso e podem incluir informar as pessoas de que estão interagindo com IA, fornecer informações e instruções para

sistemas de alto risco, informar os trabalhadores ou pessoas afetadas quando necessário, marcar conteúdo gerado ou manipulado por IA, divulgar deepfakes ou determinado texto de interesse público e informar as pessoas expostas a sistemas de reconhecimento de emoções ou categorização biométrica.

1.1283 Fase 1: cenários de transparência de inventário

Identificar:

- sistemas que interagem diretamente com pessoas naturais;
- Sistemas de alto risco que requeiram instruções ou comunicações do deployer;
- Usos de reconhecimento de emoções ou de categorização biométrica;
- geração de áudio, imagem, vídeo e texto sintético;
- Cenários de deepfake e conteúdo manipulado;
- Texto de interesse público e cenários de responsabilidade editorial;
- empregado, candidato, viajante, cliente, fornecedor e interações públicas;
- canais, idiomas, jurisdições, características do público e necessidades de acessibilidade.

1.1284 Fase 2: determinar o gatilho legal e o ator responsável

Para cada caso de uso, documento:

1. a base jurídica ou política aplicável;
2. O fornecedor responsável, o despachante, o importador, o distribuidor, o fabricante do produto ou outro ator;
3. o destinatário pretendido ou o público afetado;
4. Quando as informações devem ser fornecidas;
5. conteúdo, formato e canal necessários;
6. exceções, exclusões e datas efetivas;
7. Requisitos de marcação técnica ou legível por máquina;
8. dependências de fornecedores e informações a jusante;
9. proprietário responsável, revisor legal e aprovador;
10. evidências necessárias, monitoramento e gatilhos de reavaliação.

1.1285 Fase 3: avisos de design, divulgações e instruções

As medidas de transparência devem ser:

- clara, concisa e factualmente precisa;
- distinguíveis de termos não relacionados e linguagem de marketing;

- apresentado cedo o suficiente para influenciar a compreensão ou a escolha da pessoa;
- adequado ao público e ao contexto operacional;
- acessível a pessoas com deficiência;
- disponíveis em línguas e canais relevantes;
- consistente entre interfaces, documentos e canais de suporte;
- alinhados com o propósito real, limitações, uso de dados, supervisão e rotas de reclamação;
- Apoiado por um contato humano significativo ou caminho de escalada, quando apropriado.

1.1286 Fase 4: implementar controles técnicos e de liberação

Implementar conforme aplicável:

- avisos de interação AI visíveis;
- Indicadores de divulgação persistentes ou facilmente acessíveis;
- marcação legível por máquina de conteúdo sintético quando legalmente exigido e tecnicamente viável;
- controles de metadados e proveniência;
- Etiquetas de conteúdo deepfake e manipulado;
- Comunicações entre pessoas afetadas e trabalhadores;
- opções de apoio humano e escalada;
- registro legal de apresentação de aviso e versão do sistema;
- portões de liberação que impedem a implantação sem controles de transparência aprovados.

1.1287 Fase 5: eficácia do teste

Teste:

- tempo, posicionamento e visibilidade;
- compreensão por audiências pretendidas;
- Acessibilidade e compatibilidade com tecnologia assistiva;
- qualidade da linguagem e precisão de localização;
- apresentação móvel, web, voz, documento e canal incorporado;
- Persistência de marcação técnica após processamento ou distribuição normais;
- capacidade do usuário de obter suporte humano ou desafio, quando aplicável;
- coerência entre o comportamento real do sistema e a divulgação aprovada;
- ligação entre avisos, marcações, instruções e a versão implantada.

1.1288 Fase 6: monitorar e manter

Reavaliar após:

- mudanças de modelo, interface, propósito ou fluxo de trabalho;
- novas funções de geração ou manipulação de conteúdo;
- expansão para novos países, populações ou idiomas;
- reclamações, defeitos de acessibilidade ou evidência de confusão do usuário;
- mudanças de fornecedor ou plataforma;
- alterações nos requisitos legais, atos de execução ou orientação autorizada;
- Reclassificação, modificação substancial ou novo uso de alto risco.

1.1289 Exemplo de GlobalWay Travel Services

O GlobalWay mapeia seu chatbot de viajante, ferramenta de recrutamento, conteúdo de marketing sintético e piloto de análise de emoções no centro de chamadas. O chatbot exibe um aviso de IA antes da primeira resposta e fornece uma rota visível para um consultor humano. Os avisos dos candidatos são revisados contra o fluxo de trabalho real de recrutamento. As imagens de destino geradas recebem os controles necessários de marcação e divulgação.

O teste de acessibilidade mostra que um aviso não é anunciado corretamente pelos leitores de tela. A liberação é pausada até que o defeito seja corrigido, retestado e vinculado à versão de produção aprovada. Um portão de mudança de fornecedor requer uma revisão renovada da transparência sempre que o modelo ou a interface subjacente mudar.

1.1290 Actividades de controlo

- Manter uma matriz de aplicabilidade de transparência e uma biblioteca de avisos.
- Distingue deveres específicos do ator e datas efetivas.
- Aprovar avisos, instruções e marcações técnicas antes do lançamento.
- Teste de tempo, compreensão, acessibilidade, localização e persistência técnica.
- Reconciliar divulgações com funções reais, limitações, uso de dados e supervisão.
- Manter a evidência do fornecedor e informações a jusante.
- Monitore reclamações, confusão e falhas de divulgação.
- Reavaliação do gatilho após mudança material.
- Preserve versões aprovadas, evidências de implementação e ações corretivas.

1.1291 Provas

- Matriz de aplicabilidade de transparência;
- Análise legal do papel e do caso de uso;
- Texto de aviso, divulgação e instrução aprovado;
- exemplos de interface de usuário, documento e conteúdo;
- Acessibilidade, compreensão e testes de linguagem;
- Marcação legível por máquina e resultados dos testes de proveniência;
- Fornecedor e documentação a jusante;
- registros de implantação, liberação e versão;
- resultados do teste de escalada humana;
- histórico de mudança e reavaliação;
- registros de reclamação, defeito e remediação.

1.1292 Testes de auditoria

1. Sistemas de IA selecionados e verificar a aplicabilidade da transparência foram avaliados usando o texto legal atual.
2. Confirmar o ator correto, destinatário, tempo, canal e data efetiva foram identificados.
3. Compare divulgações e instruções aprovadas com o comportamento e limitações reais do sistema.
4. Revisão de acessibilidade, linguagem, localização e testes de compreensão.
5. Teste a marcação de conteúdo sintético e a persistência da divulgação, quando aplicável.
6. Verifique se as funções de suporte humano ou de escalada operam como representadas.
7. Confirmar as mudanças de fornecedor e versão desencadear reavaliação e aprovação.
8. A verificação de orientações não vinculativas não é representada como um dever de transparência vinculativo.

1.1293 Métricas

- Sistemas que exijam medidas de transparência;
- avisos e instruções aprovados implementados;
- Acessibilidade, compreensão ou defeitos de linguagem;
- Falhas de divulgação ou marcação;
- Reclamações de usuários ou confusão documentada;
- sistemas alterados sem reavaliação da transparência;
- Remediação tardia;
- taxa de sucesso da escalada humana;
- mudanças do fornecedor aguardando revisão.

1.1294 Lista de verificação de gestão

- Todas as interações de IA aplicáveis e usos de conteúdo sintético foram identificados?
- O ator responsável e o gatilho legal são claros?
- Os avisos são oportunos, precisos, acessíveis, compreensíveis e localizados?
- As divulgações e instruções correspondem ao comportamento real do sistema?
- As marcações legíveis por máquina são implementadas e testadas quando necessário?
- Os usuários podem obter apoio humano significativo quando apropriado?
- Os controles de transparência são retestados após mudanças materiais?

1.1295 Especificação AI Transparency Readiness Journey

Crie uma jornada desde a identificação de casos de uso e análise de gatilhos legais até o mapeamento do ator, design de aviso e instrução, revisão de acessibilidade, marcação técnica, implementação, testes de produção, aprovação de liberação, feedback do usuário, revisão de mudanças e monitoramento contínuo.

Alt text: A jornada de prontidão de transparência da IA desde a identificação de interações e conteúdo relevantes através da análise do ator, avisos e instruções aprovados, marcações técnicas, testes de acessibilidade, implantação, feedback do usuário, revisão de mudanças e monitoramento contínuo.

1.1296 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, conforme alterado: direitos aplicáveis de transparência e informação, incluindo os artigos 13.º, 26.º e 50.º, juntamente com definições relevantes, exceções, datas efetivas e requisitos de documentação do anexo IV.
- Regulamento (UE) 2026/1744, se aplicável.
- Acessibilidade aplicável, proteção ao consumidor, emprego, privacidade, mídia e direito específico do setor.
- O texto consolidado atual do EUR-Lex controla os resumos mais antigos.

1.1297 Capítulo 136 Implantação Multijurisdicional

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla o conflito anterior Capítulo 136 linguagem de rascunho.

1.1298 Finalidade

Este capítulo explica como as organizações devem governar os sistemas de IA implantados em vários países, entidades jurídicas, setores, idiomas, populações e regimes regulatórios.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1299 Exigência

As organizações que implantam IA em várias jurisdições devem determinar quais regimes legais, papéis de atores, regras setoriais, deveres contratuais e restrições locais se aplicam a cada implantação, implementar um método controlado para resolver conflitos, aplicar sobreposições locais, gerenciar dados transfronteiriços e dependências de fornecedores, preservar evidências consistentes e impedir a expansão não autorizada do uso.

1.1300 Explicação em linguagem simples

Um sistema aprovado em um país não é automaticamente legal ou operacionalmente adequado em outro. A mesma capacidade pode ter classificações diferentes, regras de uso proibido, salvaguardas de emprego, direitos de transparência, requisitos de privacidade, restrições setoriais, expectativas de idioma, necessidades de acessibilidade e contatos do regulador. A Lei de IA da UE também pode ser aplicada quando um provedor ou implantador está fora da União, mas o sistema ou sua saída é usada na União.

1.1301 Sobreposições globais de base e locais

Estabelecer:

- uma política global de governança de IA e uma linha de base de controle mínimo;
- um método comum de inventário, papel, aplicabilidade e classificação;
- Ciclo de vida mínimo, risco, dados, segurança, privacidade, supervisão, monitoramento e controles de evidências;
- sobreposições legais e regulamentares específicas da jurisdição;
- setor, cliente, força de trabalho e sobreposições de produtos;
- Critérios para a aplicação de requisitos locais mais rigorosos documentados;
- um processo de resolução de obrigações conflitantes e de escalada de questões jurídicas não resolvidas;
- controles técnicos capazes de restringir ou suspender a implantação por jurisdição.

1.1302 Avaliação da competência

Para cada implantação, documento:

1. Países, territórios, mercados e estabelecimentos envolvidos;
2. entidades jurídicas e proprietários de empresas e técnicos responsáveis;
3. Prestador, fornecedor, importador, distribuidor, representante autorizado, fabricante do produto, empregador, controlador, processador e outras funções relevantes;
4. propósito pretendido, uso real, usuários e populações afetadas;
5. aplicabilidade territorial e extraterritorial;
6. AI aplicável, privacidade, emprego, igualdade, consumidor, segurança, acessibilidade, segurança cibernética, produto e direito do setor;
7. Regulador, autoridade, notificação, consulta e contatos de representação do trabalhador;
8. dados locais, mecanismos de transferência, retenção, acesso e riscos de solicitação do governo;
9. requisitos de idioma local, cultural, acessibilidade e suporte;
10. fornecedores, subprocessadores, nuvem, modelo e locais de infraestrutura;
11. restrições, aprovações, condições de lançamento e gatilhos de reavaliação.

1.1303 Modelo de decisão de implantação

Use resultados controlados, como:

- aprovados sob a linha de base global;
- Aprovado sujeito a configuração local, aviso, consulta ou controles de contrato;
- aprovados apenas para usuários limitados, dados, propósitos ou regiões;
- Piloto aprovado com monitoramento aprimorado e critérios de saída definidos;
- diferimento pendente de correção legal, técnica, de fornecedor ou de evidência;
- Proibido ou indisponível na jurisdição;
- Suspensão ou retirada após alteração legal, incidente, reclamação ou falha de controle.

1.1304 Dados, infraestrutura e considerações sobre fornecedores

Avaliar:

- coleta, uso e reutilização legais de dados;
- Requisitos de localização ou residência;
- mecanismos de transferência internacional;
- restrições de treinamento, ajuste fino e uso secundário;
- Dados sensíveis e de categoria especial;
- retenção, exclusão, preservação e regras de acesso à autoridade;
- nuvem regional, modelo e endpoints de registro;
- o acesso do governo e o risco de concentração;
- Incidente, monitoramento e disponibilidade de evidências entre regiões;
- mudança de fornecedor, subprocessador, continuidade, portabilidade e arranjos de saída.

1.1305 Localização e proteção do usuário

Validar:

- avisos traduzidos, divulgações e instruções;
- Acessibilidade e compatibilidade com tecnologia assistiva;
- competência e autoridade local de supervisão humana;
- desempenho cultural, linguístico e específico do contexto;
- vieses locais, subgrupos e riscos de pessoas vulneráveis;
- O trabalhador, candidato, cliente e deveres de comunicação pessoa afetada;
- suporte ao cliente, reclamação, apelo e canais de escalada humana;
- emergência, incidente, regulador e escalada legal;
- arranjos locais de retorno, reversão e continuidade de serviço.

1.1306 Gestão da mudança

Reavaliar a implantação após:

- expansão para um novo país, setor, entidade jurídica ou população de clientes;
- uma nova língua ou grupo afetado;
- mudança de modelo, provedor, licença, nuvem ou subprocessador;
- nova fonte de dados, finalidade, rota de transferência ou modelo de retenção;
- lei local, decisão do regulador ou mudança de orientação autorizada;

- incidente material, reclamação, descoberta de auditoria ou preocupação com discriminação;
- aquisição, reestruturação ou novo modelo de contratação;
- modificação substancial, repurposing, ou mudança de marca.

1.1307 Exemplo de GlobalWay Travel Services

A GlobalWay planeja implantar um assistente de viajante e sistema de alocação de funcionários na UE, Reino Unido, Estados Unidos, Colômbia e México. Aplica uma linha de base comum de segurança, supervisão, inventário e evidências, criando então sobreposições de jurisdição para consulta de trabalhadores, avisos de privacidade, salvaguardas de decisão automatizada, transferências de dados, retenção, acessibilidade, testes em idiomas locais e contatos do regulador.

A implantação em um país é adiada porque o caminho de escalada do idioma local e o arranjo regional de retenção de logs estão incompletos. Uma restrição geográfica permanece ativa até que Legal, Compliance, Tecnologia e o proprietário local da empresa aprovem os controles e evidências corrigidos.

1.1308 Atividades de controle

- Manter uma jurisdição, entidade, função legal e registro de implantação.
- Defina uma linha de base global e sobreposições locais aprovadas.
- Exigir a aprovação do país e da população antes do lançamento ou expansão da produção.
- Validar idioma, acessibilidade, viés, supervisão, reclamações e suporte localmente.
- Controle dados transfronteiriços, registros, evidências e fluxos de fornecedores.
- Monitore os requisitos do regulador, notificação, consulta e informações do trabalhador.
- Use controles de restrição geográfica, configuração, identidade ou liberação quando necessário.
- Reavaliar após mudança legal, técnica, organizacional, fornecedor, finalidade ou geográfica.
- Bloquear ou suspender a implantação quando os controles locais necessários estiverem incompletos.

1.1309 Provas

- Mapas de jurisdição e entidade;
- aplicabilidade, escopo territorial e avaliações de papéis;
- Registo de obrigações legais e setoriais;
- linha de base de controle global e sobreposições locais;

- avaliações de privacidade, fluxo de dados, transferência, retenção e localização;
- avisos, instruções, consultas e aprovações localizadas;
- testes de linguagem, acessibilidade, subgrupo e supervisão;
- aprovações, restrições e registros de liberação de países;
- fornecedor, subprocessador, infraestrutura e registros de localização;
- listas de contato do regulador e da escalada;
- Evidências de geo-restrição e de aplicação técnica;
- monitoramento, incidente, mudança legal e histórico de reavaliação.

1.1310 Testes de auditoria

1. Selecionar jurisdições e verificar o escopo territorial, entidades, papéis, propósitos e populações afetadas foram avaliados.
2. Confirme que os requisitos legais e setoriais locais são mapeados para controles e evidências recuperáveis.
3. Revisão de linguagem, acessibilidade, supervisão, queixa e testes de subgrupos.
4. Verifique os controles de transferência de dados, localização, retenção e localização do fornecedor.
5. Trace o lançamento do país ou a aprovação de expansão para completar os critérios de prontidão local.
6. Confirmar legal, provedor, modelo, propósito e mudanças na população desencadear reavaliação.
7. Revisão se implantações proibidas, diferidas ou restritas são tecnicamente aplicadas.
8. Verificar conflitos e exceções não resolvidos são escalados para tomadores de decisão autorizados.

1.1311 Métricas

- jurisdições com avaliações atuais;
- implantações que aguardam aprovação local;
- lacunas de controle local ou de evidência;
- defeitos de tradução, acessibilidade ou localização;
- Exceções de transferências transfronteiriças;
- registro regional e lacunas de evidências;
- Alterações legais ou regulamentares que aguardam avaliação;
- implantações restritas, suspensas ou retiradas;
- Incidentes multijurisdicionais, reclamações e remediação atrasada.

1.1312 Lista de verificação de gestão

- Sabemos onde cada sistema de IA opera e qual entidade é responsável?
- A aplicabilidade territorial e extraterritorial está documentada?

- A linha de base global é forte o suficiente e as sobreposições locais são aprovadas?
- A linguagem, a acessibilidade, o viés, a supervisão e o suporte foram testados localmente?
- Os dados transfronteiriços, as evidências e os fluxos de fornecedores são legais e controlados?
- A implantação pode ser bloqueada, restrita ou suspensa por jurisdição?
- Conflitos legais e interpretações incertas são escalados adequadamente?

1.1313 Especificação Global AI Deployment Control Map

Crie uma linha de base de controle global central cercada por sobreposições de jurisdição para funções legais, escopo territorial, privacidade, emprego, regras do setor, idioma, acessibilidade, localização de dados, fornecedores, reguladores, monitoramento local e resposta a incidentes. Mostre os portões de lançamento do país, restrições técnicas e gatilhos de reavaliação.

** Mapa de controle de implantação global de IA com uma linha de base de governança comum, sobreposições legais e operacionais específicas da jurisdição, portões de lançamento do país, restrições técnicas e gatilhos de reavaliação para mudanças legais, técnicas, de fornecedores, população e geográficas.

1.1314 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: âmbito territorial do artigo 2.º e actor aplicável, prática proibida, alto risco, transparência, GPAI, monitorização, incidentes e disposições de execução.
- Regulamento (UE) 2016/679 e outros regulamentos nacionais, regionais, de emprego, de igualdade, de defesa do consumidor, de acessibilidade, de cibersegurança, de segurança dos produtos e do setor aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.
- Textos oficiais consolidados atuais e controle da lei local aplicável sobre resumos generalizados.

1.1315 Capítulo 137 Modelo de Maturidade da Governança da IA

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 137 anterior.

1.1316 Finalidade

Este capítulo fornece um modelo prático de maturidade para avaliar o quão consistente, eficaz e sustentável uma organização governa os sistemas de IA e atende às obrigações legais, contratuais, técnicas, operacionais e de garantia aplicáveis.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1317 Exigência

Um modelo de maturidade de governança de IA é uma ferramenta de gerenciamento voluntário, não um substituto para a conformidade legal. As organizações devem usá-lo para avaliar se as capacidades de governança, risco, conformidade, técnica, operacional, evidência e garantia são consistentemente projetadas, implementadas, medidas, desafiadas e aprimoradas.

1.1318 Explicação em linguagem simples

Um modelo de maturidade ajuda a administração a identificar capacidades fracas ou inconsistentes, priorizar o investimento e acompanhar a melhoria, mas não deve ser usado para justificar o não cumprimento, adiar controles obrigatórios ou afastar falhas críticas.

1.1319 Níveis de maturidade

1.1319.1 Nível 1 Inicial

Características:

- O uso da IA é descentralizado ou mal compreendido;
- Os inventários e a propriedade estão incompletos;
- As decisões e os controles são reativos e dependentes da pessoa;
- a documentação e as provas são inconsistentes;
- A classificação legal geralmente ocorre apenas depois que surgem problemas;
- Incidentes, reclamações e mudanças são tratados informalmente.

1.1319.2 Nível 2 Desenvolvimento

Características:

- Funções de governança e políticas básicas estão surgindo;
- Sistemas prioritários são inventariados;
- a ingestão, a prática proibida e a triagem de alto risco já começaram;

- existem controles para sistemas selecionados, mas são operados de forma inconsistente;
- treinamento está disponível, mas não totalmente baseado em funções;
- A correção e a garantia permanecem incompletas.

1.1319.3 Nível 3 Definido

Características:

- Política empresarial, papéis e direitos de decisão são aprovados;
- Os sistemas de materiais são inventariados e classificados;
- As portas e os padrões de evidência do ciclo de vida são padronizados;
- A propriedade e a frequência do controle são definidas;
- são integrados os controles de privacidade, segurança, dados, fornecedor, transparência e visão humana;
- São regidos os resultados, as exceções e o risco residual;
- relatórios de gestão e planejamento de garantia são estabelecidos.

1.1319.4 Nível 4 Gerenciado

Características:

- controles operam de forma consistente em unidades de negócios materiais e jurisdições;
- monitoramento, limiares, métricas e escalada são usados;
- modelo, dados, fornecedor, finalidade e alterações legais desencadeiam reavaliação;
- os testes de validação técnica e de eficácia operacional são de rotina;
- evidências são ligadas à versão, confiáveis e recuperáveis;
- os executivos e o conselho recebem relatórios de risco suportáveis;
- São exercidas a prontidão para o incidente, a regulamentação, a continuidade e a saída do fornecedor;
- Os resultados repetidos são ativamente reduzidos.

1.1319.5 Nível 5 Otimização

Características:

- A governança está incorporada à estratégia, aquisição, design, desenvolvimento, liberação e operações;
- A automação confiável suporta testes de inventário, evidência, monitoramento e controle;
- incidentes, reclamações, auditorias, feedback da pessoa afetada e desenvolvimentos regulatórios impulsionam a mudança;
- riscos de sistema cruzado, sistêmico, de concentração e dependência são analisados;

- Os controles são reforçados, simplificados ou aposentados com base em evidências;
- A garantia é contínua e responsável pelo risco;
- a organização se adapta rapidamente sem perder a responsabilidade, a rastreabilidade legal ou a integridade das evidências.

1.1320 Domínios de avaliação

Avaliar a maturidade em pelo menos:

- governança, responsabilidade e supervisão do conselho;
- Inventário de IA, propriedade e ingestão do ciclo de vida;
- aplicabilidade legal, papel de ator, prática proibida e classificação de alto risco;
- Gestão de riscos, segurança e direitos fundamentais;
- governança de dados, privacidade e linhagem;
- desenvolvimento seguro, documentação técnica, validação e controle de mudanças;
- supervisão humana, transparência, acessibilidade e comunicação entre pessoas afetadas;
- Segurança cibernética, resiliência, continuidade e resposta a incidentes;
- governança de fornecedores, componentes, concentração e dependência;
- Monitoramento, reclamações, ações corretivas e processos pós-mercado;
- controle de projeto, evidência, manutenção de registros, testes e garantia interna;
- conformidade e prontidão regulamentar;
- Alfabetização e competência em IA;
- implantação multijurisdicional;
- melhoria contínua e varredura do horizonte.

1.1321 Princípios de pontuação

Use pontuação conservadora:

1. pontuar cada domínio separadamente;
2. Exigir provas objetivas e atuais;
3. distinguir a maturidade do projeto da maturidade operacional;
4. utilizar o nível mais baixo demonstrado de forma fiável, em que as práticas variem materialmente;
5. registro de escopo, suposições, exceções, limitações e confiança;
6. não mediar deficiências legais ou de segurança críticas;

7. não permitir que uma documentação forte compense uma operação ineficaz;
8. avaliar sistemas críticos e jurisdições separadamente quando necessário;
9. Reportar lacunas legais obrigatórias independentemente das classificações de maturidade;
10. não tratar as pontuações de maturidade como conclusões legais ou certificação de conformidade.

1.1322 Expectativas de evidência

As evidências podem incluir:

- Políticas aprovadas, cartas e matrizes de autoridade;
- inventários, avaliações de papéis e registros de classificação;
- Registros de controle e atribuições de propriedade;
- Risco, impacto, privacidade, segurança e avaliações legais concluídas;
- Registos de formação e competência;
- dados de teste, monitoramento, incidente, reclamação e desempenho;
- registros de fornecedor, contrato, direito de auditoria e continuidade;
- Relatórios de auditoria e de garantia;
- descobertas, exceções, remediação e evidências de fechamento;
- materiais executivos e do conselho;
- Correspondência regulatória e resultados de exercícios.

1.1323 Análise de gap e estado alvo

Para cada domínio:

1. Documentar o nível atual;
2. identificar provas de apoio e confiança;
3. Registrar lacunas legais ou de controle obrigatórias separadamente;
4. definir o nível-alvo com base no risco, obrigações, escala e complexidade;
5. identificar a lacuna e a causa raiz;
6. Atribuir ações, recursos, dependências e prazos responsáveis;
7. Definir critérios mensuráveis de conclusão e validação;
8. reavaliar após a implementação ou mudança material.

Nem todos os domínios precisam de Nível 5. O alvo deve ser proporcional aos deveres legais, risco do sistema, pessoas afetadas, escala, complexidade e contexto organizacional.

1.1324 Exemplo de GlobalWay Travel Services

A GlobalWay avalia seu programa como Nível 3 geral. As aprovações de governança, inventário e ciclo de vida são definidas, mas o monitoramento e a garantia variam entre as regiões. A validação técnica é Nível 4 para sistemas de recrutamento e fraude, enquanto a evidência do fornecedor e a transparência localizada permanecem Nível 2 em vários países.

A GlobalWay não permite que a média global esconda uma fraqueza crítica na supervisão do sistema de recrutamento. O conselho recebe classificações de nível de domínio, lacunas legais, confiança em evidências, proprietários de remediação, datas-alvo e resultados de melhoria validados de forma independente.

1.1325 Actividades de controlo

- Aprovar uma estrutura de maturidade, definições de domínio e critérios de pontuação.
- Avaliar cada domínio usando evidências objetivas e atuais.
- Design, implementação e maturidade operacional separados.
- Aplique classificações conservadoras de pontuação e confiança.
- Relate as lacunas legais obrigatórias separadamente e aumente-as por gravidade.
- Definir níveis-alvo baseados em risco.
- Vincule lacunas a planos de remediação financiados e responsáveis.
- Relate fraquezas críticas separadamente das médias.
- Use revisores qualificados e desafio de gerenciamento documentado.
- Reavaliar periodicamente e após a mudança material.

1.1326 Provas

- Metodologia de maturidade aprovada e critérios de domínio;
- Registros de competência e independência do avaliador;
- índice de evidência e planilhas de pontuação;
- Racionalidade, confiança e registros de limitação;
- registo legal-gap;
- desafio de gestão e aprovação;
- análise de lacunas e aprovações do estado-alvo;
- Roteiro de melhoria financiado;
- relatórios do executivo e do conselho;
- reavaliação e resultados de tendência.

1.1327 Testes de auditoria

1. Os critérios de maturidade são definidos e aplicados de forma consistente.
2. Ratings selecionados para evidências objetivas e atuais.

3. Confirmar design, implementação e maturidade operacional são distinguidos.
4. Revise se as fraquezas críticas legais, de segurança, de direitos ou de segurança foram obscurecidas pela média.
5. Avaliar se os níveis-alvo são proporcionais ao risco e às obrigações.
6. Trace lacunas de maturidade para ações responsáveis, financiadas e mensuráveis.
7. A melhoria relatada foi independentemente suportável.
8. Verifique se as classificações de maturidade não foram representadas como conformidade legal ou certificação.

1.1328 Métricas

- nível de maturidade por domínio;
- domínios abaixo do alvo;
- lacunas legais obrigatórias por gravidade;
- Domínios de alto risco no ou acima do alvo aprovado;
- Ações de maturidade vencidas;
- Classificações com baixa confiança em evidências;
- Repetir fraquezas;
- Variação da unidade de negócio e da jurisdição;
- tempo necessário para avançar domínios prioritários;
- melhorias validadas de forma independente.

1.1329 Lista de verificação de gestão

- As classificações de maturidade são apoiadas por evidências reais?
- As lacunas legais são relatadas separadamente das melhorias voluntárias de maturidade?
- O design e a eficácia operacional são avaliados separadamente?
- As fraquezas críticas são visíveis apesar das pontuações gerais?
- Os níveis-alvo estão ligados ao risco e às obrigações legais?
- As ações de melhoria são financiadas, atribuídas e mensuráveis?
- A reavaliação verifica se a maturidade realmente melhorou?

1.1330 Especificação da Figura AI Governance Maturity Staircase

Crie uma escada de cinco níveis do Initial através de Desenvolvimento, Definido, Gerenciado e Otimização. Mostre os domínios de governança progredindo para cima, com conformidade legal, evidências, eficácia operacional, desafio independente e melhoria contínua como fundamentos obrigatórios.

Alt text: Escada de maturidade de governança de IA de cinco níveis a partir de práticas iniciais e reativas por meio de governança definida, gerenciada

e continuamente melhorada, apoiada por conformidade legal, evidências, eficácia operacional e garantia independente.

1.1331 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, alterado: governança aplicável, gestão da qualidade, gestão de riscos, documentação, monitoramento, competência, ação corretiva e deveres de garantia.
- Regulamento (UE) 2026/1744, se aplicável.
- Os níveis de maturidade e a metodologia de pontuação neste capítulo são práticas de gestão recomendadas e não são prescritas pela Lei de IA da UE.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

1.1332 Capítulo 138 Melhoria Contínua

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem de rascunho do capítulo 138 anterior.

1.1333 Finalidade

Este capítulo explica como as organizações devem melhorar continuamente a governança da IA, controles, salvaguardas técnicas, garantia, evidência e prontidão regulatória após o programa inicial de conformidade ter sido implementado.

A IA pode apoiar a tomada de decisões humanas, mas não deve remover a responsabilidade humana, julgamento ou responsabilidade.

1.1334 Exigência

As organizações devem operar um processo documentado de melhoria contínua que use monitoramento, incidentes, reclamações, conclusões de auditoria, desenvolvimentos regulatórios, mudanças técnicas, feedback do usuário, dados de desempenho e lições aprendidas para fortalecer a governança e a conformidade da IA. Quando a Lei de IA da UE ou outra lei exigir ação corretiva, monitoramento pós-comercialização, atualizações de gerenciamento de risco, atualizações de gerenciamento de qualidade, alterações de documentação ou cooperação com autoridades, essas obrigações são vinculativas.

1.1335 Explicação em linguagem simples

A governança da IA não pode permanecer estática. Modelos, dados, fornecedores, métodos de ataque, usos comerciais, requisitos legais e populações afetadas mudam. A melhoria deve, portanto, ser sistemática, baseada em evidências, priorizada pelo risco e vinculada a decisões responsáveis, em vez de lições informais ou atualizações periódicas de políticas.

Um programa não é melhorado apenas porque uma política foi revisada. A organização deve mostrar que a mudança foi implementada, testada, vinculada ao sistema e versão corretos e eficaz na prática.

1.1336 Melhoria dos inputs

Use inputs de:

- desenvolvimentos legais e regulamentares;
- Orientação oficial, atos de execução, normas e códigos, identificados por estatuto legal;
- mudanças de sistema, modelo, dados, prompt, ferramenta, interface e infraestrutura;
- novos casos de uso, jurisdições, setores e populações afetadas;
- monitoramento, deriva, erro, abstenção, substituição e dados de desempenho;
- incidentes, quase erros, reclamações, apelos e resultados adversos;
- Auditoria, validação, conformidade e resultados de testes de controle;
- alterações do fornecedor, risco de concentração, interrupções e eventos da cadeia de suprimentos;
- Segurança cibernética, privacidade, segurança e inteligência de direitos fundamentais;
- funcionário, usuário, pessoa afetada e feedback de acessibilidade;
- executivo, conselho, regulador, auditor e desafio de revisão independente;
- avaliações de maturidade, benchmarking e tendências de garantia.

1.1337 Ciclo de melhoria

O programa deve:

1. identificar o problema, oportunidade, sinal ou mudança;
2. determinar se indica não-conformidade, risco emergente, modificação substancial, alteração da finalidade pretendida ou controle da fraqueza;
3. avaliar o impacto legal, de segurança, direitos fundamentais, privacidade, segurança cibernética, operacional e empresarial;
4. conter riscos imediatos e iniciar relatórios legalmente exigidos ou ações corretivas;
5. preservar evidências e definir sistemas, versões, fornecedores, jurisdições e pessoas afetados;
6. realizar análise de causa-raiz e do escopo afetado;
7. Priorizar com base na gravidade, urgência, prazo legal e danos potenciais;

8. atribuir propriedade responsável, autoridade de decisão, recursos e prazos;
9. Design de ações corretivas, preventivas ou sistêmicas;
10. testar a alteração proposta e avaliar as consequências não intencionais;
11. aprová-lo e implementá-lo através da gestão controlada da mudança;
12. Atualizar avaliações de risco, documentação técnica, controles, instruções, avisos, treinamento, contratos e monitoramento, quando necessário;
13. validar a eficácia operacional de forma independente, quando apropriado;
14. compartilhar lições em sistemas relevantes, unidades de negócios, fornecedores e jurisdições;
15. Medir se os resultados e a eficácia do controle melhoraram;
16. preservar evidências ligadas à versão e aprovação de gerenciamento.

1.1338 Priorização

Priorizar melhorias com base em:

- danos reais ou potenciais;
- exposição a práticas proibidas;
- Obrigações de alto risco ou GPAI;
- prazo legal, pedido de autoridade ou compromisso regulamentar;
- controlar a gravidade e a duração da falha;
- população afetada, vulnerabilidade e escala;
- Repetir incidentes, reclamações, conclusões ou exceções;
- concentração, dependência ou limitações de evidência do fornecedor;
- Segurança cibernética, segurança, resiliência e impacto de continuidade;
- fraqueza na documentação, logs, testes ou rastreabilidade;
- complexidade de implementação e dependências;
- oportunidade de evitar a recorrência em vários sistemas.

1.1339 Ação corretiva e preventiva

Distinguir:

- correção: ** ação imediata que aborda um problema observado específico;
- ** ação corretiva:** ação que remove ou controla a causa de uma deficiência real;
- ** ação preventiva:** ação que reduza a probabilidade ou o impacto de uma deficiência previsível;

- Melhoria sistêmica: ação que aborda causas comuns em sistemas, fornecedores, entidades, jurisdições ou domínios de controle.

Não feche um item apenas porque um documento foi atualizado, uma reunião ocorreu ou um fornecedor prometeu remediação. Confirme que a ação opera de forma eficaz e que o risco residual é explicitamente governado.

1.1340 Gestão de mudanças regulatórias e legais

Manter um processo para:

- identificar os desenvolvimentos jurídicos e regulamentares relevantes;
- distinguir a lei vinculativa de rascunhos, orientações, normas e códigos voluntários;
- avaliar a aplicabilidade, o papel do ator, a classificação do sistema e as datas efetivas;
- identificar sistemas, modelos, entidades, fornecedores, jurisdições e controles afetados;
- Obrigação de atualização e mapeamentos artigo-controle;
- revisar políticas, contratos, avisos, avaliações, treinamento e requisitos de evidência;
- Comunicar mudanças a pessoal responsável;
- Implementação do teste antes do prazo aplicável;
- reter análise legal, aprovações e evidências de implementação.

1.1341 Gestão técnica e de mudança de fornecedor

A melhoria contínua deve responder a:

- Liberações de modelos, depreciações e capacidades alteradas;
- Avisos alterados, instruções do sistema, ferramentas, agentes ou autonomia;
- novos dados de treinamento, ajuste, validação ou recuperação;
- desempenho, subgrupo, idioma, acessibilidade ou achados de deriva;
- novas vulnerabilidades, métodos de ataque ou padrões de uso indevido;
- termos do fornecedor, locais, subprocessadores, níveis de serviço e documentação;
- registro, reprodutibilidade, retenção e limitações de evidências;
- alterações de infraestrutura, arquitetura, região da nuvem e interface;
- Componentes de código aberto e alterações de licença;
- alterações que afetem a finalidade pretendida, o papel legal, a classificação ou o estado de conformidade.

1.1342 Aprendendo com incidentes e reclamações

Para eventos materiais:

- reconstruir a linha do tempo e preservar as evidências;
- identificar causas técnicas, de processo, governança, fornecedores e humanas;
- avaliar se sistemas semelhantes compartilham a fraqueza;
- implementar contenção imediata;
- determinar as implicações de notificação, ação corretiva, retirada, recall ou suspensão;
- Atribuir ações corretivas, preventivas e sistêmicas;
- validar o encerramento independentemente onde o risco justifica;
- Atualizar cenários, treinamento, controles, documentação, contratos e monitoramento;
- Relatar lições e riscos residuais para os executivos e o conselho.

1.1343 Otimização de controle

Revise periodicamente se os controles são:

- legalmente alinhados e atuais;
- claramente possuídos e realizados com competência;
- proporcional ao risco e ao contexto do sistema;
- implementado de forma consistente em entidades e jurisdições relevantes;
- apoiado por evidências confiáveis e ligadas à versão;
- capaz de detectar falhas significativas;
- Duplicativo, fragmentado ou desnecessariamente oneroso;
- integrado em fluxos de trabalho de negócios e tecnologia;
- Resistente ao sistema, fornecedor e mudança legal;
- adequado para automação sem reduzir a responsabilidade, julgamento humano ou rastreabilidade.

A simplificação do controle só é apropriada quando preserva ou melhora a conformidade legal, a proteção, a qualidade das evidências e a eficácia operacional.

1.1344 Exemplo de GlobalWay Travel Services

A GlobalWay identifica repetidas falhas de escalada viajante-assistente após atualizações do modelo do fornecedor. A empresa determina que o problema é sistêmico: as alterações do fornecedor não acionam automaticamente a jurisdição, a transparência, a supervisão humana, o teste de regressão e as revisões de pessoal.

A GlobalWay fortalece a notificação de mudança, adiciona jurisdição obrigatória e verificações de impacto da pessoa afetada, expande os testes de regressão multilíngue, melhora o pessoal de supervisão humana e a escalada, atualiza as cláusulas do fornecedor e bloqueia a liberação quando as evidências necessárias estão incompletas. A garantia interna valida a eficácia em todos os idiomas e cenários de interrupção antes que a ação corretiva seja fechada.

1.1345 Atividades de controle

- Manter um processo de melhoria contínua aprovado e registro de sinal.
- Colete entradas de fontes legais, técnicas, operacionais, de fornecedores, usuários e de garantia.
- Priorizar com base em deveres legais, danos potenciais, gravidade, recorrência e prazos.
- Distinguir correção, ação corretiva, ação preventiva e melhoria sistêmica.
- Preserve evidências e defina o escopo afetado antes que mudanças materiais sejam feitas.
- Aplicar testes controlados, revisão legal quando necessário e aprovação antes da implementação.
- Validar a eficácia operacional antes do fechamento.
- Atualizar políticas, controles, arquivos de risco, documentação técnica, avisos, contratos, treinamento e evidências.
- Rastreie problemas de repetição, ações atrasadas e remediação ineficaz.
- Relate tendências materiais, fraquezas sistêmicas e risco residual para os executivos e o conselho.

1.1346 Provas

- Registo de alterações legais e regulamentares;
- Registo de sinais de monitorização e melhoria;
- Incidente, reclamação, recurso, auditoria e registros de fornecedores;
- avaliações de risco, gravidade, prioridade e escopo afetado;
- análises de causa-raiz;
- planos de ação corretiva, preventiva e sistêmica;
- aprovações de contenção e alteração;
- Resultados de teste, validação, regressão e revisão independente;
- Registros atualizados de risco, controle, técnico, contratual, treinamento e aviso;
- registros de revisão cross-system e lições aprendidas;
- revisão de gestão, riscos residuais e aprovações de encerramento;
- Métricas de tendência e eficácia;

- relatórios do executivo e do conselho.

1.1347 Testes de auditoria

1. Revise se os insumos relevantes legais, técnicos, fornecedores, monitoramento, incidentes, reclamações e garantias entram no processo de melhoria.
2. Trace melhorias selecionadas da identificação através da preservação, priorização, implementação, validação e fechamento.
3. Confirmar a causa-raiz e a análise do escopo afetado abordou causas sistêmicas, quando apropriado.
4. Verificar imediatamente a contenção, relatórios e deveres de ação corretiva foram avaliados prontamente.
5. As ações de confirmação não foram fechadas apenas em provas documentais, discussão ou garantia do fornecedor.
6. Avaliar se as alterações desencadearam atualizações para arquivos de risco, controles, documentação técnica, avisos, treinamento, contratos e monitoramento.
7. Revise os resultados e incidentes repetidos para remediação ineficaz ou escalada fraca.
8. Confirmar lições materiais e riscos residuais foram relatados à administração responsável e ao conselho.
9. Verifique se a simplificação ou automação do controle não reduziu a responsabilidade, a evidência ou a proteção legal.

1.1348 Métricas

- ações de melhoria abertas, atrasadas, validadas e fechadas;
- Repetir descobertas, incidentes, reclamações e exceções;
- tempo desde a detecção do sinal até a contenção e decisão responsável;
- tempo desde a remediação até o fechamento validado;
- alterações legais implementadas antes do prazo aplicável;
- problemas sistêmicos identificados em vários sistemas ou fornecedores;
- controles simplificados ou automatizados com eficácia validada;
- Melhorias que produzam redução de risco mensurável;
- Riscos residuais aceites após remediação incompleta ou mal sucedida;
- Ações fechadas sem validação independente quando necessário;
- mudanças no fornecedor recebidas e avaliadas no tempo.

1.1349 Lista de verificação de gestão

- Estamos aprendendo com incidentes, reclamações, monitoramento, auditorias, usuários e fornecedores?

- As mudanças legais obrigatórias distinguem-se do material não vinculativo e são implementadas a tempo?
- As causas raiz e o escopo afetado são abordados em vez de sintomas sozinhos?
- O risco imediato está contido enquanto a remediação de longo prazo prossegue?
- Os artefatos, avisos, controles e treinamentos necessários são atualizados após a mudança?
- A eficácia é testada antes do fechamento?
- Problemas repetidos são visíveis e escalados?
- A melhoria contínua produz redução de risco mensurável sem enfraquecer a responsabilidade?

1.1350 Especificação da Figura AI Governance Continuous-Improvement Loop

Crie um ciclo fechado conectando mudanças regulatórias, monitoramento, incidentes, reclamações, auditorias, mudanças de fornecedor, feedback do usuário, avaliações de maturidade, priorização, contenção, ação corretiva e preventiva, testes, implementação, validação, evidência atualizada e monitoramento renovado. Mostrar supervisão executiva e do conselho em todo o ciclo.

Alt text: Ciclo de melhoria contínua para a governança da IA usando mudanças legais, monitoramento, incidentes, reclamações, auditorias, mudanças de fornecedores, feedback do usuário e avaliações de maturidade para impulsionar a contenção, ação priorizada, testes, implementação, validação, evidência atualizada e supervisão renovada do executivo e do conselho.

1.1351 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: artigos 9.º, 17.º, 20.º, 72.º, 73.º e outras disposições aplicáveis em matéria de gestão de riscos, gestão da qualidade, monitorização, incidentes, acções correctivas, documentação e cooperação entre autoridades.
- Regulamento (UE) 2026/1744, se aplicável.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor, acessibilidade, igualdade e lei específica do setor.
- O ciclo mais amplo de melhoria contínua neste capítulo é uma prática de gestão recomendada, exceto quando um dever legal aplicável torna uma ação específica obrigatória.
- Textos oficiais consolidados atuais controlam resumos mais antigos.

2 Apêndices

2.1 Apêndice A Modelo de inventário de IA

Estado legal: Mestre inglês corrigido. Este é um registro de governança organizacional. Campos específicos tornam-se legalmente obrigatórios apenas quando uma disposição vinculativa se aplica ao ator, sistema, modelo, componente ou uso relevante.

2.2 Finalidade

Use este modelo para manter um inventário completo, atual, vinculado a versão e auditável de sistemas de IA, modelos GPAI, capacidades de IA incorporadas, componentes, integrações, pilotos e casos de uso de materiais em toda a organização.

O inventário deve apoiar a aplicabilidade, papel, classificação, risco, transparência, conformidade, monitoramento, incidentes, evidências e decisões de gerenciamento de mudanças. Deve distinguir as classificações estatutárias dos níveis de governança definidos pela organização.

2.3 Registro de inventário

Campo	Informações necessárias
ID do inventário	Identificador único e persistente
Estado de registro	Draft, ativo, restrito, suspenso, aposentado, arquivado
Pessoa coletiva	Entidade desenvolvendo, fornecendo, fornecendo, importando, distribuindo, integrando, colocando no mercado, colocando em serviço ou implantando o sistema / modelo
papel(s) de ator	Fornecedor, fornecedor GPAI, fornecedor a jusante, despachante, importador, distribuidor, representante autorizado, fabricante do produto, outro
Nome do sistema/modelo	Empresas, produtos, modelos e nomes técnicos oficiais
proprietário do negócio	Responsável executivo ou proprietário do processo e alternativa
Proprietário técnico	Engenharia responsável, arquitetura, dados ou proprietário de plataforma e alternativa

Campo	Informações necessárias
Proprietários de controle	Legal, Compliance, Risco, Privacidade, Segurança, Dados, Compras, RH, Produto, Auditoria ou outras funções responsáveis
Fase do ciclo de vida	Ideia, entrada, piloto, desenvolvimento, validação, pré-lançamento, produção, restrito, suspenso, aposentado
Propósito pretendido	Finalidade aprovada, contexto de decisão, usuários esperados, beneficiários e pessoas afetadas
Fins proibidos ou restritos	Usos, populações, dados, decisões, jurisdições ou funções que não são permitidas
Utilização real	Uso operacional atual, incluindo desvios do propósito pretendido aprovado
Usuários	Empregados, contratados, clientes, usuários públicos, parceiros, autoridades ou outros
Pessoas afectadas	Indivíduos ou grupos afetados materialmente, incluindo trabalhadores, candidatos, viajantes, crianças, pessoas vulneráveis ou grupos protegidos
Técnica de IA	Regras, aprendizado de máquina, aprendizado profundo, IA generativa, GPAI, IA antrópica, sistema biométrico, recomendador, híbrido, outro
Arquitetura do sistema	Principais componentes, interfaces, recuperação, ferramentas, agentes, automação, fallback e pontos de controle humano
Versão/configuração	Modelo de produção, sistema, prompts, instruções do sistema, ferramentas, dados, parâmetros, código e identificadores de liberação
Fornecedor/fornecedor	Equipe interna ou fornecedor externo
Depend dependências críticas	Modelos, APIs, serviços em nuvem,

Campo	Informações necessárias
	conjuntos de dados, software, componentes de código aberto, subprocessadores e infraestrutura
Competências	Desenvolvimento, colocação no mercado, implantação, uso de saída, hospedagem, suporte e locais de pessoas afetadas
contexto sector/utilização	Emprego, educação, crédito, seguro, viagens, saúde, serviços públicos, segurança, aplicação da lei, migração, justiça, consumidor, outros
Aplicação da lei de IA da UE	No âmbito, parcialmente no âmbito, fora do âmbito, excluídos/especialmente tratados, incertos, pendentes revisão legal
Artigo 5.o Triagem	Nenhuma preocupação, prática proibida potencial, proibida, análise de exceção exigida
Classificação de alto risco	Artigo 6.o, n.o 1/Anexo I, artigo 6.o, n.o 2/Anexo III, artigo 6.o, n.o 3, exceção considerada, não de alto risco, incerta
Classificação de transparência	Artigo 13, Artigo 26, Artigo 50, outro dever de notificação, nenhum identificado, incerto
Status GPAI	Modelo GPAI, modelo GPAI com risco sistêmico, sistema a jusante usando GPAI, não aplicável, incerto
Nível de risco de governança	Nível de risco definido pela organização, claramente separado da classificação estatutária
Fontes de dados	Dados de treinamento, tuning, validação, recuperação, entrada, operacional, monitoramento e feedback
Características dos dados	Pessoal, categoria especial, biométrico, confidencial, protegido por direitos autorais, infantil, sintético, público, licenciado, outro
Governança de dados	Proveniência, linhagem, qualidade, representatividade, controles de

Campo	Informações necessárias
	viés, retenção, exclusão, localização e transferência de informações
Saídas/ações	Previsões, rankings, recomendações, conteúdo, pontuações, classificações, decisões, alertas, chamadas de ferramentas ou ações automatizadas
Impacto na decisão	Aconselhamento, influência material, decisão automatizada, segurança crítica, impacto nos direitos, financeiro, emprego, acesso a serviços, outros
Supervisão humana	Revisor, competência, autoridade, substituir, parar, apelo, escalada, fallback e requisitos de pessoal
Avaliações necessárias	Aplicabilidade, papel, prática proibida, alto risco, FRIA, DPIA, segurança, dados, fornecedor, conformidade, transparência, modificação substancial, outros
Documentação técnica	ndice, proprietário, localização, versão, status e mapeamento do Anexo IV aplicável
Conformidade/registro	Rota, envolvimento do corpo notificado, declaração, marcação CE, registro, status e evidência, quando aplicável
Direitos de transparência	Avisos, rótulos, instruções, divulgações, marcações legíveis por máquina, idiomas e acessibilidade
Monitorização	Desempenho, precisão, deriva, resultados de subgrupos, viés, segurança, robustez, incidentes, reclamações, substituições e limiares
Deveres de notificação/incidente	Considerações de incidentes graves, ações corretivas, privacidade, segurança cibernética, produto, emprego, consumidor ou setor
Acionadores de mudança	Modelo, versão, finalidade, dados, fornecedor, população, jurisdição,

Campo	Informações necessárias
	interface, capacidade ou mudança legal
localização da evidência	Sistema de registro e repositório vinculado a versão
retenção	Requisitos legais, contratuais, operacionais e legais aplicáveis
Datas de aplicação	Datas efetivas específicas de provisão e regras de transição
Estado/aprovação	Aprovado, condicional, restrito, suspenso, rejeitado, aposentado
Achados abertos	Deficiências materiais, exceções, condições, remediação e datas de vencimento
Histórico de revisão	ltima revisão, próxima revisão, gatilho, revisor, decisão e raciocínio

2.4 Requisitos mínimos de controle

- Atribua proprietários responsáveis de negócios, técnicos e de controle.
- Grave sistemas de produção de materiais, pilotos, provas de conceito, recursos de IA incorporados, integrações GPAI e IA fornecida externamente.
- Reconciliar o inventário com a aquisição, finanças, nuvem, software, dados, segurança, RH, produtos, registros legais e de fornecedores.
- Vincule cada entrada aos registros de aplicabilidade, papel, classificação, risco, fornecedor, avaliação, controle, evidência e aprovação.
- Distinguir a operação real do propósito pretendido e registrar o uso não autorizado ou de shadow-AI.
- Preserve versões históricas, decisões de papel e classificação, restrições, suspensões, revisões de modificação substancial e evidências de aposentadoria.
- Reavaliar após propósito pretendido, ator-papel, versão, modelo, dados, fornecedor, população, jurisdição, incidente, reclamação ou mudança legal.
- Escalar sistemas sem proprietário, indocumentados, proibidos ou materialmente incertos de acordo com a gravidade.
- Textos legais oficiais consolidados atuais controlam resumos mais antigos.

2.5 Verificação da qualidade do inventário

Confirme periodicamente que:

1. Cada sistema de IA material e integração GPAI tem um registro único;
2. as versões de produção correspondem à documentação aprovada;
3. Os proprietários, fornecedores, jurisdições e status do ciclo de vida são atuais;
4. a classificação estatutária e o nível de governança interna não são confundidos;
5. As avaliações e aprovações exigidas são completas ou explicitamente pendentes;
6. links de evidência são acessíveis, compatíveis com a versão e retidos;
7. Sistemas suspensos e aposentados não podem continuar a operação não autorizada;
8. mudanças materiais desencadeiam reavaliação e aprovação.

2.6 Exemplo de GlobalWay Travel Services

O inventário identifica um modelo GPAI de terceiros usado em dois sistemas, vincula cada implantação à pessoa jurídica e jurisdição correta, registra controles de transparência e supervisão humana e sinaliza uma atualização do fornecedor do sistema de recrutamento para modificação substancial e reavaliação de alto risco.

2.7 Certificação

Papel	Nome	Decisão	Data
proprietário do negócio			
Proprietário técnico			
Legal/			
Avaliador de conformidade			
Revisor de privacidade/s			
segurança/dad			
os, quando aplicável			

Referências de evidências: Condições ou exceções: Resultados abertos e datas de vencimento: Próximo comentário trigger/date: Versão de gravação:**

2.8 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: definições aplicáveis, escopo territorial, papéis de ator, práticas proibidas, classificação de alto risco, GPAI, transparência, registro, documentação, monitoramento, incidentes e disposições de acesso à autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação aplicável em matéria de emprego, defesa do consumidor, cibersegurança, segurança dos produtos, acessibilidade, igualdade, gestão de registos e sector.
- Os campos de inventário neste modelo são controles de governança, a menos que um dever legal específico torne um campo ou registro obrigatório.

2.9 Apêndice B Formulário de admissão da IA

Estado legal: Mestre inglês corrigido. Este é um controle de admissão organizacional. As conclusões legais obrigatórias devem ser vinculadas ao ator, sistema, modelo, uso, jurisdição, provisão e data de aplicação relevantes.

2.10 Finalidade

Use este formulário antes de comprar, desenvolver, pilotar, mudar materialmente, marcar, integrar, colocar no mercado, colocar em serviço ou implantar um sistema de IA ou uma capacidade habilitada para GPAI.

A ingestão deve ocorrer cedo o suficiente para interromper a atividade proibida ou não suportada, identificar as revisões necessárias, preservar evidências, alocar a propriedade e evitar a liberação antes que as condições legais, técnicas, operacionais e do fornecedor sejam satisfeitas.

2.11.1. Solicitar informações

- Pedido de título:
- Unidade de negócios de solicitação:
- Requerente:
- Patrocinador Executivo:
- Proprietário do negócio:
- Proprietário técnico:
- Entidade ou entidades jurídicas:
- Países e territórios de desenvolvimento pretendido, colocação no mercado, implantação, uso de saída, hospedagem e suporte:
- Data-piloto solicitada:
- Data de lançamento da produção solicitada:
- Aquisição, projeto, contrato ou referência de alteração:

- ID de inventário relacionado, se existente:
- Sistema/modelo/versão existente a ser alterado, se aplicável:

2.122. Descrição do caso de uso

- Problema de negócio:
- Finalidade prevista:
- Benefícios esperados:
- Usuários:
- Pessoas e grupos afetados:
- Pessoas vulneráveis, crianças, trabalhadores, candidatos, viajantes, clientes ou grupos protegidos afetados:
- Decisões, recomendações, rankings, conteúdo ou ações influenciadas:
- Grau de automação: consultoria / influência material / decisão automatizada / ação externa automatizada:
- Tomador de decisão humano, se houver:
- Consequências de erro, uso indevido, atraso, indisponibilidade ou manipulação:
- Alternativa não-AI existente:
- Processo de fallback ou manual proposto:
- Uso indevido previsível:
- Utilização proibida ou restrita:
- Se o uso difere do propósito pretendido declarado pelo fornecedor:

2.133. Tecnologia e cadeia de valor

- Solução interna, externa ou híbrida:
- Fornecedor/fornecedores:
- Nomes de produtos, sistemas e modelos:
- Versões atuais e propostas:
- Hospedagem e regiões de nuvem:
- APIs, plugins, ferramentas, agentes, recuperação ou ações externas:
- Componentes e licenças de código aberto:
- Fornecedores de dados, subprocessadores, fornecedores a jusante e dependências críticas:
- Ajuste fino, engenharia rápida, recuperação ou alterações de modelo personalizadas:
- Branding, revenda, integração ou colocação de nome próprio:
- Processo de atualização de modelo esperado e de notificação de alteração:
- Capacidades de registro, reprodutibilidade e identificação de versão:
- Documentação do fornecedor disponível:
- Limitações técnicas ou de provas conhecidas:

2.144. Dados

- Dados de entrada:
- Dados de treinamento, ajuste, validação, recuperação, aterramento, monitoramento e feedback:
- Dados pessoais envolvidos:
- Dados de categoria especial, biométricos, infantis, confidenciais, protegidos por direitos autorais ou regulamentados:
- Sujeitos de dados ou populações afetadas:
- Fontes de dados e proveniência:
- Base legal ou base de uso autorizado:
- Dados do cliente ou usuário usados para treinamento ou melhoria de fornecedores:
- A qualidade dos dados, representatividade, viés e gap diz respeito:
- Localização dos dados, localização e transferências transfronteiriças:
- Retenção, exclusão, arquivamento e requisitos legais:
- Controles de minimização e acesso de dados:

2.155. Rastreamento preliminar legal e de risco

Resposta **Sim**, **Não**, ou **Incerto** e citar evidências.

Pergunta	Sim/Não/Incerto	Evidência ou racionalidade	Proprietário
A atual definição legal do sistema de IA se aplica?			
Quais entidades legais e papéis de ator do EU AI Act podem ser aplicados?			
Pode uma prática proibida do artigo 5o ser envolvida?			
Pode aplicar-se o n.o 1 do artigo 6.o/Anexo I tratamento de alto risco?			
Pode aplicar-se o n.o 2 do artigo 6.o/Anexo III			

Pergunta	Sim/Não/Incerto	Evidência ou racionalidade	Proprietário
tratamento de alto risco?			
Pode uma exceção ao artigo 6.o, n.o 3, ser relevante e a definição de perfis impede a sua dependência?			
O artigo 13o, o artigo 26o, o artigo 50o ou outros direitos de transparência podem ser aplicados?			
Um modelo GPAI ou modelo GPAI com risco sistêmico está envolvido?			
Podem aplicar-se os direitos do artigo 27.o da FRIA?			
Pode o GDPR DPIA, Artigo 22, privacidade, emprego, igualdade, acessibilidade, consumidor, segurança de produtos, segurança cibernética ou deveres do setor se aplicar?			
A colocação de marca própria, mudança de			

Pergunta	Sim/Não/Incerto	Evidência ou racionalidade	Proprietário
propósito pretendido ou deveres substanciais do provedor de transferência de modificação?			
O uso poderia afetar a segurança, direitos fundamentais, acesso a serviços, emprego, crédito, seguro, educação, saúde, viagens, aplicação da lei, migração, justiça ou infraestrutura crítica?			
As pessoas podem interagir diretamente com a IA?			
O sistema irá gerar ou manipular texto, áudio, imagens ou vídeo?			
O sistema poderia inferir emoções, traços sensíveis, identidade ou categorias biométricas?			
O sistema poderia agir de forma autônoma ou desencadear			

Pergunta	Sim/Não/Incerto	Evidência ou racionalidade	Proprietário
ações externas?			
As datas de aplicação específicas da provisão ou as regras de transição são materiais para a decisão?			

2.166. Supervisão, salvaguardas e evidências

- Papel e competência do revisor humano:
- Aprovação, substituição, paragem, reversão ou mecanismo de abstenção:
- Desafio, apelo, reclamação e canal de contato humano:
- Precisão, viés, subgrupo, robustez, mau uso e testes de confiabilidade:
- Testes de segurança, privacidade e ameaças:
- Limites de monitorização e escalada:
- Resposta a incidentes e avaliação de notificação:
- Método de reversão, suspensão, recuperação e continuidade de negócios:
- Usuário, trabalhador, solicitante, cliente ou pessoa afetada:
- Marcação ou divulgação de conteúdo sintético:
- Acessibilidade e requisitos linguísticos:
- Alfabetização em IA e treinamento baseado em funções necessários:
- Evidência do fornecedor, direitos de auditoria e cooperação de incidentes:
- Repositório de evidências e retenção:

2.177. Avaliações necessárias

Marca **Obrigatório**, **Completado**, **Não aplicável**, ou **Pendente**.

Revisão	Necessário?	Proprietário	Estado	Evidência/referência
Entrada ou atualização do inventário de IA				
Avaliação da aplicabilidade				

Revisão	Necessário?	Proprietário	Estado	Evidência/ referência
e				
Avaliação do papel-actor				
Triagem de prática proibida				
Classificação de alto risco				
Avaliação de risco sistémico				
GPAI/avaliaç ão de risco sistémico				
Avaliação de impacto dos direitos fundamentai s				
Avaliação de impacto na proteção de dados				
Avaliação de governança de dados				
Avaliação de segurança e ameaças				
Validação técnica				
Plano de Supervisão Humana				
due diligence do fornecedor				
Revisão de contrato e direito de				

Revisão	Necessário?	Proprietário	Estado	Evidência/ referência
auditoria				
Revisão de transparência e marcação				
Acessibilidade e e revisão da linguagem				
Avaliação de modificação substancial				
Revisão da conformidade e-preensão				
Revisão de registro, declaração ou marcação CE				
Plano de monitorização o pós- comercializa ção				
prontidão para incidentes e notificações				
Aprovação do Executivo ou Conselho de Administração				

2.188. Decisão

- ☐ Aprovado
- ☐ Aprovado com condições
- ☐ Apenas piloto restrito
- ☐ Evidências pendentes adiadas
- ☐ Rejeitado
- ☐ Proibido ou suspenso

- ☐ Revisão legal qualificada necessária

Motivo da decisão: Condições e restrições: Suposições ou incertezas não resolvidas: Proprietários de remediação e datas de vencimento: Referências de evidências: Acionadores de reavaliação: Data de validade ou próxima data de revisão: **

2.199. Aprovação

Papel	Nome	Decisão	Data
proprietário do negócio			
Proprietário técnico			
Legal/ Conformidade			
Risco/ Privacidade/ Segurança/ Dados, conforme aplicável			
Compras/ HR/Produto, conforme aplicável			
autoridade executiva ou do conselho, quando necessário			

2.20 Exemplo de GlobalWay Travel Services

A GlobalWay apresenta uma entrada para um novo assistente de interrupção do viajante usando um modelo GPAI de terceiros e ferramentas de rereserva automatizadas. A entrada identifica a interação direta com viajantes, dados sensíveis de itinerário, ações de ferramentas externas, avisos multilíngues, alterações na versão do fornecedor e a necessidade de aprovação humana antes de reembolsos ou remarcação sensível à segurança. O piloto é aprovado com condições: campos de dados restritos, confirmação humana, monitoramento aprimorado, notificação de mudança do fornecedor e conclusão da transparência, segurança, fornecedor.

2.21 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: definições aplicáveis, escopo territorial, papéis de ator, práticas proibidas, classificação de alto risco, transparência, GPAI, conformidade, monitoramento, incidentes e disposições de acesso à autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação aplicável em matéria de emprego, igualdade, acessibilidade, defesa do consumidor, cibersegurança, segurança dos produtos, gestão de registos, propriedade intelectual e sectorial.
- A aprovação de admissão é uma decisão de governança organizacional e não substitui qualquer avaliação de conformidade legalmente exigida, registro, decisão de autoridade, consulta, notificação ou análise jurídica qualificada.

2.22 Apêndice C Avaliação da aplicabilidade

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a língua anterior do Apêndice C em conflito. As conclusões de aplicabilidade devem ser validadas por um advogado qualificado, onde a interpretação é incerta ou materialmente consequente.

2.23 Finalidade

Use esta planilha para determinar se a Lei de IA da UE se aplica a uma entidade jurídica, sistema de IA, modelo GPAI, atividade, implantação, produção, integração de produtos ou relação de cadeia de valor. A avaliação deve identificar a conexão territorial relevante, assunto, papéis de ator, classificações, datas efetivas, exclusões e regimes legais relacionados.

Uma decisão de aplicabilidade não é completa, a menos que esteja ligada a fatos, evidências, o texto legal oficial atual e gatilhos de revisão definidos.

2.241. Metadados de avaliação

Campo	Resposta
Entidade jurídica avaliada	
Entidades jurídicas relacionadas	
Unidade de negócio	
Sistema ou modelo	
ID do inventário	
Propósito pretendido	
Uso real ou proposto	
Fornecedor/fornecedor	

Campo	Resposta
Integração de produto ou serviço	
Países envolvidos	
Clientes e utilizadores	
Pessoas e grupos afetados	
Proprietário da avaliação	
Revisor Legal	
Data de avaliação	
Source-text version/data	

2.252. Triagem territorial e de conexão de mercado

Resposta **Sim**, **Não**, ou **Incerto** e citar evidências.

Pergunta	Resposta	Evidência ou racionalidade
Um fornecedor está a colocar um sistema de IA no mercado da União?		
Um fornecedor está a colocar um modelo GPAI no mercado da União?		
Um provedor está colocando um sistema de IA em serviço na União?		
Um implantador está estabelecido ou localizado na União?		
A produção é produzida por um sistema de IA fora da União utilizado na União?		
Um importador, distribuidor, representante autorizado, fabricante de produtos ou fornecedor a jusante		

Pergunta	Resposta	Evidência ou racionalidade
está envolvido na atividade do mercado da União?	O sistema de IA é um componente de segurança de um produto regulamentado que entra no mercado da União?	
Os clientes da União, trabalhadores, candidatos, viajantes ou outras pessoas afetadas estão envolvidos?	Existe uma estrutura contratual, operacional ou de distribuição que ligue o sistema ou modelo ao mercado da União?	

Não baseie a conclusão apenas na sede, desenvolvedor, servidor ou localização da região da nuvem. Documente a entidade legal relevante, a atividade do mercado, a implantação e o uso da saída.

2.263. Triagem da matéria-sujeito

Pergunta	Resposta	Evidência ou racionalidade
A capacidade atende à definição legal atual de um sistema de IA?	Um modelo GPAI está envolvido, separadamente de um sistema de IA a jusante?	
A capacidade é apenas software convencional, automação, análise ou regras que não atendem à definição		

Pergunta	Resposta	Evidência ou racionalidade
estatutária?		
O sistema ou modelo é parte de um produto regulamentado ou componente de segurança?		
Pesquisa, desenvolvimento, testes, militares, defesa, segurança nacional, pessoal não profissional, código aberto ou outra exclusão ou tratamento especial é reivindicado?		
Todas as condições estatutárias e limitações de escopo para o tratamento reivindicado estão documentadas?		
O produto específico do setor, segurança, emprego, igualdade, acessibilidade, consumidor, privacidade, segurança cibernética, saúde, serviços financeiros, transporte ou outra lei também se aplica?		

Uma exclusão ou tratamento especial ao abrigo de uma disposição do AI Act não elimina as obrigações aplicáveis de forma independente ao abrigo do AI Act ou outra lei.

2.274. Actor-role triagem

Avaliar todas as entidades jurídicas relevantes e todas as funções potencialmente concorrentes:

- fornecedor de um sistema de IA;

- fornecedor de um modelo GPAI;
- Provedor a jusante;
- deployer;
- importador;
- distribuidor;
- Representante autorizado;
- fabricante do produto;
- o ator potencialmente adquirindo obrigações de provedor por meio de colocação de marca própria, modificação substancial, mudança de propósito pretendido ou outra conduta legalmente relevante.

Entidade	Competência	Papel	Base factual	Direitos aplicáveis	Provas	Incerteza jurídica
----------	-------------	-------	--------------	---------------------	--------	--------------------

A linguagem do contrato é uma evidência relevante, mas não substitui o papel legal factual.

2.285. Proibido-prática triagem

Determinar se o uso pode envolver qualquer preocupação do Artigo 5o, incluindo manipulação, exploração de vulnerabilidade, pontuação social, policiamento preditivo, raspagem de imagem facial, reconhecimento de emoções em contextos restritos, categorização biométrica sensível, identificação biométrica remota em tempo real ou outra prática proibida, conforme alterada.

Preocupação potencial	Aplica-se?	Fatos e evidências	Exceção ou limitação considerada	Revisor Legal
-----------------------	------------	--------------------	----------------------------------	---------------

Uma potencial preocupação do Artigo 5 deve ser escalada imediatamente e não pode prosseguir simplesmente porque a avaliação de aplicabilidade mais ampla é incompleta.

2.296. Triagem de alto risco

Determinar se o sistema pode envolver:

- Artigo 6.o, n.o 1, e produto anexo I ou tratamento com componente de segurança;
- Artigo 6.o, n.o 2, e tratamento de casos de utilização do anexo III;
- Artigo 6.o, n.o 3, análise da exceção;
- A ressalva de definição de perfis que possa impedir a confiança na exceção prevista no artigo 6.o, n.o 3;

- fornecedor, fornecedor, importador, distribuidor, fabricante de produtos, registro, conformidade, documentação, monitoramento, incidente ou deveres de ação corretiva.

Rota ou problema	Aplica-se?	Racionalidad e jurídica e factual	Provas	Revisão adicional necessária
Artigo 6.o, n.o 1/anexo I				
Artigo 6.o, n.o 2/anexo III				
Artigo 6.o, n.o 3, exceção				
Profiling caveat				
Sobreposição do setor/produto				

2.307. Transparência e triagem GPAI

Determine se o assunto envolve:

- Artigo 13.o Instruções ou informações do fornecedor;
- Artigo 26.o Informações sobre o deployer ou deveres relacionados com o trabalhador;
- Artigo 50.o Interação, biometria, reconhecimento de emoções, conteúdo sintético, deepfake ou deveres de texto de interesse público;
- um provedor GPAI, provedor a jusante, implantador, modelo de código aberto ou modelo GPAI de risco sistêmico;
- Política de direitos autorais, resumo de conteúdo de treinamento, avaliação, segurança cibernética, incidente ou deveres do AI Office.

Zona de obrigação	Aplica-se?	ator	Provas	Data de aplicação
Transparência GPAI				
Risco sistêmico GPAI				

2.318. Regimes legais relacionados

Avaliar as obrigações aplicáveis de forma independente, incluindo:

- GDPR e legislação nacional de privacidade;
- Regras de decisão automatizada e de definição de perfis;
- Regras de emprego, informação dos trabalhadores, consulta e direitos coletivos;
- Lei de igualdade e antidiscriminação;
- Lei de acessibilidade;
- Lei de segurança cibernética e relatórios de incidentes;
- Direito de defesa do consumidor e da prática comercial desleal;
- segurança de produtos e regulamentação setorial;
- Propriedade intelectual, direitos autorais, confidencialidade e obrigações comerciais secretas;
- gestão de registros, retenção de litígios e deveres de conservação de evidências.

2.329. Tratamento de tempo e de transição

Registre a provisão exata, data aplicável, regra de transição, status do sistema e fonte oficial. Não atribua uma data genérica de alto risco ou GPAI a todas as obrigações.

Disposição ou obrigação	Aplica-se?	Data de aplicação	Regra de transição ou sistema legado	Fonte oficial
----------------------------	------------	----------------------	---	---------------

2.3310. Resultado da aplicabilidade

Selecione um e explique:

- ☐ Em escopo
- ☐ Parcialmente no escopo
- ☐ Fora do escopo
- Excluído ou tratado especialmente, com todas as condições documentadas
- ☐ Incerto - revisão legal qualificada necessária

Conclusão: Racionalidade jurídica e factual: Atores e obrigações aplicáveis: Disposições e fundamentos não aplicáveis: Condições, suposições e incertezas: Obrigações legais relacionadas:

2.34 11. Ações necessárias

- Completar ou atualizar o registro de inventário.
- Avaliação completa do ator-papel.
- Triagem de prática proibida completa.
- Classificação completa de alto risco.
- Transparência completa e avaliações GPAI.
- Identificar datas efetivas exatas e disposições de transição.
- Mapear os deveres aplicáveis aos controles, evidências, proprietários e prazos.
- Identificar requisitos de conformidade, registro, declaração, marcação, monitoramento, incidente ou notificação, quando aplicável.
- Identificar as autoridades competentes e as rotas de resposta.
- Impor restrições, condições ou decisões de parada de uso quando necessário.

Acção	Proprietário	Data de vencimento	Estado	Provas
-------	--------------	--------------------	--------	--------

2.35 12. gatilhos de revisão

Reavaliar após mudanças em:

- Pessoa jurídica, estabelecimento, distribuidor, importador ou representante;
- jurisdição, colocação no mercado, implantação ou uso de saída;
- branding, colocação de nome próprio, acordo contratual ou integração de produtos;
- propósito pretendido, uso real, população afetada ou contexto de decisão;
- modelo, versão, dados, prompt, ferramenta, agente, interface, capacidade ou autonomia;
- fornecedor, fornecedor, licença, subprocessador ou estado de código aberto;
- texto legal, ato de execução, decisão de autoridade, norma, código ou orientação;
- incidente, queixa, matéria de execução ou descoberta de auditoria material.

2.36 Exemplo de GlobalWay Travel Services

A GlobalWay avalia um sistema de alocação de funcionários hospedado nos EUA usado pelos escritórios da UE. Embora o desenvolvimento e a hospedagem ocorram fora da União, o implantador está estabelecido na

União e os trabalhadores na União são afetados. A GlobalWay identifica o potencial tratamento de emprego, o implantador e as possíveis questões relacionadas ao papel do provedor decorrentes da personalização, sobreposições do GDPR e da lei de emprego e datas de aplicação faseadas. A implantação permanece restrita até o papel, classificação, informações do trabalhador, FRIA.

2.37 Homologação

Papel	Nome	Decisão	Data
Legal			
Conformidade			
proprietário			
do negócio			
Proprietário			
técnico			
Privacidade/			
Segurança/			
HR/Produto,			
conforme			
aplicável			

Condições ou pressupostos: Referências de evidências: Perguntas legais abertas: Próximo acionador de revisão ou data: Versão de avaliação:**

2.38 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: artigos 2.º a 4.º, artigo 5.º, artigo 6.º, definições e deveres do actor, GPAI, transparência, conformidade, registo, monitorização, incidentes e disposições de execução, juntamente com os anexos aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação nacional, de emprego, de igualdade, de acessibilidade, de defesa do consumidor, de cibersegurança, de segurança dos produtos, de propriedade intelectual e do setor.
- Texto de EUR-Lex consolidado atual e outras fontes legais oficiais controlam resumos mais antigos ou interpretações internas.

2.39 Apêndice D Lista de verificação da prática proibida

Estado legal: Mestre inglês corrigido. Use o texto atual consolidado do artigo 5, o Regulamento (UE) 2026/1744, quando aplicável, e qualquer lei nacional aplicável. Cada **Sim** ou **Incerto** resposta requer revisão jurídica qualificada. Esta lista de verificação é uma ajuda operacional, não um

substituto para o regulamento, texto oficial consolidado, interpretação da autoridade, direito nacional ou aconselhamento jurídico.

2.40 Finalidade

Use esta lista de verificação antes da aprovação, aquisição, desenvolvimento, pilotagem, implantação, modificação material, reaproveitamento ou expansão geográfica para identificar práticas de IA que possam ser proibidas.

Não classifique um uso apenas a partir de um rótulo de tecnologia, descrição do fornecedor ou declaração de política. Teste todos os elementos legais relevantes, fato de implantação, exceção, salvaguarda, população afetada e rota razoavelmente previsível para evasão.

2.41 Informações de avaliação

Campo	Resposta
Sistema ou caso de uso	
ID do inventário	
proprietário do negócio	
Proprietário técnico	
Fornecedor/fornecedor	
Papel ou papéis de ator	
Entidades jurídicas	
Competências	
Propósito pretendido	
Uso real e razoavelmente previsível	
Pessoas afetadas e grupos vulneráveis	
Versão, configuração, prompts, ferramentas e integrações	
Contexto de implantação	
Fonte legal oficial atual e data de aplicação	
Assessor e Data	
Repositório de evidências	

2.42 Instruções

Para cada pergunta de triagem:

1. Resposta **Sim**, **Não******, ou **Incerto**;
2. Identificar o ponto exato do artigo 5.o e o elemento jurídico que está a ser testado;
3. Citar fatos e evidências;
4. registrar qualquer alegação de exceção, limitação, autorização e evidência de apoio;
5. identificar o revisor, a data, a decisão, a restrição e a ação de acompanhamento;
6. avaliar proxy, fluxo de trabalho, configuração e rotas de reaproveitamento previsíveis.

Uma resposta **Não** deve ser apoiada por fatos verificados. “Vendor diz que está em conformidade” não é evidência suficiente.

2.43A. Técnicas subliminares, propositadamente manipuladoras ou enganosas

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema usa técnicas subliminares além da consciência de uma pessoa, técnicas propositadamente manipuladoras ou técnicas enganosas?		
A técnica tem o objetivo ou efeito de distorcer materialmente o comportamento?		
Isso prejudica significativamente a capacidade de tomar uma decisão informada?		
Isso poderia levar uma pessoa a tomar uma decisão que de outra forma não teria tomado?		
O uso causa, ou é razoavelmente provável que cause, danos significativos?		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
A persuasão, a recomendação, a personalização, o design da interface e a manipulação enganosa foram distinguidos factualmente?		
Os riscos de usuário vulnerável, acessibilidade, padrão escuro e design coercitivo foram testados?		

** Exemplos de evidências: ** registros de projeto, prompts, interfaces, testes comportamentais, análise de danos, pesquisa do usuário, revisão de acessibilidade, análise legal.

2.44 B. Exploração de vulnerabilidades

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema explora a vulnerabilidade devido à idade, deficiência ou uma situação social ou econômica específica?		
Qual recurso, mensagem, classificação, tempo, segmentação ou mecanismo de interação realiza a exploração?		
O uso pode distorcer materialmente o comportamento?		
O uso causa, ou é razoavelmente provável que cause, danos significativos?		
A acessibilidade legítima, assistência,		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
acomodação, proteção ou design adequado à idade foram distinguidos da exploração?		

**** Exemplos de evidências: **** análise populacional, lógica de segmentação, regras de segmentação, revisão de acessibilidade, cenários de danos, salvaguardas, pesquisa de usuários.

2.45 C. pontuação social

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema avalia ou classifica pessoas ou grupos naturais ao longo do tempo com base no comportamento social ou em características pessoais ou de personalidade conhecidas, inferidas ou previstas?		
A pontuação leva a um tratamento prejudicial ou desfavorável?		
O tratamento num contexto não está relacionado com o contexto em que os dados foram gerados ou recolhidos?		
O tratamento é injustificado ou desproporcional ao comportamento social ou à sua gravidade?		
A lealdade, a fraude, a segurança, a reputação, a elegibilidade ou as		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
pontuações de risco são reutilizadas em todos os contextos?		
As pessoas afetadas podem entender, desafiar e corrigir a pontuação ou os dados subjacentes?		

** Exemplos de evidências: ** inventário de recursos, lógica de pontuação, contexto de dados originais, mapa de uso a jusante, análise de proporcionalidade, testes de impacto adverso, registros de apelo.

2.46D. Previsão individual de risco de infração penal

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema é usado para avaliar ou prever o risco de uma pessoa natural cometer um crime?		
A previsão baseia-se unicamente na definição de perfis ou avaliação de traços ou características de personalidade?		
Se a IA apoia uma avaliação humana, essa avaliação já se baseia em fatos objetivos e verificáveis diretamente ligados à atividade criminosa?		
A área, o grupo, o evento ou a análise operacional estão sendo usados como proxy para a previsão de risco criminal individual?		
O papel da IA e da		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
avaliação humana independente estão documentados nos registros de decisão?		

**** Exemplos de evidências: **** características de entrada, propósito pretendido, registros de fatos objetivos, fluxo de trabalho humano, análise de perfil, registros de decisão.

2.47E. Rasting de imagem facial sem alvo

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema cria ou expande um banco de dados de reconhecimento facial?		
As imagens faciais obtidas através de raspagem não direcionada da internet?		
As imagens faciais obtidas através de raspagem não direcionada de imagens de televisão em circuito fechado?		
O método de coleta, os critérios de segmentação, a escala, a fonte e a função do banco de dados são documentados?		
A organização verificou independentemente as representações dos fornecedores sobre fontes de treinamento e imagem de referência?		

** Exemplos de evidências: ** registro de origem, método de aquisição, configuração do rastreador, evidência do fornecedor, testes técnicos, avaliação de dados biométricos.

2.48F. Reconhecimento de emoções nos locais de trabalho e instituições de ensino

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema infere emoções de pessoas naturais?		
Está implantado em um local de trabalho?		
Está implantado em uma instituição de ensino?		
Uma exceção médica ou de segurança é reivindicada?		
O propósito médico ou de segurança reivindicado é genuíno, necessário, proporcional, estreito e documentado?		
Um sistema rotulado como sentimento, engajamento, fadiga, atenção, estresse ou análise comportamental poderia realizar inferência emocional na prática?		
Se o uso não for proibido, as obrigações de alto risco, transparência, emprego, educação, privacidade, consulta e discriminação foram avaliadas?		

**** Exemplos de evidências: **** descrição da capacidade, contexto de implantação, análise de exceção, avaliação de necessidade, consulta de trabalhador/estudante, controles de transparência.

2.49 G. Categorização biométrica utilizando características protegidas ou sensíveis

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema categoriza as pessoas singulares individualmente com base em dados biométricos?		
Deduz ou deduz uma característica protegida ou sensível listada no texto legal atual?		
A verificação biométrica, a identificação e a categorização foram distinguidas?		
Uma exceção é reivindicada para a rotulagem ou filtragem de conjuntos de dados biométricos legalmente adquiridos em um contexto de aplicação da lei aplicável?		
O tratamento reivindicado é documentado de forma restrita, em vez de tratado como uma isenção geral?		
Se não for proibido, a classificação de alto risco e as restrições de dados de categoria especial foram avaliadas?		

** Exemplos de evidências: ** fluxo de dados biométricos, lista de categorias inferidas, saídas, ações a jusante, análise de exceções, avaliação do GDPR, testes de justiça.

2.50H. Identificação biométrica remota em tempo real em espaços acessíveis ao público para aplicação da lei

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema realiza identificação biométrica remota?		
A operação é em tempo real em vez de pós-evento?		
É usado em um espaço acessível ao público?		
É usado para fins de aplicação da lei?		
Um dos objetivos estatutários estritamente permitidos é reivindicado?		
A necessidade estrita é documentada?		
A seriedade, a probabilidade e a escala de danos estão documentadas?		
Os efeitos sobre os direitos e liberdades são avaliados?		
Os limites temporais, geográficos e pessoais são definidos?		
A autorização administrativa prévia ou independente está documentada, sujeita apenas à estrutura de emergência estreita?		
O registro, a avaliação dos direitos		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
fundamentais, as condições da legislação nacional, o registro e a revisão pós-uso estão completos?		

**** Exemplos de evidências: **** conceito operacional, propósito, autorização, análise de necessidade e proporcionalidade, governança de lista de vigilância, testes de precisão, registros completos.

2.51I. Proibições adicionais introduzidas pelo Regulamento (UE) 2026/1744

**** Controle de data de aplicação: **** Avalie a adoção e a aplicação separadamente. Use o texto alterado oficial e verifique a data **2 de dezembro de 2026** aplicável antes de confiar nesta lista de verificação.

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O sistema gera conteúdo sexualmente explícito ou íntimo não consensual envolvendo uma pessoa identificável?		
O sistema gera material de abuso sexual infantil dentro da redação estatutária alterada?		
As duas categorias proibidas são analisadas separadamente?		
O consentimento, a identidade, a idade, o material de origem, a finalidade de saída e o uso indevido previsível são documentados quando relevante?		
O produto inclui controles técnicos,		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
contratuais, de relatórios e de execução que impedem a geração proibida?		
O uso é bloqueado em vez de apenas advertido quando a proibição legal é cumprida?		

Exemplos de evidências: controles de política de uso, testes de modelo e filtro, registros de consentimento quando relevante, controles de idade e identidade, registros de saída bloqueada, resposta a incidentes.

2.52J. Proxy, repurposing, e revisão de evasão

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O projeto indiretamente alcança um resultado proibido por meio de proxies, recursos combinados, integração de fluxo de trabalho ou uso a jusante?		
A configuração, ajuste fino, modelos rápidos, plugins, agentes ou instruções do usuário podem permitir uma prática proibida?		
Poderia um piloto legal ser reaproveitado para um contexto de implantação proibido?		
O fornecedor restringiu contratualmente usos proibidos e forneceu controles técnicos aplicáveis?		
As tentativas de soluções alternativas		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
são detectadas, registradas, investigadas e bloqueadas?		
As restrições geográficas, de usuário, de dados ou de recursos podem ser tecnicamente aplicadas?		

2.53 Evidências analisadas

- declaração para fins pretendidos;
- Avaliação de utilização real e razoavelmente previsível;
- documentação do sistema, modelo, prompt, ferramenta e agente;
- fontes de dados, linhagem e lista de recursos;
- interfaces de usuário, instruções, fluxos de trabalho e demonstrações;
- Documentação do fornecedor, direitos de teste, contratos e avisos de alteração;
- Testes independentes e comportamento observado;
- contexto de implantação e análise da população afetada;
- análise de direitos jurídicos e fundamentais;
- Exceções, autorizações, registros de necessidade e proporcionalidade;
- monitoramento, uso indevido, proxy, repurposing e controles de evasão.

2.54 Decisão

- ☐ Nenhuma prática proibida identificada em fatos verificados
- ☐ Evidências adicionais necessárias
- ☐ Revisão legal qualificada necessária
- ☐ O uso deve ser redesenhado ou restrito
- ☐ Implantação proibida
- ☐ Implantação existente suspensa, retirada ou desativada

Ponto de artigo e elementos exatos avaliados: Motivo da decisão:
 Exceção, limitação ou autorização reivindicada: Evidência de apoio:
 Restrições ou redesenho obrigatório: Incerteza residual:**

2.55 gatilhos de escalada obrigatórios

Escalar e não aprovar quando:

- qualquer elemento estatutário não pode ser resolvido a partir de factos verificados;
- uma alegada exceção, limitação, autorização ou salvaguarda carece de provas;
- o fornecedor não divulgará funcionalidades relevantes, fontes de dados ou limitações observadas;
- descrições de marketing conflitam com a capacidade observada;
- crianças, trabalhadores, estudantes, migrantes, suspeitos de crimes ou outros grupos vulneráveis são afetados;
- A legislação nacional pode ser mais rigorosa ou impor condições separadas;
- O sistema pode ser reaproveitado para uma prática proibida;
- Restrições técnicas não podem bloquear de forma confiável o uso proibido;
- uma mudança material afeta o propósito, contexto, população, dados, geografia, capacidade, papel do ator ou uso da saída.

2.56 Controlos obrigatórios

- Registre a base jurídica exata, as descobertas factuais e a fundamentação da decisão.
- Aplicar restrições técnicas, contratuais, organizacionais e de acesso.
- Bloqueie configurações proibidas, fluxos de trabalho, usuários, jurisdições e saídas.
- Impedir repurposing não autorizado e detectar tentativas de evasão.
- Treinar desenvolvedores, compras, usuários, aprovadores, suporte e pessoal de incidentes.
- Monitor para uso indevido, soluções alternativas, mudanças materiais e atualizações de fornecedores.
- Preservar rejeição, suspensão, retirada, descomissionamento, testes e evidências de incidentes.
- Reavaliar após alterações de propósito, dados, características, geografia, provedor, papel de ator, população afetada ou lei.

2.57 Exemplo de GlobalWay Travel Services

A GlobalWay analisa uma ferramenta de “engajamento” de funcionários que afirma medir a fadiga e o sentimento de voz e vídeo. Testes mostram que ela infere estados emocionais em um contexto de local de trabalho. A GlobalWay suspende o piloto, preserva evidências de fornecedores e testes e aumenta para revisão legal qualificada. A garantia geral de conformidade do fornecedor é rejeitada como insuficiente porque a capacidade observada e os fatos de implantação controlam a análise.

2.58 Homologação

Papel	Nome	Decisão	Data
Revisor Jurídico Qualificado			
Revisor de conformidade			
Revisor técnico			
proprietário do negócio			
Revisor de privacidade/H R/Security, quando aplicável			

Condições: Ações e datas de vencimento: Próxima data de revisão ou gatilho: Repositório de evidências: Versão de avaliação:**

2.59 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada: Artigo 5.o e todas as definições, exceções, salvaguardas, datas efetivas e condições de direito nacional aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e o emprego, a igualdade, a acessibilidade, o processo penal, a proteção do consumidor, a proteção da criança, a cibersegurança, a segurança dos produtos e o direito nacional aplicáveis.
- Os textos oficiais consolidados atuais controlam esta lista de verificação e todos os resumos anteriores.

2.60 Apêndice E Planilha de classificação de alto risco

Estado legal: Mestre de inglês corrigido. Este arquivo controla a linguagem anterior do Apêndice E. A classificação deve ser baseada na atual Lei de IA da UE consolidada, na conduta real do ator, na finalidade pretendida do sistema, na rota relevante do anexo e na data de aplicação aplicável. A revisão legal qualificada é necessária para classificações incertas ou materialmente consequentes.

2.61 Finalidade

Use esta planilha para determinar se um sistema de IA é de alto risco nos termos do Artigo 6 e do Anexo I ou Anexo III, se uma exceção do Artigo 6(3)

é reivindicada, se a criação de perfis impede a dependência dessa exceção e quais consequências legais e operacionais se seguem.

Completar a avaliação antes da implantação da produção ou colocação no mercado e repeti-la após mudanças materiais, reaproveitamento, novas jurisdições, novas populações afetadas, supervisão humana alterada, mudanças de fornecedores ou desenvolvimentos legais.

2.621. Registro de avaliação

Campo	Resposta
Nome do sistema	
ID do inventário	
Entidade jurídica avaliada	
Papel ou papéis de ator proprietário do negócio	
Técnico/produto proprietário	
Fornecedor/fornecedor	
Integração do produto	
Versão, configuração, prompts, ferramentas e dados avaliados	
Propósito pretendido	
Uso real ou proposto	
Usuários e pessoas afetadas	
Competências	
Proprietário e data da avaliação	
Revisor Legal	
Fonte e data legal consolidada atual	

2.63 Análise de propósito pretendido e de contexto de decisão

Documento:

- O objetivo pretendido aprovado;
- Utilização real e razoavelmente previsível;
- O processo empresarial ou público apoiado;
- decisões, recomendações, previsões, classificações, rankings ou ações produzidas;

- se o sistema faz, influencia materialmente, prepara, apoia ou meramente registra uma decisão;
- usuários, tomadores de decisão, pessoas afetadas e grupos vulneráveis;
- consequências de erro, viés, atraso, uso indevido, indisponibilidade ou manipulação;
- autoridade de revisão humana, tempo, competência e capacidade de substituir;
- se o uso afeta o emprego, educação, crédito, seguro, serviços essenciais, saúde, segurança, aplicação da lei, migração, justiça, processos democráticos ou outra oportunidade ou direito material.

2.643. Artigo 6.o, n.o 1, e Anexo I

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
O próprio sistema de IA é um produto abrangido pela legislação do Anexo I?		
É um componente de segurança de um produto abrangido pela legislação do anexo I?		
O produto deve ser submetido a uma avaliação da conformidade de terceiros nos termos da legislação aplicável do anexo I?		
Que entidade legal é o fornecedor ou fabricante do produto relevante?		
Que legislação de produto, rota de conformidade e requisitos de organismo notificado se aplicam?		
A falha do componente de IA cria um risco material de saúde ou segurança?		

Pergunta	Sim/Não/Incerto	Evidência e racionalidade
Que data de aplicação, regra do sistema legado ou controles de provisão de transição?		

Conclusão do n.o 1 do artigo 6.o: Legislação aplicável do Anexo I: Implicações de conformidade:

2.654. Artigo 6.o, n.o 2, e Anexo III

Para cada categoria do Anexo III, registre o ponto exato, o uso pretendido, as pessoas afetadas, a decisão ou o processo influenciado, a evidência e a conclusão.

Área do anexo III	Em escopo?	Ponto exato	Uso pretendido e pessoas afetadas	Racionalidad e e evidência
biometria				
Infra-estruturas críticas				
Educação e formação profissional				
Emprego, recrutament o, gestão de trabalhadore s ou acesso ao trabalho por conta própria				
Serviços e benefícios públicos e privados essenciais				
Aplicação da lei				
Migração, asilo e				

Área do anexo III	Em escopo?	Ponto exato	Uso pretendido e pessoas afetadas	Racionalidad e e evidência
controle de fronteiras				
Administração da justiça e dos processos democráticos				

Não deduza o status do Anexo III apenas de uma etiqueta do setor. Combine o uso pretendido real com a categoria e o ponto listados exatos.

2.665. Material-influência e análise da revisão humana

Pergunta	Resposta e evidência
O sistema toma ou influencia materialmente uma decisão?	
A produção é apresentada como uma recomendação, mas rotineiramente seguida?	
A revisão humana significativa é realizada antes que a decisão entre em vigor?	
O revisor pode entender a base, as limitações e a incerteza da produção?	
O revisor pode desafiar, desconsiderar, substituir ou parar o sistema sem penalidade ou viés de automação?	
Há tempo suficiente, pessoal, competência e informações disponíveis para revisão?	
As pessoas afetadas estão expostas a consequências legais, econômicas, de segurança, de acesso a serviços, de emprego, educacionais ou de direitos fundamentais?	
As substituições, apelos e desacordos são registrados e monitorados?	

A participação humana não remove automaticamente o status de alto risco.

2.676. Artigo 6.o, n.o 3, análise da exceção

Um sistema listado no Anexo III não é excluído apenas porque um humano participa ou o provedor caracteriza a função como administrativa. Teste todas as condições estatutárias e documente os fatos.

Ensaio	Resposta	Provas
O sistema representa um risco significativo de danos à saúde, segurança ou direitos fundamentais?		
Influencia materialmente o resultado da tomada de decisões?		
O sistema é limitado a uma tarefa processual estreita?		
Melhora o resultado de uma atividade humana anteriormente concluída sem substituir ou influenciar materialmente esse resultado?		
Ele detecta padrões ou desvios de tomada de decisão sem substituir ou influenciar a avaliação humana anterior?		
Ele realiza uma tarefa preparatória que não influencia materialmente o resultado?		
O sistema realiza a criação de perfis de pessoas naturais?		
Todos os fatos,		

Ensaio	Resposta	Provas
salvaguardas e limitações são confiáveis e estáveis na produção?		

****Caso o sistema execute a definição de perfis de pessoas singulares dentro da regra estatutária, não confie na exceção do artigo 6.o, n.o 3, sem confirmação legal qualificada.**

Base de exceção: Factos que apoiam a exceção: Risco residual e salvaguardas: Conclusão legal:**

2.687. Conclusão da classificação

- ☐ Alto risco nos termos do artigo 6(1)/Anexo I
- ☐ Alto risco nos termos do artigo 6.o, n.o 2/anexo III
- ☐ Sistema anexo III que reúne todas as condições de exceção documentadas do artigo 6(3)
- ☐ Não de alto risco sobre os fatos verificados
- ☐ Fora do escopo atual
- ☐ Incerto - evidência adicional necessária
- ☐ Incerto - revisão legal qualificada necessária

2.68.1 Racionalidade final

Documente a rota legal exata, os fatos, o propósito pretendido, o papel do ator, as pessoas afetadas, a data da aplicação, as suposições, as incertezas e as evidências que sustentam a conclusão.

2.698. Mapeamento da consequência

Direitos de registro aplicáveis pelo ator e data.

Obrigação	ator	Aplica-se?	Data de aplicação	Proprietário	Evidência/status
Sistema de gestão da qualidade					
Sistema de gestão de riscos					
Governança de dados e dados					

Obrigação	ator	Aplica-se?	Data de aplicação	Proprietário	Evidência/status
Documentação técnica					
Registo e manutenção de registos					
Transparência e instruções de uso					
Supervisão humana					
Precisão, robustez, segurança cibernética e resiliência					
Avaliação da conformidade					
Envolvimento do organismo notificado					
Declaração UE de conformidade					
Marcação CE					
Inscrição					
Monitoramento de deployer e retenção de log					
Informações do					

Obrigações	ator	Aplica-se?	Data de aplicação	Proprietário	Evidência/status
trabalhado					
r ou					
consulta					
Avaliação					
de					
impacto					
dos					
direitos					
fundamentais					
Avaliação					
de					
impacto					
na					
proteção					
de dados					
Monitoramento					
pós-comercialização					
Relatórios					
de					
incidentes					
graves					
Ação					
corretiva,					
restrição,					
recall ou					
retirada					
Cooperação					
o e acesso					
das					
autoridades					

2.709. Seguimento exigido

Acção	Proprietário	Data de vencimento	Estado	Evidência de encerramento
-------	--------------	--------------------	--------	---------------------------

Nenhuma decisão de prontidão interna pode substituir uma avaliação de conformidade legalmente exigida, registro, declaração, marcação CE, processo de organismo notificado, decisão de autoridade ou aprovação do setor.

2.71 10. gatilhos de revisão

Reavaliar após:

- alteração da finalidade pretendida ou da utilização real;
- Ator-papel, branding, colocação de nome próprio ou mudança de entidade legal;
- modelo, versão, dados, prompt, ferramenta, fluxo de trabalho, interface ou mudança de autonomia;
- novo fornecedor, fornecedor, subprocessador ou componente de código aberto;
- mudança na supervisão humana, pessoal, autoridade ou processo de decisão;
- nova população, setor, produto ou jurisdição afetados;
- Incidente, reclamação, viés de encontrar, problema de auditoria ou critério de aceitação falhado;
- modificação ou reaproveitamento substancial;
- Alteração da rota de conformidade ou da lei do produto;
- legal, regulamentar, implementando-ato, autoridade, padrão ou mudança de código.

2.72 Exemplo de GlobalWay Travel Services

A GlobalWay avalia um sistema de alocação de funcionários usado para classificar os trabalhadores para atribuições. O uso pretendido mapeia para uma categoria de emprego do Anexo III. Embora os gerentes aprovelem as atribuições finais, os testes mostram que o ranking influencia materialmente as decisões e raramente é substituído. O fornecedor também realiza o perfilamento. A GlobalWay classifica o sistema como de alto risco, bloqueia a liberação até que o provedor e os deveres de implantação aplicáveis sejam mapeados e inicia a documentação, testes, supervisão, FRIA / DPIA, monitoramento de conformidade, conformidade, monitoramento e monitoramento de trabalho.

2.73 Homologação

Papel	Nome	Decisão	Data
Revisor Jurídico			
Qualificado			
Conformidade/ risco			

Papel	Nome	Decisão	Data
proprietário do negócio			
Técnico/produto proprietário			
Especialista em segurança de produtos ou setor, quando aplicável			

Suposições e incerteza: Referências de evidências: Condições ou restrições: Próximo comentário trigger/date: Versão de avaliação:**

2.74 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: Artigo 6.o, Anexo I, Anexo III, definições relevantes, deveres do ator, requisitos de alto risco, conformidade, registro, monitoramento, incidentes, ações corretivas e disposições de execução.
- Regulamento (UE) n.o 2026/1744, se aplicável, incluindo o calendário alterado e o tratamento transitório.
- Legislação aplicável sobre produtos do Anexo I e legislação nacional ou setorial.
- O texto atual consolidado EUR-Lex e as fontes oficiais do direito do produto controlam os resumos internos.

2.75 Apêndice F Planilha de Avaliação do Papel

Estado legal: Mestre inglês corrigido para consolidação. Este arquivo controla a linguagem anterior do Apêndice F em conflito. A classificação de papéis deve refletir a conduta real, a atividade do mercado, a marca, a modificação, a integração e o controle operacional não apenas rótulos contratuais.

2.76 Finalidade

Use esta planilha para determinar o papel de cada entidade jurídica para um sistema de IA, modelo GPAI, integração de produtos e jurisdição. A classificação de papéis impulsiona obrigações aplicáveis, requisitos de evidências, contratos, responsabilidade, atividades de conformidade, monitoramento, deveres de incidente e relações de autoridade.

Uma entidade pode desempenhar várias funções ao mesmo tempo ou diferentes funções em diferentes jurisdições, produtos, versões ou transações.

2.771. Informação de avaliação

Campo	Resposta
Sistema ou modelo	
ID do inventário	
Versão/configuração avaliada	
Entidade jurídica avaliada	
Entidades jurídicas relacionadas	
Competência	
Propósito pretendido	
Uso real ou proposto	
proprietário do negócio	
Proprietário técnico	
Actores a montante e a jusante	
Integração de produto ou serviço	
Proprietário e data da avaliação	
Revisor Legal	
fonte/versão legal oficial	

2.782. Mapa de cadeia de valor

Identificar quem desenvolve, comissões, marcas, mercados, lugares no mercado, coloca em serviço, importa, distribui, integra, implanta, modifica, monitora, apoia, suspende, lembra ou retira o sistema ou modelo.

Actividade	Entidade	Competência	Posição contratual	Conduta real	Provas
Desenvolvimento ou desenvolvimento comissionado					
Provisão do modelo GPAI					
Provisão do sistema					

Actividade	Entidade	Competência	Posição contratual	Conduta real	Provas
de IA					
Colocação de marca ou nome próprio					
Colocação no mercado da União					
Colocando em serviço					
Importação					
Distribuição					
Integração de produto ou componente de segurança					
Implantação e uso operacional					
Configuração e controle de acesso					
Ajuste, modificação ou reajuste					
Controle de dados, prompt, ferramenta ou agente					
Monitorização e					

Actividade	Entidade	Competência	Posição contratual	Conduta real	Provas
apoio a incidentes					
Comunicações da autoridade					
Suspensão, retirada, retirada ou saída					

2.793. Testes de função

2.79.1 Provedor de um sistema de IA

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Desenvolve ou tem o sistema de IA desenvolvido		
coloca-lo no mercado sob seu nome ou marca registrada		
Coloca-o em serviço sob seu nome ou marca registrada		
adquire obrigações de fornecedor através da colocação de marca própria		
Faz uma modificação substancial		
mudança de propósito de uma forma legalmente material		
Integra componentes em um sistema que fornece sob sua própria responsabilidade		
Controla a documentação do provedor, liberação, conformidade, registro		

Indicador	Sim/Não/Incerto	Evidência e racionalidade
ou obrigações pós-mercado		

2.79.2 Fornecedor de um modelo GPAI

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Desenvolve ou tem o modelo GPAI desenvolvido		
Coloca o modelo GPAI no mercado da União sob seu nome ou marca registrada		
Controla a documentação do modelo-provedor e a informação a jusante		
Controla a política de conformidade com direitos autorais e resumo de conteúdo de treinamento, quando aplicável		
Controla a avaliação de risco sistémico, mitigação, cibersegurança, incidente ou relatórios, quando aplicável		
Faz alterações que podem criar ou transferir responsabilidades GPAI-fornecedor		

2.79.3 Provedor Downstream

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Integra um modelo GPAI em um sistema de IA que desenvolve		

Indicador	Sim/Não/Incerto	Evidência e racionalidade
ou fornece		
Controla o propósito pretendido, design, lançamento ou branding do sistema a jusante		
Depende da documentação a montante para cumprir os deveres a jusante		
Afina, adapta ou combina modelos de uma forma que muda as responsabilidades		

2.79.4 Deployer

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Usa o sistema sob sua autoridade		
Usa-o em um contexto profissional ou organizacional		
Controla a configuração operacional, acesso, fluxo de trabalho ou supervisão humana		
Usa saídas para tomar ou influenciar decisões que afetam trabalhadores, candidatos, clientes, viajantes ou outros		
Monitora a operação, retém registros ou responde a incidentes no contexto de implantação		

2.79.5 Importador

Indicador	Sim/Não/Incerto	Evidência e racionalidade
está estabelecido ou localizado na União, conforme exigido pela definição legal		
Coloca no mercado da União um sistema com o nome ou marca comercial de um prestador não pertencente à União		
Realiza tarefas de verificação pré-mercado, documentação, registro ou cooperação de autoridade associadas à importação		

2.79.6 Distribuidor

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Disponibiliza um sistema de IA no mercado da União		
Não é nem o fornecedor nem importador para essa atividade		
Controla a distribuição da cadeia de suprimentos, disponibilidade, armazenamento ou provisão futura		

2.79.7 Representante autorizado

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Estabelecido na União		
Aceitou um mandato		

Indicador	Sim/Não/Incerto	Evidência e racionalidade
por escrito do provedor		
Executa apenas as tarefas obrigatórias especificadas		
Mantém a documentação necessária ou coopera com as autoridades dentro do mandato		

2.79.8 fabricante do produto

Indicador	Sim/Não/Incerto	Evidência e racionalidade
Integra a IA a um produto regulamentado ou componente de segurança		
mercados ou coloca o produto resultante em serviço sob seu nome ou marca registrada		
Detêm responsabilidades de conformidade nos termos da legislação aplicável do produto		
Controla a liberação do produto, documentação de segurança ou interação com o corpo notificado		

2.804. transferência de fornecedor e gatilhos de mudança

Escalar todas as respostas **Sim** ou **Incerto**.

Trigger	Resposta	Provas	Consequência potencial	Conclusão jurídica
Colocação ou serviço próprio nome ou marca				

Trigger	Resposta	Provas	Consequência potencial	Conclusão jurídica
própria				
Modificação substancial				
Mudança de propósito pretendido				
Integração de novos produtos ou componentes de segurança				
Novo afiliado, importador, distribuidor, representante e ou jurisdição				
Marca de material, marca branca, revenda, contrato ou mudança de controle				
Ajuste fino, combinação de modelos, novas ferramentas, agentes ou autonomia				
Retirada do fornecedor, substituição do modelo ou versão não suportada				

2.815. Realidade contratual e operacional

Documento que realmente controla:

- propósito pretendido e usos proibidos;
- modelo e seleção do sistema;
- branding e colocação no mercado;
- treinamento, ajuste, recuperação e dados operacionais;
- prompts, ferramentas, agentes, interfaces e configuração;
- acesso do usuário e populações afetadas;
- Documentação técnica, validação e liberação;
- supervisão humana, apelos e tratamento de reclamações;
- Monitoramento, registros, incidentes e notificações;
- Avaliação da conformidade, registo, declaração e marcação CE, quando aplicável;
- suspensão, reversão, recall, retirada e saída;
- retenção de provas e resposta de autoridade.

Quando o contrato e a conduta real entrarem em conflito, escale e baseie a conclusão do papel nos fatos legais aplicáveis.

2.826. conclusão do múltiplo-papel

Registre cada função separadamente por entidade, jurisdição, versão e atividade.

Entidade	Competência	Função do sistema/modelo	Base factual	Obrigações aplicáveis	Proprietário responsável	Approver
----------	-------------	--------------------------	--------------	-----------------------	--------------------------	----------

2.837. Funções legais adicionais

Regime	Papel	Entidade	Provas	Obrigações/proprietário
Protecção de dados	controlador / processador / controlador conjunto / outro			
Emprego	Empregador / agência / prestador de serviços / outro			

Regime	Papel	Entidade	Provas	Obrigações/ proprietário
Protecção dos consumidores	Trader / plataforma / intermediário / outro			
Cibersegurança	Entidade essencial/importante, fornecedor, operador de serviço, outro			
Segurança do produto	Fabricante / importador / distribuidor / outro			
Regulamentação do sector				
Propriedade intelectual	Licenciante / licenciado / fornecedor de conteúdo / outro			

Um papel sob outro regime legal não determina automaticamente o papel do Ato de Inteligência Artificial da UE, mas os papéis devem ser coordenados.

2.848. Controles do contrato e do modelo operacional

Confirme que os contratos e procedimentos abordam:

- informações técnicas, de modelo, de sistema e de conformidade;
- propósito pretendido, usos proibidos e instruções de uso;
- atribuição de papéis e notificação de eventos de mudança de papéis;
- modelo, versão, dados, fornecedor e alterações de funcionalidade;
- monitoramento, reclamações, incidentes, notificação e cooperação de ação corretiva;
- auditoria, teste, garantia e direitos de acesso a evidências;
- Comunicações de autoridade e prazos de resposta;
- documentação, registros, retenção, preservação e retenção legal;
- suspensão, reversão, retirada, recall, descomissionamento e saída;

- responsabilidades de privacidade, emprego, igualdade, consumidor, produto e propriedade intelectual.

2.859. Ambiguidade e escalada

Questão não resolvida: Interpretações alternativas: Evidências necessárias: Restrições ou controles provisórios: **Proprietário legal:** **
Prazo final da resolução: Autoridade de decisão:**

Não permita que a incerteza do papel adie a contenção imediata, a preservação de evidências ou o cumprimento de deveres que se aplicam claramente.

2.8610. gatilhos de revisão

Reavaliar após qualquer alteração em:

- Pessoa jurídica, estrutura societária, aquisição ou reestruturação;
- jurisdição, colocação no mercado, importador, distribuidor ou representante;
- fornecedor, modelo, sistema, componente de código aberto ou licença;
- finalidade pretendida, uso real, população afetada ou setor;
- branding, white-labeling, revenda ou colocação de nome próprio;
- integração de produtos ou status de componente de segurança;
- modificação substancial, ajuste fino, ferramentas, agentes ou autonomia;
- controle operacional, supervisão humana, monitoramento ou resposta a incidentes;
- contrato, fornecedor, rota de conformidade ou lei aplicável.

2.87 Exemplo de GlobalWay Travel Services

A GlobalWay licencia um modelo GPAI de terceiros e o integra em um sistema de assistência ao viajante de marca e oferecido a clientes corporativos sob o nome da GlobalWay. A empresa upstream continua a ser o provedor de modelo GPAI, enquanto a GlobalWay pode ser o provedor e implantador do sistema AI a jusante. A GlobalWay documenta ambos os papéis, obtém informações do modelo upstream, assume a documentação e as funções de monitoramento do sistema a jusante e desencadeia uma nova revisão antes do ajuste fino ou da venda do sistema através da UE.

2.88 Homologação

Papel	Nome	Decisão	Data
Revisor			
Jurídico			
Qualificado			

Papel	Nome	Decisão	Data
Conformidade			
Compras/ gestão de fornecedores			
proprietário do negócio			
Técnico/ produto proprietário			
Revisor de segurança de produto ou setor, quando aplicável			

Conclusão do papel e raciocínio: Interpretação não resolvida: **Controles ou restrições provisórias: Referências de evidências:** Próximo acionador de revisão ou data: Versão de avaliação:**

2.89 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) 2024/1689, conforme alterado: definições e deveres aplicáveis aos prestadores, prestadores de GPAI, fornecedores a jusante, distribuidores, importadores, representantes autorizados, fabricantes de produtos e intervenientes que adquiram obrigações de fornecedores através de condutas juridicamente relevantes.
- Regulamento (UE) 2026/1744, se aplicável.
- Legislação aplicável sobre produtos do Anexo I, Regulamento (UE) 2016/679 e legislação relevante em matéria de emprego, consumidores, cibersegurança, segurança dos produtos, propriedade intelectual e direito do setor.
- Textos oficiais consolidados atuais controlam rótulos contratuais e resumos internos.

2.90 Apêndice G Avaliação de Impacto dos Direitos Fundamentais

Estado legal: Mestre inglês corrigido. Este arquivo distingue a avaliação de impacto dos direitos fundamentais do artigo 27.º de uma revisão voluntária ou de impacto dos direitos exigidos pela organização. É necessária uma revisão legal qualificada para confirmar se o artigo 27.º se

aplica, se existe uma exceção e qual o processo de submissão ou notificação de autoridade atual.

2.91 Finalidade

Use esta avaliação para identificar, avaliar, mitigar, documentar e monitorar os efeitos reais ou potenciais de um sistema de IA na dignidade, autonomia, igualdade, privacidade, segurança, acesso a oportunidades e serviços, condições de trabalho, devido processo e remédio eficaz.

A avaliação deve ser concluída antes da primeira utilização onde o artigo 27.o se aplica e antes da aprovação ao abrigo da política organizacional onde é necessária uma revisão voluntária. Deve ser atualizada quando os factos materiais, riscos, populações, salvaguardas ou requisitos legais mudarem.

2.921. porta da aplicabilidade

Pergunta	Resposta	Evidência ou racionalidade
Entidade jurídica avaliada		
UE AI Act papel de deplier		
ID do sistema e do inventário		
Versão/configuração avaliada		
Classificação de alto risco e ponto exato do anexo III		
O deployer é um corpo governado pelo direito público?		
O deployer é uma entidade privada que presta serviços públicos?		
O deployer é coberto de outra forma pelo artigo 27?		
Aplica-se uma exceção legal ou tratamento especial?		
O artigo 27.o é		

Pergunta	Resposta	Evidência ou racionalidade
legalmente exigido, voluntariamente aplicado, contratualmente exigido ou exigido pela política organizacional?		
Que data de aplicação específica de provisão e regra de transição se aplica?		
Fonte legal oficial atual		

Conclusão da aplicabilidade: Avaliador legal qualificado: Incerteza ou condições:

2.932. Sistema, uso e contexto de implantação

Campo	Resposta
Sistema/modelo e versão	
Propósito pretendido	
Uso real ou proposto	
Decisão ou processo apoiado	
Período e frequência de utilização	
Competências	
Usuários e tomadores de decisão	
Categorias de pessoas e grupos naturais afetados	
Grupos vulneráveis, sub-representados ou protegidos	
Escala, duração, reversibilidade e efeito cumulativo	
Grau de automação e envolvimento humano	
Categorias e fontes de dados	
Fornecedor e dependências críticas	
Previsível mau uso e	

Campo	Resposta
reaproveitamento	
Alternativa não-AI existente	

2.943. experiência da pessoa afetada

Descreva:

- Como as pessoas encontram o sistema;
- se a participação é voluntária, evitável ou praticamente inevitável;
- Quais informações e avisos eles recebem;
- se eles podem obter uma revisão humana significativa;
- como eles podem desafiar, apelar, reclamar, corrigir dados ou buscar remédio;
- Se a linguagem, deficiência, idade, cultura, situação econômica ou acesso digital afetam sua capacidade de entender ou responder;
- se erros ou resultados adversos podem ser revertidos;
- se vários sistemas ou decisões criam danos cumulativos.

2.954. Análise de direitos e interesses

Direito ou interesse	Pathway Impacto	Pessoas/ grupos afetados	Severidade	Probabilidade	Salvaguarda existente	Risco residual
dignidad e humana e autonomia Privacidade e proteção de dados Igualdade e não discriminação Acessibilidade e direitos das pessoas com deficiênc						

Direito ou interesse	Pathway Impacto	Pessoas/ grupos afetados	Severidade	Probabilidade	Salvaguarda existente	Risco residual
ia Direitos das crianças Emprego e condições de trabalho Educação e acesso profissional Acesso a serviços públicos ou privados essenciais Protecção dos consumidores Liberdade de expressão e informação Liberdade de reunião ou associação, quando relevante						

Direito ou interesse	Pathway Impacto	Pessoas/grupos afetados	Severidade	Probabilidade	Salvaguarda existente	Risco residual
devido processo, remédio eficaz e procedimento justo						
Saúde e segurança						
Outros direitos aplicáveis						

2.965. Caminhos do impacto

Avaliar os riscos decorrentes de:

- Saídas imprecisas, não confiáveis, fabricadas ou instáveis;
- dados tendenciosos, sub-representação ou disparidades de desempenho de subgrupos;
- Discriminação por procuração ou desvantagem cumulativa;
- viés de automação, carimbo de borracha ou supervisão humana inadequada;
- Raciocínio opaco, aviso insuficiente ou explicações inacessíveis;
- incapacidade de desafiar, corrigir, apelar ou obter intervenção humana oportuna;
- vigilância excessiva, monitoramento, coleta de dados ou fluência de funções;
- compromisso de segurança, vazamento de dados, injeção imediata ou uso indevido malicioso;
- alteração do propósito pretendido, reaproveitamento ou expansão populacional não autorizada;
- Limitações de fornecedor, modelo, documentação ou acesso a auditoria;
- falhas de idioma, cultural, deficiência ou acessibilidade;
- interação do sistema com outros processos de decisão automatizados ou humanos;

- interrupções, falhas de fallback ou perda de acesso a serviços essenciais;
- exposição a falsos positivos, falsos negativos, atrasos ou encargos.

2.97 Artigo 27.o Elementos mínimos, se aplicável

Documento no mínimo:

- O processo de implantação em que o sistema de alto risco será utilizado;
- o período e a frequência da utilização prevista;
- categorias de pessoas singulares e grupos susceptíveis de serem afetados;
- Os riscos específicos de danos aos direitos fundamentais;
- medidas de supervisão humana;
- Medidas a tomar se os riscos se materializarem;
- governança, reclamação, remédio, escalada, restrição, suspensão e acordos de reversão;
- coordenação com o DPIA, quando aplicável;
- Notificação, apresentação ou registo obrigatório junto da autoridade competente, utilizando o processo legal em vigor;
- a data, destinatário, reconhecimento e obrigações de acompanhamento.

2.987. Stakeholder e entrada da pessoa afetada

Partes interessadas ou grupo	Porquê relevante	Método	Principais preocupações ou evidências	Resposta da organização
------------------------------	------------------	--------	---------------------------------------	-------------------------

Considerar, quando proporcional ou legalmente exigido:

- Pessoas afetadas e organizações representativas;
- trabalhadores e representantes dos trabalhadores;
- Especialistas em acessibilidade e deficiência;
- especialistas em igualdade, direitos civis e direitos da criança;
- profissionais de domínio;
- Legal, Compliance, Privacidade, Segurança, RH, Produto e Risco;
- revisores independentes ou organismos de ética.

Quando a consulta não for realizada, documente a lógica legal e proporcional e quaisquer evidências alternativas usadas.

2.998. salvaguardas existentes

Documento e teste:

- controles de governança e minimização de dados;
- validação, viés, subgrupo, linguagem e testes de acessibilidade;
- competência de supervisão humana, autoridade, pessoal, substituição e controles de parada;
- Avisos de transparência, explicações, instruções e comunicação entre pessoas afetadas;
- mecanismos de recurso, reclamação, correção e remédios;
- segurança, privacidade, acesso, registro e controles de evidências;
- Monitoramento, incidente, notificação e processos de ação corretiva;
- fornecedor, contrato, direito de auditoria, notificação de alterações e controles de saída;
- Restrições à finalidade, população, jurisdição, dados, automação e reaproveitamento;
- Retrocesso, continuidade de negócios e alternativas manuais.

2.100 9. Avaliação de impacto residual

Impacto	Risco inerente	Salvaguardas	Salvagar a eficácia	Risco residual	Aceitável ?	Proprietário
---------	----------------	--------------	---------------------	----------------	-------------	--------------

A aceitação do risco residual não deve substituir uma proibição ou permitir o não cumprimento de um dever legal vinculativo.

2.101 10. Necessidade, proporcionalidade e alternativas

Documento:

- O objetivo legítimo;
- Por que a IA é necessária ou materialmente benéfica;
- alternativas menos intrusivas ou não IA consideradas;
- se o escopo, população, dados, automação ou duração podem ser reduzidos;
- se os benefícios são apoiados por evidências em vez de suposição;
- se os encargos e riscos recaem desproporcionalmente sobre determinados grupos;
- condições necessárias para manter a proporcionalidade ao longo do tempo.

2.102 11. Decisão

- ☐ Estatuto Artigo 27 FRIA completa
- ☐ Revisão voluntária ou organizacional completa
- ☐ Aprovado
- ☐ Aprovado com condições
- ☐ Piloto restrito com monitoramento aprimorado
- ☐ Remediação pendente adiada ou evidência
- ☐ Uso restrito ou suspenso
- ☐ Proibido ou retirado
- ☐ Escalada para executivo, conselho, autoridade ou revisão legal qualificada

2.102.1 Fundamentação da decisão

Documentar a base legal, benefícios, necessidade, proporcionalidade, alternativas, evidências de partes interessadas, incerteza não resolvida, salvaguardas, risco residual, condições de aprovação e status de processo de autoridade.

2.103 12. Plano de acção

Acção	Proprietário	Data de vencimento	Prioridade	Estado	Método de validação	Evidência de encerramento
-------	--------------	--------------------	------------	--------	---------------------	---------------------------

2.104 13. Monitoramento e reavaliação

Definir:

- desempenho, erro, viés, subgrupo, idioma, acessibilidade e métricas de substituição;
- Reclamação, recurso, correção e tendências de remédios;
- incidentes, quase erros e gatilhos de notificação;
- mudanças de fornecedor e modelo;
- Alterações da população ou da jurisdição afectada;
- limiares de risco residual;
- Critérios de suspensão, reversão, restrição ou retirada;
- destinatários de relatórios e frequência;
- proprietário de reavaliação e cronograma.

2.105 14. Revisar gatilhos

Reavaliar após:

- mudança de propósito, uso real ou contexto de decisão;
- nova população, grupo vulnerável, jurisdição, idioma ou serviço;
- modelo, versão, dados, prompt, ferramenta, interface ou mudança de autonomia;
- mudança de supervisão humana, pessoal, recurso ou mecanismo de remédio;
- reclamação significativa, resultado adverso, incidente ou deriva;
- novo fornecedor, subprocessador, contrato ou limitação de evidência;
- Reclassificação de alto risco, modificação substancial ou alteração da conformidade;
- mudança legal, de autoridade ou de orientação relevante.

2.106 Exemplo de GlobalWay Travel Services

A GlobalWay realiza uma revisão de aplicabilidade do Artigo 27 para um sistema de alocação de funcionários de IA usado por um cliente de viagens do setor público da UE. A avaliação identifica riscos para igualdade, condições de trabalho, dignidade, privacidade, acessibilidade e remédio eficaz. Representantes de trabalhadores relatam que os gerentes raramente substituem os rankings. A GlobalWay fortalece a autoridade de revisão humana, os processos de explicação e apelo, os testes de subgrupos, acessibilidade, evidências de fornecedores e monitoramento. A implantação permanece restrita até que o processo de autoridade competente e validação estejam completos.

2.107 Homologação

Papel	Nome	Decisão	Data
Revisor Jurídico			
Qualificado			
Conformidade/ risco			
proprietário do negócio			
Privacidade/ proteção de dados			
Técnico/produto proprietário			
representante de domínio ou trabalhador afetado, quando aplicável			

Papel	Nome	Decisão	Data
autoridade executiva ou do conselho, quando necessário			

Authority notification/submission status, quando aplicável: Estado de coordenação da DPIA: Referências de evidências: Condições e restrições: Próximo comentário trigger/date: Versão de avaliação:**

2.108 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: Artigo 27.º, disposições aplicáveis de alto risco e implementador, disposições de supervisão humana, transparência, monitorização, incidente, ação corretiva e disposições de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Carta dos Direitos Fundamentais da União Europeia, Regulamento (UE) 2016/679 e regras aplicáveis em matéria de emprego, igualdade, acessibilidade, defesa do consumidor, proteção da criança, direito público e setor.
- Textos legais oficiais consolidados atuais e procedimentos de autoridade competente controlam esse modelo.

2.109 Apêndice H Avaliação de Risco AI

Estado legal: Mestre inglês corrigido. As classificações de risco inerente e residual são conceitos de gestão de risco empresarial. Não são classificações legais da Lei de IA da UE e não devem substituir o Artigo 5, Artigo 6, GPAI, transparência, papel de ator, conformidade, incidente ou análise de notificação.

2.110 Finalidade

Use esta avaliação para identificar, analisar, avaliar, tratar, monitorar, comunicar e reavaliar os riscos decorrentes de um sistema de IA durante todo o seu ciclo de vida.

A avaliação deve conectar cenários de risco a pessoas afetadas, obrigações legais, versões do sistema, controles, evidências, critérios de aceitação, limiares de monitoramento e decisões responsáveis. Os controles planejados ou não testados não devem ser tratados como eficazes.

2.111 1. Contexto da avaliação

Campo	Resposta
Sistema/modelo	

Campo	Resposta
Versão/configuração	
ID do inventário	
Pessoa jurídica e papel de ator	
Propósito pretendido	
Uso real ou proposto	
Usuários e pessoas afetadas	
Competências	
Classificação estatutária	
Fase do ciclo de vida	
Fornecedor/fornecedor e dependências	
Datas atuais de origem e aplicação legais	
proprietário do negócio	
Proprietário técnico	
Avaliador de risco	
Data e versão da avaliação	

2.112 2. Contexto de risco

Descreva:

- Objetivo de negócio e benefício esperado;
- decisão ou processo apoiado;
- pessoas afetadas, grupos vulneráveis, ativos e serviços;
- limites do sistema, interfaces, ferramentas, agentes e dependências;
- modelo, dados, infraestrutura, nuvem e componentes de fornecedores;
- Classificação jurídica e papel organizacional;
- criticidade de decisão e grau de automação;
- Mecanismos de supervisão e apelo humanos;
- Pressupostos, limitações, incertezas e lacunas de evidências;
- Previsibilidade, reaproveitamento e abuso;
- Retrocesso, continuidade, suspensão, reversão e arranjos de saída.

2.113 3. Categorias de risco

Avaliar cada categoria aplicável.

Categoria	Cenário de risco	Controles existentes	Probabilidade	Impacto	Risco inerente	Risco residual	Evidência/incerteza
Legal e regulamentar							
Direitos fundamentais							
Segurança e saúde							
Precisão e confiabilidade							
Bias e discriminação							
Transparência e explicabilidade							
Supervisão humana e viés de automação							
Privacidade e proteção de dados							
Cibersegurança, uso indevid							

Categoria	Cenário de risco	Controles existentes	Probabilidade	Impacto	Risco inerente	Risco residual	Evidência/incerteza
o e abuso							
Robustez, resiliência e continuidade							
Fornecedor, cadeia de suprimentos e concentração							
Qualidade dos dados, proveniência e linhagem							
Mudança, deriva e modificação substancial							
Operacional e financeiro							
Reputação							
Meio ambiente e							

Categoria	Cenário de risco	Controles existentes	Probabilidade	Impacto	Risco inerente	Risco residual	Evidência/incerteza
recurso							
s							
Impacto social							
e							
cumulativo							
tivo							

2.114 4. Análise de cenário

Para cada risco material, documento:

- Evento de início;
- Mecanismo de ameaça, erro, uso indevido ou falha;
- pessoa exposta, grupo, ativo, processo ou serviço;
- Potencial consequência e implicação legal;
- população e escala afetadas;
- duração, detectável, reversibilidade e efeito cumulativo;
- Controle de dependências e pontos únicos de falha;
- pior caso crível;
- Evidências e incertezas atuais;
- Exigência imediata de contenção e escalada;
- sinal de monitoramento que indicaria a materialização de risco.

Cenário ID	Evento de iniciação	Mecanismo de falha	âmbito de aplicação afetado	Consequência	Controles existentes	Provas	Proprietário
------------	---------------------	--------------------	-----------------------------	--------------	----------------------	--------	--------------

2.115 5. Método da avaliação de risco

Use a metodologia aprovada pela organização. Defina no mínimo:

- escala de verossimilhança e horizonte temporal;
- escala de impacto entre direitos, segurança, dimensões legais, operacionais, financeiras e de reputação;
- Método de agregação;
- limiares de tratamento e de escalada;

- critérios e autoridade para a aceitação de riscos residuais;
- prazos de tratamento por gravidade;
- classificação de confiança ou qualidade de evidência;
- tratamento de eventos de baixa frequência e alto impacto;
- tratamento da incerteza e falta de evidência.

Não use uma pontuação numérica como substituto para julgamento profissional, análise legal ou evidência verificada. Não average direitos severos, segurança ou bloqueadores legais.

2.116 6. Risco inerente

Avaliar a exposição antes dos controles.

Cenário	Causa	Pessoa s/ activos afectad os	Probabi lidade	Impact o	Classifi cação inerent e	Confian ça	Evidên cia/ incerte za
---------	-------	--	-------------------	-------------	-----------------------------------	---------------	---------------------------------

2.117 7. Controles e eficácia

Control o	Proprie tário	Estado	Provas	Resulta do do design	Resulta do operaci onal	Limitaç ão	Depend ência
--------------	------------------	--------	--------	----------------------------	----------------------------------	---------------	-----------------

Não reduza o risco de controles que são planejados, incompletos, não aprovados, não testados, operados inconsistentemente, não apoiados por evidências ou dependentes de informações de fornecedores indisponíveis.

2.118 8. Risco residual e bloqueadores legais

Risco	Classific ação residual	Bloquea dor legal?	Tratame nto	Propriet ário	Data de vencime nto	Exigênci a de validaçã o
-------	-------------------------------	--------------------------	----------------	------------------	---------------------------	-----------------------------------

Uma decisão de aceitação de risco não pode:

- autorizar uma prática proibida;
- renunciar a uma obrigação legal;
- Substituir uma avaliação da conformidade exigida, registo, declaração, marcação, consulta, notificação ou decisão de autoridade;
- Permitir a operação fora de um propósito ou função legal aprovado;

- Prevenir a notificação de incidentes, ações corretivas, restrição, recall ou retirada;
- substituir a privacidade, o emprego, a segurança, o consumidor, a acessibilidade, a igualdade ou a lei do setor.

2.119 9. Tratamento de risco

Selecione um ou mais:

- evitar ou proibir o uso;
- reduzir por meio de controles técnicos;
- reduzir através do processo, pessoal ou supervisão humana;
- reduzir através de dados, interface ou alterações de escopo;
- transferir ou alocar através de contrato ou seguro, sem transferir a responsabilidade legal que permanece com a organização;
- finalidade, população, geografia, dados, capacidade ou grau de automação;
- com monitoramento aprimorado e critérios de saída;
- Aceitar o risco residual através da aprovação autorizada;
- suspender, restringir, reverter, retirar ou descomissionar enquanto se aguarda a remediação.

Ação de tratamento	Proprietário	Data de vencimento	Prioridade	Estado	Método de validação	Evidência de encerramento
--------------------	--------------	--------------------	------------	--------	---------------------	---------------------------

2.120 10. Principais indicadores e limiares de risco

Indicador	Lim limiar	Fonte de dados	Frequência	Proprietário	Ação de escalação
-----------	------------	----------------	------------	--------------	-------------------

Considerar:

- taxas de erro e abstenção;
- disparidades entre subgrupos e línguas;
- sobrescrever, desacordo, apelo e taxas de reclamação;
- incidentes, quase erros e gatilhos de notificação;
- Alertas de segurança e tentativas de uso indevido;
- alterações de modelo, dados, prompt, ferramenta ou fornecedor;
- logs, provas ou documentação indisponíveis;
- drift, comportamento inesperado e testes de regressão falhados;
- descobertas atrasadas e repetidas exceções;
- continuidade do serviço e falhas de fallback.

2.121 11. Decisão de risco residual

- ☐ Aceitável dentro da tolerância aprovada
- ☐ Aceitável com condições e monitoramento aprimorado
- ☐ Aceitação de risco executivo necessária
- ☐ A escalada da diretoria necessária
- ☐ Remediação necessária antes da aprovação
- ☐ Apenas piloto restrito
- ☐ Implantação bloqueada ou suspensa
- ☐ Proibido, retirado ou desativado
- ☐ Revisão legal qualificada necessária

2.121.1 Fundamentação da decisão

Documento:

- benefícios esperados e evidências de apoio;
- alternativas menos arriscadas consideradas;
- design de controle e eficácia operacional;
- Bloqueadores legais e obrigações obrigatórias;
- Limitações de incertezas e evidências;
- Pessoas afetadas e grupos vulneráveis;
- condições de risco residual, duração e monitoramento;
- autoridade de aceitação e raciocínio;
- Critérios que exigem suspensão, reversão ou reavaliação.

2.122 12. Monitoramento e reavaliação

Definir:

- indicadores, limiares e sistemas de origem;
- Resultados de pessoa afetada, subgrupo, idioma e acessibilidade;
- Supervisão humana, substituição, recurso e monitoramento de reclamações;
- Incidente, near-miss e gatilhos de notificação;
- mudanças de modelo, fornecedor, dados, prompt, ferramenta e jurisdição;
- Rever a frequência e os destinatários dos relatórios;
- Critérios de suspensão, reversão, restrição, retirada e saída;
- requisitos de retenção de evidências e de vinculação de versões.

2.123 13. gatilhos de reavaliação

Reavaliar após:

- modelo, dados, prompt, ferramenta, agente, arquitetura ou mudança de interface;
- mudança de propósito, uso real, população, setor ou grau de automação;
- implantação em uma nova jurisdição ou entidade legal;
- Incidente material, reclamação, recurso, resultado adverso ou quase falta;
- desempenho, viés, subgrupo, idioma, acessibilidade ou deriva de segurança;
- fornecedor, contrato, subprocessador, licença ou mudança de dependência crítica;
- vulnerabilidade, inteligência de ameaças ou padrão de uso indevido;
- desenvolvimento legal, regulamentar, autoridade, padrão ou código;
- Auditoria, validação, conformidade ou descoberta de testes de controle;
- modificação substancial, repurposing, ou mudança de papel.

2.124 Exemplo de GlobalWay Travel Services

A GlobalWay avalia um assistente de interrupção do viajante que recomenda mudanças de itinerário e pode iniciar ferramentas de remarcação. Cenários materiais incluem conselhos de segurança imprecisos, reembolsos não autorizados, vazamento de privacidade, injeção imediata, interrupções de fornecedores, disparidades de idioma e viés de automação. A GlobalWay exige confirmação humana para ações externas, restringe dados sensíveis, adiciona testes de regressão multilíngues, monitora taxas de sobreerogação e reclamação e define limites de suspensão imediata. O risco residual é aprovado apenas para um fornecedor pendente restrito e validação independente.

2.125 Homologação

Papel	Nome	Decisão	Data
proprietário do negócio			
Proprietário técnico			
Proprietário de risco			
Legal/Conformidade			
Privacidade/Segurança/Dados, conforme			

Papel	Nome	Decisão	Data
aplicável			
Executivo ou Conselho de Administração			
, quando necessário			

Referências de evidências: Suposições aceitas e incerteza:

Condições, restrições e expiração: Ações abertas e datas de vencimento:

Próximo comentário trigger/date: Versão de avaliação:

2.126 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, alterado: gestão de risco aplicável, de alto risco, GPAI, transparência, supervisão humana, precisão, robustez, cibersegurança, monitorização, incidentes, ações corretivas e disposições de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação aplicável em matéria de emprego, igualdade, acessibilidade, cibersegurança, segurança dos produtos, defesa do consumidor, propriedade intelectual, ambiente e setor.
- As classificações de risco empresarial neste modelo são ferramentas de governança e não alteram classificações estatutárias ou deveres legais.

2.127 Apêndice I Avaliação da Governança de Dados

Estado legal: Mestre inglês corrigido. Este arquivo distingue as funções do Artigo 10 para provedores de sistemas de IA de alto risco de controles mais amplos de governança de dados organizacionais, privacidade, segurança, qualidade, propriedade intelectual e gerenciamento de registros.

2.128 Finalidade

Use esta avaliação para avaliar se os dados usados para treinar, ajustar, validar, testar, recuperar, operar, monitorar ou melhorar um sistema de IA são adequados, legais, seguros, representativos, rastreáveis e regidos para o propósito pretendido documentado e a população afetada.

A avaliação deve ser vinculada à versão e repetida quando a fonte, população, finalidade, modelo, característica, rótulo, transformação, fornecedor, jurisdição ou condições legais mudarem.

2.129 1. Aplicabilidade e escopo

Campo	Resposta
Sistema/modelo	
ID do inventário	
Versão/configuração	
Pessoa jurídica e papel de ator	
Classificação de alto risco e base legal	
Dataset/nome da fonte e versão	
Proprietário e administrador de dados	
Finalidade prevista e utilização do ciclo de vida	
Pessoas e populações afectadas	
Competências	
Aplica-se o artigo 10?	
Avaliação relacionada DPIA/FRIA/segurança	
Fonte legal atual e data de aplicação	
Proprietário/data da avaliação	

2.130 2. Dataset e uso do ciclo de vida

Registre cada uso separadamente.

Utilização dos dados	Dataset/ versão	Finalidade	População/ contexto	Proprietário	localização da evidência
Formação					
Validação					
Testes					
Fine-afinação					
Retrieval/ grounding					
Entrada operacion					

Utilização dos dados	Dataset/ versão	Finalidade	População/ contexto	Proprietário	localização da evidência
al					
Feedback/ aprendizagem contínua					
Monitorização					
Dados sintéticos ou aumentados					

2.131 3. Finalidade e requisitos de dados

Documento:

- Uso pretendido e usos proibidos ou restritos;
- Estágio de ciclo de vida suportado;
- contribuição esperada para o comportamento e desempenho do sistema;
- Cobertura de população, geográfica, temporal, idioma, classe e eventos raros;
- ambiente operacional e contexto de decisão;
- populações afetadas e grupos vulneráveis;
- pressupostos sobre o que os dados medem ou representam;
- características exigidas de qualidade, quantidade, estatística e linhagem;
- limitações conhecidas e condições de uso aceitável.

2.132 4. Provenance, aquisição e direitos

Pergunta	Resposta	Provas
A fonte é conhecida e documentada?		
A coleta e aquisição são legais?		
Licenças, permissões, contratos e direitos de propriedade intelectual são documentados?		

Pergunta	Resposta	Provas
A raspagem, reutilização, treinamento, ajuste fino, redistribuição e restrições a jusante são entendidas?		
Os impactos dos dados, da comunidade, do cliente ou do fornecedor são compreendidos?		
As representações dos fornecedores são verificadas independentemente onde proporcionalmente?		
As lacunas de proveniência ou fontes não verificáveis são identificadas e escaladas?		

2.133 5. Artigo 10.o e critérios de governação

Avaliar, conforme aplicável:

- Opções de design relevantes;
- Processos de coleta de dados e origem;
- preparação, anotação, rotulagem, limpeza, enriquecimento e agregação;
- formulação de suposições sobre o que os dados medem e representam;
- avaliação prévia da disponibilidade, quantidade, adequação e características exigidas;
- exame de possíveis vieses que afetem a saúde, a segurança, os direitos fundamentais ou a discriminação proibida;
- Medidas para detectar, prevenir, reduzir e mitigar o viés;
- identificação de lacunas, deficiências e remediação;
- representatividade para a população e o contexto pretendidos;
- Propriedades estatísticas adequadas;
- configuração geográfica, contextual, comportamental, funcional, de idioma e acessibilidade;

- Versão, linhagem, integridade, segurança e reprodutibilidade.

2.134 6. Relevância e representatividade

Avaliar:

- relevância para o propósito pretendido;
- Cobertura de população e subgrupos;
- Cobertura geográfica e cultural;
- Moeda temporal;
- equilíbrio de classes e cobertura de eventos raros;
- representação interseccional;
- Diferenças entre treinamento, validação, teste e condições de produção;
- cobertura de falhas realistas, uso indevido e casos de borda;
- representatividade dos dados de feedback e monitoramento.

Critério	Método	Resultado	Limitação	Acção
Cobertura da população				
Cobertura geográfica/contextual				
Moeda temporal				
Classe/ cobertura de eventos raros				
Cobertura de subgrupo/interseccional				
alinhamento da produção				

2.135 7. Avaliação da qualidade

Dimensão da qualidade	Rating/result	Provas	Lim limiar	Remediação
Precisão				
Completeness				

Dimensão da qualidade	Rating/result	Provas	Lim limiar	Remediação
s				
Consistência				
Timeliness				
Validade				
Unicidade/ deduplicação				
Qualidade do rótulo/anotação				
Ruído e outliers				
Desaparecimento				
Integridade e corrupção				
Reprodutibilidade				

2.136 8. Bias e risco de discriminação

Avaliar:

- viés histórico e estrutural;
- variáveis proxy e características correlacionadas;
- falta diferencial;
- viés de etiqueta e anotação;
- amostragem, seleção, sobrevivência e viés de medição;
- desempenho de subgrupos e interseccionais;
- linguagem, deficiência, idade e efeitos geográficos;
- ciclo de feedback e viés cumulativo;
- trade-offs de mitigação e consequências não intencionais;
- O monitoramento de dados pode detectar disparidades emergentes.

Risco de viés	Grupo afectado	Método de detecção	Resultado	Mitigação	Limitação residual
---------------	----------------	--------------------	-----------	-----------	--------------------

2.137 9. Privacidade, sensibilidade e dados de categoria especial

Documento:

- Dados pessoais, de categoria especial, biométricos, infantis, confidenciais, proprietários ou regulamentados;
- Limitação e minimização de objetivos;
- Base de processamento legal;
- risco de desidentificação, pseudonimização e reidentificação;
- controles de acesso e segregação;
- Transferências internacionais e localização;
- retenção, exclusão, arquivamento e retenção legal;
- Restrições ao treinamento, uso secundário, melhoria do fornecedor ou divulgação posterior;
- Avisos de privacidade, manipulação de direitos e impactos sobre os dados.

Onde os dados pessoais da categoria especial são processados para monitoramento, detecção ou correção de viés, registre a base legal exata, necessidade estrita, limites de acesso, salvaguardas, pseudonimização, exclusão, documentação e privacidade / aprovação legal qualificada. Não trate o AI Act como uma permissão geral para processar dados confidenciais.

2.138 10. Preparação e transformação

Gravar:

- Limpeza e normalização;
- Engenharia de recursos e seleção;
- deduplicação;
- rotulagem e anotação;
- Aumento ou geração de dados sintéticos;
- filtragem, exclusões e tratamento atípico;
- Tratamento de dados em falta;
- limiares de qualidade e critérios de rejeição;
- código de transformação, aprovações e reprodutibilidade;
- controle de versão e reversão.

Transformação	Método/ ferramenta	Versão	Proprietário	Validação	Provas
---------------	-----------------------	--------	--------------	-----------	--------

2.139 11. Linhagem e rastreabilidade

Elemento	Localização ou identificador
Fonte original	
Registro de aquisição/licença	

Elemento	Localização ou identificador
Registo de ingestão	
pipeline transformação	
Dataset version/checksum	
Homologação	
Treinamento/validação/teste	
Sistema de produção/versão modelo	
Local de retenção	
Histórico de acessos	
Registo de eliminação	

2.140 12. Segurança e integridade

Avaliar:

- autenticidade e integridade da fonte;
- alteração não autorizada, envenenamento, contaminação e vazamento;
- controle de acesso e segregação;
- encriptação e transferência segura;
- segurança do fornecedor e do gasoduto;
- backup, recuperação e disponibilidade;
- registro de auditoria e detecção de anomalias;
- Eliminação segura.

2.141 13. Decisão

- Aprovado para o uso documentado
- ☐ Aprovado com condições
- ☐ Uso limitado ou apenas piloto
- ☐ Remediação necessária antes do uso
- ☐ Proibido de uso
- ☐ Interpretação legal / de privacidade qualificada necessária

Motivo da decisão: Limitações residuais: Usos restritos ou proibidos:
Requisitos de monitorização: **

2.142 14. Plano de acção

Acção	Proprietário	Data de vencimento	Estado	Método de validação	Evidência de encerramento
-------	--------------	--------------------	--------	---------------------	---------------------------

2.143 15. Acionadores da mudança e da reavaliação

Reavaliar após mudanças em:

- fonte, licença, fornecedor, subprocessador ou método de aquisição;
- propósito pretendido, população afetada, jurisdição ou setor;
- recurso, rótulo, anotação, transformação ou método de dados sintéticos;
- modelo, pronta, recuperação, feedback ou processo de aprendizagem contínua;
- qualidade, viés, desempenho, privacidade ou resultados de segurança;
- retenção, transferência, localização ou acesso a dados;
- base legal, consentimento, contrato, posição de autoridade ou lei aplicável.

2.144 Exemplo de GlobalWay Travel Services

A GlobalWay avalia os dados de reserva, interrupção e perfil do viajante usados por um modelo de fraude. A avaliação encontra sub-representação de certos padrões de viagem regionais, rótulos inconsistentes e reutilização de fornecedores de dados do cliente para melhoria do modelo. A GlobalWay restringe o conjunto de dados, corrige rótulos, expande testes representativos, proíbe o treinamento do fornecedor sem autorização e vincula a versão aprovada do conjunto de dados ao modelo implantado e aos limites de monitoramento.

2.145 Homologação

Papel	Nome	Decisão	Data
Proprietário/ comandante de dados			
Fornecedor/ proprietário técnico			
Privacidade/ legal			

Papel	Nome	Decisão	Data
Risco/ conformidade			
Segurança, quando aplicável			

Referências de evidências: ** Limitações residuais: Condições/restrições:
Próximo comentário trigger/date: Versão de avaliação:

2.146 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: Artigo 10.o e disposições aplicáveis em matéria de gestão de riscos, documentação técnica, exploração madeireira, monitorização, incidentes e de alto risco.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e propriedade intelectual aplicável, banco de dados, direitos autorais, confidencialidade, segurança cibernética, gerenciamento de registros, emprego, igualdade e direito do setor.
- Textos oficiais consolidados atuais controlam esse modelo.

2.147 Apêndice J Plano de Supervisão Humana

** Status legal: ** Mestre inglês corrigido. Este arquivo distingue as funções de design do provedor nos termos do Artigo 14 das funções de deployer para atribuir pessoas naturais competentes e operar o sistema de acordo com as instruções aplicáveis. A supervisão humana deve ser significativa na prática e não pode ser reduzida à aprovação nominal ou revisão pós-fato.

2.148 Finalidade

Use este plano para definir como as pessoas qualificadas entenderão, supervisionarão, desafiarão, desconsiderarão, substituirão, interromperão, pararão, suspenderão e escalarão a operação de um sistema de IA.

O plano deve vincular os objetivos de supervisão, papéis, pontos de decisão, informações, autoridade, competência, carga de trabalho, fallback, evidências, testes, monitoramento e revisão de gatilhos para a versão do sistema aprovada e o propósito pretendido.

2.149 1. registro de aplicabilidade

Campo	Resposta
Sistema/modelo	
Versão/configuração	

Campo	Resposta
ID do inventário	
Pessoa jurídica e papel de ator	
Classificação de alto risco e base legal	
Propósito pretendido	
Uso real ou proposto	
Usuários e pessoas afetadas	
Instruções do fornecedor revistas	
FRIA/DPIA/avaliação de risco relacionada	
Fonte legal atual e data de aplicação	
Plano proprietário/data/versão	

2.150 2. Objetivos de supervisão

Definir a supervisão dos riscos destinada a prevenir ou reduzir, incluindo:

- resultados inseguros ou ilegais;
- viés de automação e excesso de confiança;
- Saídas imprecisas, não confiáveis, discriminatórias ou manipuladas;
- uso fora do propósito pretendido ou da população aprovada;
- falha em reconhecer a incerteza, comportamento anormal, deriva ou limitações do modelo;
- Ação autônoma ou uso inadequado de ferramentas;
- Incidente atrasado, reclamação ou resposta de escalada;
- incapacidade das pessoas afetadas para obter revisão humana, correção, recurso ou remédio;
- retorno inadequado durante interrupções, ataques, falhas de fornecedores ou condições inesperadas.

2.151 3. Medidas de supervisão concebidas pelo fornecedor

Capacidades de projeto de registro que permitem que pessoas naturais:

- compreender capacidades relevantes, limitações, suposições e uso indevido previsível;
- permanecer ciente de viés de automação e limites de desempenho;
- interpretar corretamente as saídas no contexto;

- Aceder a dados relevantes, informações de origem, indicadores de confiança ou de incerteza sempre que sejam significativos e ações anteriores;
- Desconsiderar, ignorar, reverter ou corrigir saídas;
- Prevenir ou aprovar ações externas;
- interromper ou interromper a operação com segurança;
- detectar anomalias, deriva, mau uso e condições anormais;
- aumentar incidentes, preocupações com direitos, riscos de segurança e falhas de controle;
- Use logs, explicações, informações de versão e evidências necessárias para revisão.

Medida	Proprietário do projeto	Recurso ou procedimento do sistema	Versão	Evidência de ensaio	Limitação
--------	-------------------------	------------------------------------	--------	---------------------	-----------

2.152 4. modelo operacional do deployer

Papel	Responsabilidades	Autoridade de decisão	Competência requerida	Carga/tempo de trabalho	Backup Backup	rota de escalação
-------	-------------------	-----------------------	-----------------------	-------------------------	---------------	-------------------

Confirme que o pessoal de supervisão:

- São pessoas naturais;
- Ter competência, formação, autoridade, independência, tempo, ferramentas e apoio necessários;
- compreender a finalidade pretendida, instruções, limitações e riscos relevantes;
- pode substituir ou parar o sistema sem retaliação ou pressão de desempenho conflitantes;
- Ter acesso a especialistas e contatos de emergência;
- não são atribuídas cargas de trabalho que tornam impossível uma revisão significativa;
- são apoiados por alternativas e arranjos de continuidade.

2.153 5. Pontos de decisão e intervenções

Passo do ciclo de vida/processo	Saída ou ação de IA	Revisão humana necessária	Informação disponível	Método Override /stop	limiar de escala	Evidência criada
---------------------------------	---------------------	---------------------------	-----------------------	-----------------------	------------------	------------------

Inclua aprovação de pré-lançamento, operação em tempo real, exceções, recursos, resposta a incidentes, reversão, restauração e aposentadoria, quando aplicável.

2.154 6. Informações disponíveis aos revisores

Os revisores de confirmação recebem:

- propósito pretendido, uso aprovado e uso proibido ou restrito;
- contexto de entrada e saída;
- informações relevantes sobre fonte, recuperação, ferramenta e ação;
- indicadores de confiança, incerteza, abstenção ou alerta quando significativos;
- precisão conhecida, viés, subgrupo, idioma, acessibilidade, segurança e limitações de robustez;
- Critérios legais, políticos e de decisão aplicáveis;
- substituições prévias, desentendimentos, incidentes, reclamações e recursos;
- instruções para desafio, correção, substituição, suspensão, parada, escalada e recuo;
- versão e informações de alteração;
- rotas de contato e suporte.

2.155 7. Autoridade, independência e incentivos

Documento se os revisores podem:

- Reverter ou corrigir a saída;
- exigir provas adicionais ou uma segunda revisão;
- adiar ou recusar uma decisão;
- Obter aconselhamento jurídico, técnico, clínico, de RH, de segurança ou de domínio;
- Parar, suspender, reverter ou isolar o sistema;
- escalar sem retaliação;
- dissidência recorde e incerteza não resolvida;
- proteger as pessoas afetadas enquanto a investigação prossegue.

Avalie se as metas de produção, métricas de velocidade, pessoal, incentivos ou pressão de gerenciamento prejudicam a revisão significativa.

2.156 8. Controles de Automation-bias

Use controles proporcionados, tais como:

- análise independente antes de apresentar a recomendação de IA;
- apresentação encenada de evidências de origem e saída de IA;
- Racionalidade obrigatória para aceitação e substituição em decisões materiais;
- Revisão de qualidade randomizada;
- rotação do revisor e revisão de segundo nível;
- Alertas para altas taxas de aceitação ou baixas taxas de substituição;
- treinamento baseado em cenários e exercícios de desafio;
- Separação das metas de produção de medidas de supervisão-qualidade;
- monitoramento de desentendimentos, apelo e padrões de reversão;
- Testes cegos periódicos do julgamento do revisor.

2.157 9. Competência e treinamento

Tópico	Audiência	Frequência	Evidência de conclusão	Teste de competência	Acionador de atualização
formação/competência					
Propósito e limitações					
Interpretação e incerteza					
Vieses de automação					
Riscos de direitos, segurança, privacidade e discriminação					
Sobreride, stop, fallback e escalada					

Tópico formação/ competência	Audiência	Frequência	Evidência de conclusão	Teste de competência	Acionador de atualização
preservação de incidentes e evidências Acessibilidade e comunicação pessoa afetada					

A conclusão do treinamento por si só não demonstra competência. Use observação, simulação, testes e evidências de desempenho.

2.158 10. Override e procedimento de escalada

1. Identificar a saída questionável, ação ou condição operacional.
2. Prevenir ou conter danos imediatos e usar o fallback aprovado quando necessário.
3. Preservar entradas, saídas, prompts, ferramentas, versões, logs, decisões e contexto relevantes.
4. Aplicar o processo alternativo ou manual aprovado.
5. Registrar a decisão do revisor, evidências, lógica e incerteza.
6. Notificar as pessoas afetadas ou funções responsáveis quando necessário.
7. Escalar materiais, repetidos, sistêmicos, legais, de segurança, direitos ou questões de segurança.
8. Incidente de gatilho, risco, mudança, fornecedor, notificação ou processos de ação corretiva quando necessário.
9. Validar a remediação e restauração antes que a operação normal seja retomada.
10. Comunique resultados e lições aprendidas.

2.159 11. Validação

Teste:

- compreensão do propósito e limitações do sistema pelo revisor;
- Acesso às informações necessárias;
- autoridade para desconsiderar, substituir, interromper, parar e escalar;
- Eficácia técnica dos mecanismos de substituição e paragem;

- Queda manual e continuidade;
- carga de trabalho, pessoal, fadiga e tempo de resposta;
- resistência ao viés de automação e pressão de gerenciamento;
- suporte linguístico e de acessibilidade;
- detecção de condições anormais, uso indevido, deriva e incerteza;
- escalada e eficácia de resposta a incidentes;
- criação e recuperação de provas.

Cenário de teste	Critérios		Resultado	Defeito	Proprietário	Evidência de reteste
	de	aceitação				

2.160 12. Monitorização

Faixa:

- taxas de aceitação, substituição, correção e reversão;
- discordância dos revisores e resultados de segunda revisão;
- tempo para revisão e escalada;
- excepcionalmente alta confiança ou baixas taxas de desafio;
- defeitos de qualidade, falsos positivos, falsos negativos e abstenções;
- diferenças de subgrupo, idioma, deficiência e acessibilidade;
- reclamações, recursos, remédios e resultados da pessoa afetada;
- carga de trabalho do revisor, fadiga, rotatividade e lacunas de pessoal;
- Formação e estatuto de competência;
- Intervenções fracassadas, paradas falhas e falhas de fallback;
- Repetir problemas após a ação corretiva.

Indicador	Lim limiar	Fonte	Frequência	Proprietário	Ação necessária
-----------	------------	-------	------------	--------------	-----------------

2.161 13. Falha e recuo

Documento:

- Suspensão segura e critérios de paragem;
- Processo manual ou alternativo;
- Contatos de emergência e especialistas;
- arranjos de continuidade, recuperação e restauração;
- preservação de evidências;
- comunicação a pessoas, clientes, trabalhadores ou autoridades afetados;

- restrições durante a operação degradada;
- aprovação e validação necessárias antes da restauração.

2.162 14. Decisão

- ☐ Projeto de supervisão e modelo operacional aprovado
- ☐ Aprovado com condições
- ☐ Apenas piloto restrito
- ☐ Remediação e reteste necessários
- ☐ Implantação bloqueada ou suspensa
- ☐ Revisão legal ou especializada qualificada necessária

Motivo da decisão: Limitações residuais: Condições e restrições: **Ações abertas e datas de vencimento:**

2.163 15. gatilhos de revisão

Reavaliar após:

- modelo, dados, prompt, ferramenta, agente, interface, limiar ou mudança de fluxo de trabalho;
- Finalidade pretendida, população, jurisdição ou mudança de automação;
- Instrução do fornecedor ou alteração do fornecedor;
- pessoal, carga de trabalho, competência, incentivo ou mudança de autoridade;
- Incidente, reclamação, recurso, resultado adverso ou intervenção fracassada;
- desempenho, viés, linguagem, acessibilidade ou deriva de segurança;
- modificação substancial, reclassificação ou mudança legal.

2.164 Exemplo de GlobalWay Travel Services

O assistente de interrupção de viajante da GlobalWay recomenda ações de remarcação e reembolso. O plano de supervisão requer um consultor de viagens para confirmar mudanças sensíveis à segurança e todas as ações financeiras externas. Os consultores recebem contexto do itinerário, regras do fornecedor, avisos de incerteza e ações de ferramentas anteriores. O monitoramento detecta taxas de aceitação extraordinariamente altas durante o clima severo. A GlobalWay reduz a carga de trabalho, adiciona revisão independente para ações de alto impacto, treina novamente a equipe e bloqueia a execução automática até que os testes de substituição e escalada passem.

2.165 Homologação

Papel	Nome	Decisão	Data
Fornecedor/ proprietário técnico			
Deployer/ proprietário do negócio			
Proprietário Supervisão			
Legal/ Conformidade			
Risco/ Privacidade/ Segurança/ AR, conforme aplicável			

Referências de evidências: ** Limitações residuais: **Próximo comentário trigger/date:** Versão do plano:****

2.166 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: Artigo 14.º e fornecedor, implementador, gestão de riscos, transparência, registo, monitorização, incidente, ação corretiva e disposições de autoridade aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.
- Emprego aplicável, igualdade, acessibilidade, privacidade, segurança, proteção ao consumidor e direito do setor.
- Textos oficiais consolidados atuais e controle de instruções do provedor sobre este modelo.

2.167 Apêndice K Índice de documentação técnica

Estado legal: Mestre inglês corrigido. Para provedores de sistemas de IA de alto risco, use esse índice para apoiar a documentação do Artigo 11 e do Anexo IV. Para outros atores ou sistemas, use-o como evidência de governança e não o represente como documentação legal do Anexo IV, a menos que o gatilho legal se aplique.

2.168 Finalidade

Use este índice para organizar, controlar, reconciliar e evidenciar a documentação técnica necessária para explicar o projeto, desenvolvimento,

dados, operação, testes, controles de risco, supervisão, monitoramento, mudanças e status de conformidade de um sistema de IA.

O índice deve estar vinculado à versão de produção exata e atualizado antes do lançamento, após mudança material e sempre que os requisitos legais ou de conformidade forem alterados.

2.169 1. Aplicabilidade e controle de documentos

Campo	Resposta
Sistema/modelo	
ID do inventário	
Pessoa jurídica e papel de ator	
Base jurídica de alto risco	
Propósito pretendido	
Versão/configuração da produção	
Fornecedor/fornecedor	
Aplica-se o anexo IV?	
Rota de conformidade aplicável	
Fonte legal atual e data de aplicação	
Proprietário da documentação	
Repositório/sistema de registo	
Data de versão e revisão do índice	

2.170 2. Passarela do anexo IV, quando aplicável

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
Descrição geral	Nome do sistema, fornecedor, versão, finalidade e pretendi					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
	da, usuários, contexto operacional, interfaces, dependências de hardware/software					
Elementos do sistema e processo de desenvolvimento	Decisões de design, métodos, ferramentas, ambientes, arquiteturas, componentes, recursos de computação, dependências					
Especificações e pressupostos de design	Opções de design, suposições, trade-offs, limitações, uso previsível					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
Governança de dados e dados	l e uso proibido Fontes, origem, coleção, preparação, anotação , qualidade, representatividade, viés, linhagem, retenção					
Treinamento, tuning e desenvolvimento	Métodos , parâmetros, execuções, recursos , versionamento, reprodutibilidade					
Validação e teste	Métricas , cenários, critérios de aceitação, subgrupo, idioma, acessibil					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
	idade, robustez, uso indevido e testes de segurança					
Precisão, robustez, segurança cibernética e resiliência	Desempenho, incerteza, estresse, ataque, recuperação, continuidade e evidências de retorno					
Supervisão humana	Funções, competência, informação, autoridade, sobreposição, parada, recuo, escalada e evidência de teste					
Transparência e instrução	Instruções de uso,					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
es	limitações, avisos, divulgação, acessibilidade, idioma, informações do usuário					
Registro e manutenção de registros	Eventos capturados, retenção, acesso, integridade, vinculação de versão e exportação					
Sistema de gestão de riscos	Riscos, cenários, controles, riscos residuais, decisões e atualizações					
Sistema de gestão da qualidade	Políticas, procedimentos, propriedade, liberação, forneced					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
	or, incidente, ação corretiva e controle de mudanças					
Mudanças predeterminadas e histórico de versões	Plano de mudança aprovado, histórico de lançamento, modificações, reavaliação, reversão					
Normas e conformidade	Normas harmonizadas, especificações comuns, rota de conformidade, registros de organismos notificados, declarações, registro,					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
	marcação					
Monitoramento pós-comercialização	Plano de monitoramento, métricas, limiares, reclamações, incidentes, tendências, ações corretivas					
Evidência de fornecedores e componentes	Contratos, cartões de modelo/sistema, atestado, licenças, dependências, avisos de alteração, evidência de auditoria					
Incidência e e remediação	Cronologia de incidentes, notificação, contenção					

Área do anexo IV	Conteúdo Necessário	Referência de documento/evidência	Proprietário	Versão	Estado	Gap/ação
	o, causa raiz, ação corretiva					
	, validação, lições aprendidas					

2.171 3. documentação de apoio à governança

Se relevante, índice:

- aplicabilidade, papel, prática proibida e avaliações de alto risco;
- FRIA, DPIA, governança de dados, segurança, fornecedor e avaliações de risco;
- Registos de controlo e de provas;
- Liberação, risco residual, exceção e aprovações executivas;
- handoff, instruções, treinamento e provas de competência;
- autoridade, organismo notificado, auditor, cliente e correspondência do fornecedor.

2.172 4. Reconciliação da produção-versão

Componente de produção	Versão/checksum	Versão da documentação	localização da evidência	Combinado?	Resolução/proprietário
Modelo					
Código do sistema					
Instruções do sistema/prompts					
Ferramentas/agentes/integrações					

Componente de produção	Versão/ checksum	Versão da document ação	localização da evidência	Combinado?	Resolução/ proprietário
Datasets/ fontes de recuperação					
Configuração/ limiares					
Interface do usuário/notificações					
Configuração de monitoramento/logg					

Nenhuma liberação pode depender de documentação que descreva um sistema, modelo, conjunto de dados, configuração ou processo de supervisão materialmente diferente.

2.173 5. Verificações da evidência-qualidade

Para cada item indexado, confirme:

- autêntico e atribuível a um proprietário responsável;
- completo para a finalidade legal aplicável;
- atual, aprovado e vinculado à versão implantada;
- internamente consistente com outra documentação;
- apoiados por evidências de origem e reproduzíveis quando necessário;
- protegido de alterações não autorizadas;
- acessíveis apenas a pessoas autorizadas enquanto disponíveis para auditores, organismos notificados e autoridades, conforme legalmente exigido;
- Recuperável dentro dos prazos necessários;
- retidos sob o cronograma legal, contratual, operacional e legal aplicável;
- disponível na língua e formato requeridos.

2.174 6. Gaps e decisão de liberação

Gap	Impacto jurídico/operacional	Controle Interino	Proprietário	Data de vencimento	Validação	Libertador?
-----	------------------------------	-------------------	--------------	--------------------	-----------	-------------

- ☐ Completo para fins legais aplicáveis
- ☐ Completo com condições aprovadas
- ☐ Índice de governança somente; Anexo IV não aplicável
- ☐ Incompleto liberação ou revisão de conformidade bloqueada
- ☐ Revisão legal ou de conformidade qualificada exigida

Motivo da decisão: Condições abertas:**** **Implicações de conformidade:**

2.175 7. Mudança e gatilhos de revisão

Atualização após:

- modelo, sistema, código, prompt, ferramenta, dados, limiar ou mudança de infraestrutura;
- propósito pretendido, ator-papel, população, jurisdição ou mudança de produto;
- mudança de fornecedor, componente, licença ou dependência;
- validação, monitoramento, incidente, reclamação ou descoberta de auditoria;
- uso de plano de mudança predeterminado ou modificação substancial;
- conformidade, registro, declaração, marcação, autoridade ou desenvolvimento legal;
- suspensão, reversão, retirada, recall ou aposentadoria.

2.176 Exemplo de GlobalWay Travel Services

A GlobalWay concilia a documentação técnica de um sistema de alocação de funcionários com a produção. A revisão conclui que o modelo de fornecedor implantado e a interface multilíngue diferem das versões documentadas. A liberação permanece bloqueada até que a versão do modelo, testes de dados, instruções de supervisão, avisos de transparência, limiares de monitoramento e evidências de conformidade sejam atualizadas e reconciliadas de forma independente.

2.177 Homologação

Papel	Nome	Decisão	Data
Fornecedor/proprietário			

Papel	Nome	Decisão	Data
técnico			
Qualidade/ Conformidade			
Proprietário legal/conformi dade			
Segurança/ Dados/ Privacidade, conforme aplicável			

Referências de evidências: Residuais lacunas e restrições: Próximo comentário trigger/date: Versão do índice:****

2.178 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, conforme alterado: Artigo 11.o, Anexo IV, e disposições aplicáveis de gestão de risco, dados, registo, transparência, supervisão, precisão, robustez, cibersegurança, gestão da qualidade, conformidade, monitorização, incidentes e acesso à autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Legislação aplicável do produto anexo I e requisitos de conformidade.
- Textos oficiais consolidados atuais controlam esse índice.

2.179 Apêndice L Lista de verificação da conformidade-prontidão

Esta revisão de prontidão interna não substitui o procedimento de avaliação da conformidade, o envolvimento do corpo notificado, o procedimento do setor do produto, a declaração, o registo, a marcação CE ou a decisão de autoridade exigida por lei.

2.180 Finalidade

Use esta lista de verificação para determinar se um sistema de IA e sua governança de suporte, documentação, controles, testes e evidências estão prontos para entrar no procedimento de conformidade aplicável.

A prontidão deve ser avaliada em relação ao papel exato do provedor, rota de alto risco, finalidade pretendida, versão do sistema, legislação do produto, data de aplicação e procedimento de conformidade. Uma decisão interna “pronta” não é conformidade legal ou autorização de mercado.

2.181 1. Aplicabilidade e rota

Campo	Resposta
Fornecedor/entidade jurídica	
Nome do sistema e ID do inventário	
Versão/configuração avaliada	
Propósito pretendido	
Usuários e pessoas afetadas	
Artigo 6.o, n.o 1/Anexo I ou artigo 6.o, n.o 2/Anexo III	
Legislação exata do anexo I ou ponto do anexo III	
Legislação aplicável sobre produtos	
Artigo 43.o Via de conformidade	
Rota de controle interno disponível?	
É necessário um organismo notificado?	
Normas harmonizadas / especificações comuns invocadas	
Data de aplicação atual/regra de transição	
Proprietário legal/conformidade	
Data/versão da avaliação	

2.182 2. Governança e responsabilidade

- ☐ O papel legal e a classificação de alto risco estão documentados e atualizados.
- ☐ Prestador responsável, técnico, qualidade, legal, risco, dados, segurança e proprietários de empresas são atribuídos.
- ☐ Os procedimentos de gestão da qualidade são aprovados e em funcionamento.
- ☐ Responsabilidades de gestão de risco e autoridade de aceitação são definidas.
- ☐ As atividades de projeto, desenvolvimento, validação, liberação e mudança são controladas.

- ☐ As responsabilidades do fornecedor, componente, importador, distribuidor, representante e fabricante do produto estão documentadas.
- ☐ Achados, exceções, desvios e ações corretivas são rastreados.
- ☐ Os requisitos de independência e competência são definidos para o trabalho de validação e conformidade.

2.183 3. prontidão da exigência de alto risco

Área	Aplicável?	Pronto?	Provas	Gap/ação
Artigo 9.o Sistema de gestão dos riscos				
Artigo 10.o Governança de dados e dados				
Artigo 11.o Documentação técnica				
Artigo 12.o Manutenção de registros/regi stros				
Artigo 13.o Transparência e instruções de utilização				
Artigo 14.o Supervisão humana				
Artigo 15.o Precisão, robustez, ciberseguran ça e resiliência				
Sistema de gestão da qualidade				
Obrigações e				

Área	Aplicável?	Pronto?	Provas	Gap/ação
responsabilidade do fornecedor				
Informações de cadeia de valor e controles de fornecedores				
Monitoramento pós-comercialização				
Relatórios de incidentes graves				
Ação corretiva, restrição, recall e retirada				
Cooperação e acesso das autoridades				
Requisitos da lei de produto				

2.184 4. prontidão da gestão de risco

- Riscos previsíveis são identificados ao longo do ciclo de vida.
- ☐ Segurança, direitos fundamentais, privacidade, segurança cibernética, cenários operacionais e de uso indevido são avaliados.
- ☐ Os controles de risco são implementados e testados.
- ☐ Critérios de aceitação foram aprovados antes da validação.
- ☐ Riscos residuais, limitações e informações necessárias do usuário são documentados.
- ☐ A evidência de risco corresponde às versões avaliadas e de produção.
- ☐ Os gatilhos de monitoramento e reavaliação são definidos.
- Os bloqueadores legais não podem ser substituídos pela aceitação de riscos internos.

2.185 5. prontidão de governança de dados

- ☐ Fontes de dados, proveniência, direitos, licenças e aquisição estão documentados.
- ☐ Relevância, adequação, qualidade, representatividade e propriedades estatísticas são avaliadas.
- ☐ Os riscos de viés e subgrupos são avaliados e mitigados.
- ☐ Preparação, anotação, transformação e versionamento são reproduzíveis.
- ☐ Privacidade, minimização, retenção, acesso, transferência e controles de segurança operam.
- ☐ As versões do conjunto de dados estão ligadas ao treinamento, validação, teste e produção.
- ☐ O uso de dados de categoria especial tem aprovação legal e de privacidade qualificada, quando aplicável.

2.186 6. prontidão técnica-documentação

- ☐ A aplicabilidade do anexo IV é confirmada.
- A arquitetura do sistema, componentes, interfaces, recursos e dependências são atuais.
- ☐ Modelo, configuração, prompts, ferramentas, agentes, dados e informações de versão estão completos.
- ☐ Propósito pretendido, usos proibidos, limitações e uso indevido previsível são claros.
- ☐ Desenvolvimento, treinamento, afinação, validação, testes e histórico de mudanças estão documentados.
- ☐ Evidência de precisão, robustez, segurança cibernética e resiliência está disponível.
- ☐ As informações sobre o design e o deployer da visão humana estão documentadas.
- ☐ A documentação é internamente consistente e reconciliada com a produção.

2.187 7. Logging e prontidão de rastreabilidade

- ☐ Os eventos obrigatórios são registrados automaticamente quando necessário.
- ☐ A retenção de registros, integridade, acesso, confidencialidade e exportação são controlados.
- ☐ Entradas, saídas, substituições, ações de ferramentas, avisos, erros e incidentes são rastreáveis.
- ☐ As versões de produção e documentação podem ser reconciliadas.
- ☐ As evidências são ligadas à versão e recuperáveis dentro dos prazos necessários.

- ☐ Os registros e evidências controlados pelo fornecedor são contratualmente e operacionalmente acessíveis.

2.188 8. Transparência e prontidão humano-supervisão

- ☐ As instruções de uso são completas e precisas.
- ☐ Propósito pretendido, desempenho, limitações, riscos e requisitos de supervisão são divulgados.
- ☐ Os avisos, rótulos, divulgações, idiomas e acessibilidade necessários são implementados.
- ☐ Os revisores humanos são competentes, treinados, autorizados, apoiados e adequadamente funcionários.
- ☐ Override, stop, fallback, escalada, recurso e mecanismos de reclamação operam.
- ☐ Os controles de automação-viés são implementados e testados.
- ☐ Evidências de entrega e treinamento do deployer estão completas.

2.189 9. Validação e prontidão de teste

- ☐ Os critérios de aceitação são aprovados e baseados no risco.
- ☐ A eficácia do projeto e a eficácia operacional são testadas.
- ☐ O desempenho é testado em condições esperadas, de borda, adversas e de uso indevido.
- ☐ Subgrupos, idiomas, jurisdições e cenários de acessibilidade relevantes são avaliados.
- ☐ Precisão, incerteza, robustez, segurança, resiliência, recuo e recuperação são testados.
- ☐ Supervisão humana, superação, parada e escalada são testadas.
- ☐ Os conjuntos de dados de teste, métodos, ambientes, limitações, defeitos e provas de reteste são documentados.
- ☐ Os defeitos não resolvidos são regidos como bloqueadores de liberação ou condições aprovadas.

2.190 10. prontidão da qualidade-gestão

Confirme que os endereços do SGQ:

- Estratégia de conformidade e responsabilidade;
- controle de projeto e desenvolvimento;
- validação e aceitação;
- governança de dados;
- documentação técnica e registros;
- governança de fornecedores e componentes;
- Liberação, configuração e controle de mudanças;
- monitorização pós-comercialização;
- incidentes, reclamações e ações corretivas;

- autoridade, organismo notificado e cooperação com o cliente;
- competência, treinamento e garantia interna;
- retenção de documentos e controle de versão.

2.191 11. Prontidão pós-mercado e incidente

- ☐ Indicadores de monitoramento, limiares, frequência e proprietários são definidos.
- Reclamações, apelos, incidentes, deriva, substituições e mudanças de fornecedor são revisados.
- ☐ As rotas de avaliação e notificação de incidentes graves estão documentadas.
- ☐ Processos de ação corretiva, restrição, reversão, recall, retirada e restauração são testados.
- ☐ Os compromissos regulatórios e as comunicações de autoridade são rastreados.
- ☐ Evidências de monitoramento e incidentes estão ligadas à versão de produção.

2.192 12. Rota de conformidade e saídas formais

Confirmar, conforme aplicável:

- ☐ rota de controle interno ou organismo notificado selecionada corretamente;
- ☐ Procedimento de conformidade do setor do produto identificado;
- ☐ engajamento do corpo notificado e escopo completo;
- ☐ Normas harmonizadas ou especificações comuns identificadas, incluindo limitações;
- ☐ Documentação completa do anexo IV;
- ☐ documentação técnica e de qualidade disponível para revisão;
- ☐ Declaração UE de conformidade preparada e aprovada;
- ☐ Requisitos de marcação CE cumpridos;
- ☐ Registo completo da base de dados da UE;
- ☐ deveres de representante autorizado, importador, distribuidor e fabricante do produto completos;
- ☐ conformidade, declaração, registro, marcação e evidência de versão preservada.

2.193 13. Reconciliação da produção-versão

Componente	Versão de produção	Versão Avaliada/Documentada	Combinado?	Resolução
Modelo				
Sistema/				

Componente	Versão de produção	Versão Avaliada/Documentada	Combinado?	Resolução
código				
Dados/retrieval				
Avisos/ferramentas/agentes				
Configuração/limiaries				
Interface/notificações				
Logging/monitorização				

2.194 14. Status de prontidão final

Área	Pronto	Parcialmente pronto	Não pronto	Referência de evidência
Governança e QMS				
Gestão de riscos				
Governança de dados				
Documentação técnica				
Registo e rastreabilidade				
Transparência e instruções				
Supervisão humana				
Validação e teste				
Monitoramento pós-comercializa				

Área	Pronto	Parcialmente pronto	Não pronto	Referência de evidência
ção				
Incidente e ação corretiva				
Saídas formais de conformidade e				

2.195 15. Decisão de prontidão

- ☐ Pronto para entrar no procedimento de conformidade aplicável
- ☐ Pronto sujeito às condições listadas
- ☐ Não pronto - remediação necessária
- ☐ Lançamento ou colocação no mercado bloqueada
- ☐ Rota ou classificação incerta revisão legal ou de conformidade qualificada exigida

Motivo da decisão: Estado de conformidade formal: Estado do organismo notificado: Condições e Bloqueadores de Liberação:**

A aprovação de prontidão não deve ser descrita como conformidade completa, autorização, certificação ou permissão para colocar o sistema no mercado ou colocá-lo em serviço.

2.196 16. Ações abertas

Acção	Proprietário	Data de vencimento	Impacto jurídico	Prioridade	Validação	Evidência de encerramento

2.197 17. Acionadores de revisão

Reavaliar após:

- Classificação, papel, propósito pretendido, produto ou mudança de rota de conformidade;
- modelo, sistema, dados, prompt, ferramenta, agente, interface ou mudança de infraestrutura;
- uso de plano de mudança predeterminado ou modificação substancial;
- alteração do fornecedor, importador, distribuidor, representante ou fabricante do produto;

- Falha no teste, incidente, reclamação, auditoria, órgão notificado ou descoberta de autoridade;
- nova norma harmonizada, especificação comum, alteração legal ou data de aplicação;
- suspensão, reversão, recall, retirada ou restauração.

2.198 Exemplo de GlobalWay Travel Services

GlobalWay prepara um sistema de alocação de funcionários para revisão de conformidade. A avaliação de prontidão confirma o risco concluído, dados, supervisão, validação, QMS e trabalho pós-mercado, mas descobre que o modelo do fornecedor de produção difere da versão documentada e que a evidência de registro está incompleta. GlobalWay bloqueia a liberação, atualiza a documentação técnica, repete a validação, resolve o problema de registro e só então aprova a entrada no processo de conformidade formal aplicável.

2.199 Homologação

Papel	Nome	Decisão	Data
Fornecedor/ proprietário da empresa			
Proprietário técnico			
Qualidade/ Conformidade			
Proprietário legal/conformi dade			
Product- safety/sector proprietário, quando aplicável			

Referências de evidências: ** Limitações residuais: **Próximo comentário trigger/date: Versão de avaliação:**

2.200 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com as alterações que lhe foram introduzidas: artigos 8.o-17.o, artigo 43.o, artigos 47.o-49.o, deveres de fornecedor e de cadeia de valor, monitorização pós-comercialização, incidente, ação corretiva, autoridade e anexos IV, VI, VII e VIII aplicáveis.
- Regulamento (UE) 2026/1744, se aplicável.

- Legislação aplicável do produto anexo I, normas harmonizadas, especificações comuns e requisitos do organismo notificado.
- Textos oficiais consolidados atuais e o controle formal do procedimento de conformidade aplicável sobre esta lista de verificação.

2.201 Apêndice M Plano de monitorização pós-mercado

Estado legal: Mestre inglês corrigido. Para provedores de sistemas de IA de alto risco, este plano suporta o Artigo 72. Para implantadores e outros atores, o monitoramento pode ser exigido por outras disposições da Lei de IA, outras leis, contratos ou políticas organizacionais e deve ser identificado separadamente.

2.202 Finalidade

Use este plano para definir como um sistema de IA será monitorado após a colocação no mercado ou implantação para desempenho, segurança, impactos de direitos fundamentais, segurança cibernética, reclamações, incidentes, uso indevido, mudanças de fornecedores, falhas de controle e conformidade contínua.

O plano deve ser ativo, sistemático, proporcionado, vinculado à versão, integrado com gerenciamento de risco e qualidade e capaz de desencadear investigação, restrição, suspensão, notificação, ação corretiva, retirada ou recall em tempo hábil.

2.203 1. registro de aplicabilidade

Campo	Resposta
Pessoa jurídica e papel de ator	
ID do sistema/modelo e inventário	
Versão/configuração da produção	
Propósito pretendido	
Classificação de alto risco/base legal	
Aplica-se o artigo 72?	
Outros deveres de monitorização	
Competências	
Fornecedor/fornecedor e dependências	

Campo	Resposta
Fonte legal atual/data da aplicação	
Proprietário de monitoramento	
Versão/data do plano	

2.204 2. Objectivos de acompanhamento

Definir objetivos para:

- precisão, confiabilidade e desempenho;
- subgrupo, linguagem, acessibilidade e resultados justos;
- Risco para a segurança, saúde e direitos fundamentais;
- Eficácia da visão humana, sobreposições e escalada;
- Segurança cibernética, uso indevido, abuso, injeção imediata e ações de ferramentas/agentes;
- transparência, instruções, divulgação, reclamações e apelos;
- mudanças de deriva, dados, modelo, fornecedor e infraestrutura;
- resiliência, fallback, continuidade e recuperação;
- Compromissos legais, de conformidade, de registo e regulamentares;
- eficácia de ação corretiva e repetição de falhas.

2.205 3. Indicadores e limiares

Indicador	linha de base	Limite de aviso	Lim limiar crítico	Fonte de dados	Frequência	Proprietário	Acção necessária
-----------	---------------	-----------------	--------------------	----------------	------------	--------------	------------------

Os indicadores devem ser baseados no risco e incluir, sempre que relevante:

- precisão, erro, abstenção e confiabilidade;
- Taxas falso-positivas e falso-negativas;
- disparidades entre subgrupos e interseccionais;
- defeitos de linguagem e acessibilidade;
- sobrescrever, desacordo, apelo e taxas de reclamação;
- incidentes, quase erros e resultados adversos;
- alertas de segurança, tentativas de uso indevido e ações de ferramentas anômalas;
- condições de deriva e fora de distribuição;
- mudanças no fornecedor/modelo/versão;
- logs, provas ou documentação em falta;

- falhas de recuperação, queda, e;
- resultados atrasados e ações corretivas repetidas.

2.206 4. Coleta de dados e evidências

Coleta de documentos e governança para:

- logs de produção e telemetria;
- Entradas e saídas amostradas;
- prompts, fontes de recuperação, chamadas de ferramentas e ações do agente;
- humano-revisão, substituição, parada e escalada de registros;
- reclamações, recursos, correções e remédios;
- incidentes, quase erros e notificações;
- Alertas de segurança e inteligência de ameaças;
- avisos de fornecedores, lançamentos, interrupções e alterações na documentação;
- testes de deriva, desempenho, viés, linguagem, acessibilidade e robustez;
- Auditoria interna, conformidade, organismo notificado e resultados de autoridades;
- mudança, reversão, suspensão, retirada, recall e registros de restauração.

Aplicar privacidade, minimização, confidencialidade, acesso, integridade, retenção, retenção legal e controles transfronteiriços.

2.207 5. cadência da revisão

Revisão	Frequência	Participantes	Entradas	Saída
Monitorização operacional				
Validação técnica				
Revisão de risco e conformidade				
Revisão dos direitos fundamentais				

Revisão	Frequência	Participantes	Entradas	Saída
Revisão de privacidade				
Revisão de segurança				
Revisão do fornecedor				
Relatório executivo/board				
Garantia independente				

2.208 6. Matriz de gatilho e resposta

Trigger	Ação necessária	ator/proprietário	Prazo/fonte legal	Escalada	Provas
Incidente grave ou alegação de dano credível					
Degradação significativa do desempenho					
Disparidade de subgrupo, idioma ou acessibilidade					
Reclamação material ou tendência de apelo					
Compromisso de					

Trigger	Acção necessária	ator/ proprietário	Prazo/ fonte legal	Escalada	Provas
segurança ou uso indevido					
Modelo, serviço, dados ou mudança de contrato do fornecedor					
Finalidade prevista, população ou mudança de jurisdição					
Registros ou evidências ausentes					
Desenvolvi mento legal ou regulamen tar					
Auditoria de materiais, conformid ade ou descobert a de controle modificaçã o substancia l potencial					

As ações possíveis incluem investigação, preservação de evidências, supervisão aprimorada, mudança de configuração, restrição de escopo, comunicação do usuário, reciclagem, escalada do fornecedor, suspensão, reversão, retirada, recall, reavaliação de conformidade, atualização de documentação e notificação quando legalmente exigido.

2.209 7. Integração de incidentes e ações corretivas

Para sinais materiais:

1. preservar evidências relevantes e identificar versões afetadas;
2. conter risco imediato;
3. Avaliar os deveres de notificação de incidentes graves e de notificação paralela;
4. identificar pessoas, jurisdições, fornecedores e sistemas afetados;
5. realizar análise de causa-raiz e do escopo afetado;
6. definir ações corretivas e preventivas;
7. atualização de risco, técnica, SGQ, instruções, avisos e registros de monitoramento;
8. validar a remediação antes da restauração ou do encerramento;
9. Compartilhe lições em sistemas semelhantes.

2.210 8. Monitoramento do fornecedor e da dependência

Monitor:

- Liberações de modelos, depreciações, capacidades alteradas e limitações conhecidas;
- fonte de dados, subprocessador, hospedagem e alterações de localização;
- níveis de serviço, interrupções, eventos de segurança e avisos de incidentes;
- licenciamento, código aberto, direitos autorais e alterações contratuais;
- auditoria, documentação, registro de registros e limitações de acesso a evidências;
- concentração, continuidade, portabilidade e risco de saída.

2.211 9. Relatório e escalada

Condição	Destinatário	Prazo	Conteúdo necessário/evidência	Autoridade de decisão
----------	--------------	-------	-------------------------------	-----------------------

Os relatórios devem distinguir fatos, suposições, incerteza, deveres legais, controles atuais, risco residual e decisões necessárias.

2.212 10. Retenção da evidência

Manter dados de monitoramento, análises, decisões, aprovações, reclamações, registros de incidentes, notificações, correspondência de autoridade, avisos de fornecedores, resultados de testes e evidências de ação corretiva de acordo com o cronograma estatutário, contratual, operacional, de privacidade e legal aplicável.

2.213 11. Decisão

- ☐ Artigo 72.o Plano de Prestador aprovado
- ☐ Plano de monitoramento de outros atores aprovado
- ☐ Aprovado com condições
- ☐ Apenas monitoramento restrito do piloto
- ☐ Remediação necessária
- ☐ Implantação bloqueada ou suspensa

Motivo da decisão: Condições e limiares: Base de retenção: Acções abertas:**

2.214 12. gatilhos de revisão

Revisão após:

- modelo, sistema, dados, prompt, ferramenta, agente, fornecedor ou mudança de infraestrutura;
- novo propósito, população, jurisdição ou contexto da pessoa afetada;
- Incidente, reclamação, recurso, deriva ou falha no controle;
- Violação do limiar de monitorização;
- modificação substancial ou alteração da conformidade;
- desenvolvimento legal, autoridade, padrão ou código;
- suspensão, reversão, retirada, recall ou restauração.

2.215 Exemplo de GlobalWay Travel Services

A GlobalWay monitora um assistente de interrupção do viajante para remarcações incorretas, conselhos sensíveis à segurança, disparidades de subgrupos e idiomas, ações de ferramentas não autorizadas, taxas de substituição, reclamações, alterações de fornecedores e interrupções. Uma atualização do fornecedor aumenta as recomendações incorretas em casos de clima severo. Limites críticos desencadeiam restrição de recursos, preservação de evidências, remarcação apenas humana, escalada de fornecedores, testes de regressão e revisão legal antes da restauração.

2.216 Homologação

Papel	Nome	Decisão	Data
Fornecedor/ proprietário técnico			
Proprietário de monitorament o			
Qualidade/ Conformidade			
Legal			
Risco/ Privacidade/ Segurança, conforme aplicável			

Referências de evidências: Base de retenção: Próximo comentário
trigger/date: **Versão do plano:****

2.217 Referências jurídicas primárias

- Regulamento (UE) n.º 2024/1689, com as alterações que lhe foram introduzidas: Artigo 72.º e disposições aplicáveis relativas ao prestador, ao deployer, à gestão de riscos, à gestão da qualidade, à exploração madeireira, à monitorização, ao incidente, à acção correctiva, à autoridade e ao elevado risco.
- Regulamento (UE) 2026/1744, se aplicável.
- Privacidade aplicável, segurança cibernética, segurança de produtos, emprego, proteção ao consumidor e direito do setor.
- Textos oficiais consolidados atuais controlam esse plano.

2.218 Apêndice N Relatório de incidentes graves

Estado legal: Mestre inglês corrigido. Os deveres de relatório são actor-, evento-, provisão-, autoridade-, e data-específico. Não há nenhum prazo de incidente AI universal. Avalie AI Act, privacidade, segurança cibernética, segurança do produto, emprego, consumidor, e obrigações do setor separadamente.

2.219 Finalidade

Use este formulário para documentar, avaliar, escalar, investigar, relatar, remediar e fechar um incidente grave ou evento de IA potencialmente reportável.

O formulário deve distinguir a gravidade interna do teste de incidente grave legal, preservar evidências prontamente, identificar o ator responsável e a autoridade, controlar os prazos de relatório e evitar o reinício antes que as ações corretivas sejam validadas.

2.220 1. Incidente e contexto jurídico

Campo	Resposta
Identificação do Incidente	
ID do sistema/modelo e inventário	
Versão/configuração	
Pessoa jurídica e papel de ator	
Propósito pretendido/classificação	
Data/hora ocorrida	
Data/hora detetada	
Data/hora confirmada ou escalada	
Repórter	
Negócio/fornecedor/proprietário do deployer	
Incidente chumbo	
Competências	
Pessoas, sistemas e serviços afetados	
Fornecedor/fornecedor e dependências	
Fonte legal atual/data da aplicação	

2.221 2. Descrição inicial do evento

Descreva:

- fatos verificados e incertezas conhecidas;
- Como o evento foi detectado;
- sistemas, modelos, versões, pessoas, grupos, ativos e processos afetados;
- consequências reais e potenciais;
- escala, duração, reversibilidade e exposição contínua;
- situação operacional atual;

- fornecedor, subprocessador, ferramenta, dados ou envolvimento em infraestrutura;
- Reclamações, apelos, alertas de segurança ou avisos anteriores relacionados.

2.222 3. contenção imediata

Acção	Proprietário	Tempo concluído	Estado	Provas
Restringir, suspender, isolar, reverter ou parar o sistema				
Proteger e apoiar as pessoas afetadas				
Ativar o processo de fallback/manual				
Preservar logs, versões, prompts, dados, saídas, decisões e comunicações				
Emitir retenção legal quando necessário				
Notificar internos Jurídico, Conformidade, Segurança, Privacidade, Risco e executivos				
Provedor de				

Acção	Proprietário	Tempo concluído	Estado	Provas
contato / fornecedor e exigem preservação Prevenir a recorrência em sistemas semelhantes				

2.223 4. teste legal sério-incidente

Use a definição estatutária atual e as regras de relatório. Não deduza a reportabilidade apenas de uma classificação de gravidade interna.

Elemento estatutário ou outro gatilho	Conheci?	Evidência e racionalidade	Revisor
Morte ou sérios danos à saúde Disrupção grave e irreversível da infra-estrutura crítica Violação das obrigações do direito da União destinadas a proteger os direitos fundamentais Danos sérios à propriedade ou ao meio ambiente Outro gatilho aplicável do AI Act Violação de privacidade/prot eção de dados Incidente de cibersegurança			

Elemento estatutário ou outro gatilho	Conheci?	Evidência e racionalidade	Revisor
A segurança do produto ou o gatilho do setor			
Emprego, igualdade, consumidor, contratual ou gatilho de seguro			

Conclusão legal: Actor responsável: Evento de início de bloqueio:
Revisor qualificado: **

2.224 5. matriz de notificação

Regime / provisã o	Actor respon sável	Destina tário	Evento de início do relógio	Prazo	Relatór io inicial	Relatór io de acompa nhame nto/rela tório final	Estado/ evidênc ia

Gravar:

- autoridade e canal de contato;
- Relatórios preliminares ou faseados permitidos;
- Tratamento de informações incompletas;
- fatos, incerteza, contenção e atualizações planejadas;
- autoridade de aprovação;
- reconhecimento da entrega;
- justificativa para não-notificação;
- consistência entre notificações paralelas.

2.225 6. Evidência preservada

Preservar conforme aplicável:

- modelo, sistema, código, prompt, ferramenta, agente e versões de configuração;
- entradas, saídas, resultados de recuperação, ações de ferramentas, avisos e registros;

- humano-revisão, substituição, parada e escalada de registros;
- dados relevantes, linhagens, transformações e versões de conjunto de dados;
- liberação, implantação, reversão e alteração de registros;
- monitoramento, segurança e telemetria do sistema;
- comunicações, avisos, contratos e provas do fornecedor;
- reclamações, informações de testemunhas, comunicações entre pessoas afetadas e registros de suporte;
- Análises jurídicas, comunicações de autoridade e decisões de relatórios.

item de evidência	Fonte/custódia	tempo da coleção	Integridad e/checksum	Armazenamento	Restrições de acesso
-------------------	----------------	------------------	-----------------------	---------------	----------------------

2.226 7. Investigação e escopo afetado

Documento:

- Cronologia de eventos;
- técnico, modelo, dados, processo, governança, fornecedor e causas humanas;
- versões, jurisdições, populações, clientes e serviços afetados;
- se sistemas semelhantes compartilham a fraqueza;
- controles falhados ou ausentes;
- sinais anteriores, reclamações, conclusões ou exceções;
- Implicações de propósito pretendido, papel, classificação, conformidade ou modificação substancial;
- causa raiz, fatores contribuintes e incerteza;
- impacto legal, de segurança, direitos, privacidade, segurança cibernética, financeiro e de reputação.

2.227 8. Ação corretiva e preventiva

Acção	Tipo	Proprietário	Data de vencimento	Consequência jurídica	Estado	Evidência de validação
	Correção / corretivo / preventivo / sistêmico					

Acção	Tipo	Proprietário	Data de vencimento	Consequência jurídica	Estado	Evidência de validação
	o					

As atualizações necessárias podem incluir arquivos de risco, documentação técnica, SGQ, controles de dados, supervisão humana, instruções, avisos, contratos, monitoramento, treinamento, evidências de conformidade e revisões de sistemas semelhantes.

2.228 9. Reiniciar, restrição ou decisão de retirada

- ☐ Continuar a operação
- ☐ Operação restrita com condições
- ☐ Reinício monitorado limitado
- ☐ Permanecer suspenso
- ☐ Retirar ou recordar
- ☐ Descomission
- ☐ Revisão legal, de conformidade ou de autoridade qualificada exigida

2.228.1 Fundamentação da decisão

Documento:

- contenção e remediação validadas;
- Risco e incerteza não resolvidos;
- salvaguardas da pessoa afetada;
- Autoridade requerida ou aprovação do cliente;
- limiares de monitorização;
- Critérios de reversão ou paragem;
- aprovação responsável e expiração das condições.

2.229 10. Critérios de encerramento

Confirmar:

- Todos os relatórios iniciais, de acompanhamento e finais necessários estão completos;
- As questões e compromissos de autoridade são resolvidos ou rastreados;
- As pessoas afetadas receberam o apoio necessário, comunicação, correção ou remédio;
- as provas são retidas e as obrigações legais são satisfeitas;
- a causa raiz e o escopo afetado são aprovados;
- As ações corretivas e preventivas são validadas;

- Sistemas similares foram avaliados;
- políticas, controles, documentação, contratos, treinamento e monitoramento foram atualizados;
- O reinício ou a retirada permanente foi formalmente aprovado;
- As lições aprendidas foram comunicadas à administração e ao conselho onde o material.

2.230 Exemplo de GlobalWay Travel Services

A GlobalWay descobre que uma atualização de fornecedor fez com que seu modelo de fraude bloqueasse um grupo geográfico de viajantes desproporcionalmente. A empresa restringe o recurso, ativa a revisão manual, preserva o modelo afetado, dados, saídas, substituições e comunicações de fornecedores e avalia as tarefas de AI Act, GDPR, consumidor e relatórios contratuais separadamente. O reinício é aprovado apenas após análise de causa raiz, reteste de subgrupo, monitoramento atualizado, controles de fornecedores e remediação validada.

2.231 Homologação

Papel	Nome	Decisão	Data
Incidente chumbo /deployer/ proprietário do negócio Legal/ Conformidade Técnico/ Seguridade Privacidade/ risco/produto, conforme aplicável Executivo ou Conselho de Administração , quando necessário			

Referências de evidências: Retenção/base legal: Estado da notificação: Ações e compromissos abertos: Próxima ação/revisão: Versão do relatório:**

2.232 Referências jurídicas primárias

- Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689, com a redação que lhe foi dada pelo Regulamento (UE) n.o 2024/1689: disposições aplicáveis em matéria de incidentes graves, de monitorização pós-comercialização, de fornecedores, de implementadores, de acções correctivas, de cooperação entre autoridades e de alto risco.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação aplicável em matéria de cibersegurança, segurança dos produtos, emprego, igualdade, defesa do consumidor, ambiente, seguros, contratos e setor.
- Textos oficiais consolidados atuais e instruções de autoridade competente controlam este relatório.

2.233 Apêndice O Questionário do Fornecedor de IA

**** Status legal: **** Mestre inglês corrigido. As respostas do fornecedor são asserções até que sejam apoiadas por evidências atuais, compatíveis com o escopo e com a versão. Os rótulos dos contratos não determinam os papéis legais do ator.

2.234 Finalidade

Use este questionário para avaliar a governança de um fornecedor de IA, papel legal, evidência de sistema e modelo, práticas de dados, segurança, segurança, resiliência, transparência, monitoramento, resposta a incidentes, cadeia de suprimentos, compromissos contratuais e capacidade de apoiar a conformidade ao longo do relacionamento.

2.235 1. Identidade do fornecedor e do serviço

Campo	Resposta
Nome legal do fornecedor e jurisdição	
Entidade contratante	
Produto/serviço	
Sistema/modelo/versão	
Finalidade prevista e utilizações suportadas	
Locais de hospedagem e suporte	
Prestadores de modelos	
Subprocessadores e dependências críticas	
Contatos legais/conformidade	

Campo	Resposta
Segurança/contato acidental	
Contacto técnico/produto	
Repositório de Evidência/Sala de Dados	

2.236 2. Papel, classificação e escopo legal

Solicitar provas para:

- Prestador de serviços, prestador de serviços GPAI, fornecedor a jusante, despachante, importador, distribuidor, representante autorizado, fabricante de produtos e outras funções;
- propósito pretendido, uso real suportado, uso proibido e uso indevido previsível;
- Artigo 5.o Triagem;
- Artigo 6.o/Classificação do Anexo I ou Anexo III;
- Artigo 50.o e outros direitos de transparência;
- GPAI e tratamento de risco sistêmico;
- Datas de aplicação e regras transitórias;
- A rota de conformidade, o estado do organismo notificado, a declaração, o registo, a marcação CE e o estado da autoridade, quando aplicável;
- jurisdições apoiadas e restrições setoriais.

Reclamação	Resposta do fornecedor	Provas	Jogo de versão/escopo	Conclusão interna
papel de ator				
Classificação estatutária				
Status de conformidade e/registo				
Datas aplicáveis				

2.237 3. Propósito pretendido e restrições de uso

Peça ao fornecedor para fornecer:

- declaração formal para fins pretendidos;
- casos de uso e populações apoiados;
- Usos proibidos, não suportados ou de alto risco;
- Limitações conhecidas e modos de falha;

- restrições de configuração e acesso;
- Controlos que impeçam a reorientação ou a evasão;
- instruções para integração segura, implantação, supervisão e recuo;
- limitações geográficas, linguísticas, de acessibilidade e sectoriais.

2.238 4. Informações do sistema e do modelo

Pedido:

- arquitetura e dependências materiais;
- modelo, fornecedor, versão, configuração e histórico de lançamento;
- prompts, instruções do sistema, ferramentas, agentes, recuperação e ações externas;
- métodos de avaliação, métricas, conjuntos de dados, limitações e defeitos conhecidos;
- Resultados de precisão, incerteza, abstenção, subgrupo, idioma e acessibilidade;
- robustez, mau uso, equipe vermelha e evidências de testes contraditórios;
- processo de liberação, depreciação, reversão e notificação de mudança;
- capacidade de preservar, identificar, reproduzir e apoiar versões anteriores;
- documentação técnica e cartões de modelo/sistema apropriados ao papel.

2.239 5. Governança de dados e propriedade intelectual

Solicitar provas para:

- fontes e proveniência de dados de treinamento, ajuste, validação, avaliação, recuperação e monitoramento;
- Aquisição legal, licenças, permissões e controlos de propriedade intelectual;
- restrições de raspagem e fontes de dados;
- Qualidade, relevância, representatividade e métodos de viés;
- testes de subgrupos e interseccionais;
- uso de dados de clientes para treinamento, melhoria ou feedback;
- Dados pessoais, de categoria especial, biométricos, infantis, confidenciais e regulamentados;
- retenção, exclusão, localização, transferência e controlos de acesso;
- Utilização e rotulagem de dados sintéticos;
- Política de conformidade com direitos autorais e resumo de conteúdo de treinamento, quando aplicável;

- conjunto de dados e linhagem de modelos, versionamento e reprodutibilidade.

2.240 6. Segurança, segurança e resiliência

Pedido:

- Ciclo de vida de desenvolvimento seguro e governança;
- modelos de ameaça e casos de uso indevido;
- testes adversos, penetração, injeção imediata, abuso de ferramentas e cadeia de suprimentos;
- Identificação de vulnerabilidade, remediação, divulgação e cronogramas;
- controle de acesso, criptografia, segredos e isolamento do inquilino;
- registro, telemetria, detecção de anomalias e exportação de evidências;
- História de incidentes e lições aprendidas;
- disponibilidade, backup, recuperação, fallback, continuidade e recuperação de desastres;
- suporte de concentração, portabilidade, substituição e saída;
- Segurança independente, segurança e garantia de resiliência.

2.241 7. Supervisão humana, transparência e apoio à pessoa afetada

Solicitar provas para:

- instruções de uso e limitações conhecidas;
- informações necessárias para a interpretação e supervisão humana;
- sobrescrever, parar, reverter e aumentar as capacidades;
- salvaguardas de automação-viés;
- Avisos de transparência, divulgações e marcação de conteúdo sintético;
- Acessibilidade e suporte linguístico;
- suporte a reclamações, recursos, correções e remédios;
- considerações de uso de trabalhador, candidato, cliente ou serviço público;
- materiais de treinamento e competência.

2.242 8. Monitoramento, mudanças e incidentes

Definir e solicitar provas para:

- Monitorização pós-implantação e limiares de desempenho/drift;
- subgrupo, idioma, acessibilidade, segurança, reclamação e monitoramento de substituição;

- Identificação, notificação e cooperação de incidentes graves;
- regulador, órgão notificado, auditor e suporte ao cliente;
- modelo, serviço, dados, hospedagem, subprocessador e alterações contratuais;
- Identificação da versão afetada e preservação de evidências;
- ação corretiva, restrição, reversão, retirada, recall e restauração;
- Avisos de deprecation e fim de apoio.

2.243 9. Evidência e direitos de auditoria

Confirmar disponibilidade de:

- documentação técnica;
- Relatórios de validação e avaliação;
- evidência de governança de dados;
- avaliações de risco e segurança;
- resultados dos testes de segurança;
- relatórios de auditoria, certificações ou atestados;
- Registros de incidentes e reclamações;
- Liberação e mudança de história;
- logs e evidências de versão afetada;
- informações voltadas para o regulador;
- auditoria ao cliente, inspeção, testes e suporte de cooperação de autoridade.

Reclamação	Evidência fornecida	Atual?	Jogo de versão/escopo	validada de forma independente?	Limitação/gap
------------	---------------------	--------	-----------------------	---------------------------------	---------------

2.244 10. Cadeia de fornecimento e concentração

Dependência	Fornecedor	Localização	Função	Criticidade	Evidência/limitação de acesso	Opção de saída ou substituição
-------------	------------	-------------	--------	-------------	-------------------------------	--------------------------------

Avalie pontos únicos de falha, subprocessadores ocultos, lacunas de evidências proprietárias, dependências transfronteiriças, restrições de licença, versões não suportadas e tempo de substituição.

2.245 11. Compromissos contratuais

Confirme a vontade de apoiar:

- informações precisas sobre o papel, a classificação e a finalidade pretendida;
- direitos de acesso a provas, auditoria, inspeção e testes;
- modelo, versão, funcionalidade, dados, localização, licença e aviso de alteração do subprocessador;
- Incidente, vulnerabilidade, reclamação e aviso regulamentar;
- restrições de uso de dados, confidencialidade, privacidade, retenção, exclusão e devolução;
- Preservação de provas e retenção legal;
- autoridade, organismo notificado, auditor, cliente e cooperação pessoa afetada;
- Remediação, reteste, créditos de serviço, suspensão e rescisão;
- rollback, portabilidade, continuidade, transição e saída;
- responsabilidade, indenização, seguro e alocação apropriada ao risco;
- Redução do fluxo de requisitos para subprocessadores e provedores a montante;
- sobrevivência de provas, incidentes, eliminação e deveres de cooperação após a rescisão.

2.246 12. Conclusão do risco

- ☐ Aprovado
- ☐ Aprovado com condições
- ☐ Apenas piloto restrito
- ☐ Remediação ou evidência necessária
- ☐ Não aprovado
- ☐ Legal qualificado, segurança, privacidade ou revisão técnica necessária

Motivo da decisão: Afirmções não verificadas: Diferenças de evidências materiais: Condições e restrições: Saída/continuidade:**

2.247 13. Ações abertas

Acção	Proprietário do vendedor	Proprietário interno	Data de vencimento	Risco/ impacto legal	Estado	Evidência de encerramento
-------	--------------------------	----------------------	--------------------	----------------------	--------	---------------------------

2.248 14. Revisar gatilhos

Reavaliar após:

- modelo, sistema, versão, dados, capacidade ou mudança de propósito pretendido;
- novo subprocessador, provedor de modelo, localização, licença ou dependência;
- incidente, vulnerabilidade, reclamação, interrupção ou descoberta de auditoria;
- renovação de contrato, alteração material, aquisição ou deterioração financeira;
- alterações legais, de conformidade, de autoridade ou de classificação;
- expansão para uma nova jurisdição, população, idioma ou setor;
- deprecation, fim do suporte ou planejamento de saída.

2.249 Exemplo de GlobalWay Travel Services

A GlobalWay avalia um fornecedor de GPAI para um sistema de assistência ao viajante. O fornecedor fornece documentação atual do modelo e testes de segurança, mas não pode fornecer evidências de subgrupo específicas de versão, garante apenas 30 dias de aviso prévio para mudanças no modelo e reserva amplos direitos de uso de solicitações de melhoria do cliente. A GlobalWay permite apenas um piloto restrito após a obtenção de restrições de uso de dados, aviso de mudança mais forte, direitos de preservação de evidências, cooperação de incidentes, suporte de reversão e conclusão de testes independentes multilíngue e ação de ferramentas.

2.250 Homologação

Papel	Nome	Decisão	Data
Proprietário/ Procurement			
Legal/ Conformidade			
Segurança/ Privacidade/ Técnica			
proprietário do negócio			
Risco/Dados/ Produto, conforme aplicável			

Referências de evidências: Afirmações não verificadas: Condições e remediação: Próximo comentário trigger/date: Versão de perguntas:**

2.251 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: cadeia de valor aplicável, fornecedor, GPAI, a jusante, importador, distribuidor, representante, fabricante de produtos, alto risco, transparência, monitoramento, incidentes, ações corretivas e disposições de autoridade.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e legislação aplicável em matéria de cibersegurança, segurança dos produtos, emprego, defesa do consumidor, acessibilidade, propriedade intelectual, contrato e setor.
- Textos oficiais consolidados atuais e controle de evidências verificadas sobre afirmações de fornecedores.

2.252 Apêndice P AI Contract-Clause Checklist

Os contratos alocam responsabilidades operacionais, evidências, cooperação, risco e remédios, mas não alteram os papéis legais do ator, removem deveres legais, transferem responsabilidade intransferível ou tornam um uso ilegal legal.

2.253 Finalidade

Use esta lista de verificação ao adquirir, licenciar, integrar, hospedar, distribuir, white-labeling, modificar ou apoiar um sistema de IA ou um serviço habilitado para GPAI.

Os termos do contrato devem refletir a conduta real, a finalidade pretendida, as versões do sistema e do modelo, as dependências do fornecedor, as funções legais aplicáveis, as evidências necessárias, o monitoramento, os incidentes, as mudanças, a cooperação da autoridade, a continuidade e a saída.

2.254 1. Partidos, serviço e papéis

Documento:

Campo	Resposta
Entidades adjudicantes	
Serviço/produto	
Sistema/modelo/versão	
Finalidade prevista e utilizações aprovadas	
Usos proibidos/restritos	
Jurisdições, setores, usuários e pessoas afetadas	

Campo	Resposta
Arranjos de branding/white label	
Modificação, ajuste fino, ferramenta, agente e direitos de configuração	
Agir papéis com base na conduta real	
Funções de proteção de dados	
Papéis de segurança/sector do produto	
Dependências críticas/subprocessadores	
Acionadores de mudança de função e reavaliação	

2.255 **mbito e uso permitido**

- ☐ O propósito pretendido é preciso e ligado à versão.
- ☐ Utilizações aprovadas, não suportadas, restritas e proibidas são listadas.
- ☐ Usuários, populações, jurisdições, setores, tipos de dados e contextos de decisão são definidos.
- ☐ Grau de automação e autoridade de ação externa são controlados.
- ☐ Configuração do cliente, ajuste fino, pronta, recuperação, ferramenta e direitos do agente são definidos.
- ☐ As implicações de marca branca, marca, revenda e nome próprio são abordadas.
- ☐ O reaproveitamento e a evasão são proibidos e tecnicamente controlados sempre que possível.
- ☐ Instruções do fornecedor, limitações e deveres operacionais do cliente são incorporados.

2.256 **3. Papéis do ator e cronograma de responsabilidade**

- ☐ O papel do Ato de Inteligência Artificial da UE de cada parte é documentado com base em fatos.
- ☐ As responsabilidades do provedor GPAI e do provedor a jusante são abordadas.
- ☐ Os gatilhos de transferência de papel-fornecedor são identificados.
- ☐ Os direitos de importador, distribuidor, representante autorizado e fabricante do produto são abordados quando relevante.

- ☐ Responsabilidade para o propósito pretendido, modificação substancial, conformidade, registro, declaração, marcação, monitoramento, incidentes e ação corretiva é alocada.
- Os papéis de proteção de dados, emprego, consumidor, segurança cibernética, produto, propriedade intelectual e setor são definidos separadamente.
- ☐ O contrato requer aviso prévio de fatos que poderiam mudar um papel estatutário.

2.257 4. Documentação e evidência

- ☐ A documentação técnica atual é fornecida e mantida.
- ☐ Cartões de modelo/sistema, instruções, limitações e registros de propósito pretendido são fornecidos.
- ☐ Validação, desempenho, viés, linguagem, acessibilidade, robustez, uso indevido e evidências de segurança estão disponíveis.
- ☐ Procedência de dados, aquisição legal, qualidade, representatividade e evidência de linhagem estão disponíveis.
- ☐ Registro, rastreabilidade, identificação de versão, exportação e suporte de retenção são definidos.
- ☐ A conformidade, o organismo notificado, a declaração, o registro, a marcação e as provas de certificação são fornecidas quando aplicável.
- ☐ As evidências são compatíveis com a versão e o escopo.
- ☐ As provas podem ser fornecidas a clientes, auditores, organismos notificados e autoridades dentro dos prazos exigidos.
- ☐ Os termos de segredo comercial e confidencialidade permitem a conformidade legal e o acesso à autoridade.

2.258 5. Dados, privacidade e propriedade intelectual

- ☐ Propriedade de dados, controle, acesso, uso permitido e restrições são definidas.
- Os dados do cliente não são usados para treinamento, ajuste fino, avaliação ou melhoria do serviço sem autorização explícita.
- [Prompt, saída, recuperação, feedback, telemetria e uso de dados derivados é abordado.
- As proteções de dados pessoais, de categoria especial, biométricas, infantis, confidenciais e regulamentadas estão incluídas.
- Base legal, direitos de sujeito de dados, avisos, minimização e limitação de propósito são suportados.
- ☐ Retenção, exclusão, retorno, portabilidade, arquivamento e retenção legal são abordados.
- ☐ Localização de dados, localização, transferência, acesso do governo e controles de subprocessadores são especificados.
- ☐ Licenças e direitos de propriedade intelectual são suficientes para o uso pretendido.

- ☐ Direitos autorais, dados de treinamento, código aberto, modelo de saída, violação e riscos de proveniência são alocados.
- ☐ Exclusão pós-terminação e deveres de sobrevivência de evidências são exequíveis.

2.259 6. Segurança, segurança e resiliência

- ☐ Os requisitos de desenvolvimento seguro, arquitetura e configuração são definidos.
- ☐ Modelos de ameaças, testes contraditórios, injeção imediata, abuso de ferramentas, vulnerabilidade e obrigações de patches estão incluídos.
- ☐ Controle de acesso, criptografia, segregação, segredos e proteções de inquilinos são abordados.
- Incidentes de segurança e segurança definiram gatilhos de notificação, relógios, prazos e conteúdo.
- ☐ Registros, suporte forense, preservação de evidências e identificação da versão afetada são necessários.
- ☐ Disponibilidade, backup, recuperação, fallback, continuidade dos negócios e recuperação de desastres são abordados.
- ☐ Restrições de serviço, desativação de emergência, reversão e validação de restauração são suportadas.
- ☐ Saída, transição, substituição, portabilidade e suporte de continuidade estão incluídos.

2.260 7. Modelo, serviço e mudanças na cadeia de valor

- ☐ É necessário aviso prévio para alterações materiais.
- Modelo, versão, provedor, dados, recurso, capacidade, prompt, ferramenta, agente, subprocessador, hospedagem, localização, licença, política e mudanças de propósito pretendido são cobertos.
- ☐ Os períodos de aviso são proporcionais ao risco e permitem a avaliação antes da implementação.
- ☐ Os direitos de aprovação, atraso, reversão, restrição ou rescisão do cliente são definidos.
- ☐ Versões anteriores, documentação, registros e evidências podem ser preservadas quando necessário.
- ☐ Planos de mudança predeterminados e implicações substanciais de modificação são abordados.
- ☐ A depreciação, o fim do suporte, a migração e o suporte de substituição são especificados.
- ☐ Mudanças a montante são fluidas para baixo rapidamente.

2.261 8. Desempenho, monitoramento e supervisão humana

- ☐ Funções de monitoramento de desempenho, deriva, subgrupo, idioma, acessibilidade e confiabilidade são atribuídas.
- ☐ Métricas, limiares, acesso a dados e frequência de relatórios são definidos.
- ☐ Instruções do usuário, limitações, incerteza e intervalos de desempenho são fornecidos.
- ☐ A revisão humana, a substituição, a parada, a escalada, o fallback e a funcionalidade de apelo são suportados.
- ☐ Automatização-viés e salvaguardas de pessoas afetadas são abordadas.
- ☐ Avisos de transparência, marcação de conteúdo sintético, localização e suporte de acessibilidade são definidos.
- Reclamações de clientes, recursos, correções e remédios recebem suporte do fornecedor.

2.262 9. Incidentes, reclamações e ações corretivas

- ☐ É necessária uma cooperação entre incidentes graves, segurança, privacidade, segurança e eventos de serviço.
- ☐ Cláusulas de notificação identificam o evento que inicia o relógio, prazo, destinatário, conteúdo inicial e atualizações.
- ☐ Preservação de evidências e obrigações legais estão incluídas.
- ☐ É necessário suporte à investigação de causa-raiz, escopo afetado e sistema similar.
- ☐ Ação corretiva, retestes, atualizações de documentação e validação de fechamento são definidos.
- ☐ Suspensão, restrição, reversão, retirada, recall e apoio ao desmantelamento estão incluídos.
- ☐ As comunicações de autoridade e pessoa afetada são coordenadas.
- ☐ Obrigações de incidentes sobrevivem à rescisão quando necessário.

2.263 10. Auditoria, testes e cooperação regulatória

- ☐ Auditoria, inspeção, acesso a evidências e direitos de teste são proporcionais e exequíveis.
- ☐ Relatórios e atestados independentes são fornecidos com informações de escopo e versão.
- ☐ O teste ao cliente não anula o suporte ou a proteção contratual quando realizado com segurança.
- ☐ Consultas regulatórias, inspeções, solicitações de informações, revisões de órgãos notificados e questões de aplicação são apoiadas.
- ☐ Os registros necessários podem ser produzidos dentro de prazos legalmente exigidos.

- ☐ A conformidade do subprocessador e do provedor a montante é fluida para baixo.
- ☐ Prazos de remediação e escalada para lacunas de evidências são definidos.
- ☐ Os termos de confidencialidade não obstruem a divulgação legal.

2.264 11. Responsabilidade, seguro e remédios

- ☐ As garantias se alinham com a capacidade documentada, propósito pretendido, desempenho e limitações.
- ☐ Garantias abordam a autoridade, licenças, direitos de dados, segurança, documentação e representações de conformidade.
- ☐ Indenizações abordam dados, privacidade, propriedade intelectual, segurança, regulatório, produto e reivindicações de terceiros, conforme apropriado.
- Os limites máximos e exclusões de responsabilidade refletem o risco material da IA e não neutralizam os remédios essenciais.
- ☐ Os requisitos de seguro são proporcionais e atuais.
- Os créditos de serviço não substituem remediação, suspensão, rescisão, indenização ou danos, quando apropriado.
- Os direitos de rescisão existem para descumprimento, incidentes graves, falha de evidências, mudanças não suportadas ou defeitos repetidos.
- ☐ A assistência de transição e saída é exequível.

2.265 12. Revisão da eficácia da cláusula

área da cláusula	Necessário?	Incluído?	Proprietário ou operacional	Evidência/teste	Gap/ação
Papéis e propósito pretendido					
Documentação/evidência					
Dados/privacidade/IP					
Segurança/resiliência					
Alterações / subprocessos					

área da cláusula	Necessário?	Incluído?	Proprietário operacional	Evidência/teste	Gap/ação
sadores					
Monitoramento/supervisão					
/transparência					
Incidentes					
/ação corretiva					
Cooperação em auditoria/regulamentação					
Continuidade / Saída					
Responsabilidade/remédios					

Confirme que os proprietários operacionais entendem e podem exercer as cláusulas. Um direito contratual que não pode ser invocado, testado ou imposto não é um controle efetivo.

2.266 13. Decisão

- ☐ Aprovado
- ☐ Aprovado com desvios e controles de compensação
- ☐ Apenas piloto restrito
- ☐ Necessário negociação
- ☐ Não aprovado
- ☐ Revisão legal ou especializada qualificada necessária

Motivo da decisão: Desvios aprovados: Controles de compensação: Riscos não resolvidos: Preparação para término/saída:**

2.267 14. Ações abertas

Acção	Proprietário	Data de vencimento	Risco/ impacto legal	Estado	Evidência de encerramento
-------	--------------	--------------------	----------------------	--------	---------------------------

2.268 15. gatilhos de revisão

Reavaliar após:

- renovação, alteração, cessão, aquisição ou reestruturação;
- modelo, serviço, dados, recurso, subprocessador, hospedagem, licença ou mudança de política;
- mudança de função, classificação, propósito pretendido, conformidade ou jurisdição;
- incidente, vulnerabilidade, reclamação, interrupção, descoberta de auditoria ou solicitação de autoridade;
- deprecation, fim do suporte, deterioração do fornecedor ou evento de saída;
- desenvolvimento legal, regulatório, padrão, código ou autoridade.

2.269 Exemplo de GlobalWay Travel Services

A GlobalWay negocia um serviço GPAI de assistência ao viajante. O contrato inicial permite mudanças de modelo não anunciadas, amplo uso de treinamento de alertas, acesso limitado a evidências e sem obrigação de reversão. A GlobalWay exige restrições explícitas de uso de dados, aviso de mudança antecipada, preservação de versão, auditoria e cooperação reguladora, aviso de incidente, suporte a testes multilíngues, reversão, continuidade e assistência de saída antes de aprovar um piloto restrito.

2.270 Homologação

Papel	Nome	Decisão	Data
Legal			
Procurement/ Gestão de Vendor			
Segurança/ Privacidade/ Técnica			
proprietário do negócio			
Risco/			

Papel	Nome	Decisão	Data
Conformidade			
Dados/ Produto/HR, conforme aplicável			

Desvios aprovados: Referências de evidências: Controlos de compensação: Acionador de reavaliação/data: Versão da lista de verificação:

2.271 Referências jurídicas primárias

- Regulamento (UE) 2024/1689, conforme alterado: cadeia de valor aplicável, provedor, GPAI, a jusante, importador, distribuidor, representante, fabricante de produtos, alto risco, transparência, monitoramento, incidente, ação corretiva, autoridade e provisões de evidências.
- Regulamento (UE) 2026/1744, se aplicável.
- Regulamento (UE) 2016/679 e segurança cibernética, segurança de produtos, emprego, igualdade, acessibilidade, proteção do consumidor, propriedade intelectual, contrato, concorrência e direito do setor aplicáveis.
- Textos oficiais consolidados atuais controlam resumos contratuais.

2.272 Apêndice Q Matriz de Literacia em IA

Estado legal: Mestre inglês corrigido. O artigo 4o exige que os provedores e os implantadores tomem medidas, na sua melhor medida, para garantir um nível suficiente de alfabetização em IA para a equipe relevante e outras pessoas que lidam com sistemas de IA em seu nome. A Lei não prescreve um currículo universal, frequência, exame ou certificado.

2.273 Finalidade

Use essa matriz para definir, entregar, testar e rastrear o conhecimento, a competência prática e o suporte baseado em funções necessários para pessoas que desenvolvem, adquirem, integram, implantam, supervisionam, auditam, governam ou lidam com sistemas de IA em nome da organização.

2.274 1. Aplicabilidade e escopo do programa

Campo	Resposta
Entidades jurídicas e funções de prestador/empregador	
Sistemas/modelos e jurisdições	
Pessoal e outras pessoas no âmbito	

Campo	Resposta
de	
Conhecimento, experiência, educação, treinamento e contexto de uso considerados	
Pessoas/grupos em quem os sistemas são utilizados considerados	
Fonte legal atual/data da aplicação	
Proprietário do programa	
Data de versão/revisão do programa	

2.275 2. Matriz de papel

Papel	responsabilidades legais/operacionais	Conhecimentos necessários	Competência prática	Método de entrega	Frequência/gatilho	Provas
Conselheiro e executivos	Estratégia, responsabilidade, apetite de risco, supervisão, escalada, recursos	Capacidades e limitações da IA, exposição legal material, risco sistêmico, deveres de governança	Gestão de desafios, aprovar decisões de risco, supervisionar a remediação	Briefing, exercício de cenário, oficina de diretoria	No compromisso, anual e orientado para eventos	Frequência, minutos, resultados do exercício
Proprietários de empresas/sistemas	Propósito pretendido, propriedade, aprovação, monitoramento, mudança	Classificação, pessoas afetadas, obrigações de controle, limites de fornecidos	Aprovar o uso, gerenciar controle, interpretar relatório, escalar	Oficina de papel e exercício de caso	Antes da posse, anual e após a mudança material	Avaliação, atestação, registros de decisão

Papel	responsabilidades legais/operacionais	Conhecimentos necessários	Competência prática	Método de entrega	Frequência/gatilho	Provas
Desenvolvedores, engenheiros e equipes de dados	, risco residual Design, dados, testes, documentação, desenvolvimento seguro, monitoramento	Qualidade dos dados, viés, robustez, segurança cibernética, documentação técnica, supervisão humana	Construir, testar, documentar, validar, corrigir, preservar evidências	Módulos técnicos e laboratórios práticos	Antes da atribuição e recorrente	Teste prático, evidência de código/revisão, registros de projeto
Pessoal de supervisão humana	Revisão, desafio, superação, parar, escalar, decisões de registro	Propósito pretendido, limitações, viés de automação, comportamento anormal, salvaguardas de pessoas afetadas	Interpretar saída, desafiar recomendações, aplicar fallback, preservar evidências	Formação baseada em cenários e prática supervisionada	Antes da atribuição, recorrente, após incidentes/mudanças	Teste de competência, exercício observado, sobrepor a qualidade
Compras e gestão de fornecedores	Due diligence, contratação, monitoramento	papéis de atores, suficiência de evidências	Avaliar vendedores, negociar controles,	Workshop de papel e estudo de caso de	Antes do papel, anual e antes da aquisição crítica	Questionário completo, revisão de contrato,

Papel	responsabilidades legais/operacionais	Conhecimentos necessários	Competência prática	Método de entrega	Frequência/gatilho	Provas
	mento, saída	as, mudanças e cláusulas de incidentes, risco de dependência	rastrear remediação, invocar direitos de saída	fornecedor		avaliação
Legal, conformidade, privacidade e segurança	Aplicabilidade, interpretação, controle, notificações, investigações, garantia	Disposições da AI Act, GDPR e leis relacionadas, segurança, evidências, interação de autoridade	Aconselhar, revisar, investigar, escalar, manter a rastreabilidade	Treinamento especializado e briefings de mudança jurídica	Atualizações contínuas e tarefas específicas	Registros de revisão, exercícios, evidência de educação continuada
Auditoria e garantia interna	Planejamento independente, testes, relatórios, validação de fechamento	Controle de projeto, confiabilidade de evidências, conceitos de garantia técnica, distinção legal	Auditorias de escopo, amostra, teste, desafio, relatório, validar	Formação específica de auditoria e briefings técnicos	Anual e antes da atribuição	Papéis de trabalho, avaliação de competência, revisão de QA
Usuários gerais e	Uso aprovado	Ferramentas	Use com segurança	Onboarding,	Antes do acesso,	Quiz, atestado,

Papel	responsabilidades legais/operacionais	Conhecimentos necessários	Competência prática	Método de entrega	Frequência/gatilho	Provas
contratados	o, confidencialidade, verificação de saída, relatório de incidentes	aprovas, uso proibido, limitações, privacidade, segurança, transparência	a, verifique saídas, evite entradas sensíveis, relate problemas	microlearning, exemplos	anual e após mudanças na política/sistema	registro de acesso

2.276 3. Seleção do currículo

Selecione proporcionalmente de:

- Conceitos, capacidades, limitações, incerteza e alucinação;
- propósito pretendido, uso aprovado, uso proibido ou restrito e uso previsível;
- funções legais, classificações estatutárias, datas de aplicação e controles organizacionais;
- proteção de dados, confidencialidade, propriedade intelectual e restrições de dados do cliente;
- vies, igualdade, acessibilidade, direitos fundamentais, crianças e pessoas vulneráveis;
- supervisão humana, viés de automação, sobreposição, parada, recuo, apelo e escalada;
- Segurança cibernética, injeção imediata, uso indevido de ferramentas, ação antrópica e relatórios de incidentes;
- Transparência, avisos, marcação de conteúdo sintético e comunicação pessoa afetada;
- documentação, evidência, registro, gerenciamento de mudanças e retenção legal;
- risco do fornecedor, monitoramento, reclamações, ações corretivas e cooperação regulatória.

2.277 4. Acessibilidade e entrega

Fornecer idiomas relevantes, acomodações com deficiência, formatos acessíveis, exemplos baseados em papéis, cenários realistas, exercícios

práticos, prática supervisionada quando necessário e material de atualização após incidentes, descobertas, mudanças legais, mudanças no fornecedor ou mudanças no sistema material.

2.278 5. Tracker da competência e da conclusão

Pessoa/ grupo	Papel	Módulos obrigatórios	Conclusão	Resultado da competência	Restrição/ supervisão interna	Renovação/ gatilho	Exceções
------------------	-------	-------------------------	-----------	-----------------------------	-------------------------------------	-----------------------	----------

A conclusão por si só não estabelece competência. As funções de alto impacto devem incluir validação prática ou baseada em cenários.

2.279 6. Medidas de eficácia

Faixa, conforme apropriado:

- taxas de conclusão e atraso;
- avaliação e resultados práticos-exercício;
- incidentes de uso inseguro e violações de políticas;
- override do revisor e qualidade da escalada;
- Resultados repetidos de auditoria ou falhas de controle;
- confiança dos funcionários na identificação e relato de risco;
- Acessibilidade e defeitos de linguagem;
- melhoria de desempenho após remediação direcionada;
- pessoal restrito de deveres pendentes de competência.

2.280 7. gestão da exceção e da remediação

Exceções temporárias de documentos, razões, risco, supervisão provisória ou restrições de acesso, proprietário de remediação, data de vencimento, método de validação e autoridade de aprovação. Não permita que uma exceção renuncie a um dever vinculativo ou permita que uma pessoa não qualificada realize uma supervisão de alto impacto sem salvaguardas adequadas.

2.281 Homologação

Papel	Nome	Decisão	Data
Proprietário do programa			
HR/ aprendizagem			
Legal/			

Papel	Nome	Decisão	Data
conformidade			
Patrocinador			
Executivo			

Referências de evidências: Exceções/controles intermediários:

Próximo comentário trigger/date:**

2.282 Apêndice R Modelos de Aviso de Transparência

Estado legal: Mestre inglês corrigido. Selecione apenas o módulo de aviso desencadeado pelo ator, sistema, uso, saída e disposição aplicável. Um aviso de IA genérico não satisfaz todos os artigos 13, 26, 50, privacidade, emprego, consumidor, acessibilidade ou dever do setor.

2.283 Finalidade

Use esses modelos para identificar o gatilho de transparência aplicável, preparar avisos precisos e acessíveis, vinculá-los à versão do sistema aprovada, testar se eles funcionam no contexto real do usuário e reter evidências de aprovação e implantação.

2.284 1. registro de aplicabilidade

Campo	Resposta
Sistema/modelo, ID do inventário, versão/configuração	
Pessoa jurídica e papel de ator	
Uso, saída, público e pessoas afetadas	
Jurisdição e Língua	
Disposição desencadeante ou outra base jurídica	
Data de aplicação, exceção ou exclusão	
Proprietário e aprovador do aviso	
canal de entrega e tempo	

2.285 2. Módulo A Interação humana com IA

Declare claramente e no momento apropriado que a pessoa está interagindo com um sistema de IA, a menos que isso seja óbvio para uma pessoa

razoavelmente bem informada, observadora e circunspecta nas circunstâncias ou outra exceção estatutária se aplica.

Campos sugeridos:

- organização responsável;
- finalidade da interação;
- se um ser humano está disponível;
- Como solicitar assistência humana;
- Limitações materiais relevantes para a interação;
- privacidade, reclamação, acessibilidade e contatos de incidentes.

2.286 3. Módulo B Instruções de alto risco e informações de deployer

Fornecer ou operacionalizar instruções, capacidades, limitações, precisão esperada, finalidade pretendida, requisitos de entrada, medidas de supervisão humana, registro, manutenção, uso indevido previsível e outras informações necessárias para a relação provedor / operador relevante.

Confirme se a informação voltada para o deployer corresponde ao sistema liberado e está disponível para as pessoas responsáveis pela operação, supervisão, monitoramento, resposta a incidentes e comunicação entre pessoas afetadas.

2.287 4. Módulo C conteúdo gerado ou manipulado por IA

Gravar:

- capacidade de marcação do fornecedor;
- formato legível por máquina;
- viabilidade técnica, robustez, confiabilidade e interoperabilidade;
- tipo de conteúdo e canal de saída;
- dever de divulgação do deployer;
- visibilidade e tempo de divulgação;
- persistência após o processamento normal;
- Exceções legais ou tratamento de responsabilidade editorial.

Distinguir deepfake, texto de interesse público e outros casos de conteúdo sintético. Não assuma que um rótulo satisfaz cada contexto de saída e uso.

2.288 5. Módulo D Reconhecimento de emoção ou categorização biométrica

Informar as pessoas singulares expostas onde o gatilho estatutário se aplica. Coordenar o aviso com:

- triagem de prática proibida;
- Classificação de alto risco;
- privacidade e análise de dados de categorias especiais;
- Emprego, consulta dos trabalhadores, educação, igualdade e deveres setoriais;
- Requisitos de acessibilidade e de idioma;
- rotas de reclamações e remédios.

2.289 6. Campos de aviso de língua simples do núcleo

Inclua apenas o que é preciso e aplicável:

2.289.1 envolvimento da IA

Explique se a pessoa está interagindo com a IA ou se a IA apoia um processo ou decisão que a afeta.

2.289.2 Finalidade

Explique o que o sistema faz, por que está sendo usado, quais decisões, recomendações, classificações, conteúdo ou ações ele suporta, e se um ser humano faz ou revisa o resultado final.

2.289.3 Informação utilizada

Descreva as principais categorias de informações utilizadas e forneça o aviso de privacidade relevante ou outras informações de uso de dados.

2.289.4 Limitações de material

Explique erros previsíveis, incerteza, limites de desempenho conhecidos, limitações de idioma ou acessibilidade, usos não suportados e circunstâncias em que o sistema não deve ser confiável.

2.289.5 Revisão humana e remédio

Declare se a revisão humana está disponível ou necessária e explique como:

- Solicitar revisão ou correção;
- desafio ou recurso de um resultado;
- entrar em contato com uma pessoa em vez de um serviço automatizado;
- solicitar suporte de acessibilidade ou acomodação;
- apresentar uma reclamação ou relatar um incidente.

2.289.6 Tabela de contato

Finalidade do contato	Detalhes
-----------------------	----------

Questões gerais	
-----------------	--

Finalidade do contato

Detalhes

Revisão humana, desafio ou
apelo

Pedido de privacidade

Acessibilidade ou suporte
linguístico

Reclamação ou incidente

2.290 7. Lista de verificação da qualidade e da evidência

- ☐ Entregue antes ou no momento legal e operacionalmente apropriado.
- ☐ Claro, conciso, compreensível e não escondido entre termos não relacionados.
- ☐ Acessível a pessoas com deficiência e disponível em idiomas relevantes.
- ☐ Consistente com o comportamento real do sistema, propósito pretendido e limitações.
- ☐ Não exagera a precisão, a capacidade, o envolvimento humano ou o status legal.
- ☐ Queixa, revisão, apelo e rotas de contato humano funcionam na prática.
- ☐ A marcação legível por máquina funciona e persiste quando aplicável.
- ☐ O aviso aprovado está ligado à versão e ao canal implantados.
- ☐ Mudanças desencadeiam reavaliação e re-aprovação.

2.291 8. Registro de teste

Ensaio	Audiência/ canal	Método	Resultado	Defeito/ ação	Provas
Tempo e visibilidad e legibilidad e e compreens ão Acessibilid ade e tecnologia assistiva Tradução					

Ensaio	Audiência/ canal	Método	Resultado	Defeito/ ação	Provas
e localização Marcação técnica e persistência a Rota de contato humano e rota de apelo consistência jurídica e operacional					

2.292 9. Aprovação

- ☐ Módulo legal aplicável aprovado
- ☐ Notificação voluntária/organizacional aprovada
- ☐ Aprovado com condições
- ☐ Aviso não obrigatório raciocínio documentado
- ☐ Revisão legal qualificada necessária

Papel	Nome	Decisão	Data
Empresa/ proprietário do produto Legal/ conformidade Privacidade Acessibilidade /comunicação			

Referências de evidências: Racionalidade de exceção/não aplicabilidade: Próximo comentário trigger/date:**

2.293 Apêndice S Avaliação de mudança de modelo

Estado legal: Mestre inglês corrigido. Esta avaliação distingue a mudança controlada comum, a mudança operacional material, a mudança de

propósito pretendido, a mudança do papel do provedor e a modificação substancial potencial. Ela própria não determina o status legal.

2.294 Finalidade

Use esta avaliação antes de implementar uma nova versão do modelo, mudança de provedor, atualização de ajuste fino, alteração de prompt ou ferramenta, mudança de recuperação, alteração de dados, mudança de configuração, mudança de filtro de segurança, mudança de hospedagem ou mudança de capacidade de material.

2.295 1. Alterar registro

Campo	Resposta
ID do sistema/inventário	
Modelo/versão/configuração atual e proposto	
Pessoa jurídica e papel de ator	
Propósito pretendido antes/depois	
Alterar proprietário e data planejada	
Jurisdições e populações afetadas	
Fonte legal atual/data da aplicação	
Related release/change ticket	

2.296 2. Alterar descrição e escopo

Descreva:

- O que está mudando e por quê;
- benefício esperado e processo de negócios afetado;
- Provedor/modelo, arquitetura, prompts, instruções do sistema, ferramentas, agentes, recuperação, dados, limiares, filtros de segurança, hospedagem, subprocessadores, interfaces e capacidade autônoma afetada;
- Usuários, revisores, clientes, trabalhadores ou outras pessoas afetadas;
- se a finalidade pretendida, o uso real, a marca, a distribuição ou as alterações no controle operacional;
- se as versões anteriores podem ser preservadas e restauradas.

2.297 3. Triagem legal e operacional

Área	Sem impacto	Menor Menor	Material	Revisão legal necessária	Evidência/ racional
Propósito pretendido					
Papel de ator ou colocação de marca própria					
Artigo 5o Risco de prática proibida					
Artigo 6/Classificação do Anexo I ou III					
Artigo 6.o, n.o 3, hipóteses de exceção					
modificaçã o substancia l potencial					
Conformid ade, registro, declaração ou marcação					
Governanç a de dados, privacidade e uso legal					
Precisão, confiabilid					

Área	Sem impacto	Menor Menor	Material	Revisão legal necessária	Evidência/ racional
ade, viés, segurança e direitos fundamentais					
Supervisão humana e transparência					
Segurança cibernética, registro, monitoramento e resposta a incidentes					
Fornecimento, dependência, portabilidade e continuidade					
Acessibilidade, idioma e implantação					
jurisdicional					

2.298 4. Validação necessária

Selecione e defina critérios de aceitação antes da liberação:

- ☐ Teste de regressão
- ☐ Testes de desempenho e confiabilidade
- ☐ Subgrupo, viés e testes de justiça
- ☐ Segurança, uso indevido, injeção imediata e teste de abuso de ferramentas

- ☐ Supervisão humana, substituição, parada e validação de escalada
- ☐ Transparência, aviso e revisão de marcação
- ☐ Data-governança e revisão de privacidade
- ☐ Resiliência, fallback, reversão e testes de continuidade
- ☐ Testes de jurisdição, idioma e acessibilidade
- ☐ Registro, evidência e validação de monitoramento
- ☐ Reconciliação da versão de documentação para produção

Ensaio	Critérios de aceitação	Resultado	Limitação/ defeito	Proprietário	Provas
--------	------------------------	-----------	--------------------	--------------	--------

2.299 5. Documentação e atualizações de controle

Documento ou controle	É necessária uma actualização?	Proprietário	Estado	Provas
Inventário e avaliação de papéis				
Classificação de aplicabilidade e/alto risco				
Avaliação de risco e FRIA/DPIA				
Documentação técnica e histórico de versões				
Plano de visão humana e treinamento				
Aviso de transparência, instruções e marcações				
Registros de fornecedor, contrato e dependência				

Documento ou controle	É necessária uma actualização?	Proprietário	Estado	Provas
Plano e limites de monitorização o pós-comercialização Incidente, fallback, continuidade e procedimentos legais Conformidade e, declaração, registro ou marcação de evidência				

2.300 6. Decisão

- ☐ Aprovado como mudança controlada comum
- ☐ Aprovado com monitoramento aprimorado
- ☐ Piloto restrito
- ☐ Testes ou evidências pendentes diferidos
- ☐ Rejeitado
- ☐ Escalado para substancial modificação / revisão do papel do fornecedor
- ☐ Reavaliação de conformidade necessária

2.301 7. Rollback e contingência

Versão de reversão, gatilhos de reversão, autoridade de decisão, pessoal responsável, preservação de evidências, proteções de pessoas afetadas, comunicações, processo de reversão e critérios de restauração.

2.302 Homologação

Papel	Nome	Decisão	Data
proprietário do negócio			
Técnico/ produto			

Papel	Nome	Decisão	Data
proprietário			
Legal/			
conformidade			
Proprietário			
de			
risco/conformi			
dade			

Referências de evidências: ** Limitações residuais: **Próximo comentário trigger/date:**

2.303 Apêndice T Avaliação da Modificação Substancial

Estado legal: Mestre inglês corrigido. Use a definição legal atual e as regras específicas do ator. Uma mudança operacional material não é automaticamente uma modificação substancial, e uma modificação substancial pode transferir as responsabilidades do provedor e desencadear obrigações de conformidade renovadas.

2.304 Finalidade

Use esta avaliação para determinar se uma mudança proposta ou concluída pode constituir uma modificação substancial, alterar o propósito pretendido, alterar o papel legal ou classificação, ou exigir reavaliação de conformidade e outras ações de pré-implantação.

2.305 1. Sistema e registro da mudança

Campo	Resposta
Nome do sistema, ID do inventário e versão	
Papéis atuais de provedores e atores	
Entidade que faz a mudança	
Propósito pretendido atual	
Mudança proposta	
Classificação de alto risco/base legal	
Jurisdições e populações afetadas	
Proprietário/data da avaliação	
Fonte legal atual/data da aplicação	

2.306 2. Alterar descrição

Documento:

- modelo, fornecedor, arquitetura, dados, prompts, ferramentas, capacidade agentical, interfaces, hospedagem, subprocessadores, limiares e salvaguardas afetados;
- razão de negócios e resultado esperado;
- novos usuários, pessoas afetadas, contextos de decisão, setores ou jurisdições;
- branding, colocação de nome próprio, distribuição, integração e controle operacional;
- Se a alteração foi planejada na documentação original de conformidade ou no plano de alteração predeterminado;
- se salvaguardas, supervisão, transparência, registro ou monitoramento são alterados.

2.307 3. Teste de limiar

Avaliar se a mudança foi imprevista ou não planejada na avaliação inicial de conformidade e se afeta o cumprimento dos requisitos aplicáveis ou altera o propósito pretendido.

Pergunta	Sim/Não/Incerto	Evidência/racional
A mudança foi predeterminada e documentada na documentação técnica original ou no plano de mudança aprovado?		
A mudança altera o propósito pretendido ou o uso razoavelmente previsível?		
Introduz uma nova população afetada, contexto de decisão, setor ou jurisdição?		
Afeta o cumprimento dos artigos 9.o a 15.o ou outros requisitos aplicáveis?		
Ele altera a análise do Artigo 5 ou Artigo 6, a integração do produto		

Pergunta	Sim/Não/Incerto	Evidência/racional
ou a rota de conformidade?		
Isso afeta materialmente desempenho, viés, segurança, direitos fundamentais, governança de dados, supervisão, transparência, robustez ou segurança cibernética?		
Ele introduz um novo modelo, provedor, arquitetura, fonte de dados, capacidade autônoma, ferramenta ou agente?		
Ele remove, enfraquece, ignora ou altera materialmente as salvaguardas?		
Isso afeta o registro, rastreabilidade, monitoramento, resposta a incidentes ou retenção de evidências?		
Requer novo registro, declaração, marcação, instruções ou interação de autoridade?		

2.308 4. Consequência do papel do fornecedor e da cadeia de valor

Determine se o deployer modificado, distribuidor, importador, fabricante do produto, integrador ou outro terceiro se torna o provedor sob a regra aplicável da cadeia de valor.

- colocação de nome próprio ou marca própria;
- mudança intencional;
- modificação substancial;

- rebranding ou white labeling;
- integração de produtos;
- alocação contratual versus conduta real;
- deveres de notificação a montante e a jusante.

Entidade	Papel actual	novo papel potencial	Base factual	Obrigações desencadeadas	Conclusão jurídica
----------	--------------	----------------------	--------------	--------------------------	--------------------

2.309 5. Evidência revisada

- Documentação técnica original e ficheiro de conformidade;
- Plano de mudança predeterminado;
- Avaliação da mudança de modelo;
- resultados de validação, regressão, subgrupo, segurança e resiliência;
- Risco, FRIA, DPIA e avaliações de governança de dados;
- avisos de fornecedores e termos de contrato;
- Registros de liberação, configuração, versão e reversão;
- análise legal, de produto e de conformidade.

2.310 6. Ações legais e de controle necessárias

Acção	Aplica-se?	Proprietário	Data de vencimento	Estado	Provas
Reavaliação do papel do fornecedor					
Artigo 5.o/Artigo 6.o					
Reavaliação					
Atualização da gestão de riscos e da avaliação de impacto					
Documentação técnica e					

Acção	Aplica-se?	Proprietário	Data de vencimento	Estado	Provas
atualização de versão					
Validação/regressão/teste de segurança					
Avaliação ou reavaliação da conformidade					
Declaração CE, marcação CE ou atualização de registro					
Instruções, transparência, acessibilidade e atualização de treinamento					
Monitoramento pós-mercado e atualização de processos de incidentes					
Notificação de contrato,					

Acção	Aplica-se?	Proprietário	Data de vencimento	Estado	Provas
fornecedor , cliente ou autoridade Bloqueio de liberação, restrição, suspensão ou reversão					

2.311 7. Conclusão

- ☐ Não é uma modificação substancial
- ☐ Mudança pré-determinada dentro da estrutura de conformidade documentada
- ☐ Potencialmente substancial – evidência adicional necessária
- ☐ Modificação substancial
- ☐ Transferência de papel de fornecedor ou outra consequência do artigo 25.o
- ☐ Reavaliação de conformidade necessária
- ☐ Aconselhamento legal ou de conformidade externa qualificado necessário

2.311.1 Racional

Documente os fatos, suposições, interpretação legal, incerteza e evidências que apoiam a conclusão.

2.312 Homologação

Papel	Nome	Decisão	Data
Legal/ conformidade			
Técnico/ produto proprietário			
proprietário do negócio			
Qualidade/ conformidade proprietário			

Rationale e suposições: Referências de evidências: **Próximo comentário**
trigger/date:

2.313 Apêndice U AI Control Register

**** Status legal: **** Mestre inglês corrigido. O registro deve identificar se cada controle implementa lei vinculativa, contrato, política organizacional, um padrão, prática de governança recomendada ou um aprimoramento opcional. Um controle não deve ser rotulado legalmente exigido, a menos que a disposição citada se aplique ao ator gravado, sistema, uso, jurisdição e data de inscrição.

2.314 Finalidade

Use este registro para documentar os controles de IA, sua base legal ou de governança, escopo, propriedade, frequência operacional, evidências, testes, eficácia, correção e gatilhos de revisão.

2.315 Registo de controlo

[illegible]

2.316 Tipos de fonte

- Dever estatutário ou regulamentar vinculativo
- Direito contratual
- Política ou controle imposto pela organização
- Padrão harmonizado, especificação comum ou outro padrão reconhecido
- Prática recomendada de governança ou garantia
- Melhoria opcional

2.317 Domínios mínimos de controle

- governança, responsabilidade e supervisão do conselho;
- status de inventário, ingestão, propriedade e ciclo de vida;
- aplicabilidade, papel de ator e classificação estatutária;
- triagem de prática proibida;
- avaliação de riscos, segurança e direitos fundamentais;
- governança de dados, privacidade e controles de propriedade intelectual;
- documentação técnica, controle de versão e gerenciamento de evidências;
- Controles de precisão, robustez, segurança cibernética, resiliência e uso indevido;
- transparência, instruções, acessibilidade e supervisão humana;
- registro, rastreabilidade, monitoramento e manutenção de registros;
- fornecedor, contrato, dependência e governança da cadeia de suprimentos;
- mudança, liberação, propósito pretendido e controles substanciais de modificação;
- Conformidade, registro, declaração, marcação e prontidão regulamentar, quando aplicável;
- monitoramento pós-mercado, incidentes, reclamações e ações corretivas;
- Alfabetização, competência, auditoria interna, descobertas e melhoria contínua.

2.318 Campos de controle-design

Para cada controle, registre:

- escopo, ator, sistema, versão, jurisdição e data de aplicação;
- acionador e entradas necessárias;
- Procedimentos pormenorizados e critérios de decisão;
- autoridade, segregação de deveres e caminho de escalada;
- caráter preventivo ou detetive;
- dependências manuais ou automatizadas de operação e automação;
- evidência gerada e sistema de registro;
- Base de retenção e restrições de confidencialidade;
- Método de teste, critérios de aceitação e resultado operacional;
- dependências de controle, fallback e controles compensadores;
- Consequências de falhas e resposta necessária;
- gatilhos de mudança e reavaliação.

2.319 Status do controle

Use um:

- Projetado
- Implementado
- Funcionamento
- Parcialmente eficaz
- Ineficaz
- Não aplicável, com fundamentação documentada
- Suspens
- Aposentado

Não classifique um controle como operacional ou eficaz apenas porque existe uma política ou procedimento. O status deve refletir evidências atuais e vinculadas à versão do desempenho.

2.320 Teste e remediação

ID de controle	Período de ensaio/amostra	Resultado do design	Resultado operacional	gravidade da deficiência	Controle Interno	Remediação apropriada	Data de vencimento	Evidência de encerramento	Validação independente
----------------	---------------------------	---------------------	-----------------------	--------------------------	------------------	-----------------------	--------------------	---------------------------	------------------------

Falhas repetidas, exceções não suportadas ou ações de alta gravidade atrasadas devem ser escaladas de acordo com o modelo de governança aprovado.

2.321 Gatilhos de revisão

Reavaliar após alterações legais, de ator-função, para fins pretendidos, sistema/modelo/versão, dados, fornecedor, jurisdição, incidente, reclamação, auditoria, falha de controle, conformidade ou data de aplicação.

2.322 Homologação

Papel	Nome	Decisão	Data
Proprietário do registro			
Legal/conformidade			
Proprietário de			

Papel	Nome	Decisão	Data
risco/controle			
Auditoria/ garantia interna, quando aplicável			

- acurado, oportuno e atribuível a uma fonte responsável;
- autênticos e protegidos contra alteração ou eliminação não autorizada;
- Reprodutível e reproduzível, quando apropriado;
- compreensível sem suposições não suportadas;
- internamente consistente e reconciliado com registros relacionados;
- acessível a revisores autorizados enquanto protege a confidencialidade, privacidade, propriedade intelectual e segredos comerciais;
- recuperável dentro do prazo contratual, regulamentar, de auditoria ou de resposta a incidentes aplicável;
- retido e descartado de acordo com uma base legal e comercial documentada.

Um título de política, certificado, captura de tela, declaração de fornecedor ou página da Web ao vivo não é suficiente por si só, a menos que o escopo, a versão, o período, a fonte e os detalhes de suporte sejam estabelecidos.

2.327 Categorias de Evidência

- Inventário, propriedade, aplicabilidade, papel de ator e classificação;
- Prática proibida, risco, FRIA, DPIA, segurança e avaliações de direitos;
- Procedência, governança, qualidade, privacidade e linhagem de dados;
- arquitetura, documentação técnica, configuração e histórico de versões;
- validação, teste, precisão, robustez, segurança cibernética, acessibilidade e resultados de subgrupos;
- A rota de conformidade, o organismo notificado, a declaração, o registo, a marcação e os registos da legislação do produto, se aplicável;
- avisos de transparência, instruções, supervisão humana, treinamento e competência;
- registro, monitoramento, incidentes, reclamações, recursos e ações corretivas;
- fornecedor, contrato, dependência, notificação de mudança e registros de saída;
- correspondência, submissões regulatórias, participações legais, litígios e investigações;
- testes de controle interno, auditoria, garantia, descobertas, exceções e aprovações de gerenciamento.

2.328 Validação de provas

ID da evidência	mbito/versão match	Autenticidade verificada	Resultado da compliance	Resultado da consistência	Teste de retrievabilidade	Revisor	Data de revisão	Limitação/ação
-----------------	--------------------	--------------------------	-------------------------	---------------------------	---------------------------	---------	-----------------	----------------

Não trate as evidências como atuais quando se refere a um modelo, configuração, jurisdição, fornecedor, período de controle ou quadro legal substituído.

2.329 Retenção e retenção legal

Para cada registro, identifique o controle legal, regulamentar, contratual, conformidade, litígio, investigação, emprego, privacidade, segurança do produto ou base organizacional. Registre o evento de início do relógio, período de retenção, método de descarte, suspensão de descarte e proprietário legal.

2.330 Gestão de lacunas

Gap ID	Evidência ausente ou fraca	Impacto legal/controlado	Contrôle Interino	Proprietário	Data de vencimento	Estado	Evidência de encerramento	Validação independente
--------	----------------------------	--------------------------	-------------------	--------------	--------------------	--------	---------------------------	------------------------

As lacunas de evidências materiais que afetam um dever legal, rota de conformidade, investigação de incidentes, solicitação de autoridade, decisão de liberação ou risco residual aceito devem ser escaladas e podem exigir restrição ou suspensão.

2.331 Gatilhos de revisão

Atualização após sistema, modelo, dados, ator-papel, fornecedor, jurisdição, legal, controle ou mudanças de retenção; incidentes ou reclamações; auditorias ou atividades de conformidade; solicitações de autoridade; litígios ou investigações antecipadas; retenções legais; e falhas de qualidade de evidência.

2.332 Homologação

Papel	Nome	Decisão	Data
Proprietário do registro			

Papel	Nome	Decisão	Data
Legal/ conformidade			
Registros/ privacidade/ segurança, conforme aplicável			
Auditoria/ garantia, quando aplicável			

Versão de aprovação: Repositório de evidências: Limitações materiais abertas: Próximo comentário trigger/date:**

2.333 Apêndice W Programa de Auditoria Interna

Estado legal: Mestre inglês corrigido. A Lei de IA da UE não impõe uma função de auditoria interna autônoma universal em todas as organizações. A auditoria interna é uma prática de garantia voluntária ou exigida pela organização e não substitui a responsabilidade da administração, a avaliação da conformidade, o envolvimento do organismo notificado ou a supervisão da autoridade.

2.334 Finalidade

Use este programa para planejar cobertura de auditoria interna baseada em risco de governança de IA, sistemas, controles, evidências, prontidão legal e eficácia do programa.

2.335 1. Informações sobre o programa

Campo	Resposta
Período de auditoria	
Diretor executivo de auditoria ou proprietário do programa	
entidade homologadora	
Entidades de escopo e jurisdições	
Independência e direitos de acesso	
Base de base legal e política atual	
Especialistas técnicos/legais	

2.336 2. universo de auditoria AI

Inclua, conforme aplicável:

- governança de IA corporativa, responsabilidade e supervisão do conselho;
- inventários, ingestão, propriedade, status do ciclo de vida e IA sombra;
- a aplicabilidade, o papel de ator, o artigo 5o, o artigo 6o, o artigo 50o, a GPAI e as classificações setoriais;
- Sistemas, modelos, versões e implantações de IA de alto risco e outros materiais;
- Processos de risco, direitos fundamentais, privacidade, segurança e governança de dados;
- Documentação técnica, reconciliação de versões, validação, robustez, segurança cibernética e resiliência;
- supervisão humana, transparência, acessibilidade, reclamações e apelos;
- fornecedores críticos, fornecedores de modelos, subprocessadores, contratos e risco de concentração;
- Gestão de mudanças, alterações para fins pretendidos, modificação substancial e controles de liberação;
- Disponibilidade de conformidade, registo, declarações, marcação e interfaces da legislação do produto, quando aplicável;
- Monitoramento, incidentes, ações corretivas, retenção legal, preservação de evidências e resposta da autoridade;
- Alfabetização, competência, testes de controle, exceções, remediação e melhoria contínua.

2.337 3. Avaliação de risco e plano anual

Área auditável	Significa do jurídico/ operacio nal	Risco inerente	Maturid ade do controle	Achados/ incident es anterior es	Nível de mudança	Priorida de planejad a
-------------------	---	-------------------	-------------------------------	--	---------------------	---------------------------------

Engajamento da auditoria	Objectivo	Escopo	Timing	chumbo	Habilidades necessárias	Esforço estimado	Estado
--------------------------	-----------	--------	--------	--------	-------------------------	------------------	--------

A priorização deve considerar prazos legais, exposição a práticas proibidas, obrigações de alto risco e GPAI, populações afetadas, incidentes, reclamações, mudanças significativas, dependência do fornecedor, evidências fracas e correção atrasada.

2.338 4. projeto do envolvimento

Cada auditoria deve definir:

- objetivos, critérios, escopo, período, entidades, jurisdições, sistemas, modelos e versões;
- papéis relevantes do ator, fins pretendidos, disposições legais, contratos, políticas e padrões;
- exclusões, suposições, limitações de evidências e confiança em outras garantias;
- Estratégia de amostragem e integralidade da população;
- conhecimentos técnicos, legais, de privacidade, segurança, dados, acessibilidade e domínio;
- independência, conflitos, acesso à gestão, confidencialidade e revisão de qualidade;
- métodos de relatório, escalada, ação corretiva e validação de encerramento.

2.339 5. Objetivos principais da auditoria

- avaliar a governança, a responsabilidade, os direitos de decisão e os relatórios do conselho;
- integridade do inventário de teste, propriedade, aplicabilidade, papéis de ator e classificação estatutária;
- controles de práticas proibidas e exceções legalmente apoiadas;
- teste de risco, direitos, privacidade, dados, segurança e governança de acessibilidade;
- reconciliar documentação técnica, evidências, configurações e versões de produção;
- precisão do teste, desempenho do subgrupo, robustez, segurança cibernética, registro, supervisão e controles de transparência;
- revisar a evidência do fornecedor, a aplicabilidade do contrato, o gerenciamento de dependência e a prontidão de saída;

- Monitoramento de testes, incidentes, reclamações, retenções legais, resposta regulatória e ações corretivas;
- Avaliar a prontidão em conformidade sem representar a auditoria interna como avaliação da conformidade;
- determinar se as descobertas, exceções e riscos aceitos são escalados com precisão e remediados de forma sustentável.

2.340 6. Métodos de teste

Use conforme apropriado:

- Investigação e observação;
- Inspeção de documentos e registros;
- passo a passo e reperformance;
- Análise de dados e reconciliação da população;
- configuração, código, prompt, modelo e revisão de controle;
- amostragem baseada no risco;
- validação técnica e testes contraditórios por especialistas qualificados;
- exercícios de mesa e simulações regulatórias;
- Evidência de terceiros e revisão de contrato;
- produção-versão e reconciliação evidência-repositório.

A investigação por si só não é evidência suficiente de operação de controle.

2.341 7. Independência e competência

Independência do auditor do documento, conflitos, competência técnica, envolvimento especializado, consulta legal, revisão de qualidade, limitações de acesso e quaisquer restrições de gerenciamento. Os auditores não devem validar o trabalho para o qual possuíam design incompatível ou responsabilidade operacional sem salvaguardas apropriadas.

2.342 8. Encontrando a classificação

Classificação	Critérios	Consequência jurídica/operacional	Escalada	Remediação de alvo
Crítico				
Alto				
Moderado				
Baixo	baixo			

Uma classificação interna não determina se é necessária notificação, retirada, recall, ação corretiva ou cooperação de autoridade.

2.343 9. Acompanhamento e encerramento

Encontro ID	Severidade	Relevante legal	Proprietário	Data de vencimento	Controle e Interim o	Método de validação	Data de encerramento/ status
----------------	------------	--------------------	--------------	-----------------------	-------------------------------	---------------------------	------------------------------------

O fechamento requer evidências de que a remediação opera efetivamente. Extensões repetidas, aceitação de risco sem suporte e descobertas recorrentes devem ser escaladas.

O fechamento interno não substitui a correção legalmente exigida, retirada, recall, relatório, notificação, atividade de conformidade ou ação de autoridade.

2.344 10. Relatórios

Alcance do relatório, critérios, sistemas e versões testados, limitações de evidências, descobertas, temas sistêmicos, ações atrasadas, falhas repetidas, risco residual, aceitação da administração, implicações legais e questões que exigem atenção do executivo, do conselho, do comitê de auditoria, da conformidade ou da autoridade.

2.345 Homologação

Papel	Nome	Decisão	Data
Diretor executivo de auditoria/proprietário do programa	Comitê de Auditoria/Comitê de Auditoria, quando aplicável		

Referências de evidências: ** Limitações de independência ou escopo: Questões de alto risco não resolvidas: **Revisão do próximo plano:**

2.346 Apêndice X Plano de Ação Corretiva

Estado legal: Mestre inglês corrigido. Este fluxo de trabalho de remediação interna suporta, mas não substitui, medidas corretivas legalmente exigidas, retirada, recall, suspensão, relatórios de incidentes, cooperação com autoridades ou remédios para pessoas afetadas.

2.347 Finalidade

Use este plano para corrigir a governança da IA, deficiências legais, técnicas, operacionais, de fornecedores ou evidências e para validar o fechamento sustentável. O fechamento requer evidências de que a correção opera efetivamente, não apenas que a documentação foi atualizada.

2.348 1. Questão e contexto jurídico

Campo	Resposta
Encontrar/incidente/ identificação do problema	
Origem e data	
Sistema/modelo/versão e jurisdições	
Pessoa jurídica e papel de ator	
Requisito/controle afetado	
Estado esperado e condição real	
Severidade, risco e pessoas afetadas	
Data identificada	
Proprietário da emissão e patrocinador executivo	
Repositório de evidências	

2.349 2. Declaração de emissão

Descrever a condição verificada, requisito ou controle aplicável, estado esperado, estado real, sistemas afetados, modelos, versões, entidades, jurisdições, pessoas, evidências, incerteza e consequências legais ou operacionais.

2.350 Contenção ou correção imediata

Acção	Proprietário	Prazo	Finalidade jurídica/operacional	Estado	Provas
-------	--------------	-------	---------------------------------	--------	--------

Avaliar e documentar, conforme aplicável:

- suspensão, restrição, desativação, retirada ou recall;
- Retrocesso manual e proteção das pessoas afetadas;
- Preservação de provas e retenção legal;

- escalonamento do fornecedor ou da cadeia de valor;
- Regulamentação, cliente, trabalhador, titular de dados ou outra notificação;
- Controles temporários de monitoramento, revisão ou acesso;
- prevenção de recorrência enquanto a correção permanente está pendente.

2.351 4. Análise de causa-raiz e do escopo afetado

Avaliar:

- governança, responsabilidade e autoridade de decisão;
- design de processo ou controle;
- arquitetura técnica, modelo, configuração, prompts, ferramentas ou interfaces;
- qualidade, proveniência, rotulagem, linhagem ou representatividade;
- fatores humanos, carga de trabalho, incentivos, treinamento ou competência;
- contribuição do fornecedor, subprocessador ou dependência;
- Fraquezas de recursos, agendamento ou segregação de deveres;
- Monitoramento, detecção, escalada ou falha na resposta a incidentes;
- documentação, controle de versão, retenção ou fraqueza de evidência;
- sistemas semelhantes, modelos, versões, jurisdições, unidades de negócios ou controles compartilham a deficiência.

2.351.1 Conclusão causa-raiz

Documento por que a deficiência ocorreu, as evidências que sustentam a conclusão, explicações alternativas consideradas, incerteza e o escopo afetado confirmado.

2.352 5. Ações corretivas, preventivas e sistêmicas

Acção	Tipo	Proprietário	Data de vencimento	Dependência	Critérios de sucesso	Estado	Evidência de validação
	Correção / corretivo / preventivo / sistêmico						

Distinguir:

- **correção** ação imediata que aborda a condição observada;
- **ação corretiva** ação que remove a causa de uma deficiência real;
- **** ação preventiva**** ação que reduz a probabilidade de uma deficiência previsível;
- **ação sistêmica** ação que aborda uma causa comum entre sistemas, fornecedores, entidades ou domínios de controle.

2.353 6. Mapeamento legal das consequências

Dever	ator	Aplica-se?	Prazo ou fonte	Proprietário	Status e evidência
Medida correctiva					
Notificação de incidente ou de notificação regulamentar					
Retirada, revogação, restrição ou suspensão					
Gerenciamento de risco ou atualização do SGQ					
Atualização de documentação técnica ou de conformidade					
Registro, declaração, marcação ou atualização de autoridade					

Dever	ator	Aplica-se?	Prazo ou fonte	Proprietário	Status e evidência
Remédio afetado por pessoa, cliente, trabalhado r ou sujeito de dados					
Ação contratual ou do fornecedor					

2.354 7. Risco durante a remediação

Controles intermediários de documentos, risco residual, condições ou exceções aprovadas, frequência de relatórios, limiares de monitoramento, gatilhos de escalada, critérios de suspensão e a autoridade autorizada a aceitar exposição temporária. A aceitação do risco não pode renunciar à lei vinculativa ou autorizar o uso proibido ou não conforme.

2.355 8. Plano de Validação

Passo de validação	Testador independente	Evidência necessária	Data prevista	Resultado	Limitação ou acompanhamento

A validação deve confirmar a adequação do projeto, a implementação, a eficácia operacional, a ligação da versão, a cobertura do escopo afetado, a ausência de consequências materiais não intencionais e a sustentabilidade durante um período apropriado.

2.356 9. decisão de encerramento

- ☐ Fechado e eficaz
- ☐ Fechado com monitoramento contínuo
- ☐ Parcialmente completo
- ☐ Reaberto após falha na validação
- ☐ Permanecer aberto porque os deveres legais ou operacionais estão incompletos
- ☐ Risco aceito apenas dentro da autoridade legal

2.357 10. Lições aprendidas e atualizações do programa

Atualizações de registro necessárias para políticas, controles, padrões técnicos, modelos, dados, treinamento, monitoramento, contratos, supervisão do fornecedor, avaliações, documentação, requisitos de evidências, cenários de incidentes e sistemas relacionados.

2.358 Homologação

Papel	Nome	Decisão	Data
Proprietário da emissão			
validador independente			
Legal/ conformidade/ risco			
Técnico ou proprietário do produto			
Patrocinador Executivo, quando necessário			

Referências de evidências: Risco residual e limitações: Fechamento externo ou de autoridade obrigatório: **Próxima data de monitoramento ou revisão:** **

2.359 Apêndice Y Painel de bordo

** Status legal: ** Mestre inglês corrigido. O relatório do conselho ou do órgão de governo é uma prática de governança, a menos que uma lei específica, dever de governança corporativa, regra do setor ou mandato organizacional exija isso. As métricas do painel não demonstram por si mesmas conformidade legal.

2.360 Finalidade

Use este painel para fornecer ao conselho de administração ou ao órgão regulador uma supervisão concisa e baseada em evidências do risco, conformidade, incidentes, prontidão, correção, dependências e decisões estratégicas da IA. Relate conclusões legais, metas de gerenciamento e indicadores de maturidade separadamente.

2.361 1. escopo e confiabilidade do relatório

Campo	Resposta
Entidade e período de relato	
Sistemas, modelos, versões, jurisdições e unidades de negócios cobertos	
Status de proprietário e validação de dados	
Sistemas de fonte e data de corte	
Exclusões, limitações e incertezas conhecidas	
Datas atuais de base e de aplicação legais	
Validação ou garantia independente realizada	

2.362 2. Estado executivo

Área	Estado	Tendência	Evidência/ fonte	Mensagem chave	Decisão requerida
Governança e propriedade					
Datas de aplicação legal e prontidão					
Exposição à prática proibida					
Sistemas de alto risco e conformidade					
Obrigações de transparência e de transparência					
Direitos					

Área	Estado	Tendência	Evidência/ fonte	Mensagem chave	Decisão requerida
fundamentais, segurança, privacidade e acessibilidade					
Segurança, resiliência e fornecedores					
Incidentes, Reclamações e Questões Regulatórias					
Garantia, resultados e remediação					
Alfabetização e competência em IA					
Oportunidades estratégicas e restrições					

2.363 3. Perfil do portfólio

Métrica	Atual	Período anterior	Alvo ou limiar	Qualidade/ status dos dados
Sistemas de IA total inventariados e				

Métrica	Atual	Período anterior	Alvo ou limiar	Qualidade/status dos dados
integrações GPAI				
Estimativa de cobertura de inventário				
Sistemas confirmados ou potencialmente de alto risco				
Sistemas que aguardam decisão de função ou classificação				
Sistemas com avaliações ou controles atrasados				
Sistemas suspensos, restritos, rejeitados ou aposentados				
Sistemas em conformidade ou preparação de registo				
Fornecedores críticos e dependências de concentração				
Mudanças no modelo de material ou no				

Métrica	Atual	Período anterior	Alvo ou limiar	Qualidade/status dos dados
fornecedor aguardando revisão				

2.364 4. Exposição legal e de conformidade

Indicador	Estado	Fonte/data aplicável	Lim limiar	Ação de gestão
Suspeitos de práticas proibidas				
Questões de classificação de alto risco não resolvidas				
Obrigações vinculativas em atraso				
Conformidade, registro, declaração ou marcação de lacunas				
Riscos residuais elevados ou bloqueadores ilegais				
lacunas de evidência material				
Compromissos regulatórios ou pedidos de autoridade				
Exceções aceitas ou controles				

Indicador	Estado	Fonte/data aplicável	Lim limiar	Ação de gestão
compensadores				

Não descreva prontidão interna, maturidade, aceitação de risco ou aprovação do conselho como conformidade ou autorização legal.

2.365 5. Desempenho e impacto humano

Relatório, com sistemas afetados, versões, populações, jurisdições e tendências:

- precisão do material, confiabilidade, robustez ou deterioração da segurança;
- disparidades de subgrupos, indicadores de discriminação e efeitos interseccionais;
- revisão humana, substituição, desacordo e tendências de apelo;
- falhas de acessibilidade, linguagem e alojamento;
- preocupações de segurança e direitos fundamentais;
- reclamações, resultados adversos e impactos em grupos vulneráveis;
- Indicadores de automação-viés, carga de trabalho ou supervisão ineficaz;
- evidência de melhoria ou incerteza contínua.

2.366 6. Incidentes e resiliência

Métrica ou evento	Atual	Severidade e	Tendência	Acção necessária	Proprietário/data
Incidentes graves ou avaliações de reportabilidade					
Eventos de segurança ou privacidade					
Interrupções de serviço ou fallback falhado					

Métrica ou evento	Atual	Severidade e	Tendência	Acção necessária	Proprietário/data
Falhas do fornecedor ou do fornecedor do modelo					
Continuidade de falhada, incidentes ou exercícios regulatórios					
Retiradas abertas, recalls, suspensões ou restrições					

2.367 7. Garantia e remediação

Métrica	Atual	Alvo	Tendência	Evidência/limitação
Descobertas críticas abertas				
Descobertas altas abertas				
Ações corretivas atrasadas				
Repetir descobertas ou incidentes				
Taxa de fechamento validada				
Auditoria ou				

Métrica	Atual	Alvo	Tendência	Evidência/ limitação
conclusão do plano de garantia Controles testados quanto à eficácia operaciona l				
Resultados com aceitação de risco de gestão				

O fechamento interno não substitui a correção necessária, retirada, recall, relatório, notificação ou ação de autoridade.

2.368 8. Alfabetização e competência da IA

Relatório de conclusão, resultados de competência, papéis de alto risco atrasados, restrições temporárias, exercícios de cenário fracassados, padrões recorrentes de uso inseguro e se o pessoal, a carga de trabalho, a autoridade ou os incentivos prejudicam a supervisão efetiva.

2.369 9. Decisões exigidas do conselho

Decisão	Recomendação de gestão	Consequência legal/risco de atraso	Alternativas	Data exigida	Decisão do Conselho de Administração

As decisões potenciais incluem financiamento, apetite de risco, suspensão ou restrição, prioridade de remediação, saída do fornecedor, revisão independente, resposta regulatória, pessoal e aprovação do próximo roteiro do programa.

2.370 10. Atestado da gestão

A gestão deve divulgar:

- escopo, metodologia, sistemas de origem e corte de relatórios;

- métricas não validadas e problemas de qualidade de dados conhecidos;
- incerteza jurídica, técnica ou operacional não resolvida;
- Exclusões materiais ou pontos cegos;
- Métricas baseadas em afirmações de fornecedores em vez de evidências verificadas;
- questões omitidas por razões legais de privilégio, confidencialidade, segurança ou segredo comercial;
- se as tendências relatadas são estatisticamente e operacionalmente significativas.

2.371 Homologação

Papel	Nome	Decisão ou atestado	Data
Patrocinador			
Executivo			
Proprietário do risco/conformidade			
Proprietário legal ou regulamentar, quando aplicável			
Presidente do Conselho ou do Comité			

Referências de evidências: ** Limitações e incertezas conhecidas: Ações ou decisões levadas adiante: Próxima data de relato:**

2.372 Apêndice Z AI-Governança Implementação Roteiro

Estado legal: Mestre inglês corrigido. As fases de 30 dias, 90 dias e mensalmente abaixo são marcos do programa interno recomendados, não prazos legais da Lei de Inteligência Artificial da UE. As datas de inscrição vinculativas e as regras de transição devem ser mantidas em um registro de data legal atual separado.

2.373 Finalidade

Use este roteiro para planejar, sequenciar, atribuir, financiar, monitorar e relatar a implementação de um programa de prontidão para AI-governança

e AI Act da UE. Os marcos internos nunca devem obscurecer datas vinculantes anteriores, deveres específicos do ator, dependências de conformidade ou ação de autoridade necessária.

2.374 1. Programa e base legal

Campo	Resposta
Patrocinador Executivo	
Proprietário do programa	
Entidades, sistemas, modelos e jurisdições de escopo	
Data de início e datas-alvo internas	
Fonte jurídica consolidada atual	
Provisão vinculativa e localização do registo da data de aplicação	
Orçamento, pessoal e proprietário de recursos	
Assessores jurídicos, de conformidade e de garantia	
Repositório de evidências	

2.375 2. controle imediato da data legal

Antes de usar o roteiro, identifique cada provisão, ator, sistema ou modelo aplicável, data de aplicação, regra de transição, dependência de conformidade, interação com a autoridade e proprietário responsável. Os marcos internos devem ser acelerados onde uma data vinculante ocorre mais cedo.

Disposiç ão ou obrigaçã o	ator	Sistema/ modelo	Data de aplicaçã o	Transiçã o/ dependê ncia	Propriet ário	Estado/ evidênci a
------------------------------------	------	--------------------	--------------------------	-----------------------------------	------------------	--------------------------

2.376 3. Fase 1 Primeiros 30 dias: estabelecer o controle

Acções recomendadas:

Acção	Proprietári o	Data de venciment o interna	Dependên cia jurídica	Estado	Provas
Estabelece r					

Acção	Proprietário	Data de vencimento interna	Dependência jurídica	Estado	Provas
governança, direitos de decisão e escalada					
Verifique a linha de base legal atual e datas efetivas					
Identificar, bloquear, restringir ou escalar usos proibidos e não resolvidos					
Crie o inventário inicial do sistema de IA e GPAI					
Atribuir entidade legal, ator-papel, sistema, técnico, dados e proprietários de risco					
Triagem de alto risco, transparência, GPAI, privacidade, segurança, acessibilidade					

Acção	Proprietário	Data de vencimento interna	Dependência jurídica	Estado	Provas
ade, emprego, exposição ao consumido r, produto e setor Estabelece r processos imediatos de incidente, reclamação, o, conservação de evidências , retenção legal e revisão qualificada Comece medidas proporcionadas de alfabetização em IA Definir blocos de liberação urgentes e controles intermediários					

2.377 4. Fase 2 Dias 3190: operacionalize

Acções recomendadas:

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
Reconciliar inventário, papéis de ator, fins pretendidos e classificações					
Aplicabilidade de prioridade completa, prática proibida, alto risco, FRIA / DPIA, risco e avaliações de fornecedores					
Estabelecer registros de controle, evidência, data legal, emissão e exceção					
Revisar fornecedores críticos, contratos, provedores de modelos, subprocessadores e dependências de					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
saída					
Aprovar a entrada, liberação, mudança e portões de modificação					
o substancial do ciclo de vida					
Aprovar a supervisão humana, transparência, acessibilidade, monitoramento, reclamações, incidentes e processos de ação corretiva					
Remediar a documentação urgente, segurança, dados, registro, acessibilidade, idioma e lacunas de contrato					
Estabelece					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
r relatórios de gestão e de conselho					

2.378 5. Fase 3 Meses 46: estabilizar e validar

Acções recomendadas:

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
Implementar linhas de base de controle de alto risco e GPAI aplicáveis					
Documentação técnica de prioridade completa e reconciliação de versões					
Realizar testes de desempenho, subgrupo, robustez, segurança cibernética, supervisão e uso indevido					
Operacion					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
analize a mudança, liberação, fornecedor e gerenciamento de modificação substancial Continuidade do teste, fluxos de trabalho de sério incidente, legal-hold e de resposta regulatória Comece o design independente e a garantia de eficácia operacional Fechar descobertas críticas e validar de forma independente a correção Revisar a conformidade					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
ade, registro, declaração, marcação e prontidão de acesso à autoridade, quando aplicável					

2.379 Fase 4 Meses 712: escala e maduro

Acções recomendadas:

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
Escalar a governança entre entidades, unidades de negócios, idiomas e jurisdições Melhorar o monitoramento confiável, a coleta de evidências e a vinculação de versão Processos estatutários formais e de conformidade					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
ade-readiness aplicáveis completos					
Expandir auditoria interna, revisão temática e testes de eficácia operacional					
Realizar simulações de resposta regulatória, incidente, continuidade e saída do fornecedor					
Realizar avaliação de maturidade e risco residual sem tratar a maturidade como conformidade					
Aprovar o próximo roteiro, orçamento , pessoal,					

Acção	Proprietário	Data de vencimento interna	Dependência	Estado	Provas
tecnologia e plano de melhoria contínua					
Reportar exposição legal não resolvida, remediação atrasada e risco aceito para órgãos de governança apropriados					

2.380 7. Rastreador Workstream

Pista no mínimo:

- governança e responsabilidade;
- aplicabilidade legal, escopo territorial, papéis de ator e datas de aplicação;
- Inventário, finalidade pretendida e classificação;
- controles de práticas proibidas;
- prontidão de alto risco e GPAI;
- avaliação de risco, direitos fundamentais, privacidade, segurança e acessibilidade;
- governança e linhagem de dados;
- documentação técnica, validação, registro, robustez e segurança cibernética;
- supervisão humana, transparência, reclamações e remédios;
- fornecedor, contrato, concentração, continuidade e gestão de saída;
- mudança, liberação, propósito pretendido e controles substanciais de modificação;
- monitoramento pós-comercialização, incidentes, ações corretivas e resposta de autoridade;
- conformidade, registro, declaração, marcação e prontidão regulatória;

- Alfabetização e competência em IA;
- evidência, retenção, retenção legal, auditoria, remediação e melhoria contínua.

Workstream	Obrigações/data vinculativa	Marco interno	Proprietário	Dependência	Estado	Provas
------------	-----------------------------	---------------	--------------	-------------	--------	--------

2.381 8. Marcos e dependências

Milestone	Dependência	Data-alvo	Proprietário	Estado	Provas
-----------	-------------	-----------	--------------	--------	--------

As dependências podem incluir interpretação legal, evidências de fornecedores, conformidade com a lei do produto, capacidade do corpo notificado, correção de dados, validação técnica, consulta local, acessibilidade, pessoal, compras, orçamento e processos de autoridade.

2.382 9. Risco e registro de emissão

Risco ou problema	Impacto jurídico/operacional	Mitigação ou controle	Probabilidade	Intercalar	Proprietário	Data de vencimento	Escalada	Estado
-------------------	------------------------------	-----------------------	---------------	------------	--------------	--------------------	----------	--------

2.383 10. Métricas do programa

Acompanhe métricas com fontes, proprietários, limiares, datas de corte e limitações definidas, incluindo:

- Cobertura de inventário e propriedade;
- Ator-papel e conclusão da classificação;
- revisões de uso proibido e usos bloqueados;
- Sistemas de alto risco e GPAI com evidências atuais;
- Obrigações aplicáveis cumpridas antes das datas vinculativas;
- Estado de conformidade e de registro;
- controles atrasados, exceções e remediação;
- Evidência de fornecedores críticos, incidentes e exposição à concentração;
- Conclusão da alfabetização AI e resultados de competência;
- reclamações, apelos, incidentes e resultados da pessoa afetada;

- resultados de auditoria, falhas repetidas e encerramento validado de forma independente;
- Indicadores de prontidão e maturidade claramente rotulados como medidas internas.

2.384 11. cadência da governança

Fórum	Frequência	Finalidade	Relatórios exigidos	Autoridade de decisão
grupo de trabalho				
Comitê de governança ou risco da IA				
Comitê Executivo				
Conselho de Administração ou Conselho de Administração				
Fórum de risco, auditoria, legal ou conformidade				

2.385 12. Regra da conclusão

A conclusão do programa requer:

- Mapeamento legal atual e data de aplicação;
- Defensável ator-papel e decisões de classificação;
- propriedade responsável e recursos financiados;
- controles implementados e operacionais;
- evidência atual, ligada à versão, recuperável;
- Supervisão humana testada, escalada, reversão, incidentes e processos de resposta regulatória;
- Processos legais de conformidade e autoridade concluídos, quando aplicável;
- Remediação validada e monitorização sustentável;
- um plano de melhoria contínua financiado.

Documentos, listas de verificação, aprovações internas, revisões de prontidão ou pontuações de maturidade por si só não estabelecem conformidade legal.

2.386 Homologação

Papel	Nome	Decisão	Data
Patrocinador Executivo			
Proprietário do programa			
Legal/ conformidade			
Liderança técnica/produ to			
Risco/ audição/ conformidade, conforme aplicável			

Referências de evidências: Dependências legais, técnicas, de fornecedores ou de conformidade não resolvidas: Desvios e controles provisórios aprovados: Próximo acionador de revisão ou data: **